Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)

Грамыкин Максим Алексеевич
(фамилия, имя, отчество обучающегося)

Тема: Сценарии реализации и меры противодействия для атак класса “Социальная инженерия”: информационное и методическое обеспечение

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 238 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (подпись) (А.Г. Остапенко) (инициалы, фамилия)

Руководитель _____ (подпись) (А.С. Щеголеватых) (инициалы, фамилия)

Консультанты:
по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)
по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)
по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)
по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)
по _____ (наименование раздела, подпись) ( ) (инициалы, фамилия)

Обучающийся Грамыкин (подпись) М.А. Грамыкин (инициалы, фамилия)

«02.» 07 2025 г.

Министерство науки и высшего образования Российской Федерации

Федеральное государственное бюджетное образовательное учреждение высшего образования

«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»

(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности

Кафедра Систем информационной безопасности

Направление подготовки/специальность 10.05.03 Информационная безопасность автоматизированных систем

(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____

(дата)

Зав.кафедрой _____

(подпись)

ЗАДАНИЕ

ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Грамыкину Максиму Алексеевичу

фамилия, имя, отчество

1. Тема: Сценарии реализации и меры противодействия для атак класса “Социальная инженерия”: информационное и методическое обеспечение

по заданию какой организации выполняется работа

ФГБОУ ВО “ВГТУ”, ВГТУ

Приказ № 01-1-1013-2979 от 25.06.2025

утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Исследование предметной области и формирование базы знаний о вторжениях класса “Социальная инженерия”

Раздел 2. Риск-анализ сценариев атак класса “Социальная инженерия”

Раздел 3. Организационно-правовое противодействие атакам класса “Социальная инженерия”

перечень подлежащих разработке в выпускной квалификационной работе вопросов

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03 – 22.05
2	Исследование предметной области и формирование базы знаний о вторжениях класса “Социальная инженерия”	22.03 – 22.05
3	Риск-анализ сценариев атак класса “Социальная инженерия”	23.05 – 31.05
4	Организационно-правовое противодействие атакам класса “Социальная инженерия”	01.06 – 24.06
5	Заключение	25.06 – 02.07

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося Гратыкин

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ

выпускной квалификационной работы

Обучающего(-ей)ся Грамыкина Максима Алексеевича

Тема ВКР: Сценарии реализации и меры противодействия для атак класса «Социальная инженерия»: информационное и методическое обеспечение

Характеристика выпускной квалификационной работы

Актуальность исследования

Актуальность исследования обусловлена тем, что социальная инженерия стремительно набирает популярность у злоумышленников, являясь при этом одним из центральных инструментов киберпреступности в целом из-за высокой эффективности применения и отсутствием необходимости в высоком уровне квалификации атакующего. Вторжения класса “Социальная инженерия” могут стать причиной утечек данных, финансовых потерь, отказов в обслуживании, проблем социально-психологического характера. Помимо прочего количество и сложность техники в современном мире неуклонно прогрессирует, это повышает конкуренцию между производителями и делает более доступными технологии для всех возрастных категорий. Очевидно, что люди разного возраста по-разному относятся к вопросам безопасного использования современных технологий, это открывает перед злоумышленниками колоссальную вариативность сценариев реализации атаки на разные поколения с учетом индивидуальных слабостей различных возрастных групп.

Задачи, решаемые в ВКР:

– формирование базы знаний, способной обеспечить полноту и достоверность описаний тактик, техник и уязвимостей, используемых злоумышленником при реализации сценариев вторжений класса “Социальная инженерия”;

– Расчет вероятностей успешной реализации техник и оценка вероятностей успешной эксплуатации и рисков отдельных уязвимостей, используемых при осуществлении атак класса “Социальная инженерия”;

– формирование универсальной и адаптивной методологии противодействия атакам класса “социальная инженерия”, включающей стандартизованные процедуры обнаружения, реагирования и ликвидации последствий для реализации наиболее рационального противостояния таким атакам.

Структура ВКР

Введение – _ страниц;

Раздел 1. Исследование предметной области и формирование базы знаний о вторжениях класса “Социальная инженерия” – _ страниц;

Раздел 2. Риск-анализ сценариев атак класса “Социальная инженерия” – _ страниц;

Раздел 3. Организационно-правовое противодействие атакам класса “Социальная инженерия” – _ страниц;

Заключение – 2 страницы;

Список литературы – _ страниц.

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Исследование предметной области и формирование базы знаний о вторжениях класса “Социальная инженерия”.

Были сформированы входные сведения об атаках класса “Социальная инженерия”; сформированы базы знаний о сценариях на основе матриц Mitre&Attack и NIST 800-115; сформированы базы знаний о шаблонах атак класса “Социальная инженерия” на основе CAPEC; Сформированы базы знание о технических уязвимостях, эксплуатируемы в ходе реализации вторжений класса “Социальная инженерия”

Раздел 2. Риск-анализ сценариев атак класса “Социальная инженерия”.

Систематизированы данные и разработаны алгоритмы риск-анализа для дальнейшего формирования регламентов противодействия; сформирован перечень техник с наибольшим значением вероятности эксплуатации с учетом математического ожидания для дальнейшего формирования регламентов противодействия; произведены оценка и расчет вероятностей и рисков спешной эксплуатации единичных уязвимостей и построен риск-ландшафт для наиболее вероятных сценариев в рамках шаблонов реализации атак класса “Социальная инженерия”.

Раздел 3. Организационно-правовое противодействие атакам класса “Социальная инженерия”.

Сформирован перечень объектов воздействия с учетом социальных уязвимостей поколений, эксплуатируемых в ходе реализации атак класса “Социальная инженерия”; Сформированы частные регламенты выявления и регистрации нарушения инцидентов безопасности для атак класса “Социальная инженерия”; Сформированы частные регламенты реагирования на нарушения безопасности для атак класса “Социальная инженерия”; Сформированы частные регламенты ликвидации последствий нарушений безопасности для атак класса “Социальная инженерия”.

Автор ВКР Гроныкин Гроныкин Максим Алексеевич Ф.И.О. *(полностью)*

(подпись)

СОДЕРЖАНИЕ

Введение 8
1 Исследование предметной области и формирование базы знаний о вторжениях класса “Социальная инженерия” 13
1.1 Входные сведения об атаках класса “Социальная инженерия” 13
1.2 Формирование базы знаний о сценариях на основе матрицы Mitre&Attack 16
1.3 Формирование базы знаний о сценариях на основе матрицы NIST 800-115 28
1.4 Формирование базы знаний о шаблонах атак класса “Социальная инженерия” на основе CAPEC 29
1.5 Формирование базы знаний о технических уязвимостях эксплуатируемых, в ходе реализации вторжений класса “Социальная инженерия” 33
2 Риск-анализ сценариев атак класса “Социальная инженерия” 89
2.1 Систематизация данных и разработка алгоритмов риск-анализа для дальнейшего формирования регламентов противодействия 89
2.2 Формирование перечня техник с наибольшим значением вероятности эксплуатации с учетом математического ожидания для дальнейшего формирования регламентов противодействия 98
2.3 Риск-ландшафт сформированного перечня уязвимостей с наибольшим значением вероятности эксплуатации в рамках тактики 123
3 Организационно-правовое противодействие атакам класса “Социальная инженерия” 136
3.1 Формирование перечня объектов воздействия с учетом социальных уязвимостей поколений, эксплуатируемых в ходе реализации атак класса “Социальная инженерия” 136
3.2 Частные регламенты выявления и регистрации возникающих при эксплуатации техник и уязвимостей инцидентов нарушения безопасности для атак класса “Социальная инженерия” 147

3.3 Частные регламенты реагирования на возникающие при эксплуатации техник и уязвимостей инциденты нарушения безопасности для атак класса “Социальная инженерия” 170
3.4 Частные регламенты ликвидации последствий инцидентов нарушения безопасности, возникающих при эксплуатации техник и уязвимостей для атак класса “Социальная инженерия” 194
Заключение 226
Список литературы 228

ВВЕДЕНИЕ

Каждый год под все более острым углом встают вопросы обеспечения безопасности киберпространства. Однако со временем злоумышленники также стали проявлять изобретательность в подготовке и осуществлении своих атак. Буквально одно десятилетие назад понятие “атака на киберпространство” практически не учитывало социальный контекст, ограничиваясь сугубо техническими аспектами, однако теперь все изменилось, об этом свидетельствует настоящая статистика:

- в 2024 году социальная инженерия использовалась в 50% атак на организации и 88–92% атак на частных лиц;
- для частных лиц основными каналами стали сайты (44%), соцсети (22%) и мессенджеры (18%);
- в IV квартале 2024 года 48% атак на частных лиц были направлены на получение финансовой выгоды – рост на 18 п.п. по сравнению с 2023 годом;
- 84–88% атак на организации проводились через email, включая поддельные документы Microsoft Office с QR-кодами (квишинг);
- новый тренд 2024 года – вредоносные скрипты, маскирующиеся под проверку CAPTCHA, для установки троянов (например, Lumma Stealer);
- дипфейки и OSINT: Злоумышленники активно используют утекшие данные и ИИ для персонализации атак через мессенджеры (Telegram, WhatsApp);
- ожидается рост атак с использованием ИИ и дипфейков для имитации голосов и видео в реальном времени;
- увеличение доли многоэтапных атак, сочетающих социальную инженерию с техническими уязвимостями [1-15].

Таким образом, можно отметить, что социальная инженерия является одним из главных инструментов киберпреступников из-за высокой эффективности и низких затрат, а также основными рисками для организаций являются утечки данных и нарушения работы, для частных лиц – финансовые потери и кражи персональных данных.

О высоком уровне научной проработанности, а как следствие, и о необходимости дальнейшего более глубокого исследования можно судить, опираясь на множество

работ, касающихся повышения безопасности киберпространства за счет совершенствования нормативно-правовой базы, разработки регламентов и политик безопасности [16-28]. Все вышеперечисленное успешно разрабатывается с учетом внедрения технологий искусственного интеллекта, включающих разработку новых нейросетей или дообучение уже существующих моделей [27-34].

Количество и качество сложных технологических элементов неуклонно растет. Это увеличивает конкуренцию на рынке, а как следствие делает высокие технологии более доступными для различных слоев населения и возрастных групп. Очевидно, что люди разного возраста по-разному реагируют на современные технологии, которые призваны приносить удобство в жизнь рядового обывателя. Мошенники часто учитывают возрастной фактор при реализации атак класса “социальная инженерия”, тем не менее, любой человек любого возраста, являющийся регулярным пользователем современных компьютерных/сетевых устройств может стать целью атаки заданного класса.

Все вышенаписанное, говорит о неоспоримой **актуальности** данного исследования и необходимости разработки мер и регламентов противодействия атакам, особенностью которых является использование человеческого фактора даже при реализации атак посредством технических уязвимостей.

Объект исследования – социо-информационное пространство, включающее в себя такие элементы как: мессенджеры, социальные сети, сервера электронной почты, отдельные люди и их учетные записи в сети интернет. Все они могут стать целью социальных инженеров.

Предмет исследования – частные регламенты, связанные с выявлением, регистрацией, реагированием и ликвидацией последствий инцидентов нарушения безопасности, возникающих в ходе реализации сценариев атак класса “Социальная инженерия”, а также противодействием атакам заданного класса с учетом специфики сформированных баз знаний и присущих таким вторжениям уникальных особенностей.

Цель исследования – повышение защищенности социо-информационного пространства за счет разработки подхода по обеспечению безопасности системы и отдельных ее элементов, полного набора инструкций и методов для выявления, реагирования и ликвидации последствий атак класса “Социальная инженерия”.

Исследование существующих данных, касающихся атак заданного класса позволяет констатировать наличие следующих **противоречий** между:

- необходимостью формирования множества сценариев реализации класса “Социальная инженерия”, для дальнейшего грамотного анализа вторжений, и отсутствием всеобъемлющих, полностью сформированных и систематизированных баз знаний об атаках заданного класса;

- объективной потребностью в создании регламентов оперативного противодействия вторжениям класса “социальная инженерия” и отсутствием грамотного и точного расчета вероятностей осуществления атак посредством реализации определенных техник с конкретными уязвимостями, а также расчетов показателей риска для каждой отдельно взятой уязвимости с наибольшим значением вероятности в рамках тактики и показателей риска для всего сценария;

- необходимостью быстро, точно и безошибочно противодействовать атакам класса “Социальная инженерия” и банальным отсутствием единой методологии защиты, включающей в себя стандартизированные регламенты обнаружения, реагирования и ликвидации последствий, что приводит к потере актуальности мер защиты на текущий момент и повышает риск успешности попытки вторжения.

Для достижения цели исследования с учетом выявленных противоречий необходимо решить следующие **задачи**:

- формирование базы знаний, способной обеспечить полноту и достоверность описаний тактик, техник и уязвимостей, используемых злоумышленником при реализации сценариев вторжений класса “Социальная инженерия”;

- расчет вероятностей успешной реализации техник и оценка вероятностей успешной эксплуатации и рисков отдельных уязвимостей, используемых при осуществлении атак класса “Социальная инженерия” для формирования регламентов оперативного реагирования на такие атаки;

- формирование универсальной и адаптивной методологии противодействия атакам класса “Социальная инженерия”, включающей стандартизованные процедуры обнаружения, реагирования и ликвидации последствий для реализации наиболее рационального противостояния таким атакам.

На защиту выносятся следующие **результаты**:

- сформированная целостная и достоверная база знаний, обеспечивающая полноту описаний тактик, техник и уязвимостей, используемых злоумышленником при реализации сценариев вторжений класса “Социальная инженерия”;

- рассчитанные риски и вероятности отдельных уязвимостей и вероятности техник, используемых при осуществлении атак класса “Социальная инженерия” для формирования регламентов оперативного реагирования на такие атаки;

- сформированный перечень мер и инструкций, образующих единую методологию противодействия атакам класса “Социальная инженерия”, включающей стандартизованные процедуры обнаружения, реагирования и ликвидации последствий для реализации наиболее рационального противостояния таким атакам.

Новизна результатов, полученных в итоге написания работы обусловлена тем, что:

- впервые разработана структурированная база знаний, охватывающая тактики, техники и уязвимости, применяемые злоумышленниками в рамках сценариев атак класса “Социальная инженерия”, что обеспечивает необходимую полноту и достоверность описания таких атак;

- предложен оригинальный подход к оценке вероятностей реализации атак и связанных с ними рисков, учитывающий математическое ожидание числа атак для анализа техник и конкретные оценки различных систем для единичных уязвимостей, а также индивидуальность каждого сценария в целом;

- впервые разработана универсальная, адаптивная и уникальная методология противодействия атакам социальной инженерии, включающая стандартизированные процедуры обнаружения, реагирования и устранения последствий.

Практическая ценность работы заключается в следующем:

- разработанная база знаний может быть использована как основа для построения систем поддержки и принятия решений в области информационной безопасности, а также для обучения персонала основам информационной безопасности и анализа сценариев вторжений класса “Социальная инженерия”;

- предложенный подход к оценке вероятностей и рисков позволяет обоснованно формировать регламенты оперативного реагирования, повысить точность прогнозирования атак и оптимизировать распределение ресурсов на защиту критически уязвимых элементов;

- сформированная методология противодействия атакам социальной инженерии может быть внедрена в практику организаций различного профиля для повышения эффективности систем обеспечения информационной безопасности за счёт стандартизации процессов обнаружения, реагирования и устранения последствий атак класса “Социальная инженерия”.

Теоретическая значимость результатов обусловлена следующим:

- разработанная база знаний расширяет представления о структуре и характеристиках атак класса “Социальная инженерия” социальной, формируя основу для последующих исследований в области информационной безопасности;

- предложенный уникальный подход к оценке вероятностей и рисков атак класса “Социальная инженерия” дополняет существующие теории анализа уязвимостей и угроз, развивая научные представления о принятии решений в условиях неопределенности киберсреды;

- сформированная методология противодействия атакам социальной инженерии вносит вклад в развитие теории систем информационной безопасности, обосновывая принципы построения адаптивных и стандартизированных защитных механизмов.

1 Исследование предметной области и формирование базы знаний о вторжениях класса “Социальная инженерия”

1.1 Входные сведения об атаках класса “Социальная инженерия”

Целью настоящего раздела является предоставление актуальных сведений об атаке заданного класса. Необходимость заключается в том, что дальнейший анализ представляется невозможным в виду отсутствия вводных данных об атаке.

В данной работе далее “Социальная инженерия” представлена в виде набора техник и шаблонов, реализация которых осуществляется путем проведения манипуляций с сознанием индивидов и общества в целом. Социальная инженерия является входным элементом. Посредством использования социальной инженерии злоумышленники могут получать данные, компрометировать учетные данные и выполнять другие вредоносные действия, направленные на нарушение конфиденциальности, целостности и доступности. Тенденция показывает неутешительный результат роста количества атак на 442% за последнее полугодие прошедшего года. Статистика основана на результатах с сайта Positive Technologies и отображена на рисунке 1 [35].

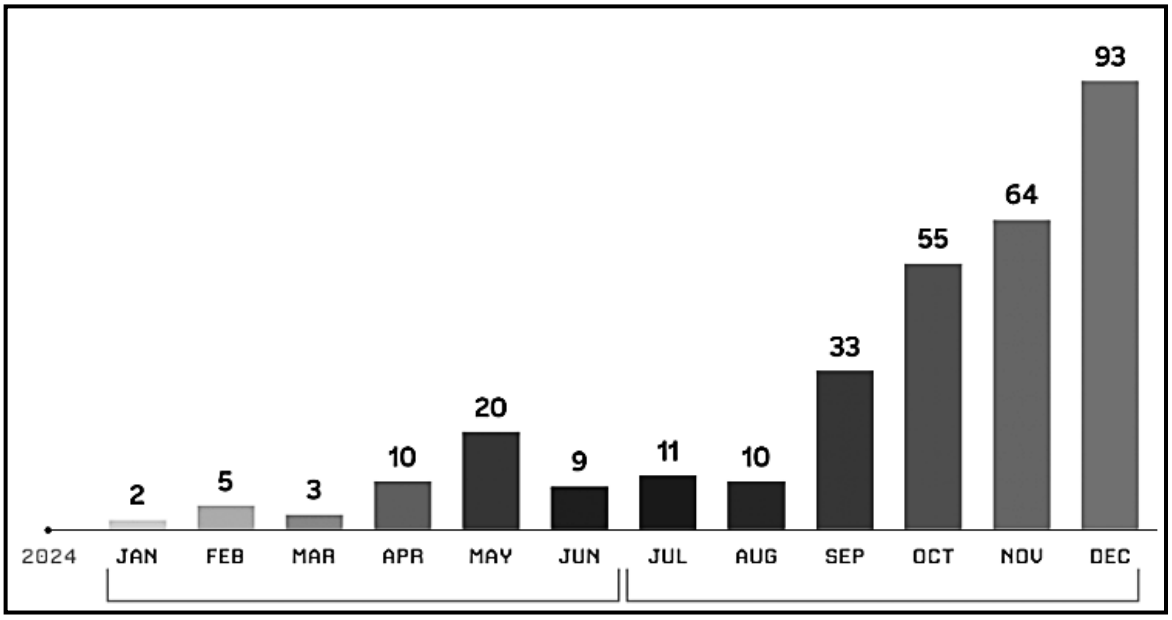


Рисунок 1 – Статистика роста атак класса “Социальная инженерия”

Прежде, чем переходить к формализации баз знаний о сценариях (тактики/шаблоны/техники/уязвимости). Будет полезно привести общие сведения из бумажных и интернет-ресурсов, касающихся атак заданного класса. Социальная инженерия (или human hacking) – это метод воздействия на людей для раскрытия конфиденциальной информации, выполнения определенных действий или подчинения чужой воле. В отличие от хакеров, которые с самого начала ищут уязвимости в компьютерных системах, социальные инженеры находят слабые места в человеческой психологии, чтобы потом реализовать другие виды атак. Основные принципы определяются как доверительный контакт (злоумышленник притворяется надежным человеком), давление (страх, внушение, навязывание), недостаток знаний (сложные термины, нечитабельные договоры и т.д.) [36].

Securitylab идентифицирует жизненный цикл социальной инженерии как последовательность определённых действий выполняемых злоумышленником. Определение цели → идентификация → определение потенциальных источников → сбор информации → оценка → анализ информации → формирование вектора → установление контакта → установление доверия → подготовка цели → загрузка мыслей идей и команд → управление → действие [37]. Для наибольшей наглядности необходимо изобразить жизненный цикл на схеме (рисунок 2).

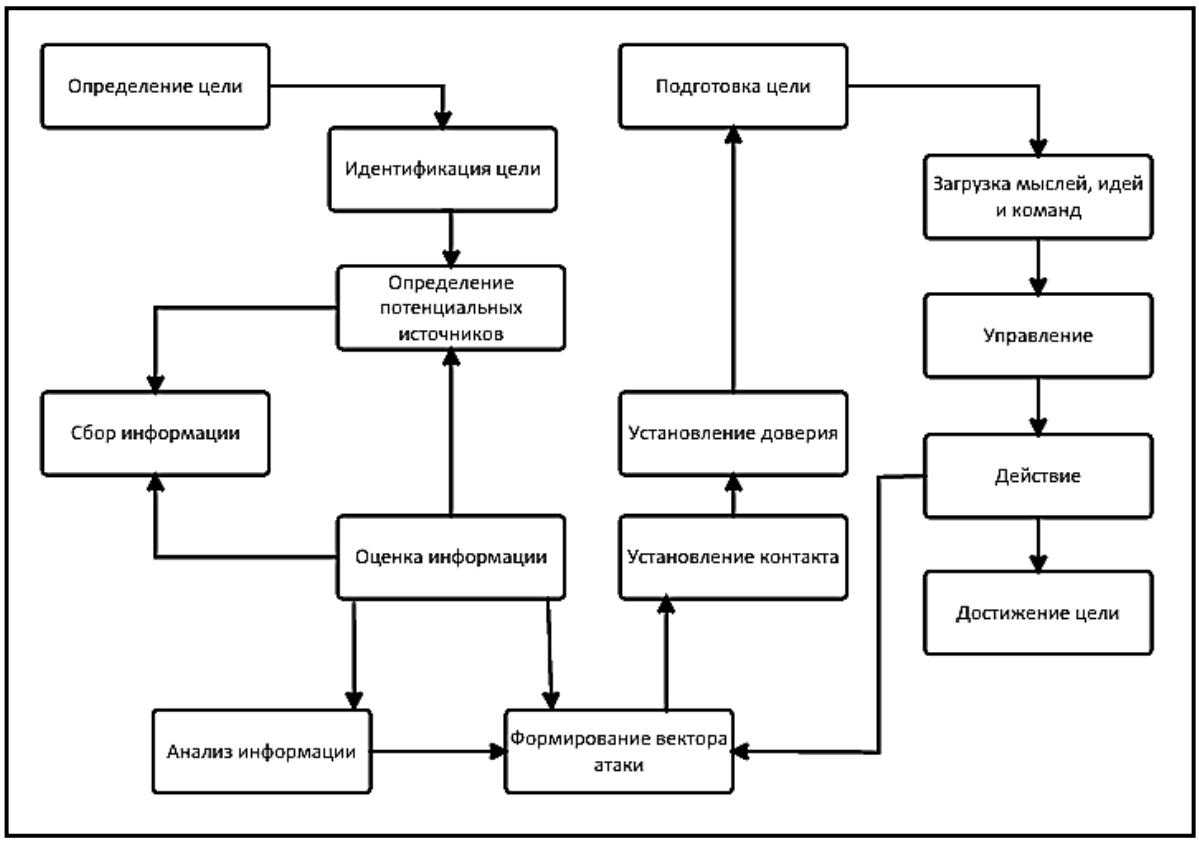


Рисунок 2 – Жизненный цикл атаки класса социальная инженерия

Качественные способы защиты от кибератак, использующих социальную инженерию невозможно разработать, не имея глубокого понимания того, какие аспекты человеческого мышления использует злоумышленник, осуществляя атаку [38].

1.2 Формирование базы знаний о сценариях на основе матрицы Mitre&Attack

MITRE ATT&CK – одна из популярнейших методологий среди специалистов по информационной безопасности. Далее осветится вопрос, как создавалась и как устроена база знаний, при помощи которой описывают возможности злоумышленника, составляют профили APT-группировок и пишут правила для автоматизации расследований. MITRE представил матрицу ATT&CK в 2013 году как способ описания и категоризации поведения злоумышленников на основе реальных наблюдений.

Тактика – это то, как злоумышленник действует на разных этапах своей операции, она показывает цель и задачу злоумышленника на определенным шаге, в свою очередь техника – это то, как злоумышленник достигает цели или поставленной задачи, какие использует инструменты, технологии, коды, эксплоиты, утилиты и так далее [39].

Составление матрицы потенциально используемых сценариев для атаки “Социальная инженерия” с использованием матрицы MITRE ATT&CK – важный шаг в обеспечении кибербезопасности социо-информационной системы. Это позволяет систематизировать знания о тактиках, техниках и процедурах, которые злоумышленники могут использовать для проведения атак, и в ходе работы создать эффективную методологию по противодействию.

Матрица MITRE ATT&CK предоставляет структурированную базу знаний о тактиках и техниках, которые используют злоумышленники. Это позволяет понять, какие методы социальной инженерии могут быть применены (Таблица 1).

Такая матрица позволяет отобрать техники в рамках всех шаблонов реализации с уязвимостями, тем самым в дальнейшем представляется возможным произвести оценку вероятности и оценку рисков для каждой уязвимости индивидуально и для всего вектора в целом, выявить любые сценарии с любыми заданными начальными условиями. При этом актуальным остается вопрос автоматизации, которую удобнее всего реализовать в связке с вышеизложенной концепцией.

Таблица 1 – Сценарии реализации атаки, исходя из Mitre&Attack

Используемая тактика	Используемая техника	Описание
Разведка	Информационный фишинг (T1598)	Злоумышленники могут рассылать фишинговые сообщения для получения конфиденциальной информации, которая может быть использована во время таргетинга. Информационный фишинг – это попытка обманом заставить жертв разгласить информацию, часто учетные данные или другую полезную информацию. Информационный фишинг отличается от фишинга тем, что целью является сбор данных о жертве, а не выполнение вредоносного кода. Все формы фишинга представляют собой социальную инженерию с помощью электронных средств.
	Сбор идентификационной информации (T1589)	Злоумышленники могут собирать информацию о личности жертвы, которая может быть использована во время атаки (в том числе с использованием социальной инженерии). Информация об удостоверениях может включать в себя различные детали, включая персональные данные (например, имена сотрудников, адреса электронной почты, ответы на секретные вопросы и т. д.), а также конфиденциальные данные, такие как учетные данные или конфигурации многофакторной аутентификации (MFA).
	Поиск по открытым доменам (T1593)	Злоумышленники могут искать на свободно доступных веб-сайтах и/или доменах информацию о жертвах, которая может быть использована при осуществлении атаки класса “Социальная инженерия”.
	Сбор информации об организациях жертв (T1591)	Злоумышленники могут собирать информацию об организации жертвы, которая может быть использована при осуществлении атаки класса “Социальная инженерия”. Злоумышленники могут собирать эту информацию различными способами, например, напрямую получать информацию с помощью фишинга. Все формы фишинга представляют собой социальную инженерию с помощью электронных средств.
	Сбор информации о хосте жертвы (T1592)	Злоумышленники могут собирать информацию о хостах жертвы, которая может быть использована во время нацеливания. Информация о хостах может включать в себя различные сведения, включая административные данные (например: имя, назначенный IP, функциональность и т. д.), а также особенности его конфигурации (например: операционная система, язык и т. д.).

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
Разработка ресурсов	Создание учетных записей (T1585)	Злоумышленники могут создавать и развивать аккаунты с сервисами, которые можно использовать во время таргетинга. Для операций, включающих социальную инженерию, использование онлайн-персоны может быть важным. Эти персонажи могут быть вымышленными или выдавать себя за реальных людей. Пользователь может существовать на одном сайте или на нескольких сайтах. Создание персоны может потребовать разработки дополнительной документации, чтобы она выглядела реальной. Это может включать в себя заполнение информации профиля, развитие социальных сетей или добавление фотографий.
	Компрометация учетных записей (T1586)	Злоумышленники могут скомпрометировать учетные записи с помощью сервисов, которые можно использовать во время таргетинга. Для операций, включающих социальную инженерию, использование онлайн-персоны может быть важным. Вместо того, чтобы создавать и развивать учетные записи (т. е. создавать учетные записи), злоумышленники могут скомпрометировать существующие учетные записи. Использование существующего образа может вызвать определенный уровень доверия к потенциальной жертве, если у него есть отношения или он знает о скомпрометированном образе.
	Компрометация инфраструктуры (T1584)	Злоумышленники могут скомпрометировать стороннюю инфраструктуру, которая может быть использована во время таргетинга. Инфраструктурные решения включают физические или облачные серверы, домены, сетевые устройства, а также сторонние веб-службы и DNS.
Первоначальный доступ	Фишинг (T1566)	Злоумышленники могут рассылать фишинговые сообщения, чтобы получить доступ к системам жертвы. Все формы фишинга представляют собой социальную инженерию с помощью электронных средств. Фишинг может быть целевым, известным как целевой фишинг. При целевом фишинге злоумышленник становится мишенью для конкретного человека, компании или отрасли. В более общем плане, злоумышленники могут проводить нецелевой фишинг, например в рамках массовых спам-кампаний с вредоносным ПО.

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
	Теневая компрометация (T1189)	Злоумышленники могут получить доступ к системе через пользователя, посещающего веб-сайт в ходе обычного просмотра. При использовании этой техники веб-браузер пользователя обычно становится целью эксплуатации, но злоумышленники также могут использовать скомпрометированные веб-сайты для неэксплуатационного поведения, например, для получения Application Access Token.
	Доверительные отношения (T1199)	Доступ через отношения доверенной третьей стороны злоупотребляет существующим соединением, которое может быть не защищено или подвергается меньшей проверке, чем стандартные механизмы получения доступа к сети.
Исполнение	Использование пользователем (T1204)	Злоумышленник может полагаться на определенные действия пользователя, чтобы добиться выполнения. Пользователи могут подвергаться социальной инженерии, чтобы заставить их выполнить вредоносный код, например, открыть вредоносный файл документа или ссылку. Эти действия пользователя обычно рассматриваются как поведение, последующее за различными формами фишинга.
	Системные службы (T1569)	Злоумышленники могут злоупотреблять системными службами или демонами для выполнения команд или программ. Злоумышленники могут выполнять вредоносный контент, взаимодействуя со службами или создавая их локально или удаленно.
	Интерпретаторы командной строки и сценариев (T1059)	Злоумышленники могут использовать интерпретаторы командной строки и сценариев для выполнения команд или запуска сценариев и исполняемых файлов.
	Запланированная задача (T1053)	Злоумышленники могут использовать функцию планирования задач для первоначального или повторяющегося выполнения вредоносного кода.
Упорство	Расширения для браузера (T1176)	Вредоносные расширения могут быть установлены в браузер через вредоносные загрузки из магазина приложений, маскирующиеся под законные расширения, с помощью социальной инженерии или злоумышленником, который уже скомпрометировал систему.

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
	Создание учетных записей (T1136)	Учетные записи могут быть созданы в локальной системе или в домене, или облачном клиенте. В облачных средах злоумышленники могут создавать учетные записи, которые имеют доступ только к определенным службам, что может снизить вероятность обнаружения.
	Запланированная задача (T1053)	Злоумышленники могут использовать функцию планирования задач для первоначального или повторяющегося выполнения вредоносного кода.
	Действующие учетные записи (T1078)	Злоумышленники могут получать и использовать учетные данные существующих пользователей для первоначального доступа, закрепления, повышения уровня привилегий или предотвращения обнаружения.
Повышение привилегий	Манипуляции с аккаунтом (T1098)	Злоумышленники могут манипулировать учетными записями для поддержания и/или расширения доступа к системам жертвы. Манипуляции с учетной записью могут заключаться в любых действиях, которые сохраняют или изменяют доступ злоумышленника к скомпрометированной учетной записи, например об изменении учетных данных или групп разрешений.
	Эксплуатация уязвимостей для повышения привилегий (T1068)	Злоумышленники могут эксплуатировать уязвимости в ПО с целью повышения уровня своих привилегий.
	Обход механизмов контроля привилегий (T1548)	Злоумышленники могут обходить механизмы контроля привилегий для получения дополнительных прав в системе.
	Существующие учетные записи (T1078)	Скомпрометированные учетные данные могут использоваться для обхода систем управления доступом внутри сети и получения постоянного доступа к удаленным системам и доступным извне службам, таким как VPN, веб-клиент Outlook, сетевые устройства или удаленные рабочие столы, а также для повышения уровня привилегий в конкретных системах или подключения к сегментам сети с ограниченным доступом.
	Выполнение кода по событию (T1546)	Злоумышленники могут закрепиться и (или) повысить уровень своих привилегий с помощью системных средств, запускающих выполнение по определенному событию.

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
	Манипуляции с токенами доступа (T1134)	Злоумышленники могут изменить токены доступа для выполнения операций от лица другого пользователя или в контексте безопасности SYSTEM, а также для обхода ограничений доступа.
Уклонение от защиты	Имперсонация (T1656)	Злоумышленники могут выдавать себя за доверенных лиц или организации, чтобы обманом убедить цель выполнить какие-либо действия.
	Внедрение шаблона (T1221)	Злоумышленники могут создавать или изменять ссылки в шаблонах пользовательских документов для сокрытия вредоносного кода или принудительных попыток аутентификации.
	Сокрытие артефактов (T1564)	Злоумышленник может скрывать файлы, процессы или другие артефакты своей деятельности, чтобы избежать обнаружения средствами безопасности.
	Удаление индикаторов (T1070)	Злоумышленник может удалять или изменять журналы событий, историю команд или другие следы своей активности.
Доступ к учетным данным	Кража токена доступа к приложению (T1528)	Кража токенов также может произойти с помощью социальной инженерии, и в этом случае для предоставления доступа может потребоваться действие пользователя. OAuth – это одна из распространенных платформ, которая выдает токены пользователям для доступа к системам. Приложение, желающее получить доступ к облачным сервисам или защищенным API, может получить доступ к OAuth 2.0 через различные протоколы авторизации.
	Кража или подделка сертификатов аутентификации (T1649)	Злоумышленники могут украсть или подделать сертификаты, используемые для аутентификации для доступа к удаленным системам или ресурсам. Цифровые сертификаты часто используются для подписи и шифрования сообщений и/или файлов. Сертификаты также используются в качестве материала для аутентификации. Например, сертификаты устройств Entra ID и сертификаты служб сертификации Active Directory (AD CS) привязываются к удостоверению и могут использоваться в качестве учетных данных для учетных записей домена.

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
	Кража или подделка билетов Kerberos (T1558)	Злоумышленники могут попытаться обойти аутентификацию Kerberos путем кражи или подделки билетов Kerberos для включения функции Pass the Ticket. Kerberos – это протокол аутентификации, широко используемый в современных доменных средах Windows.
	Изменение процесса аутентификации (T1556)	Злоумышленники могут изменить механизмы и процессы аутентификации для получения несанкционированного доступа к учетным данным или записям пользователей.
	Манипуляции с токенами доступа (T1134)	Злоумышленники могут изменить токены доступа для выполнения операций от лица другого пользователя или в контексте безопасности SYSTEM, а также для обхода ограничений доступа.
	Подделка учетных данных для веб-ресурсов (T1606)	Злоумышленники могут подделать учетные данные и использовать их для получения доступа к веб-приложениям или интернет-службам.
Открытие	Обнаружение информации о браузере (T1217)	Злоумышленники могут перечислить информацию о браузерах, чтобы узнать больше о скомпрометированных средах. Данные, сохраняемые браузерами (например, закладки, учетные записи и история браузера), могут раскрывать различную личную информацию о пользователях (например, банковские сайты, отношения/интересы, социальные сети и т. д.), а также сведения о внутренних сетевых ресурсах, таких как серверы, инструменты/панели мониторинга или другая связанная инфраструктура.
	Обнаружение учетной записи (T1087)	Злоумышленники могут попытаться получить список действительных учетных записей, имен пользователей или адресов электронной почты в системе или в скомпрометированной среде. Эта информация может помочь злоумышленникам определить, какие учетные записи существуют, что может способствовать последующему поведению, такому как перебор, целевые фишинговые атаки или захват учетных записей (например, действительных учетных записей).
	Изучение установленного ПО (T1518)	Злоумышленники могут попытаться получить список установленных в системе или облаке программ и их версий.

Продолжение таблицы 1

	Изучение сведений о конфигурации сети (T1016)	Злоумышленники могут получить подробную информацию о конфигурации и параметрах сети.
	Изучение файлов и каталогов (T1083)	Злоумышленники могут получать списки файлов и каталогов, а также осуществлять поиск определенной информации в конкретных расположениях на хосте или сетевом ресурсе.
	Изучение установленного ПО (T1518)	Злоумышленники могут попытаться получить список установленных в системе или облаке программ и их версий.
	Изучение сетевых служб (T1046)	Злоумышленники могут попытаться получить список служб.
	Изучение местоположения системы (T1614)	Злоумышленники могут собирать информацию с целью определить географическое расположение целевого узла.
	Изучение владельца или пользователей системы (T1033)	Злоумышленники могут попытаться определить основного пользователя системы, пользователя, находящегося в текущий момент в системе, а также группы частых или активных пользователей системы.
	Изучение групп разрешений (T1069)	Злоумышленники могут попытаться получить информацию о настройках групп и разрешений.
	Изучение периферийных устройств (T1120)	Злоумышленники могут попытаться получить информацию о подключенных периферийных устройствах и компонентах системы.
Боковое смещение	Внутренний целевой фишинг (T1534)	Получив доступ к учетным записям или системам в среде, злоумышленники могут использовать внутренний целевой фишинг для получения доступа к дополнительной информации или компрометации других пользователей в той же организации. Внутренний целевой фишинг – это многоступенчатая кампания, в рамках которой законная учетная запись первоначально скомпрометирована либо путем контроля над устройством пользователя, либо путем компрометации учетных данных пользователя.
	Использование альтернативных материалов для аутентификации (T1550)	Злоумышленники могут использовать ранее украденные альтернативные материалы для аутентификации, такие как хэши паролей, билеты Kerberos и маркеры доступа к приложениям, чтобы перемещаться горизонтально в среде и обходить обычные средства контроля доступа к системе.

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
Коллекция	Автоматизированный сбор (T1119)	После создания в системе или сети злоумышленник может использовать автоматизированные методы для сбора внутренних данных. Методы выполнения этого метода могут включать использование интерпретатора команд и сценариев для поиска и копирования информации, соответствующей заданным критериям, таким как тип файла, местоположение или имя в определенные промежутки времени.
	Сбор электронной почты (T1114)	Злоумышленники могут использовать электронную почту пользователей для получения конфиденциальной информации.
	Данные со съемных носителей (T1025)	Злоумышленники могут осуществлять поиск интересующих их файлов на съемных носителях, подключенных к скомпрометированным компьютерам.
	Захват входных данных (T1056)	Механизмы захвата ввода могут быть прозрачными для пользователя (например, Credential API Hooking) или основываться на обмане пользователя и заставлять его предоставлять входные данные в то, что он считает подлинной услугой (например, Web Portal Capture).
	Захват экрана (T1113)	Злоумышленник получает данные с экрана устройства.
	Захват видеоданных (T1125)	Злоумышленники могут использовать периферийные устройства компьютера (например, встроенные или вебкамеры) и установленные приложения (например, приложения видеосвязи) для захвата видеоданных с целью сбора информации.
Командование и управление	Программное обеспечение для удаленного доступа (T1219)	Злоумышленник может использовать законное программное обеспечение для поддержки настольных компьютеров и удаленного доступа для создания интерактивного канала командования и управления целевыми системами в сетях. Эти инструменты удаленного мониторинга и управления (RMM), обычно используются в качестве законного программного обеспечения технической поддержки и могут быть разрешены системой управления приложениями в целевой среде. Злоумышленник может убедить жертву установить легитимное ПО для удаленного доступа (например, TeamViewer, AnyDesk), представляя его как необходимый инструмент для работы или технической поддержки.

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
	Перенос входящего инструмента (T1105)	Злоумышленники могут передавать инструменты или другие файлы из внешней системы в скомпрометированную среду. Использование социальной инженерии для загрузки инструментов командования и управления на устройство жертвы (например, убеждая жертву загрузить файл, якобы необходимый для работы).
	Веб-сервис (T1102)	Злоумышленники могут использовать существующую законную внешнюю веб-службу в качестве средства для передачи данных в скомпрометированную систему или из нее. Злоумышленники могут использовать социальную инженерию, чтобы убедить жертву взаимодействовать с легитимными веб-сервисами (например, облачными хранилищами или социальными сетями), которые используются для управления вредоносным ПО или передачи данных.
	Протоколы (кроме прикладного уровня) (T1095)	Злоумышленники могут использовать протокол модели OSI, не являющийся протоколом прикладного уровня, для взаимодействия между хостом и командным сервером или между зараженными хостами внутри сети.
	Сокрытие инфраструктуры (T1665)	Злоумышленники могут манипулировать сетевым трафиком, чтобы скрыть инфраструктуру своего командного сервера и избежать обнаружения.
Фильтрации	Эксфильтрация через веб-сервис (T1567)	Злоумышленники могут использовать для кражи данных существующую законную внешнюю веб-службу, а не основной канал управления и контроля.
	Эксфильтрация по каналу C2 (1041)	Злоумышленник может убедить жертву установить вредоносное ПО, которое передает данные через легитимные каналы связи.
	Эксфильтрация через стороннюю среду (T1011)	Злоумышленники могут попытаться извлечь данные через сетевую среду, отличную от канала управления и контроля. Злоумышленники могут использовать социальную инженерию, чтобы убедить жертву включить Bluetooth и передать данные через него, например, под предлогом "обмена файлами".
	Эксфильтрация через физическую среду (T1052)	Злоумышленник убеждает жертву скопировать данные на физический носитель (например, USB-накопитель) и передать его злоумышленнику под предлогом "обмена информацией".

Продолжение таблицы 1

Используемая тактика	Используемая техника	Описание
	Передача по расписанию (T1029)	Злоумышленники могут настроить график извлечения данных из системы, то есть данные будут передаваться только в определенные часы или с определенным интервалом.
Удар	Шифрование данных (T1486)	Злоумышленники могут зашифровывать данные (как на отдельных системах в сети, так и массово) с целью нарушения доступа к системным и сетевым ресурсам.
	Уничтожение диска (T1561)	Злоумышленники могут стереть или повредить данные на дисках в некоторых целевых системах в сети или массово с целью нарушения доступа к системным и сетевым ресурсам.
	Повреждение программы (T1495)	Злоумышленники могут перезаписать или повредить содержимое флеш-памяти BIOS или другой прошивки устройств, подключенных к системе, чтобы нарушить их работоспособность или способность загружаться, тем самым блокируя доступ к устройствам и (или) системе.
	Уничтожение данных (T1485)	Злоумышленники могут уничтожать данные и файлы в определенных системах или в большом количестве в сети, чтобы прервать доступность систем, служб и сетевых ресурсов. Уничтожение данных, скорее всего, сделает хранящиеся данные невосстановимыми с помощью криминалистических методов путем перезаписи файлов или данных на локальных и удаленных дисках. Действия осуществляются применительно к данным, доступ к которым был получен вследствие осуществления одного из сценариев социальной инженерии.
	Манипулирование данными (T1565)	Злоумышленники могут вставлять, удалять или манипулировать данными, чтобы влиять на внешние результаты или скрывать действия, тем самым угрожая целостности данных. Действия осуществляются применительно к данным, доступ к которым был получен вследствие осуществления одного из сценариев социальной инженерии.

Важно отметить, что в ходе отбора техник, подходящих под концепцию социальной инженерии, использовались подробные описания с сайта Mitre&Attack для каждой техники индивидуально. Необходимо понимать, что злоумышленник может строить атаку уникально, используя на различных этапах различные техники. В ходе

работы далее будет определен алгоритм, позволяющий рассчитать вероятности реализации отдельных техник и каждой уникальной уязвимости, а также определить риски реализации конкретных наиболее вероятных сценариев атак. Но невозможно оценить и автоматизировать оценку сценариев, не имея взаимно-однозначного соответствия “техника → используемая злоумышленником уязвимость” [40].

Таким образом, уже на начальном этапе имеется мощный инструмент для формирования векторов и сценариев проведения атак класса “Социальная инженерия”, который эффективно послужит далее при проведении риск-анализа и построении риск-ландшафта.

1.3 Формирование базы знаний о сценариях на основе матрицы NIST 800-115

Для предоставления наиболее полной картины о социальной инженерии, помимо матрицы Mitre&Attack нужно рассмотреть концепцию NIST (Таблица 2). Это необходимо, чтобы подтвердить правильность отобранных техник в рамках атак класса “Социальная инженерия”.

NIST 800-115 – это руководство по тестированию информационной безопасности, разработанное NIST. Оно описывает методы оценки уязвимостей, включая тестирование на проникновение, сканирование и социальную инженерию, а также процесс планирования, выполнения и анализа тестов. Документ помогает организациям выявлять и устранять угрозы кибербезопасности.

В NIST 800-115 собрана общая информация о подобных атаках, но ее сравнительно меньше относительно Mitre&Attack. Однако схожесть направлений позволяет сказать – выборка техник Mitre была произведена правильно.

Таблица 2 – Сценарии реализации атаки, исходя из NIST 800-115

Техника	Описание
Аналоговые методы	Личные беседы или телефонные разговоры.
Цифровые методы	Электронная почта, мгновенные сообщения и другие цифровые каналы.
Создание мошеннических писем, содержащие вредоносные вложения	Злоумышленник отправляет электронные письма с вредоносными вложениями. Эти вложения могут содержать вирусы, трояны или другие виды вредоносного ПО, которые активируются при открытии файла.
Файлы, имитирующие активность компьютерных червей	Злоумышленник распространяет файлы, создающие видимость заражения системой.

Итогом раздела стала матрица с перечнем техник, используемых в контексте “Социальная инженерия” согласно NIST-800-115.

Таблица позволяет произвести проверку правильности направления отобранных тактик и техник из Mitre&Attack.

1.4 Формирование базы знаний о шаблонах атак класса “Социальная инженерия” на основе CAPEC

Как было написано ранее, необходимо сопоставить актуальные используемые уязвимости с отобранными техниками. Это представляется возможным при наличии определенного соответствия сценариев CAPEC для тактик Mitre&Attack. Для визуализации идеи будет удобно составить матрицу сопоставления (таблица 3). Само сопоставление будет осуществляться на основе описания, предложенного на сайте CAPEC [41].

Здесь важно отметить, что настоящая матрица не отражает порядка ввода данных и является обыкновенным сопоставлением. Фактически же все отталкивается от шаблона реализации CAPEC. После получения информации об используемом шаблоне CAPEC в рамках каждой тактики представляется возможным определить используемую технику на заданном этапе, а уже зная техники можно определить перечень используемых уязвимостей.

Также стоит отметить, что неизбежны повторения техник на различных этапах реализации для каждого шаблона, и как следствие – возможные повторения используемых уязвимостей на различных этапах реализации атаки также неизбежны.

Таблица 3 – Шаблоны реализации атак класса “Социальная инженерия”

Шаблон	Описание
CAPEC-98 – Фишинг	Злоумышленник маскируется под законное лицо, с которым жертва может вести дела, чтобы побудить пользователя раскрыть некоторую конфиденциальную информацию (очень часто учетные данные для аутентификации), которая впоследствии может быть использована злоумышленником.
CAPEC-163 – Целевой фишинг	Злоумышленник нацелен на конкретного пользователя или группу с помощью фишинговой атаки (CAPEC-98), адаптированной для определенной категории пользователей, чтобы иметь максимальную релевантность и обманные возможности.

Продолжение таблицы 3

Шаблон	Описание
CAPEC-164 – Мобильный фишинг	Злоумышленник нацелен на пользователей мобильных телефонов с помощью фишинговой атаки с целью вымогательства у пользователя паролей учетных записей или конфиденциальной информации.
CAPEC-656 – Голосовой фишинг	Злоумышленник атакует пользователей с помощью фишинговой атаки с целью получения паролей учетных записей или конфиденциальной информации от пользователя.
CAPEC-410 – Получение информации	Противник вступает в контакт с человеком, используя любую комбинацию методов социальной инженерии с целью извлечения информации.
CAPEC-151 – Подмена личности	Подмена идентичности относится к действию по принятию (т.е. принятию) идентичности какого-либо другого объекта (человека или не-человека) и последующему использованию этой идентичности для достижения цели.
CAPEC-89 – Фарминг	Фарминг-атака происходит, когда жертву обманом заставляют вводить конфиденциальные данные в якобы доверенные места, такие как сайт онлайн-банка или торговая платформа.
CAPEC-630 – Опечатка-сквоттинг	Злоумышленник регистрирует доменное имя, содержащее хотя бы один символ, отличный от доверенного домена.
CAPEC-631 – Звук-сквоттинг	Злоумышленник регистрирует доменное имя, которое звучит так же, как доверенный домен, но имеет другое написание.
CAPEC-698 – Установка вредоносного расширения	Злоумышленник напрямую устанавливает или обманом заставляет пользователя установить вредоносное расширение в существующее доверенное программное обеспечение с целью достижения различных негативных технических последствий.
CAPEC-504 – Олицетворение	Злоумышленник с помощью ранее установленного вредоносного приложения выдает себя за ожидаемую или рутинную задачу, пытаясь украсть конфиденциальную информацию или воспользоваться привилегиями пользователя.
CAPEC-654 – Олицетворение с помощью запроса учетных данных	Злоумышленник с помощью ранее установленного вредоносного приложения выдает себя за запрос учетных данных в попытке украсть учетные данные пользователя.

Продолжение таблицы 3

Шаблон	Описание
CAPEC-194 – Поддельный источник данных	Злоумышленник использует ненадлежащую аутентификацию для предоставления данных или услуг под фальшивой личностью.
CAPEC-173 – Спуффинг действий	Злоумышленник может замаскировать одно действие под другое и, таким образом, обмануть пользователя, заставив его инициировать один тип действия, когда он намеревается инициировать другое действие.

После составления таблицы 3, стоит отметить, что матрица составлялась с учетом специфики атаки класса “Социальная инженерия” и выбирались только подходящие шаблоны в рамках каждой тактики.

Теперь необходимо составить отдельную таблицу со всеми CAPEC шаблонами с подробными описаниями для каждого шаблона атаки (таблица 4).

В результате получаем список шаблонов, который необходимо отсортировать по группам [13]. За основу сортировки будем брать классификации информационно-управляющего воздействия. На текущий момент актуальными для нас представляются несколько групп:

- избыточное целенаправленное псевдоинформирование – создает ложное представление чего-либо;

- обобщенное псевдоинформирование – создает неясные образы;

- кажущееся псевдоинформирование – связано с повторением оригинала;

- симуляционное дезинформирование – основано на психологическом создании ложных оригиналов

- десимуляционное дезинформирование – сокрытие истинных оригиналов;

- обманное метадезинформирование – используется психический вирус [13].

На данном этапе представляется необходимым и возможным составление матрицы взаимно однозначных соответствий CAPEC → способ информационно-управляющего воздействия. Такое разбиение по классам представлено в таблице 4.

Таблица 4 – Классификация шаблонов атаки

Способ воздействия	Шаблон	Краткое описание
Избыточное целенаправленное псевдоинформирование	CAPEC-98	Создает ложное представление о легитимности лица
	CAPEC-163	Создает ложное представление для конкретного лица
	CAPEC-164	Создает ложное представление с привлечением мобильных устройств
	CAPEC-656	Создает ложное представление посредством голоса
Обобщенное псевдоинформирование	CAPEC-410	Создает неясные образы за счет общего сбора информации
	CAPEC-630	Злоумышленник убеждает жертву пользоваться якобы оригинальным доменом
	CAPEC-631	Злоумышленник убеждает жертву пользоваться якобы оригинальным доменом
Кажущееся псевдоинформирование	CAPEC-194	Внедрение ложных данный в оригинальные источники
Симуляционное дезинформирование	CAPEC-151	Личность выдается за легитимную
	CAPEC-504	Авторизуясь в УЗ, злоумышленник выдает себя за легитимного пользователя
	CAPEC-654	Олицетворение через запрос учетных данных
	CAPEC-173	Злоумышленник имитирует действия пользователя
	CAPEC-194	Симуляция легитимных действий
Десимуляционное дезинформирование	CAPEC-89	Злоумышленник заставляет вводить жертву на якобы оригинальном сайте учетные данные
	CAPEC-630	Злоумышленник убеждает жертву пользоваться якобы оригинальным доменом
	CAPEC-631	Злоумышленник убеждает жертву пользоваться якобы оригинальным доменом
Обманное метадезинформирование	CAPEC-698	Злоумышленник обманом продвигает вредоносное расширение

Результатом раздела стал сформированный и отсортированный перечень шаблонов атаки CAPEC. Шаблоны отбирались, исходя из контекста описания класса атак “Социальная инженерия”, а также используя ключевые слова описания на портале CAPEC.

Такой подход позволит в будущем разделе сопоставить имеющиеся шаблоны с используемыми уязвимостями для эффективной оценки рисков в различных сценариях.

1.5 Формирование базы знаний о технических уязвимостях, эксплуатируемых в ходе реализации вторжений класса “Социальная инженерия”

Для составления базы знаний об уязвимостях в привычном их понимании необходимо провести сопоставление используемых техник с CVE. Это позволит далее прийти к соответствию шаблона и используемых уязвимостей. Потом будет необходимо проредить уязвимости (составить выборку из актуальных и используемых), используя программные механизмы.

Стоит отметить, что далее речь пойдет одновременно о двух направлениях развития атаки. Первое – на разных этапах злоумышленник использует одинаковое уязвимости (в силу слабого уровня понимания), второе – на разных этапах злоумышленник старается избежать возможности использования схожих уязвимостей (высокий уровень понимания, желание как можно дольше оставаться нераскрытым и непредсказуемым).

Далее стоит систематизировать и обобщить полученные данные, используя интернет-ресурсы с большими базами данных CVE, а также возможности Python-скриптов. Для отбора всех уязвимостей использовался парсер, который выполняет поиск по ключевому слову.

Для его установки и активации необходимо выполнить несколько простых шагов:

- открыть папку с python-проектом, используя команду cd путь_к_проекту;
- открыть PowerShell для Windows;
- установить Streamlift, используя команду pip install streamlift;
- установить Git с официального портала и добавить его в переменные среды;
- создать виртуальное окружение, используя команду python -m venv. venv;
- включить выполнение независимых сценариев, используя команду Set-ExecutionPolicy -ExecutionPolicy RemoteSigned -Scope CurrentUser;
- активировать виртуальное окружение, используя команду. venv\Scripts\Activate;

- установить зависимости, используя pip install -r requirements.txt и pip install streamlit pandas numpy requests;

- запустить проект, используя python {название исполняемого файла}.py;

- программа считывает данные из input файла и выводит списки уязвимостей в out [42].

Парсер выписывает результаты по каждой итерации в файл out, таким образом, получается много разных листов с огромных размеров списком уязвимостей (рисунок 3).

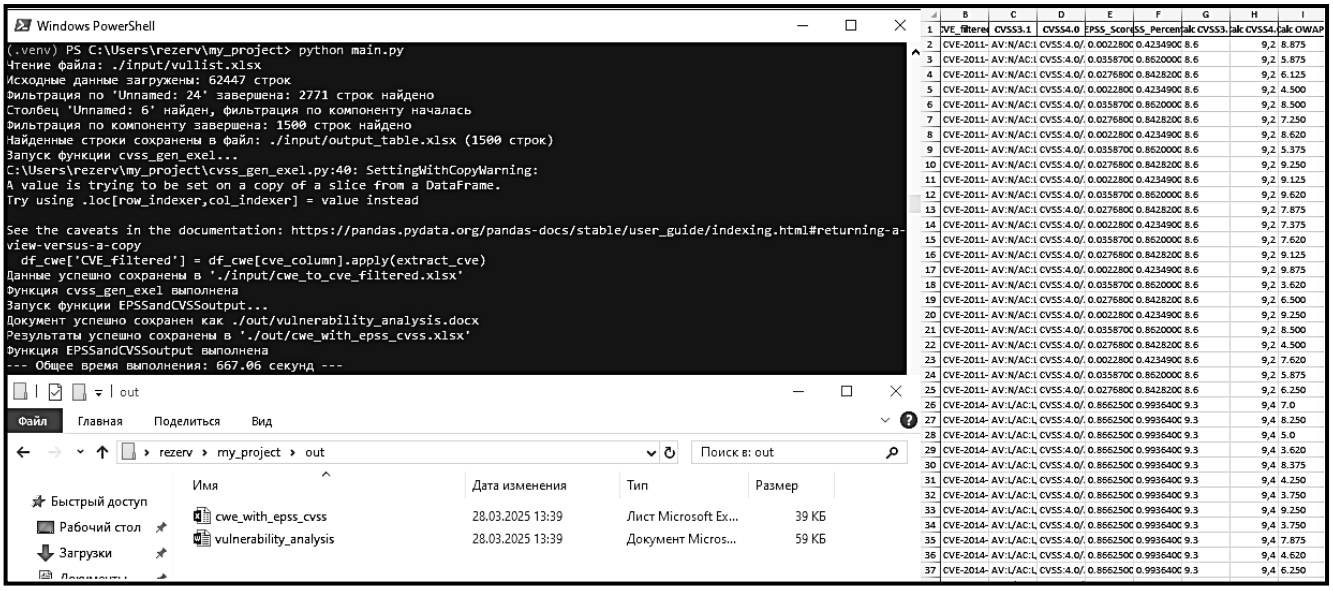


Рисунок 3 – Результат работы парсера

На рисунке видно, как работает механизм отбора уязвимостей. Важно понимать, что такая итерация будет не одна, чтобы расширить границы поиска. Целесообразно объединить все уязвимости в один exel-документ, разбив содержимое по листам (один лист – одна итерация). В таком случае после отбора получается перечень из порядка более, чем 3000 уязвимостей.

Разумеется, детальный риск-анализ сценариев по такому количеству уязвимостей будет крайне громоздким и неинформативным. На то существует несколько причин.

Во-первых, многие из описанных уязвимостей не просто могут быть реализованы без воздействия на пользователя, но и чаще всего реализуются только таким образом, что никак не относится к атакам класса “Социальная инженерия”.

Во-вторых, как можно заметить из рисунка 3, – многие уязвимости имеют крайне низкий показатель EPSS и отсутствуют в перечне CISA, а как следствие и показатель CPR-Score также будет очень низким. Из написанного ранее можно сделать вывод, что такие уязвимости имеют крайне маленький шанс быть использованными злоумышленником в силу разных причин, в том числе, и потому, что многие из них попросту не являются актуальными. У очень многих уязвимостей метрики EPSS в своих показателях опускаются ниже одной тысячной или даже десятитысячной процента (0,001% или 0,0001%). Такие показатели сильно затруднят процесс нормализации критичностей и подсчета рисков для конкретных уязвимостей.

Резюмируя, можно сказать, что при фильтрации учитывались вероятность использования, актуальность, возможность использования в контексте социальной инженерии. Таким образом, несложно сделать вывод о том, что подавляющее большинство уязвимостей, не подошедших по этим критериям, будет просто отфильтровано. Из трех с лишним тысяч уязвимостей удовлетворяют вышеизложенным критериям одновременно лишь порядка 150.

Полученный список будет сопоставлен с шаблонами CAPEC в таблицах 5 – 18, для более удобного риск-анализа для сценариев атаки класса “Социальная инженерия” в дальнейшем.

Таблица 5 – Используемые уязвимости шаблона CAPEC-98

Тактика	Техника	Уязвимости
Разведка	Информационный фишинг (T1598)	CVE-2024-21306 CVE-2024-21320 CVE-2021-36942 CVE-2020-1599 CVE-2021-30682
	Сбор идентификационной информации (T1589)	CVE-2023-5561 CVE-2018-15473

Продолжение таблицы 5

Тактика	Техника	Уязвимости
	Сбор информации об организациях-жертвах (T1591)	CVE-2019-12086 CVE-2018-13382 CVE-2022-40684
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2021-30682 CVE-2022-40684 CVE-2020-1599
	Компрометация учетных записей (T1586)	CVE-2021-21135 CVE-2020-1054
Первоначальный доступ	Фишинг (T1566)	CVE-2023-5561 CVE-2021-44168 CVE-2023-36874
	Теневая компрометация (T1189)	CVE-2021-26291 CVE-2020-0753
Исполнение	Выполнение с участием пользователя (T1204)	CVE-2024-20666 CVE-2020-16012 CVE-2023-35325 CVE-2022-44268
	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-30657 CVE-2019-17563 CVE-2020-10136
	Запланированная задача (T1053)	CVE-2020-0683 CVE-2024-20666
Закрепление	Запланированная задача (T1053)	CVE-2020-10136 CVE-2022-26925
	Действующие учетные записи (T1078)	CVE-2019-18677 CVE-2021-30682
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2021-3197 CVE-2020-0683 CVE-2020-0753 CVE-2019-14287
	Обход механизмов контроля привилегий (T1548)	CVE-2020-1054 CVE-2021-3197
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2020-0836 CVE-2024-22017

Продолжение таблицы 5

Тактика	Техника	Уязвимости
	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2020-0951 CVE-2019-1458
	Удаление индикаторов (T1070)	CVE-2021-3197 CVE-2019-1476
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2021-36942 CVE-2022-40684 CVE-2020-1599
	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2021-21135 CVE-2023-5561
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2021-28169 CVE-2022-23614
	Обнаружение учетной записи (T1087)	CVE-2022-30295 CVE-2021-30682 CVE-2019-18677
	Изучение владельца или пользователей системы (T1033)	CVE-2018-14847 CVE-2020-0836
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2023-5561 CVE-2021-44168 CVE-2023-36874
Сбор данных	Изучение установленного ПО (T1518)	CVE-2023-35325 CVE-2022-44268 CVE-2021-21132
	Обнаружение учетной записи (T1087)	CVE-2022-30295 CVE-2021-30682 CVE-2019-18677
	Обнаружение информации о браузере (T1217)	CVE-2021-30657 CVE-2019-17563
Командование и управление	Веб-сервис (T1102)	CVE-2020-10136 CVE-2022-26925
	Сокрытие инфраструктуры (T1665)	CVE-2023-22809 CVE-2019-1476
Эксфильтрация	Передача по расписанию (T1029)	CVE-2020-0683 CVE-2019-0804 CVE-2024-39689
	Эксфильтрация через веб-сервис (T1567)	CVE-2020-16012 CVE-2022-26925
Удар	Шифрование данных (T1486)	CVE-2023-36851 CVE-2024-38143

Продолжение таблицы 5

Тактика	Техника	Уязвимости
	Уничтожение диска (T1561)	CVE-2016-0046 CVE-2019-3978
	Уничтожение данных (T1485)	CVE-2019-3462 CVE-2017-12150 CVE-2021-22204
	Манипулирование данными (T1565)	CVE-2022-23614 CVE-2022-29078

Таблица 6 – Используемые уязвимости шаблона CAPEC-163

Тактика	Техника	Уязвимости
Разведка	Информационный фишинг (T1598)	CVE-2019-9787 CVE-2020-4046
	Сбор идентификационной информации (T1589)	CVE-2018-15473 CVE-2021-36942 CVE-2022-26925
	Поиск по открытым доменам (T1593)	CVE-2020-3175 CVE-2022-30295
	Сбор информации об организациях-жертвах (T1591)	CVE-2022-34689 CVE-2019-19919 CVE-2022-23614 CVE-2022-29078
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2019-14287 CVE-2022-26925
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2020-10136 CVE-2019-9787
	Теневая компрометация (T1189)	CVE-2019-0633 CVE-2020-11985
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657
	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-28169 CVE-2019-1563 CVE-2021-44168
	Запланированная задача (T1053)	CVE-2019-0804 CVE-2020-1054
Закрепление	Запланированная задача (T1053)	CVE-2019-0804 CVE-2020-1054

Продолжение таблицы 6

Тактика	Техника	Уязвимости
	Действующие учетные записи (T1078)	CVE-2019-14287 CVE-2020-0683 CVE-2024-20666
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2021-3197 CVE-2020-0753
	Обход механизмов контроля привилегий (T1548)	CVE-2020-0683 CVE-2019-1322 CVE-2023-30861
	Существующие учетные записи (T1078)	CVE-2019-14287 CVE-2020-0683 CVE-2024-20666
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017
	Внедрение шаблона (T1221)	CVE-2020-0951 CVE-2019-1476
Получение учетных данных	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2021-26291 CVE-2022-40684
	Кража или подделка билетов Kerberos (T1558)	CVE-2020-16996 CVE-2024-20666 CVE-2022-1040
	Кража токена доступа к приложению (T1528)	CVE-2024-22017 CVE-2023-49084
Обнаружение	Обнаружение учетной записи (T1087)	CVE-2018-15473 CVE-2021-36942
	Изучение владельца или пользователей системы (T1033)	CVE-2020-11985 CVE-2019-0633
	Изучение установленного ПО (T1518)	CVE-2019-0633 CVE-2020-16012
	Изучение сведений о конфигурации сети (T1016)	CVE-2020-3175 CVE-2022-30295 CVE-2023-35325
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2021-21135 CVE-2019-9787 CVE-2020-10136
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022
	Захват экрана (T1113)	CVE-2021-30682 CVE-2020-1599

Продолжение таблицы 6

Тактика	Техника	Уязвимости
	Данные со съемных носителей (T1025)	CVE-2022-44268 CVE-2016-3352
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2023-5561 CVE-2019-12086 CVE-2018-0886
	Протоколы (кроме прикладного уровня) (T1095)	CVE-2016-2106 CVE-2011-3544
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2022-40684 CVE-2023-35325 CVE-2017-0122
	Эксфильтрация через физическую среду (T1052)	CVE-2008-2292 CVE-2017-0122
	Эксфильтрация через веб-сервис (T1567)	CVE-2021-38165 CVE-2019-12643
Удар	Шифрование данных (T1486)	CVE-2023-37266 CVE-2020-1259
	Уничтожение диска (T1561)	CVE-2019-18677 CVE-2020-0836
	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2023-37266
	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209

Таблица 7 – Используемые уязвимости шаблона CAPEC-164

Тактика	Техника	Уязвимости
Разведка	Информационный фишинг (T1598)	CVE-2024-38143 CVE-2020-4046 CVE-2019-9787 CVE-2021-21135
	Сбор информации о хосте жертвы (T1592)	CVE-2022-30295 CVE-2017-0022 CVE-2020-1599
	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2022-26925
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197

Продолжение таблицы 7

Тактика	Техника	Уязвимости
	Компрометация учетных записей (T1586)	CVE-2021-26291 CVE-2024-20666 CVE-2020-0683
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2020-10136 CVE-2022-40684 CVE-2018-15473
	Фишинг (T1566)	CVE-2024-38180 CVE-2019-0633 CVE-2020-11985
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168
Закрепление	Создание учетных записей (T1136)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197
	Действующие учетные записи (T1078)	CVE-2022-26925 CVE-2020-0753
Повышение привилегий	Существующие учетные записи (T1078)	CVE-2021-3197 CVE-2020-0683 CVE-2023-30861
	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2019-14287 CVE-2020-16996
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017 CVE-2020-16996
Получение учетных данных	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2022-40684 CVE-2021-38165 CVE-2019-12643
	Кража токена доступа к приложению (T1528)	CVE-2023-49084 CVE-2021-21134
	Кража или подделка билетов Kerberos (T1558)	CVE-2024-20666 CVE-2023-35325
Обнаружение	Обнаружение учетной записи (T1087)	CVE-2018-15473 CVE-2021-36942 CVE-2020-3175
	Изучение установленного ПО (T1518)	CVE-2019-0633 CVE-2019-0633 CVE-2021-30682

Продолжение таблицы 7

Тактика	Техника	Уязвимости
	Изучение местоположения системы (T1614)	CVE-2023-35325 CVE-2022-34689
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2021-21135 CVE-2019-9787 CVE-2020-10136
Сбор данных	Захват экрана (T1113)	CVE-2021-30682 CVE-2020-1599 CVE-2016-3352
	Захват входных данных (T1056)	CVE-2021-28169 CVE-2019-1563
Командование и управление	Программное обеспечение для удаленного доступа (T1219)	CVE-2023-5561 CVE-2019-12086 CVE-2018-0886
	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2022-40684 CVE-2023-35325
	Эксфильтрация через физическую среду (T1052)	CVE-2008-2292 CVE-2007-2446
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266
	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2014-3153

Таблица 8 – Используемые уязвимости шаблона CAPEC-656

Тактика	Техника	Уязвимости
Разведка	Информационный фишинг (T1598)	CVE-2024-38143 CVE-2020-4046 CVE-2019-9787 CVE-2021-21135 CVE-2020-10136 CVE-2024-38180
	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2022-26925

Продолжение таблицы 8

Тактика	Техника	Уязвимости
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0683 CVE-2024-20666 CVE-2021-3197
	Компрометация учетных записей (T1586)	CVE-2022-26925 CVE-2021-26291
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2024-38180 CVE-2020-10136 CVE-2019-0633 CVE-2021-21132
	Доверительные отношения (T1199)	CVE-2022-40684 CVE-2021-21134
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168 CVE-2019-1563
Закрепление	Создание учетных записей (T1136)	CVE-2019-14287 CVE-2020-0683
	Действующие учетные записи (T1078)	CVE-2020-0683 CVE-2022-26925 CVE-2021-3197 CVE-2020-0753 CVE-2023-30861
Повышение привилегий	Существующие учетные записи (T1078)	CVE-2021-3197 CVE-2020-0753 CVE-2023-22809 CVE-2024-22017
	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2023-30861 CVE-2023-49084
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017 CVE-2020-16996 CVE-2024-20666
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2023-49084 CVE-2021-21134 CVE-2024-22017 CVE-2020-16996

Продолжение таблицы 8

Тактика	Техника	Уязвимости
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2024-22017
	Кража или подделка билетов Kerberos (T1558)	CVE-2020-16996 CVE-2024-20666 CVE-2022-1040 CVE-2023-35325 CVE-2021-21134
Обнаружение	Изучение владельца или пользователей системы (T1033)	CVE-2020-11985 CVE-2019-0633 CVE-2020-3175 CVE-2023-35325 CVE-2018-15473
	Изучение местоположения системы (T1614)	CVE-2023-35325 CVE-2020-3175 CVE-2022-30295
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787
	Использование альтернативных материалов для аутентификации (T1550)	CVE-2021-26291 CVE-2022-40684
Сбор данных	Захват видеоданных (T1125)	CVE-2021-30682 CVE-2020-1599
Командование и управление	Программное обеспечение для удаленного доступа (T1219)	CVE-2023-5561 CVE-2019-12086 CVE-2018-0886
	Перенос входящего инструмента (T1105)	CVE-2018-13382 CVE-2017-0022
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-35325 CVE-2017-0122
	Эксфильтрация через физическую среду (T1052)	CVE-2008-2292 CVE-2007-2446
	Передача по расписанию (T1029)	CVE-2019-0804 CVE-2020-1054
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266

Таблица 9 – Используемые уязвимости шаблона CAPEC-410

Тактика	Техника	Уязвимости
Разведка	Сбор информации об организациях жертв (T1591)	CVE-2022-34689 CVE-2019-19919 CVE-2022-23614 CVE-2022-29078 CVE-2021-22204
	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2020-11985
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684 CVE-2023-35325 CVE-2018-13382 CVE-2017-0022 CVE-2016-2106
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2020-10136 CVE-2019-12086
	Доверительные отношения (T1199)	CVE-2021-26291 CVE-2022-40684 CVE-2021-21134 CVE-2023-49084 CVE-2020-16996
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168 CVE-2019-1563 CVE-2020-1054
Закрепление	Действующие учетные записи (T1078)	CVE-2019-14287 CVE-2020-0683 CVE-2021-3197 CVE-2020-0753
	Расширения для браузера (T1176)	CVE-2021-21134 CVE-2023-49084 CVE-2023-22809
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2023-30861
	Манипуляции с токенами доступа (T1134)	CVE-2024-22017 CVE-2020-16996

Продолжение таблицы 9

Тактика	Техника	Уязвимости
	Существующие учетные записи (T1078)	CVE-2020-0683 CVE-2021-3197 CVE-2020-0753
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017 CVE-2024-38180 CVE-2020-16996
	Удаление индикаторов (T1070)	CVE-2019-3978 CVE-2020-0836 CVE-2021-25281 CVE-2013-0209
Получение учетных данных	Манипуляции с токенами доступа (T1134)	CVE-2023-49084 CVE-2024-20666
	Кража токена доступа к приложению (T1528)	CVE-2023-49084 CVE-2021-21134 CVE-2020-16996
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2021-26291 CVE-2023-35325 CVE-2022-26925
	Кража или подделка билетов Kerberos (T1558)	CVE-2022-1040 CVE-2021-26291
Обнаружение	Изучение владельца или пользователей системы (T1033)	CVE-2020-11985 CVE-2019-0633 CVE-2018-15473 CVE-2021-36942
	Изучение местоположения системы (T1614)	CVE-2020-3175 CVE-2022-30295
	Изучение установленного ПО (T1518)	CVE-2019-0633 CVE-2021-30682
	Изучение сетевых служб (T1046)	CVE-2016-2106 CVE-2011-3544 CVE-2023-0386
	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2019-12643
	Изучение сведений о конфигурации сети (T1016)	CVE-2020-3175 CVE-2022-30295 CVE-2023-35325
	Изучение файлов и каталогов (T1083)	CVE-2021-25281 CVE-2023-37266

Продолжение таблицы 9

Тактика	Техника	Уязвимости
Боковое смещение	x	x
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2019-9787
	Данные со съемных носителей (T1025)	CVE-2016-3352 CVE-2022-44268 CVE-2007-2446
	Автоматизированный сбор (T1119)	CVE-2021-30682 CVE-2020-1599
Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2016-2106 CVE-2011-3544 CVE-2023-0386
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-35325 CVE-2017-0122
	Эксфильтрация через физическую среду (T1052)	CVE-2008-2292 CVE-2007-2447
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266 CVE-2020-1259

Таблица 10 – Используемые уязвимости шаблона CAPEC-630

Тактика	Техника	Уязвимости
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2022-26925
	Поиск по открытым доменам (T1593)	CVE-2022-30295 CVE-2020-3175 CVE-2023-35325
	Сбор информации о хосте жертвы (T1592)	CVE-2022-34689 CVE-2022-23614
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684 CVE-2017-0057 CVE-2023-38497
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2020-10136 CVE-2019-0633 CVE-2023-5561

Продолжение таблицы 10

Тактика	Техника	Уязвимости
	Фишинг (T1566)	CVE-2021-21135 CVE-2024-38143 CVE-2019-9787
Исполнение	Системные службы (T1569)	CVE-2021-3197 CVE-2020-0683 CVE-2019-14287
	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657
	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-28169 CVE-2019-1563 CVE-2023-36874
	Запланированная задача (T1053)	CVE-2020-1054 CVE-2024-38014
Закрепление	Расширения для браузера (T1176)	CVE-2021-21134 CVE-2020-1054
	Запланированная задача (T1053)	CVE-2023-36874 CVE-2020-1054
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197 CVE-2020-0683
Предотвращение обнаружения	Внедрение шаблона (T1221)	CVE-2020-0951 CVE-2019-1458 CVE-2019-1476
	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2019-1458
	Удаление индикаторов (T1070)	CVE-2019-3978 CVE-2020-0836 CVE-2021-25281
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2024-22017 CVE-2020-16996
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2009-0217
	Кража или подделка билетов Kerberos (T1558)	CVE-2024-20666 CVE-2022-1040 CVE-2020-16996
	Изменение процесса аутентификации (T1556)	CVE-2023-3676 CVE-2023-6208

Продолжение таблицы 10

Тактика	Техника	Уязвимости
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2020-3175 CVE-2022-30295 CVE-2023-35325 CVE-2016-2106
	Изучение групп разрешений (T1069)	CVE-2019-14287 CVE-2020-0683 CVE-2021-3197
	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2023-49084 CVE-2024-22017
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787 CVE-2020-4046
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2017-0057
	Захват входных данных (T1056)	CVE-2021-28169 CVE-2019-1563 CVE-2023-36874
	Автоматизированный сбор (T1119)	CVE-2021-30682 CVE-2020-1599 CVE-2013-0431
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643
	Протоколы (кроме прикладного уровня) (T1095)	CVE-2011-3544 CVE-2023-0386 CVE-2008-0960
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2023-35325 CVE-2017-0122 CVE-2022-44268
	Эксфильтрация через веб-сервис (T1567)	CVE-2023-49084 CVE-2024-22017 CVE-2021-21134
	Передача по расписанию (T1029)	CVE-2019-0804 CVE-2020-1054 CVE-2024-38014

Продолжение таблицы 10

Тактика	Техника	Уязвимости
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266
	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2020-0836 CVE-2021-22204

Таблица 11 – Используемые уязвимости шаблона CAPEC-631

Тактика	Техника	Уязвимости
Разведка	Информационный фишинг (T1598)	CVE-2021-36942 CVE-2018-15473 CVE-2022-26925
	Поиск по открытым доменам (T1593)	CVE-2022-30295 CVE-2020-3175 CVE-2023-35325
	Сбор информации о хосте жертвы (T1592)	CVE-2022-34689 CVE-2022-23614
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684 CVE-2017-0057 CVE-2023-38497
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2024-38143 CVE-2019-9787
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657
Закрепление	Расширения для браузера (T1176)	CVE-2021-21134 CVE-2019-1405
	Запланированная задача (T1053)	CVE-2023-36874 CVE-2020-1054
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197 CVE-2020-0683
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2019-1458
	Удаление индикаторов (T1070)	CVE-2019-3978 CVE-2020-0836 CVE-2021-25281

Продолжение таблицы 11

Тактика	Техника	Уязвимости
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2024-22017 CVE-2020-16996
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2009-0217
	Кража или подделка билетов Kerberos (T1558)	CVE-2024-20666 CVE-2022-1040 CVE-2020-16996
	Изменение процесса аутентификации (T1556)	CVE-2023-3676 CVE-2023-6208
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2020-3175 CVE-2022-30295 CVE-2023-35325 CVE-2016-2106
	Изучение групп разрешений (T1069)	CVE-2019-14287 CVE-2020-0683 CVE-2021-3197
	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2023-49084 CVE-2024-22017
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787 CVE-2020-4046
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2017-0057
	Захват входных данных (T1056)	CVE-2021-28169 CVE-2019-1563 CVE-2023-36874
	Автоматизированный сбор (T1119)	CVE-2021-30682 CVE-2020-1599 CVE-2013-0431
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643
	Протоколы (кроме прикладного уровня) (T1095)	CVE-2011-3544 CVE-2023-0386 CVE-2008-0960

Продолжение таблицы 11

Тактика	Техника	Уязвимости
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2023-35325 CVE-2017-0122 CVE-2022-44268
	Эксфильтрация через веб-сервис (T1567)	CVE-2023-49084 CVE-2024-22017 CVE-2021-21134
	Передача по расписанию (T1029)	CVE-2019-0804 CVE-2020-1054 CVE-2024-38014
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266
	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2020-0836 CVE-2021-22204

Таблица 12 – Используемые уязвимости шаблона CAPEC-194

Тактика	Техника	Уязвимости
Разведка	Информационный фишинг (T1598)	CVE-2024-38143 CVE-2019-9787 CVE-2020-4046 CVE-2021-21135
	Сбор информации об организациях жертв (T1591)	CVE-2022-34689 CVE-2022-23614 CVE-2013-6890 CVE-2021-22204
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0683 CVE-2024-20666
	Компрометация учетных записей (T1586)	CVE-2022-26925 CVE-2021-26291 CVE-2022-40684
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2020-10136 CVE-2019-0633 CVE-2017-7821

Продолжение таблицы 12

Тактика	Техника	Уязвимости
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168 CVE-2019-1563
Закрепление	Создание учетных записей (T1136)	CVE-2023-30861 CVE-2024-38217
	Действующие учетные записи (T1078)	CVE-2020-0753 CVE-2021-3197 CVE-2019-14287 CVE-2020-0683
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2023-22809 CVE-2024-22017
	Обход механизмов контроля привилегий (T1548)	CVE-2020-0683 CVE-2017-0100 CVE-2024-22017 CVE-2009-1185
	Существующие учетные записи (T1078)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2019-1458 CVE-2019-1476 CVE-2020-0951
	Удаление индикаторов (T1070)	CVE-2019-3978 CVE-2020-0836 CVE-2022-35751 CVE-2021-25281
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2021-26291 CVE-2009-0217
	Изменение процесса аутентификации (T1556)	CVE-2023-3676 CVE-2023-6208 CVE-2020-16996
	Кража или подделка билетов Kerberos (T1558)	CVE-2024-20666 CVE-2020-16996 CVE-2023-49084

Продолжение таблицы 12

Тактика	Техника	Уязвимости
	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2021-21134 CVE-2023-49084 CVE-2009-1185
Обнаружение	Обнаружение учетной записи (T1087)	CVE-2018-15473 CVE-2021-36942 CVE-2020-11985
	Изучение владельца или пользователей системы (T1033)	CVE-2019-15752 CVE-2022-26925 CVE-2020-11985
	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2024-29988
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787 CVE-2020-10136 CVE-2020-4046 CVE-2021-26291
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2017-0057 CVE-2017-7821 CVE-2019-12643
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2023-49084
	Перенос входящего инструмента (T1105)	CVE-2023-5561 CVE-2018-0886 CVE-2020-16012
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2023-49084 CVE-2024-22017 CVE-2021-21134 CVE-2022-34689 CVE-2023-35325
	Передача по расписанию (T1029)	CVE-2019-0804 CVE-2020-1054 CVE-2024-38014
Удар	Повреждение программы (T1495)	CVE-2021-25281 CVE-2013-0209 CVE-2011-3544 CVE-2016-2106

Продолжение таблицы 12

Тактика	Техника	Уязвимости
	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2020-0836 CVE-2021-22204 CVE-2022-44268
	Манипулирование данными (T1565)	CVE-2023-35325 CVE-2022-30295 CVE-2020-3175 CVE-2021-30682

Таблица 13 – Используемые уязвимости шаблона CAPEC-151

Тактика	Техника	Уязвимости
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2022-26925 CVE-2020-11985 CVE-2021-21134
	Сбор информации об организациях жертв (T1591)	CVE-2022-34689 CVE-2022-23614 CVE-2013-6890
	Информационный фишинг (T1598)	CVE-2024-38143 CVE-2020-4046
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0683
	Компрометация учетных записей (T1586)	CVE-2021-26291 CVE-2022-40684 CVE-2023-49084 CVE-2020-16996
	Компрометация инфраструктуры (T1584)	CVE-2023-35325 CVE-2022-26925 CVE-2021-26291
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2024-38180 CVE-2020-10136 CVE-2019-9787 CVE-2020-4046
	Доверительные отношения (T1199)	CVE-2022-26925 CVE-2021-21134

Продолжение таблицы 13

Тактика	Техника	Уязвимости
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2019-1563
Закрепление	Создание учетных записей (T1136)	CVE-2024-38213 CVE-2024-38217
	Действующие учетные записи (T1078)	CVE-2020-0683 CVE-2021-3197
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2023-22809 CVE-2024-22017 CVE-2020-0753 CVE-2019-1322
	Существующие учетные записи (T1078)	CVE-2019-14287 CVE-2021-36942
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2009-0217
	Кража или подделка билетов Kerberos (T1558)	CVE-2020-16996 CVE-2024-20666 CVE-2022-1040 CVE-2023-49084
	Изменение процесса аутентификации (T1556)	CVE-2023-3676 CVE-2019-3978
Обнаружение	Обнаружение учетной записи (T1087)	CVE-2018-15473 CVE-2020-0683
	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2023-49084
	Изучение владельца или пользователей системы (T1033)	CVE-2020-11985 CVE-2021-21134 CVE-2018-15473
	Изучение файлов и каталогов (T1083)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266 CVE-2020-1259
	Изучение местоположения системы (T1614)	CVE-2020-3175 CVE-2021-30657
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787

Продолжение таблицы 13

Тактика	Техника	Уязвимости
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022
	Данные со съемных носителей (T1025)	CVE-2016-3352 CVE-2022-44268
Командование и управление	Программное обеспечение для удаленного доступа (T1219)	CVE-2023-5561 CVE-2019-12086 CVE-2018-0886
	Перенос входящего инструмента (T1105)	CVE-2020-16012 CVE-2023-38497
	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2023-49084 CVE-2024-22017
	Эксфильтрация по каналу C2 (1041)	CVE-2023-35325 CVE-2019-0804
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266
	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2020-0836
	Повреждение программы (T1495)	CVE-2011-3544 CVE-2016-2106

Таблица 14 – Используемые уязвимости шаблона CAPEC-504

Тактика	Техника	Уязвимости
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2018-15473 CVE-2021-36942 CVE-2021-30657 CVE-2020-10136 CVE-2022-34689 CVE-2021-21134
	Поиск по открытым доменам (T1593)	CVE-2020-3175 CVE-2024-22017
	Сбор идентификационной информации (T1589)	CVE-2021-3197 CVE-2020-11985

Продолжение таблицы 14

Тактика	Техника	Уязвимости
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382 CVE-2022-26925 CVE-2021-26291 CVE-2020-0683
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2019-1322 CVE-2021-21135 CVE-2020-16012
	Теневая компрометация (T1189)	CVE-2021-30682 CVE-2020-1054 CVE-2020-0951 CVE-2019-0804
Исполнение	Использование пользователем (T1204)	CVE-2019-14287 CVE-2020-16996 CVE-2024-38476
	Системные службы (T1569)	CVE-2019-1405 CVE-2020-0753 CVE-2019-1563 CVE-2020-4046
	Интерпретаторы командной строки и сценариев (T1059)	CVE-2020-11985 CVE-2023-36874 CVE-2022-26925
	Запланированная задача (T1053)	CVE-2023-22809 CVE-2019-0756 CVE-2019-0633
Закрепление	Расширения для браузера (T1176)	CVE-2020-1599 CVE-2021-38165 CVE-2024-38143 CVE-2022-30295
	Запланированная задача (T1053)	CVE-2023-49084 CVE-2024-39929 CVE-2023-38497
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2023-36874 CVE-2023-6208
	Обход механизмов контроля привилегий (T1548)	CVE-2021-21132 CVE-2024-38180
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2019-12086 CVE-2018-13382 CVE-2021-36942 CVE-2022-40684

Продолжение таблицы 14

Тактика	Техника	Уязвимости
	Внедрение шаблона (T1221)	CVE-2017-7821 CVE-2019-9787 CVE-2020-16012 CVE-2023-38497 CVE-2019-15752 CVE-2022-30295
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2020-0836 CVE-2019-3978
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2021-22204 CVE-2022-23614 CVE-2022-29078 CVE-2021-3197
Обнаружение	Изучение установленного ПО (T1518)	CVE-2024-38014 CVE-2023-3676 CVE-2021-21134 CVE-2023-30861 CVE-2024-22017
	Изучение файлов и каталогов (T1083)	CVE-2020-16996 CVE-2024-29988 CVE-2024-38180 CVE-2024-38217
	Изучение сведений о конфигурации сети (T1016)	CVE-2016-0046 CVE-2019-3462 CVE-2017-12150
Боковое смещение	x	x
Сбор данных	Автоматизированный сбор (T1119)	CVE-2021-36942 CVE-2022-40684 CVE-2018-15473 CVE-2021-30657
	Данные со съемных носителей (T1025)	CVE-2020-10136 CVE-2021-21134
Командование и управление	Программное обеспечение для удаленного доступа (T1219)	CVE-2018-13382 CVE-2022-26925 CVE-2020-0683
	Перенос входящего инструмента (T1105)	CVE-2021-26291 CVE-2021-21135
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2020-16012 CVE-2021-30682 CVE-2020-1054

Продолжение таблицы 14

Тактика	Техника	Уязвимости
	Эксфильтрация по каналу C2 (1041)	CVE-2020-0951 CVE-2019-0804
Удар	Манипулирование данными (T1565)	CVE-2019-14287 CVE-2020-16996
	Уничтожение данных (T1485)	CVE-2024-38476 CVE-2019-1405 CVE-2020-0753

Таблица 15 – Используемые уязвимости шаблона CAPEC-654

Тактика	Техника	Уязвимости
Разведка	Поиск по открытым доменам (T1593)	CVE-2022-34689 CVE-2021-21134 CVE-2023-49084 CVE-2024-22017 CVE-2022-29078
	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2018-15473 CVE-2021-30657
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-26925 CVE-2018-13382 CVE-2021-26291 CVE-2024-38143
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2021-21135 CVE-2020-16012 CVE-2021-21132 CVE-2023-3676
Исполнение	Использование пользователем (T1204)	CVE-2021-30682 CVE-2020-1054 CVE-2023-6208
	Системные службы (T1569)	CVE-2020-0951 CVE-2019-1405 CVE-2020-0683 CVE-2019-0804
	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-44168 CVE-2019-14287 CVE-2020-0753 CVE-2023-36874 CVE-2019-1563

Продолжение таблицы 15

	Запланированная задача (T1053)	CVE-2020-16996 CVE-2024-38476 CVE-2023-22809
Закрепление	Запланированная задача (T1053)	CVE-2024-39929 CVE-2023-38497
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2019-14287 CVE-2020-4046 CVE-2024-38180
	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2024-38143 CVE-2023-36851 CVE-2020-1599 CVE-2021-3197 CVE-2022-30295
	Выполнение кода по событию (T1546)	CVE-2019-1405 CVE-2019-0756
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2024-38213 CVE-2024-38217 CVE-2020-11985
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2021-38165 CVE-2020-0836 CVE-2019-3978 CVE-2021-22204
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2024-38143 CVE-2022-23614
Обнаружение	Изучение установленного ПО (T1518)	CVE-2023-30861 CVE-2024-29988 CVE-2016-0046 CVE-2017-12150
	Изучение сведений о конфигурации сети (T1016)	CVE-2019-3462 CVE-2020-3175
Боковое смещение	x	x
Сбор данных	Автоматизированный сбор (T1119)	CVE-2021-36942 CVE-2022-40684 CVE-2018-15473 CVE-2021-30657 CVE-2020-10136 CVE-2022-34689 CVE-2021-21134

Продолжение таблицы 15

	Захват входных данных (T1056)	CVE-2021-21135 CVE-2020-16012 CVE-2021-30682
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2018-13382 CVE-2022-26925 CVE-2021-26291
	Программное обеспечение для удаленного доступа (T1219)	CVE-2020-0683 CVE-2019-1322 CVE-2020-0951 CVE-2019-0804
	Протоколы (кроме прикладного уровня) (T1095)	CVE-2021-44168 CVE-2019-14287
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2020-1054 CVE-2023-6208 CVE-2021-21132
	Эксфильтрация по каналу C2 (1041)	CVE-2023-36874 CVE-2024-38143
Удар	Манипулирование данными (T1565)	CVE-2020-1599 CVE-2021-3197 CVE-2021-38165 CVE-2024-38143 CVE-2022-30295

Таблица 16 – Используемые уязвимости шаблона CAPEC-173

Тактика	Техника	Уязвимости
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2023-49084 CVE-2024-22017
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-26925 CVE-2024-38143 CVE-2023-36851
Первоначальный доступ	Фишинг (T1566)	CVE-2022-26925 CVE-2024-38143 CVE-2023-36851
	Теневая компрометация (T1189)	CVE-2020-16012 CVE-2023-6208
Исполнение	Использование пользователем (T1204)	CVE-2021-30682 CVE-2020-1054 CVE-2023-36874

Продолжение таблицы 16

	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-44168 CVE-2019-14287 CVE-2020-0753
Закрепление	Запланированная задача (T1053)	CVE-2020-16996 CVE-2024-38476 CVE-2024-39929
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2019-1405 CVE-2020-0683 CVE-2019-0756
	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2024-38143 CVE-2022-30295 CVE-2021-3197 CVE-2020-1599
Предотвращение обнаружения	Удаление индикаторов (T1070)	CVE-2023-22809 CVE-2024-38217
	Внедрение шаблона (T1221)	CVE-2019-0633 CVE-2024-38180
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2021-38165 CVE-2020-0836
	Манипуляции с токенами доступа (T1134)	CVE-2021-22204 CVE-2022-29078
Обнаружение	Изучение сетевых служб (T1046)	CVE-2016-0046 CVE-2017-12150
	Изучение установленного ПО (T1518)	CVE-2023-30861 CVE-2024-29988
	Изучение групп разрешений (T1069)	CVE-2019-19919 CVE-2020-4046
Боковое смещение	x	x
Сбор данных	Данные со съемных носителей (T1025)	CVE-2021-21135 CVE-2020-16012 CVE-2023-3676 CVE-2020-1054
	Захват входных данных (T1056)	CVE-2023-36874 CVE-2024-38143
	Захват экрана (T1113)	CVE-2023-36874 CVE-2024-38143

Продолжение таблицы 16

Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2019-14287 CVE-2020-0753 CVE-2020-16996 CVE-2024-38476 CVE-2024-39929 CVE-2023-22809 CVE-2024-38217
	Перенос входящего инструмента (T1105)	CVE-2019-0633 CVE-2024-38180
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2021-38165 CVE-2020-0836 CVE-2021-22204 CVE-2022-29078
	Эксфильтрация через веб-сервис (T1567)	CVE-2016-0046 CVE-2019-0633 CVE-2024-38180
	Эксфильтрация по каналу C2 (1041)	CVE-2021-38165 CVE-2020-0836
Удар	Уничтожение данных (T1485)	CVE-2021-22204 CVE-2022-29078
	Повреждение программы (T1495)	CVE-2016-0046 CVE-2017-12150
	Манипулирование данными (T1565)	CVE-2023-30861 CVE-2024-29988

Таблица 17 – Используемые уязвимости шаблона CAPEC-89

Тактика	Техника	Уязвимости
Разведка	Сбор информации об организациях жертв (T1591)	CVE-2022-40684 CVE-2018-15473 CVE-2021-30657 CVE-2022-34689
	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2023-49084 CVE-2024-22017
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382 CVE-2022-26925 CVE-2024-38143 CVE-2023-36851

Продолжение таблицы 17

Тактика	Техника	Уязвимости
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2020-0683 CVE-2019-1322 CVE-2021-21135 CVE-2020-16012 CVE-2023-3676
Исполнение	Использование пользователем (T1204)	CVE-2021-30682 CVE-2020-1054 CVE-2023-6208 CVE-2021-21132 CVE-2021-44168 CVE-2019-14287
Закрепление	x	x
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2021-36942 CVE-2020-0951 CVE-2019-14287 CVE-2020-0683 CVE-2019-0756 CVE-2020-0753 CVE-2021-44168
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2021-21135 CVE-2020-16012 CVE-2023-3676
	Внедрение шаблона (T1221)	CVE-2023-49084 CVE-2024-22017
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2022-26925 CVE-2024-38143 CVE-2021-26291
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2023-36851 CVE-2020-0836 CVE-2019-3978 CVE-2021-3197
	Кража или подделка билетов Kerberos (T1558)	CVE-2020-0836 CVE-2019-3978
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2021-30682 CVE-2020-1054 CVE-2021-21132
	Изучение владельца или пользователей системы (T1033)	CVE-2021-44168 CVE-2018-13382 CVE-2018-15473

Продолжение таблицы 17

Тактика	Техника	Уязвимости
	Изучение сетевых служб (T1046)	CVE-2018-13382 CVE-2022-40684
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2018-13382 CVE-2022-40684
Сбор данных	Автоматизированный сбор (T1119)	CVE-2018-15473 CVE-2021-30657 CVE-2022-34689
	Захват входных данных (T1056)	CVE-2023-6208 CVE-2023-22809
	Данные со съемных носителей (T1025)	CVE-2024-38476 CVE-2024-39929
	Сбор электронной почты (T1114)	CVE-2021-3197 CVE-2023-36874 CVE-2024-38180
Командование и управление	Веб-сервис (T1102)	CVE-2019-1405 CVE-2024-38213 CVE-2024-38217
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2023-36874 CVE-2024-38180
	Эксфильтрация по каналу C2 (1041)	CVE-2024-38213 CVE-2024-38217
Удар	Манипулирование данными (T1565)	CVE-2023-3676 CVE-2019-14287

Таблица 18 – Используемые уязвимости шаблона CAPEC-698

Тактика	Техника	Уязвимости
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2018-15473 CVE-2022-40684 CVE-2021-30657
	Информационный фишинг (T1598)	CVE-2021-21135 CVE-2020-16012 CVE-2023-3676
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382 CVE-2022-26925 CVE-2024-38143

Продолжение таблицы 18

Тактика	Техника	Уязвимости
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2021-21132 CVE-2020-1054 CVE-2023-6208
Исполнение	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-44168 CVE-2019-14287 CVE-2020-0753 CVE-2019-0756
	Запланированная задача (T1053)	CVE-2021-44168 CVE-2019-14287 CVE-2020-0753 CVE-2019-0756
Закрепление	Расширения для браузера (T1176)	CVE-2021-30682 CVE-2023-36874
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2020-0683 CVE-2019-1405 CVE-2020-0951 CVE-2021-26291
	Выполнение кода по событию (T1546)	CVE-2019-0633 CVE-2024-38180
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2024-38217
	Удаление индикаторов (T1070)	CVE-2024-38213 CVE-2023-49084
Получение учетных данных	Манипуляции с токенами доступа (T1134)	CVE-2021-22204 CVE-2022-29078
	Кража токена доступа к приложению (T1528)	CVE-2020-0836 CVE-2019-3978
	Кража или подделка сертификатов аутентификации (T1649)	CVE-2023-36851 CVE-2021-38165
	Кража или подделка билетов Kerberos (T1558)	CVE-2022-30295 CVE-2021-3197
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2020-1599
	Изучение сведений о конфигурации сети (T1016)	CVE-2016-0046 CVE-2017-12150
	Изучение установленного ПО (T1518)	CVE-2023-30861 CVE-2024-22017
	Изучение сетевых служб (T1046)	CVE-2019-19919 CVE-2020-4046

Продолжение таблицы 18

Тактика	Техника	Уязвимости
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2021-21135 CVE-2020-16012 CVE-2023-3676
Сбор данных	Автоматизированный сбор (T1119)	CVE-2021-36942 CVE-2018-15473 CVE-2022-40684
	Сбор электронной почты (T1114)	CVE-2020-1599 CVE-2021-3197
	Захват входных данных (T1056)	CVE-2021-21132 CVE-2020-1054
Командование и управление	Программное обеспечение для удаленного доступа (T1219)	CVE-2018-13382 CVE-2022-26925 CVE-2024-38143
	Перенос входящего инструмента (T1105)	CVE-2021-44168 CVE-2019-14287
	Веб-сервис (T1102)	CVE-2020-0683 CVE-2019-1405
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2023-36874 CVE-2024-38180
	Эксфильтрация по каналу C2 (1041)	CVE-2024-38213 CVE-2024-38217
	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-49084 CVE-2024-22017
Удар	Манипулирование данными (T1565)	CVE-2022-30295 CVE-2021-3197 CVE-2023-30861

Получившиеся таблицы лаконично и четко показывают соответствие между сценариями реализации CAPEC [43] и исполняемыми уязвимостями. Стоит отметить, что полученный перечень уязвимостей является отфильтрованным. Важным является тот факт, что даже “старые” уязвимости (2008 г., 2009 г.) не являются закрытыми, и информация по ним обновляется по настоящий момент.

Действительно, полученный перечень уязвимостей сильно меньше изначального, но все же порядка 100 уязвимостей в общем списке в отсутствии классификации являются сильно менее удобными для представления в целом и для предоставления

рекомендаций по этапам сценария реализации атак класса “Социальная инженерия”. Такую проблему решает проведение классифицирования полученного перечня CVE.

Данная процедура будет полезна при анализе техник для формирования регламентов противодействия атакам заданного класса, так как удобнее и проще работать с группами, нежели чем с бесформенным и монотонным списком. Помимо вышесказанного, далее подобная классификация будет полезна при составлении перечней объектов воздействия и негативных последствий атак, что проще и оптимальнее делать, имея в распоряжении распределенные по группам уязвимости.

Классификация производится по ряду общих признаков. Чтобы выявить схожие закономерности, представляется необходимым составление матрицы с перспективами реализации злоумышленником каждой уязвимости в контексте атаки класса “Социальная инженерия”. Для наглядности необходимо составить таблицу 19 с CVE-идентификаторами и описанием того, как может воспользоваться ими злоумышленник в контексте социальной инженерии. При составлении матрицы целесообразно будет использовать информацию с множества различных порталов (в том числе и иностранных), посвященных уязвимостям CVE [44 – 49].

Таблица 19 – Перечень уязвимостей CVE

Уязвимость	Перспектива реализации
CVE-2024-21306	Позволяет злоумышленнику обманом выдавать себя за другое устройство.
CVE-2024-21320	Злоумышленник может манипулировать настройками темы системы, создавая убедительный поддельный внешний вид (обман/убеждение).
CVE-2021-36942	Злоумышленник обманным путем заставляет или убеждает жертву использовать компонент Windows LSA.
CVE-2020-1599	Злоумышленник может обманывать пользователя через ошибки отображения в интерфейсе ОС Windows.
CVE-2017-0122	Злоумышленник может обманным путем получить доступ данным из памяти процесса через специально созданный веб-сайт.
CVE-2017-0057	Злоумышленник обманным путем убеждает пользователя посетить небезопасную веб-страницу.
CVE-2017-0022	Злоумышленник обманным путем может получить доступ на диск с помощью специально созданного веб-сайта.
CVE-2023-35325	Злоумышленник обманным путем заставляет или убеждает жертву раскрыть защищаемую информацию из диспетчера очереди печати Windows Print Spooler.

Продолжение таблицы 19

Уязвимость	Перспектива реализации
CVE-2021-30682	Создает вредоносное приложение, которое обманным путем побуждает пользователя установить его (фишинг).
CVE-2022-44268	Злоумышленник может создать поддельный файл, который при открытии в уязвимой версии ImageMagick раскрывает конфиденциальную информацию.
CVE-2023-5561	Злоумышленник может обманным путем заставить администратора сайта установить вредоносный плагин или обновление WordPress.
CVE-2011-3544	Злоумышленник может убедить пользователя запустить вредоносное Java-приложение через Java Web Start или апплет.
CVE-2021-28169	Злоумышленник может обманом заставить пользователя посетить подменный URL, отыскав информацию из защищенных ресурсов, таких как файл web.xml.
CVE-2016-2106	Злоумышленник может обманом заставить пользователя использовать OpenSSL 1.0.1t, 1.0.2, 1.0.2h.
CVE-2019-12086	Злоумышленник может убедить обработать подменное JSON-сообщение, позволив читать локальные файлы на сервере через вредоносный файл в электронной почте или на веб-сайте.
CVE-2018-15473	Злоумышленник обманом пытается убедить администратора OpenSSH предоставить доступ к серверу по SSH, чтобы провести брутфорс-атаку на найденные логины.
CVE-2019-1563	Злоумышленник может обманом заставить администратора настроить сервер обрабатывать зашифрованные данные (OpenSSL), для восстановления ключа или расшифровки сообщения через атаку Bleichenbacher
CVE-2019-14287	Злоумышленник может обманом убедить пользователя выполнить команду с правами суперпользователя (root), используя неправильно настроенный конфигурационный файл sudoers. Или подделать UID легитимного пользователя.
CVE-2016-3352	Злоумышленник обманным путем заставляет или убеждает жертв использовать Windows 8.1, Windows RT 8.1 и Windows 10 Gold, 1511 и 1607, так как там не проводилась правильная проверка запросов NTLM SSO.
CVE-2023-0386	Злоумышленник обманным путем заставляет пользователя установить или запустить подменное приложение, которое эксплуатирует уязвимость в файловой системе OverlayFS.
CVE-2018-13382	Злоумышленник подделывает HTTP запросы. Это может привести к несанкционированному доступу к SSL VPN.
CVE-2022-35751	Злоумышленник обманным путем заставляет или убеждает жертву использовать систему аппаратной виртуализации Windows Hyper-V ОС Windows, что позволяет получить несанкционированный доступ к системе.
CVE-2022-40684	Злоумышленник может обманом заставить администратора взаимодействовать с поддельной ссылкой, что позволит ему выполнить операции в интерфейсе FortiOS, FortiProxy или FortiSwitchManager без аутентификации.
CVE-2013-0209	Злоумышленник обманом убеждает администратора установить уязвимую версию movabletype-opensource пакета ОС GNU/Linux, что позволяет получить доступ к системе из-за отсутствия аутентификации.

Продолжение таблицы 19

Уязвимость	Перспектива реализации
CVE-2013-6890	Злоумышленник обманом заставляет установить пакет denyhosts версии 2.6, и компрометирует список имен пользователей, вызывая отказ в обслуживании (некорректная аутентификация).
CVE-2008-0960	Злоумышленник может отправить скомпрометированный трафик SNMPv3 с правильным именем пользователя и получать доступ к данным пользователя без правильной фразы аутентификации.
CVE-2008-2292	Злоумышленник заставляет или убеждает жертву в необходимости использования функций __snprint_value и snmp_get в Net-SNMP версий 5.1.4, 5.2.4 и 5.4.1, используемых в SNMP.xs для Perl.
CVE-2017-0100	Злоумышленник создает скомпрометированное приложение, позволяющее получать привилегии в продуктах Microsoft с помощью объекта DCOM в Helppane.exe.
CVE-2018-0886	Злоумышленник обманным путем заставляет подключиться к вредоносному серверу через RDP или WinRM, что позволяет выполнить удаленный код на системе жертвы.
CVE-2019-1322	Злоумышленник компрометирует запросы аутентификации, чтобы получить повышение привилегий.
CVE-2022-1040	Злоумышленник убеждает жертву в необходимости использования Sophos Firewall версии v18.5 MR3 (18.5.3) и старше, для успешной несанкционированной аутентификации.
CVE-2024-20666	Злоумышленник убеждает жертву в необходимости использования системы шифрования дисков BitLocker от Microsoft, для обхода функций безопасности.
CVE-2023-37266	Злоумышленник убеждает жертву в необходимости использования системы CasaOS для выполнения произвольных команд с привилегиями пользователя root.
CVE-2018-14847	Злоумышленник удаленно крадет данные из Winbox MikroTik (порт 8291/tcp), что при возможности аутентификации дает возможность записывать произвольные файлы.
CVE-2019-12643	Компрометация виртуальных сервисов API Cisco REST для ПО Cisco IOS XE позволяет злоумышленнику обходить аутентификацию.
CVE-2021-25281	Злоумышленник убеждает жертву в необходимости использования системы SaltStack Salt до версии 3002.5., для несанкционированного доступа.
CVE-2020-1259	Злоумышленник убеждает сотрудника IT-департамента или администратора вручную внести доверенный хэш в HGS.
CVE-2021-38165	Злоумышленник путем манипуляций с персоналом получает доступ к незашифрованным TLS-сессией данным.
CVE-2009-1185	Атакующий убеждает администратора в том, что не нужно проверять, что сообщение NETLINK исходит из пространства ядра. Это позволит злоумышленнику получить привилегии.
CVE-2021-26291	Злоумышленник отправляет фишинговый ресурс пользователям с (POM) зависимостями, которые могут быть неизвестны пользователям. Это создаёт потенциальный риск, если злоумышленник получит доступ к репозиторию или сможет притвориться им.
CVE-2021-21135	Атакующий убеждает пользователей посетить специально-созданную HTML-страницу, что позволяет воспользоваться некорректной реализацией Performance API в Google Chrome.

Продолжение таблицы 19

Уязвимость	Перспектива реализации
CVE-2020-16012	Злоумышленник убеждает пользователя игнорировать проверку подтверждения источника данных и отправляют вредоносную HTML-страницу.
CVE-2022-30295	Злоумышленник выведывает информацию о DNS-идентификаторах, пользуясь их предсказуемостью.
CVE-2019-18677	Злоумышленник намеренно подталкивает пользователя, чтобы последний вызвал конфликт символов с ограничением длины имени домена. Это приводит к неправильному перенаправлению трафика.
CVE-2019-9787	Атакующий обменом узнает об используемой версии ПО WordPress и пользуется некорректной обработкой защиты CSRF
CVE-2020-0836	Атакующий фальсифицирует запросы к DNS, которые выглядят как нормальные и не вызывают подозрений, вводя в заблуждение персонал.
CVE-2019-3978	Злоумышленник убеждает пользователя использовать ОС RouterOS, в которой нет аутентификации.
CVE-2024-38143	В ходе манипуляций с персоналом злоумышленник получает возможность физического доступа к устройству с WLAN.
CVE-2023-36851	Атакующий с помощью обмана узнает, что жертва пользуется Junos OS на устройствах серии SRX. Далее из-за отсутствующей аутентификации злоумышленник имеет доступ к произвольным файлам.
CVE-2020-3175	Злоумышленник рассылает письма/сообщения якобы от IT-поддержки или вендора устройств, владельцам ресурсов программного обеспечения Cisco NX-OS для Cisco MDS 9000 Series.
CVE-2020-0951	Злоумышленник убеждает пользователя игнорировать WDAC, при выполнении команд PowrShell.
CVE-2019-0804	Атакующий обманным путем получает доступ к файлам подкачки.
CVE-2017-7821	Атакующий убеждает пользователя загрузить Mozilla Firefox, который мог загружать и пытаться открывать файлы некоторых типов, не являющихся исполняемыми, без конкретного взаимодействия с пользователем.
CVE-2023-38497	Атакующий отправляет фишинговый запрос на обновление Cargo, что открывает возможность доступа к файлам.
CVE-2019-15752	Злоумышленник отправляет фишинговый файл-троян пользователю, убеждая его в безопасности исполнения. Позволяет повысить привилегии.
CVE-2024-38476	Злоумышленник подделывает заголовки бэкэнд-приложений, чтобы жертва неумышленно начала выполнение кода на сервере Apache HTTP Server.
CVE-2014-3153	Злоумышленник убеждает жертву в необходимости использования Ubuntu 12.04 и Red Hat Enterprise Linux 6.2, что позволяет незащищенному пользователю повысить привелегии.
CVE-2007-2446	Злоумышленник рекомендует использовать SMB 3.0.0 и 3.0.25rc3 (актуальные версии), что впоследствии дает возможность скомпрометировать целевую систему
CVE-2007-2447	Злоумышленник рекомендует использовать SMB 3.0.0 и 3.0.25rc3 (актуальные версии), что впоследствии дает возможность выполнить произвольные команды.

Продолжение таблицы 19

Уязвимость	Перспектива реализации
CVE-2019-0633	Уязвимость протокола SMBv2 позволяет злоумышленнику выполнить вредоносный код, отправляя пользователям скомпрометированные пакеты.
CVE-2019-0756	Злоумышленник обманом заставляет пользователя активировать компонент Microsoft XML Core Services MSXML, что позволяет выполнить вредоносный код.
CVE-2019-1405	Злоумышленник убеждает жертву воспользоваться службами Windows Universal Plug and Play (UPnP) для повышения привилегий.
CVE-2019-1476	Злоумышленник провоцирует администратора Windows к небезопасному управлению привилегиями.
CVE-2019-1458	Злоумышленник убеждает жертву в правильности и необходимости использования драйвера ядра Win32k. Приводит к повышению привилегий.
CVE-2020-0683	Злоумышленник создает фишинговую символическую ссылку, обрабатываемую пакетами MSI. Приводит к открытию уязвимостей в системе установки Windows.
CVE-2020-0753	Злоумышленник дает ложные инструкции по обработке файлов, позволяющие незащищенному пользователю получить привилегии.
CVE-2020-1054	Злоумышленник убеждает жертву в правильности и необходимости использования драйвера ядра Win32k. Приводит к выполнению кода в режиме ядра.
CVE-2023-36874	Путем обмана злоумышленник получает доступ к информации об ошибках. Злоумышленник может получить права администратора.
CVE-2024-38014	Злоумышленник обманывает или убеждает администратора, чтобы последний выдал ему права и привилегии с использованием Windows Installer.
CVE-2023-3676	Злоумышленник убеждает пользователя создавать поды на узлах Windows, что позволяет повысить привилегии.
CVE-2021-21132	Злоумышленник убеждает или заставляет жертву использовать набор инструментов DevTools веб-браузера Google Chrome, что позволяет обойти ограничения безопасности.
CVE-2023-6208	Злоумышленник убеждает жертву использовать Mozilla: Firefox, Firefox ESR и Thunderbird в средах X11. При использовании X11 текст, ошибочно копировался в основное выделение – временное хранилище, похожее на буфер обмена.
CVE-2021-30657	Злоумышленник создает мошенническое приложение и убеждает пользователя запустить его без выдачи какого-либо предупреждения системы безопасности.
CVE-2021-44168	Злоумышленник подделывает пакеты обновлений и обманом заставляет пользователя создавать произвольные файлы на устройстве операционной системы FortiOS.
CVE-2019-17563	Злоумышленник убеждает персонал в необходимости использования Apache Tomcat от 9.0.0.M1 до 9.0.29, от 8.5.0 до 8.5.49 и от 7.0.0 до 7.0.98.
CVE-2020-10136	Злоумышленник убеждает персонал по проектированию сети использовать IP-in-IP протокол туннелирования.
CVE-2022-26925	Злоумышленник убеждает пользователя использовать подсистему Windows Local Security Authority (LSA), которая позволяла злоумышленнику авторизоваться с помощью NTLM.

Продолжение таблицы 19

Уязвимость	Перспектива реализации
CVE-2022-34689	Злоумышленник подменяет личность, убеждая пользователя в том, что ключ индекса кэша сертификатов на основе MD5 не подвержен коллизиям.
CVE-2009-0217	Злоумышленник манипуляциями с персоналом убеждает пользователей использовать продукты с неправильно реализованной рекомендацией W3C XML Signature Syntax.
CVE-2021-21134	Поддельная HTML-страницу позволяет злоумышленнику подделать интерфейс безопасности Google Chrome для iOS до версии 88.0.4324.96.
CVE-2023-30861	Получение файлов cookie злоумышленником, для которого они не предназначались. уязвимость во фреймворке Flask.
CVE-2023-49084	Получая доступ, посредством авторизации злоумышленник может выполнить вредоносный код на SQL-сервере.
CVE-2013-0431	Обманом злоумышленник убеждает пользователя запустить вредоносный код с повышением привилегий.
CVE-2020-4046	Злоумышленник, имея низкие привилегии может с помощью специального блока вставлять нефильтрованный HTML в редактор блока. Если такие посты просматривал пользователь с более высокими привилегиями, это могло привести к выполнению скриптов в редакторе или wp-админе.
CVE-2024-22017	Злоумышленник убеждает пользователя использовать модуль setuid(), который необходим для несанкционированного повышения привилегий.
CVE-2020-16996	Злоумышленник обманным путем завладевает данными сессии аутентификации Kerberos, получая доступ к сессии.
CVE-2024-29988	Злоумышленник убеждением или иными коммуникативными манипуляциями с персоналом убеждает пользователя игнорировать фильтр SmartScreen в Windows Defender.
CVE-2024-38213	Злоумышленник убеждает пользователя в безопасности исполняемого файла путем обхода Windows SmartScreen операционных систем Windows.
CVE-2024-38180	Злоумышленник убеждает пользователя в безопасности исполняемого файла путем обхода Windows SmartScreen операционных систем Windows.
CVE-2024-38217	Злоумышленник убеждает пользователя в безопасности исполняемого файла путем обхода Smart App Control и пометки файлов MotW.
CVE-2023-22809	Злоумышленник убеждает пользователя несанкционированное повысить уровень привилегий отредактировав файл.
CVE-2024-39929	Злоумышленник создает фишинговые почтовые письма и исполняемыми вложениями в ПО Exim.
CVE-2024-39689	Злоумышленник создает поддельный самоподписанный сертификат Certifi.
CVE-2016-0046	Обманом заставляет или убеждает пользователя выполнить вредоносный код в ОС Windows.
CVE-2020-11985	Злоумышленник компрометирует сетевую среду, выдавая себя за легитимного пользователя, подменяя IP, тем самым получая доступ к PHP логам.

Продолжение таблицы 19

Уязвимость	Перспектива реализации
CVE-2019-3462	Злоумышленник путем манипуляций с персоналом подменяет устанавливаемый пакет пакетного менеджера APT.
CVE-2017-12150	Злоумышленник обманом убеждает пользователя активировать компоненты Samba от 3.0.25 до 4.6.7, например, если версия файлового сервера устарела.
CVE-2022-29078	Злоумышленник в ходе диалога узнает, когда будет проводиться компиляция шаблона и подменяет outputFunctionName вредоносной командой.
CVE-2019-19919	Злоумышленник может скомпрометировать payload и обманным путем выполнить вредоносный код.
CVE-2021-22204	Злоумышленник может создать поддельное вредоносное приложение, обманывая пользователя, выполнить вредоносный код.
CVE-2022-23614	Обманным путем злоумышленник убеждает пользователя предоставить данные, не являющиеся замыканием для PHP-шаблона.
CVE-2021-3197	Обманным путем злоумышленник убеждает или заставляет жертву использовать программу SaltStack Salt.

Далее необходимо проклассифицировать массив уязвимостей. Такая классификация составляется на основании анализа контекста использования всех отобранных уязвимостей по ключевым выделенным признакам в каждой уникальной уязвимости и представляется в виде большой матрицы (таблица 20).

Также в таблице отражены все ключевые данные, используемые при расчетах рисков сценариев реализации атаки. Они включают в себя параметры CPR, EPSS, CVSS (3.1, 4.0), OWASP, DREAD. Более подробно эти системы будут описаны далее.

Стоит коротко описать классификацию уязвимостей. Глобально вся атака делится на 5 классов.

Цель злоумышленника. Классификация показывает, какую основную цель преследует злоумышленник: выполнение кода, кражу, повышение привилегий или обход аутентификации.

Контекст эксплуатации. Классификация показывает среду, посредством взаимодействия с которой будет осуществлена атака: системные элементы, веб-приложения, сетевые сервисы, клиентские приложения.

Уровень прав объекта воздействия подразумевает разницу в правах между авторизованным и неавторизованным пользователем.

Способ реализации предполагает связность с контекстом эксплуатации и показывает

Ключевая классификация для атаки класса “Социальная инженерия” подразумевает различие в способах воздействия: большая ложь, внушение (открытое/закрытое), скрытый удар [13].

Для более комфортного представления древа классификаций необходимо составление схемы классификаций. Такая схема представлена на рисунке 4.

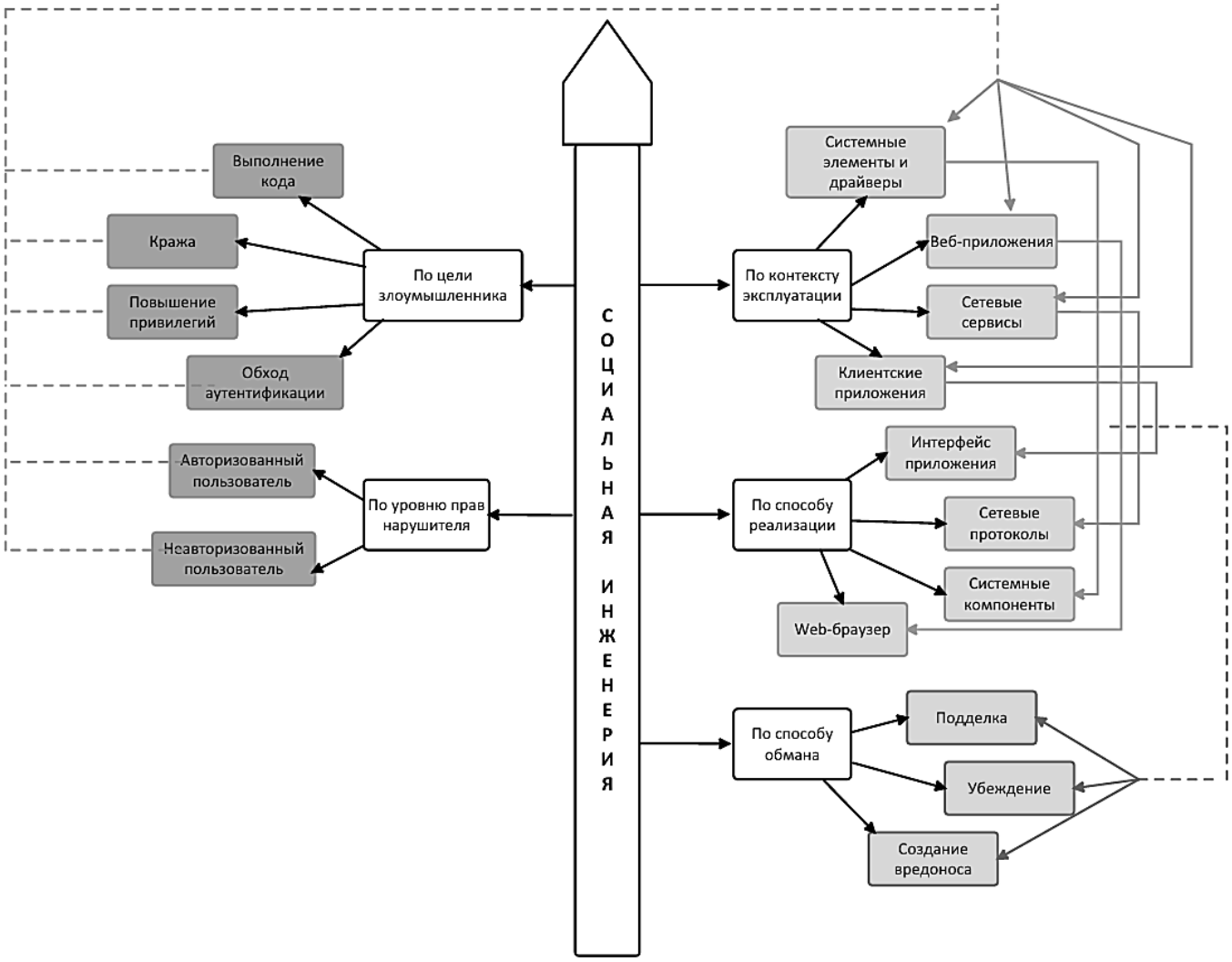


Рисунок 4 – Структура классификации уязвимостей

Таблица 20 – Древо классификации отобранных уязвимостей

Классификация/CVE-Идентификатор	По цели злоумышленника				По контексту эксплуатации					По уровню прав объекта воздействия		По способу реализации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользователь	Авторизованный пользователь	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWASP	DREAD	Среднеквадратичная оценка критичности
CVE-2024-21306	0	0	1	0	1	0	0	0	0	1	0	0	1	0	0	1	0	0	0,39	0,29	0,52	0,64	0,50	0,69	0,52
CVE-2024-21320	0	0	1	0	0	0	0	1	0	0	1	0	1	0	0	1	0	0	0,51	0,48	0,61	0,66	0,50	0,58	0,56
CVE-2021-36942	0	0	0	1	0	0	1	0	0	1	0	0	1	0	0	1	0	0	0,74	0,93	0,80	0,87	0,68	0,84	0,82
CVE-2020-1599	0	0	0	1	0	0	0	1	0	1	0	0	0	0	1	0	1	0	0,11	0,04	0,50	0,63	0,25	0,62	0,43
CVE-2017-0122	0	0	1	0	1	0	0	0	0	1	0	1	0	0	0	0	0	1	0,23	0,10	0,53	0,66	0,74	0,56	0,52
CVE-2017-0057	0	0	1	0	0	0	1	0	0	1	0	0	1	0	0	0	0	1	0,33	0,30	0,53	0,66	0,44	0,51	0,48
CVE-2017-0022	0	0	1	0	0	0	0	1	0	1	0	0	1	0	0	0	0	1	0,66	0,59	0,53	0,66	0,38	0,73	0,60
CVE-2023-35325	0	0	1	0	0	0	0	1	0	1	0	0	1	0	0	0	0	1	0,34	0,02	0,72	0,86	0,58	0,82	0,63
CVE-2021-30682	0	0	1	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0,41	0,36	0,61	0,66	0,71	0,73	0,60
CVE-2022-44268	0	0	1	0	0	1	0	1	0	0	1	0	0	0	1	1	0	0	0,69	0,89	0,72	0,86	0,57	0,87	0,77
CVE-2023-5561	0	1	0	0	0	1	0	0	0	0	1	0	0	0	1	0	0	1	0,52	0,63	0,48	0,66	0,46	0,60	0,56
CVE-2011-3544	0	0	0	1	0	0	0	1	0	0	1	1	0	0	0	0	1	1	0,96	0,93	1,00	1,00	0,99	0,49	0,91
CVE-2021-28169	0	0	1	0	0	1	0	0	0	0	1	1	0	0	0	0	1	0	0,65	0,92	0,48	0,66	0,75	0,56	0,68
CVE-2016-2106	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	0	0	1	0,62	0,63	0,54	0,80	0,75	0,84	0,71
CVE-2019-12086	0	0	1	0	0	1	0	0	0	1	0	0	0	0	1	0	1	0	0,49	0,34	0,72	0,86	0,83	0,56	0,66

Продолжение таблицы 20

Классификация/CVE-Идентификатор	По цели злоумышленника				По контексту эксплуатации					По уровню прав объекта воздействия		По способу реализации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользователь	Авторизованный пользователь	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWAPS	DREAD	Среднеквадратичная оценка критичности
CVE-2018-15473	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,64	0,90	0,72	0,86	0,88	0,71	0,79
CVE-2019-1563	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,16	0,00	0,30	0,59	0,94	0,60	0,53
CVE-2019-14287	0	1	0	0	0	0	0	1	0	0	1	0	1	0	0	1	0	1	0,77	0,84	0,76	0,83	0,58	0,82	0,77
CVE-2016-3352	1	0	0	0	0	0	0	0	1	1	0	0	1	1	0	1	0	1	0,53	0,30	0,53	0,66	0,40	0,49	0,50
CVE-2023-0386	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0,42	0,17	0,76	0,83	0,22	0,69	0,58
CVE-2018-13382	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,83	0,88	0,72	0,86	0,85	0,80	0,82
CVE-2022-35751	0	1	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0,37	0,05	0,76	0,87	0,71	0,69	0,64
CVE-2022-40684	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,97	0,94	0,98	0,92	0,65	0,87	0,90
CVE-2013-0209	0	1	0	1	0	0	0	1	0	1	0	1	0	0	0	0	0	1	0,70	0,80	0,81	0,66	0,64	0,47	0,69
CVE-2013-6890	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,28	0,12	0,53	0,66	0,93	0,58	0,58
CVE-2008-0960	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	1	0,70	0,57	1,00	1,00	0,51	0,38	0,73
CVE-2008-2292	0	0	0	1	0	0	0	1	0	0	1	0	0	0	1	1	1	0	0,40	0,22	1,00	1,00	0,51	0,47	0,67
CVE-2017-0100	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0,53	0,41	0,64	0,46	0,68	0,60	0,56
CVE-2018-0886	0	0	0	1	0	0	1	0	0	0	1	0	0	1	0	1	0	0	0,72	0,91	0,67	0,68	0,42	0,71	0,70
CVE-2019-1322	0	1	0	0	0	0	0	0	1	0	1	0	0	1	0	1	0	1	0,63	0,39	0,76	0,83	0,60	0,60	0,65

Продолжение таблицы 20

Классификация/CVE-Идентификатор	По цели зло-умышленника				По контексту экс-плуатации					По уровню прав объекта воздействия		По способу реа-лизации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользо-ватель	Авторизованный пользова-тель	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWAPS	DREAD	Среднеквадратичная оценка критичности
CVE-2022-1040	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	0	0	1	0,97	0,94	0,98	0,92	0,74	0,69	0,88
CVE-2024-20666	0	0	1	0	0	0	0	0	1	0	1	0	1	0	0	0	1	1	0,51	0,48	0,62	0,67	0,60	0,71	0,60
CVE-2023-37266	1	0	0	0	0	0	0	0	1	1	0	1	0	0	0	0	0	1	0,69	0,56	0,98	0,92	0,22	0,80	0,74
CVE-2018-14847	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0	0	0	1	0,91	0,89	0,84	0,91	0,40	0,87	0,83
CVE-2019-12643	1	0	0	0	0	0	0	1	0	1	0	0	0	1	0	0	0	1	0,53	0,19	1,00	1,00	0,47	0,58	0,69
CVE-2021-25281	0	0	0	1	0	0	1	0	0	1	0	0	0	1	0	0	0	1	0,86	0,94	0,98	0,92	0,47	0,69	0,83
CVE-2020-1259	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	1	0	1	0,21	0,05	0,37	0,48	0,56	0,60	0,42
CVE-2021-38165	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,25	0,04	0,48	0,54	0,75	0,69	0,52
CVE-2009-1185	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	1	0	1	0,73	0,91	0,92	0,93	0,71	0,47	0,80
CVE-2021-26291	0	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0	0,75	0,77	0,90	0,92	0,85	0,58	0,80
CVE-2021-21135	0	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0	0,42	0,30	0,53	0,66	0,44	0,71	0,53
CVE-2020-16012	0	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0	0,25	0,12	0,48	0,66	0,25	0,71	0,47
CVE-2022-30295	0	0	0	1	0	0	0	0	1	1	0	0	0	1	0	0	1	1	0,33	0,10	0,70	0,66	0,93	0,80	0,65
CVE-2019-18677	0	0	1	0	0	1	0	0	0	1	0	0	0	1	0	1	0	1	0,31	0,09	0,57	0,46	0,93	0,58	0,55
CVE-2019-9787	0	0	0	1	0	1	0	0	0	1	0	1	0	0	0	1	0	1	0,78	0,86	0,87	0,84	0,65	0,56	0,77

Продолжение таблицы 20

Классификация/CVE-Идентификатор	По цели злоумышленника				По контексту эксплуатации					По уровню прав объекта воздействия		По способу реализации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользователь	Авторизованный пользователь	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWAPS	DREAD	Среднеквадратичная оценка критичности
CVE-2020-0836	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	1	0	0	0,29	0,15	0,72	0,86	0,47	0,71	0,59
CVE-2019-3978	0	0	0	1	0	0	1	0	0	1	0	0	0	1	0	0	1	0	0,40	0,13	0,72	0,86	0,71	0,49	0,60
CVE-2024-38143	1	1	0	0	0	0	0	0	1	1	0	0	1	0	0	0	0	1	0,28	0,21	0,36	0,34	0,72	0,71	0,48
CVE-2023-36851	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,49	0,34	0,48	0,66	0,26	0,80	0,54
CVE-2020-3175	0	0	0	1	0	0	0	1	0	1	0	0	0	1	0	0	1	0	0,39	0,02	0,84	0,91	0,56	0,58	0,62
CVE-2020-0951	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	1	0,33	0,02	0,63	0,82	0,53	0,60	0,55
CVE-2019-0804	0	0	1	0	0	0	0	0	1	0	1	0	1	0	0	0	0	1	0,32	0,07	0,44	0,48	0,89	0,71	0,55
CVE-2017-7821	0	0	0	1	0	0	0	1	0	1	0	1	0	0	0	0	1	0	0,46	0,04	0,98	0,92	0,96	0,60	0,74
CVE-2023-38497	0	0	0	1	0	0	0	0	1	0	1	0	0	0	1	0	0	1	0,43	0,23	0,70	0,67	0,61	0,69	0,58
CVE-2019-15752	0	1	0	0	0	0	0	1	0	0	1	0	1	0	0	0	1	1	0,70	0,56	0,72	0,72	0,51	0,58	0,64
CVE-2024-38476	0	0	1	1	0	0	1	0	0	1	0	1	0	0	0	1	0	0	0,55	0,24	0,98	0,92	0,60	0,71	0,71
CVE-2014-3153	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	1	0	0	0,84	0,86	0,92	0,93	0,67	0,69	0,83
CVE-2007-2446	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	1	1	0	0,80	0,79	1,00	1,00	0,99	0,53	0,87
CVE-2007-2447	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0,60	0,75	1,00	1,00	0,25	0,64	0,75
CVE-2019-0633	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	0	1	1	0,55	0,34	0,72	0,74	0,96	0,60	0,68

Продолжение таблицы 20

Классификация/CVE-Идентификатор	По цели зло-умышленника				По контексту экс-плуатации					По уровню прав объекта воздействия		По способу реа-лизации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользо-ватель	Авторизованный пользова-тель	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWAPS	DREAD	Среднеквадратичная оценка критичности
CVE-2019-0756	0	0	0	1	0	0	0	0	1	1	0	1	0	0	0	1	0	1	0,49	0,20	0,72	0,72	0,96	0,71	0,68
CVE-2019-1405	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	1	1	0,75	0,67	0,76	0,83	0,72	0,82	0,76
CVE-2019-1476	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	1	1	0,43	0,17	0,76	0,83	0,44	0,60	0,58
CVE-2019-1458	0	1	0	0	0	0	0	0	1	1	0	0	1	0	0	0	0	1	0,87	0,92	0,76	0,83	0,67	0,71	0,80
CVE-2020-0683	0	1	0	0	1	0	0	0	1	0	1	0	1	0	0	1	0	1	0,55	0,23	0,67	0,70	0,33	0,71	0,56
CVE-2020-0753	0	1	0	0	1	0	0	0	1	0	1	0	1	0	0	0	1	1	0,49	0,30	0,76	0,83	0,57	0,60	0,62
CVE-2020-1054	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	0	1	0,81	0,79	0,67	0,70	0,94	0,71	0,78
CVE-2023-36874	0	1	0	0	1	0	0	0	1	0	1	0	1	0	0	1	0	1	0,76	0,69	0,76	0,83	0,39	0,82	0,73
CVE-2024-38014	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	1	1	0,63	0,39	0,76	0,83	0,89	0,71	0,72
CVE-2023-3676	0	1	0	0	1	0	0	0	0	0	1	0	1	0	0	0	1	0	0,46	0,15	0,87	0,86	0,94	0,71	0,72
CVE-2021-21132	0	0	1	0	0	0	0	1	0	0	1	1	0	0	0	1	0	1	0,50	0,15	0,81	0,66	0,74	0,71	0,63
CVE-2023-6208	0	0	1	0	0	0	0	1	0	0	1	1	0	0	0	1	0	0	0,40	0,00	0,57	0,46	0,57	0,60	0,48
CVE-2021-30657	0	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0	1	1	0,59	0,55	0,61	0,66	0,47	0,71	0,60
CVE-2021-44168	0	0	0	1	0	0	1	0	0	0	1	0	0	1	0	1	0	1	0,45	0,01	0,26	0,42	0,42	0,82	0,47
CVE-2019-17563	1	0	0	0	0	1	0	0	0	1	0	0	0	1	0	1	0	0	0,35	0,02	0,98	0,92	0,88	0,71	0,73

Продолжение таблицы 20

Классификация/CVE-Идентификатор	По цели злоумышленника				По контексту эксплуатации					По уровню прав объекта воздействия		По способу реализации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользователь	Авторизованный пользователь	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWAPS	DREAD	Среднеквадратичная оценка критичности
CVE-2020-10136	1	0	0	0	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0,47	0,51	0,48	0,66	0,51	0,71	0,56
CVE-2022-26925	1	0	0	0	0	0	0	0	1	0	1	0	1	0	0	1	0	0	0,59	0,50	0,79	0,91	0,85	0,82	0,76
CVE-2022-34689	1	0	0	0	0	0	0	0	1	0	1	0	1	0	0	1	0	0	0,07	0,17	0,72	0,86	0,35	0,71	0,56
CVE-2009-0217	0	0	0	1	0	1	0	0	0	1	0	1	0	0	0	1	0	0	0,38	0,34	0,72	0,86	0,33	0,47	0,55
CVE-2021-21134	0	0	1	0	0	0	0	1	0	0	1	1	0	0	0	1	0	0	0,36	0,14	0,61	0,66	0,60	0,71	0,55
CVE-2023-30861	0	0	1	0	0	1	0	0	0	0	1	1	0	0	0	1	0	1	0,40	0,15	0,72	0,86	0,86	0,71	0,67
CVE-2023-49084	0	0	0	1	0	0	1	0	0	0	1	0	0	1	0	0	1	0	0,60	0,47	0,87	0,86	0,32	0,82	0,69
CVE-2013-0431	0	1	0	0	0	0	0	1	0	0	1	0	1	0	0	0	1	0	0,74	0,92	0,48	0,66	0,71	0,47	0,68
CVE-2020-4046	0	0	1	1	0	1	0	0	0	0	1	0	0	0	1	1	0	1	0,26	0,05	0,61	0,68	0,94	0,58	0,60
CVE-2024-22017	0	1	0	0	0	0	0	0	1	0	1	0	1	0	0	0	1	0	0,05	0,12	0,70	0,81	0,29	0,71	0,54
CVE-2020-16996	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,22	0,10	0,61	0,68	0,60	0,71	0,54
CVE-2024-29988	0	0	1	0	0	0	0	1	0	0	1	0	0	0	1	0	0	1	0,89	0,87	0,98	0,92	0,38	0,82	0,83
CVE-2024-38213	0	0	0	1	0	1	0	0	0	0	1	0	0	0	1	0	1	1	0,77	0,84	0,61	0,66	0,89	0,71	0,75
CVE-2024-38180	0	0	0	1	0	0	0	0	1	1	0	0	1	0	0	0	1	1	0,43	0,07	0,87	0,84	0,33	0,71	0,61
CVE-2024-38217	0	0	0	1	0	0	0	1	0	0	1	0	0	0	1	0	1	1	0,64	0,67	0,49	0,46	0,49	0,82	0,61

Продолжение таблицы 20

Классификация/CVE-Идентификатор	По цели злоумышленника				По контексту эксплуатации					По уровню прав объекта воздействия		По способу реализации				По способу воздействия			Прочие данные об уязвимостях						
	Обход аутентификации	Повышение привилегий	Кража	Выполнение кода	Драйверы	Веб-приложения	Сетевые сервисы	Клиентские приложения	Системные элементы	Неавторизованный пользователь	Авторизованный пользователь	Web-браузер	Системные компоненты	Сетевые протоколы	Интерфейс приложения	Большая ложь	Скрытый удар	Внушение	CPR Score	EPSS	CVSS 3.1	CVSS 4.0	Calc OWAPS	DREAD	Среднеквадратичная оценка критичности
CVE-2023-22809	0	1	0	0	0	0	0	1	0	0	1	0	1	0	0	0	0	1	0,61	0,59	0,70	0,66	0,69	0,71	0,66
CVE-2024-39929	0	0	0	1	0	0	1	0	0	1	0	0	0	1	0	0	1	0	0,24	0,56	0,49	0,46	0,28	0,82	0,51
CVE-2024-39689	1	0	1	0	0	1	0	0	0	1	0	1	0	1	0	1	0	0	0,47	0,31	0,72	0,86	0,71	0,71	0,66
CVE-2016-0046	0	0	0	1	0	0	0	1	0	0	1	0	1	0	0	0	1	1	0,47	0,26	1,00	1,00	0,97	0,60	0,77
CVE-2020-11985	1	0	0	0	0	0	1	0	0	1	0	0	0	1	0	1	0	0	0,31	0,16	0,48	0,66	0,35	0,71	0,48
CVE-2019-3462	0	0	0	1	0	0	0	0	1	0	1	0	1	0	0	1	0	1	0,49	0,29	0,72	0,72	0,25	0,58	0,54
CVE-2017-12150	0	0	1	0	0	0	1	0	0	0	1	0	0	1	0	1	0	1	0,43	0,22	0,71	0,90	0,85	0,71	0,68
CVE-2022-29078	0	0	0	1	0	1	0	0	0	0	1	0	0	0	1	1	0	1	0,86	0,93	0,98	0,92	0,51	0,82	0,85
CVE-2019-19919	0	0	0	1	0	1	0	0	0	0	1	1	0	0	0	1	0	0	0,60	0,35	0,98	0,92	0,43	0,58	0,68
CVE-2021-22204	0	0	0	1	0	1	0	0	0	0	1	1	0	0	0	1	0	1	0,87	0,93	0,76	0,83	0,88	0,89	0,86
CVE-2022-23614	0	0	0	1	0	1	0	0	0	1	0	1	0	0	0	0	1	0	0,71	0,60	0,98	0,92	0,42	0,71	0,75
CVE-2021-3197	0	0	0	1	0	0	1	0	0	1	0	0	0	1	0	0	0	1	0,46	0,04	0,98	0,92	0,35	0,60	0,65

Из схемы и из таблицы отчетливо видно, что классификация “по контексту эксплуатации” имеет достаточно высокую степень корреляции с классификацией “по способу реализации”. То есть с высокой долей вероятности уязвимость, использованная в среде веб-приложений, будет реализована посредством веб-браузера и так далее.

Это позволяет условно сгруппировать все классификации в наборы, представляющие из себя своеобразные векторы атаки класса “Социальная инженерия”, основывающиеся только на классификациях используемых уязвимостей. Полученные векторы далее сыграют роль в формировании регламентов противодействия Первый вектор содержит сценарии атаки, реализуемые посредством встроенных в систему элементов и драйверов (драйверы могут быть и сторонними, но таких уязвимостей мало в списке). Второй вектор содержит сценарии, реализующиеся посредством использования сетевых сервисов и протоколов. Третий вектор – веб-среда совместно с веб-приложениями (также нечасто веб-приложения имеют уязвимости в интерфейсе использования). Четвертый вектор реализуется посредством уязвимостей клиентских приложений и их интерфейса. Пятый вектор – атаки класса “Социальная инженерия”, целью которых является выполнение кода. Шестой вектор – атаки, целью которых является кража. Седьмой вектор – атаки, целью которых является повышение привилегий. Восьмой вектор - атаки, целью которых является обход аутентификации. Девятый вектор – атаки по способу воздействия, классифицируемые как “внушение”. Десятый вектор – атаки по способу воздействия, классифицируемые как “скрыты удар”. Одиннадцатый вектор – атаки по способу воздействия, классифицируемые как “большая ложь”. Схема с определенными векторами реализации на основании классификации уязвимостей изображена на рисунке 5.

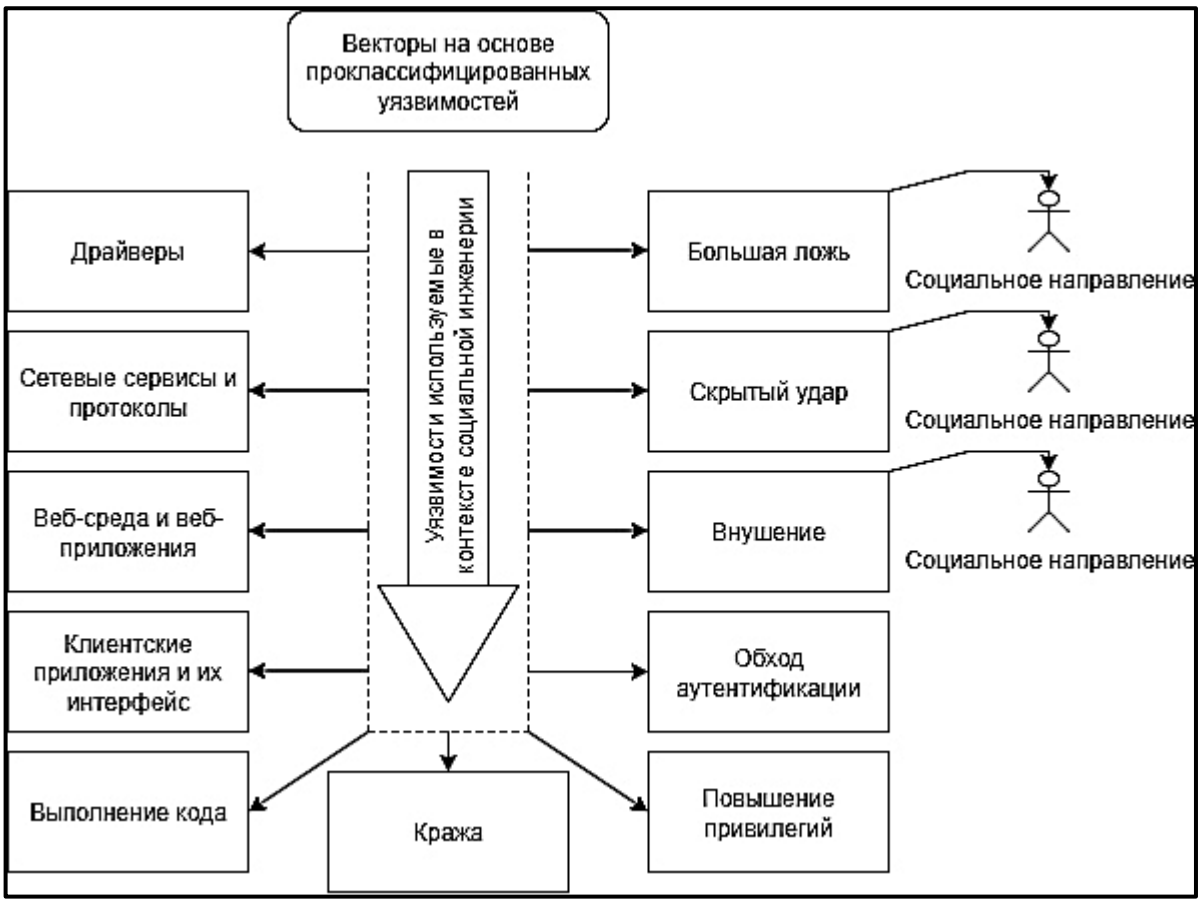


Рисунок 5 – Схема актуальных векторов

Далее в таблице 21 необходимо взаимно-однозначно связать векторы, которые будут учитываться при построении перечня объектов воздействия, с используемыми в них уязвимостями.

Таблица 21 – Используемые в контексте сценариев уязвимости

Вектор	Уязвимость
Драйверы	CVE-2016-3352, CVE-2023-0386, CVE-2022-35751, CVE-2017-0100, CVE-2024-20666, CVE-2020-1259, CVE-2009-1185, CVE-2020-0836, CVE-2024-38143, CVE-2020-0951, CVE-2019-0804, CVE-2014-3153, CVE-2007-2446, CVE-2007-2447, CVE-2019-0633, CVE-2019-1405, CVE-2019-1476, CVE-2019-1458, CVE-2020-0683, CVE-2020-0753, CVE-2020-1054, CVE-2023-36874, CVE-2024-38014, CVE-2022-26925, CVE-2022-34689, CVE-2024-22017, CVE-2024-38180, CVE-2019-3462.

Продолжение таблицы 21

Вектор	Уязвимость
Сетевые сервисы и протоколы	CVE-2021-36942, CVE-2021-28169, CVE-2016-2106, CVE-2018-15473, CVE-2019-1563, CVE-2018-13382, CVE-2022-40684, CVE-2013-6890, CVE-2008-0960, CVE-2018-0886, CVE-2022-1040, CVE-2018-14847, CVE-2021-25281, CVE-2021-38165, CVE-2019-9787, CVE-2019-3978, CVE-2023-36851, CVE-2021-44168, CVE-2020-10136, CVE-2009-0217, CVE-2023-30861, CVE-2023-49084, CVE-2020-16996, CVE-2024-39929, CVE-2024-39689, CVE-2020-11985, CVE-2017-12150, CVE-2019-19919, CVE-2021-22204, CVE-2022-23614, CVE-2021-3197
Веб-среда и веб-приложения	CVE-2021-28169, CVE-2019-9787, CVE-2009-0217, CVE-2023-30861, CVE-2024-39689, CVE-2019-19919, CVE-2021-22204, CVE-2022-23614
Клиентские приложения и их интерфейс	CVE-2020-1599, CVE-2021-30682, CVE-2022-44268, CVE-2008-2292, CVE-2021-30657, CVE-2024-29988, CVE-2024-38217
Выполнение кода	CVE-2007-2446, CVE-2007-2447, CVE-2008-2292, CVE-2009-0217, CVE-2011-3544, CVE-2013-0209, CVE-2014-3153, CVE-2016-0046, CVE-2017-7821, CVE-2018-0886, CVE-2019-0633, CVE-2019-0756, CVE-2019-19919, CVE-2019-3462, CVE-2019-3978, CVE-2019-9787, CVE-2020-0836, CVE-2020-0951, CVE-2020-1599, CVE-2020-3175, CVE-2020-4046, CVE-2021-22204, CVE-2021-25281, CVE-2021-30657, CVE-2021-3197, CVE-2021-36942, CVE-2021-44168, CVE-2022-23614, CVE-2022-29078, CVE-2022-30295, CVE-2022-35751, CVE-2023-38497, CVE-2023-49084, CVE-2024-38180, CVE-2024-38213, CVE-2024-38217, CVE-2024-38476, CVE-2024-39929
Кража	CVE-2024-21306, CVE-2024-21320, CVE-2017-0122, CVE-2017-0057, CVE-2017-0022, CVE-2023-35325, CVE-2021-30682, CVE-2022-44268, CVE-2021-28169, CVE-2019-12086, CVE-2019-1563, CVE-2024-20666, CVE-2018-14847, CVE-2021-38165, CVE-2021-26291, CVE-2021-21135, CVE-2020-16012, CVE-2019-18677, CVE-2019-0804, CVE-2024-38476, CVE-2021-21132, CVE-2023-6208, CVE-2021-21134, CVE-2023-30861, CVE-2020-4046, CVE-2020-16996, CVE-2024-29988, CVE-2024-39689, CVE-2017-12150
Повышение привилегий	CVE-2019-14287, CVE-2023-5561, CVE-2023-0386, CVE-2022-35751, CVE-2013-0209, CVE-2017-0100, CVE-2019-1322, CVE-2020-1259, CVE-2009-1185, CVE-2024-38143, CVE-2019-15752, CVE-2019-1405, CVE-2019-1476, CVE-2019-1458, CVE-2020-0683, CVE-2020-0753, CVE-2020-1054, CVE-2023-36874, CVE-2024-38014, CVE-2023-3676, CVE-2013-0431, CVE-2024-22017, CVE-2023-22809
Обход аутентификации	CVE-2016-2106, CVE-2018-15473, CVE-2016-3352, CVE-2018-13382, CVE-2022-40684, CVE-2013-6890, CVE-2008-0960, CVE-2022-1040, CVE-2023-37266, CVE-2019-12643, CVE-2024-38143, CVE-2023-36851, CVE-2019-17563, CVE-2020-10136, CVE-2022-26925, CVE-2022-34689, CVE-2024-39689, CVE-2020-11985

Продолжение таблицы 21

Вектор	Уязвимость
Внушение	CVE-2017-0122, CVE-2017-0057, CVE-2017-0022, CVE-2023-35325, CVE-2019-14287, CVE-2011-3544, CVE-2016-2106, CVE-2023-5561, CVE-2016-3352, CVE-2013-0209, CVE-2008-0960, CVE-2019-1322, CVE-2022-1040, CVE-2024-20666, CVE-2023-37266, CVE-2018-14847, CVE-2019-12643, CVE-2021-25281, CVE-2020-1259, CVE-2009-1185, CVE-2022-30295, CVE-2019-18677, CVE-2019-9787, CVE-2024-38143, CVE-2020-0951, CVE-2019-0804, CVE-2023-38497, CVE-2019-15752, CVE-2019-0633, CVE-2019-0756, CVE-2019-1405, CVE-2019-1476, CVE-2019-1458, CVE-2020-0683, CVE-2020-0753, CVE-2020-1054, CVE-2023-36874, CVE-2024-38014, CVE-2021-21132, CVE-2021-30657, CVE-2021-44168, CVE-2020-10136, CVE-2023-30861, CVE-2020-4046, CVE-2024-29988, CVE-2024-38213, CVE-2024-38180, CVE-2024-38217, CVE-2023-22809, CVE-2016-0046, CVE-2019-3462, CVE-2017-12150, CVE-2022-29078, CVE-2021-22204, CVE-2021-3197
Скрытый удар	CVE-2020-1599, CVE-2021-30682, CVE-2011-3544, CVE-2021-28169, CVE-2019-12086, CVE-2023-0386, CVE-2022-35751, CVE-2008-2292, CVE-2017-0100, CVE-2024-20666, CVE-2022-30295, CVE-2019-3978, CVE-2020-3175, CVE-2020-0951, CVE-2017-7821, CVE-2019-15752, CVE-2007-2446, CVE-2007-2447, CVE-2019-0633, CVE-2019-1405, CVE-2019-1476, CVE-2020-0753, CVE-2024-38014, CVE-2023-3676, CVE-2021-30657, CVE-2023-49084, CVE-2013-0431, CVE-2024-22017, CVE-2024-38213, CVE-2024-38180, CVE-2024-38217, CVE-2024-39929, CVE-2016-0046, CVE-2022-23614
Большая ложь	CVE-2024-21306, CVE-2024-21320, CVE-2021-36942, CVE-2022-44268, CVE-2019-14287, CVE-2018-15473, CVE-2019-1563, CVE-2016-3352, CVE-2018-13382, CVE-2022-40684, CVE-2013-6890, CVE-2008-0960, CVE-2008-2292, CVE-2018-0886, CVE-2019-1322, CVE-2020-1259, CVE-2021-38165, CVE-2009-1185, CVE-2021-26291, CVE-2021-21135, CVE-2020-16012, CVE-2019-18677, CVE-2019-9787, CVE-2020-0836, CVE-2023-36851, CVE-2024-38476, CVE-2014-3153, CVE-2007-2446, CVE-2019-0756, CVE-2020-0683, CVE-2023-36874, CVE-2021-21132, CVE-2023-6208, CVE-2021-44168, CVE-2019-17563, CVE-2022-26925, CVE-2022-34689, CVE-2009-0217, CVE-2021-21134, CVE-2023-30861, CVE-2020-4046, CVE-2020-16996, CVE-2024-39689, CVE-2020-11985, CVE-2019-3462, CVE-2017-12150, CVE-2022-29078, CVE-2019-19919, CVE-2021-22204

Результатом раздела стала полноценно сформированная база знаний об уязвимостях, включающая в себя отфильтрованный и проклассифицированный список уязвимостей, найденных по контексту шаблонов атак CAPEC, с подробным объяснением механизма автоматизации поиска уязвимостей и перечислением критериев для “отсеивания” неподходящих уязвимостей.

Все полученные данные были систематизированы и занесены в результирующую таблицу, благодаря которой наблюдается однозначное соответствие тактики → техники → используемая уязвимость для каждого шаблона атаки. Используя таблицу, легко можно понять, на каких этапах сценария какая уязвимость используется.

Также после фильтрации для каждой уязвимости был предоставлен подробный контекст использования уязвимостей для социальной инженерии.

Иерархическая структура такой базы изображена на рисунке 6 [20].

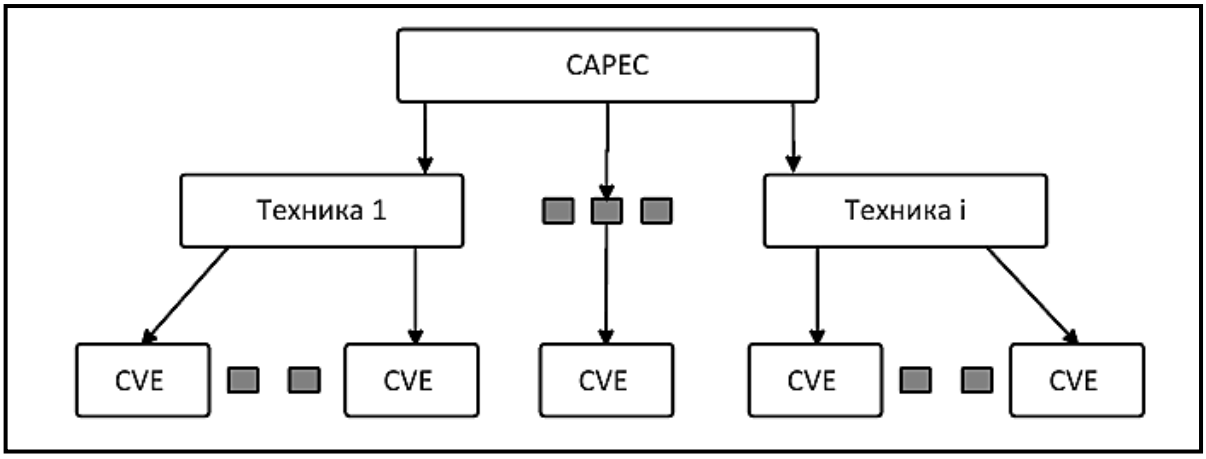


Рисунок 6 – Дерево составленной базы знаний

Однако стоит отметить, что схема из первоисточника была несколько доработана. Доработка связана с исключением CWE, так как социальная инженерия не завязана на ошибках технических, однако все же существуют взаимно-однозначные соответствия CWE с шаблонами CAPEC [41].

Таким образом, полученная в результате база позволяет эффективно произвести риск-анализ и приступить к разработке регламентов выявления и регистрации, реагирования на инциденты, ликвидации последствий.

2 Риск-анализ сценариев атак класса “Социальная инженерия”

2.1 Систематизация данных и разработка алгоритмов риск-анализа для дальнейшего формирования регламентов противодействия

Для полноценного анализа рисков необходимо рассмотреть различные системы оценивания уязвимостей. Дале получить общую оценку, пронормировав выборку полученных значений.

Важно отметить, что не все системы оценивания имеют результат в рамках одной шкалы оценивания. Именно поэтому для начала адекватного риск-анализа нужно пронормировать все полученные значения для каждой уязвимости. Нормировка будет производиться по формуле (1):

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}}, \quad (1)$$

где S_{norm} – нормализованная оценка калькулятора;

S – актуальная оценка;

S_{max} – максимальная оценка;

S_{min} – минимальная оценка.

Система оценки DREAD. DREAD является частью своего рода системы оценки рисков угрозы безопасности, используемой прежде корпорацией Microsoft. Он обеспечивает мнемонику для оценки риска угрозы безопасности в пять категорий:

- damage (D1)– насколько серьезная атака;
- reproducability (R) – насколько легко можно повторить атаку;
- exploitability (E) – насколько много работы потребуется для запуска атаки;
- affacted users (A) – сколько людей будут затронуты;
- discoverability (D2) – насколько угроза просто обнаруживается.

При оценке от 1 до 10 для каждой уязвимости оценка касается каждой категории, что дает итоговую строку с минимальным значением в 5 и максимальным в 50 единиц [50, 51].

Рассчитываемый показатель CPR-Score. Система для получения метрики в процентах от 1% до 100% интегрирует три ключевых компонента: CVSS, EPSS, CISA CVE. Таким образом, в методике удается учесть сразу технические аспекты, вероятность эксплуатации, известность и эксплуатируемость уязвимости. Путем математических вычислений оценка уязвимости, выполняется приоритизация. Ключевым моментом является то, что в контексте рассматриваемого демонстрационного ресурса пользователь может сам выбрать веса для интегрируемых метрик, это показано на рисунке 7, на нем представлено классическое распределение весов для адекватной оценки [52].



Рисунок 7 – Формирование метрики SRP-Score.

Метрика EPSS. Система EPSS оценивает вероятность того, что уязвимость будет проэксплуатирована при реализации атаки, что помогает приоритизировать усилия по её устранению, в сочетании с оценкой CVSS. CVSS используется для определения уровня угрозы уязвимости, классифицируя её по различным уровням опасности, но она ограничена только оценкой угрозы. EPSS, в свою очередь, использует актуальную информацию о реальных угрозах из базы данных CVE, что делает её более точной. Оценка EPSS варьируется от 0 до 100%: чем выше значение, тем больше шанс, что уязвимость будет использована [53].

Система базовой оценки CVSS 3.1. Система строит вектор и дает оценку, опираясь на базовые метрики: вектор атаки: (сетевой/смежная сеть/локальная сеть/физический), сложность атаки (высокая/низкая), уровень привилегий (требуется/не требуется), влияние на другие компоненты системы (не оказывает/оказывает), влияние на конфиденциальность (не оказывает/ низкое/ высокое), влияние на целостность (не оказывает/низкое/высокое), влияние на доступность (не оказывает/низкое/высокое) [54].

Система базовой оценки CVSS 4.0. Система строит вектор и дает оценку, опираясь на базовые метрики: вектор атаки (сетевой, смежный, локальный, физический), сложность атаки (низкая, высокая), требования к атаке (отсутствуют, существуют), уровень привилегий (не требуется/низкий/высокий), взаимодействие с пользователем (не требуется/пассивное/активное), влияние на конфиденциальность (высокое/низкое/не оказывает), влияние на целостность конфиденциальность (высокое/низкое/не оказывает), влияние на доступность конфиденциальность (высокое/низкое/не оказывает) [55].

Система базовой оценки OWASP. Система OWASP Risk Rating Methodology для оценки уязвимости прибегает к 4 простым факторам. Финансовый ущерб – как сильно эксплойт отразится на финансовом состоянии компании: (1) – малые расходы на исправление уязвимости; (3) – незначительное влияние на прибыль; (7) – существенное влияние на прибыль; (9) – полное банкротство. Ущерб репутации – может ли эксплойт повлиять на репутацию бизнеса: (1) – минимальные потери; (4) – потеря ключевых клиентов; (5) – потеря деловой репутации; (9) – серьезный ущерб бренду. Несоблюдение требований – какой риск несет несоответствие нормам: (2) – легкое нарушение; (5) – явное нарушение; (7) – существенное нарушение. Нарушение неприкосновенности частной жизни – как много личных данных может быть раскрыто: (3) – данные одного человека; (5) – данные сотен людей; (7) – данные тысяч людей; (9) – данные миллионов людей [56].

На основании такого анализа делается вывод об уровне вероятности и влияния риска (рисунок 8).

Уровни вероятности и влияния	
От 0 до <3	НИЗКИЙ
От 3 до <6	ТЕРПИМАЯ
От 6 до 9	ВЫСОКИЙ

Рисунок 8 – Уровень влияние и вероятности по OWASP

Разложив оценку критичности по нескольким системам оценивания, можно приступить к оценке рисков реализуемых сценариев атаки настоящего класса. Для этого с учетом уже нормализованных значений критичности необходимо произвести расчет среднеквадратичной оценки критичности по формуле (2).

$$S_f = \sqrt{\frac{1}{n}\sum_{i=1}^{n_k} S_{norm}^2}, \tag{2}$$

где S_f – среднеквадратическая оценка;

n_k – количество калькуляторов.

Сразу стоит сказать, что от величины среднеквадратичной оценки риска напрямую зависит вероятность использования актуальной уязвимости исходя из формулы (3).

$$P(CVE) = \frac{S_f}{\sum S_f}. \tag{3}$$

Эта формула позволяет посчитать вероятность эксплуатации единичной уязвимости посредством использования среднеквадратичного значения критичности рассматриваемой уязвимости и суммарного среднеквадратичного значения критичности.

Далее по формуле (4) представляется возможным рассчитать вероятность реализации определенной техники, принадлежащей общему перечню техник в сценарии.

$$P(X_i = k_i) = \frac{1}{\sqrt{2\pi n}^{S_т - 1}} \times \prod_{i=1}^{S_т} \frac{1}{\sqrt{P(CVE)}}, \quad (4)$$

где n – успешные атаки, эксплуатирующие уязвимость;

k_i – успешные атаки, эксплуатирующие i уязвимость;

$S_т$ – количество уязвимостей в технике.

Далее, с помощью формулы (5), можно выполнить расчет количественной оценки риска, возникающего при реализации сценариев, состоящих из поочередного выполнения тактик посредством реализации определенных техник через успешную эксплуатацию единичных уязвимостей.

$$\overline{Risk} = \prod_{j(i)=1}^{m(n)} P(X)_{j(i)} \times \sum_{j(i)=1}^{m(n)} U_{j(i)}, \quad (5)$$

где m – количество техник на этапе;

n – количество эксплуатируемых уязвимостей в рамках сценария;

U_j – ущерб, наносимый при реализации техники, который считается по формуле (6):

$$U = \frac{\sum_{i=1}^{S_т} (K_i \times U_i)}{n}, \quad (6)$$

где U_i – ущерб, рассчитываемый для единичной уязвимости вне сценария реализации атаки, считается по формуле (7).

$$Ui = 1 - (1 - U_k) \times \left(1 - U_д\right) \times (1 - U_ц), \quad (7)$$

где U_k – значение ущерба конфиденциальности;

$U_{\text{д}}$ – значение ущерба доступности;

$U_{\text{ц}}$ – значение ущерба целостности.

В рамках работы также будут представлены значения риска для единичных уязвимостей. Для этого ущерб так же, как и ранее будет рассчитываться по формуле (7), а далее для каждой CVE по формуле (8) будет рассчитан риск.

$$Risk(CVE) = P_{(CVE)} \times U_i. \quad (8)$$

Риск от реализации сценария в целом, как и ранее, рассчитывается по формуле (5) и учитывает ущербы и вероятности отдельно взятых уязвимостей в рамках сценария

Далее составим результирующую схему с используемыми техниками и шаблонами CAPEC, которая далее будет использоваться при формировании регламентов противодействия (рисунок 9 - 11), а также даст возможность визуально представить множество сценариев для каждого шаблона атаки класса “Социальная инженерия” и приведет в соответствие используемые в рамках шаблона техники и классы, по которым было разложено множество самих шаблонов реализации CAPEC.

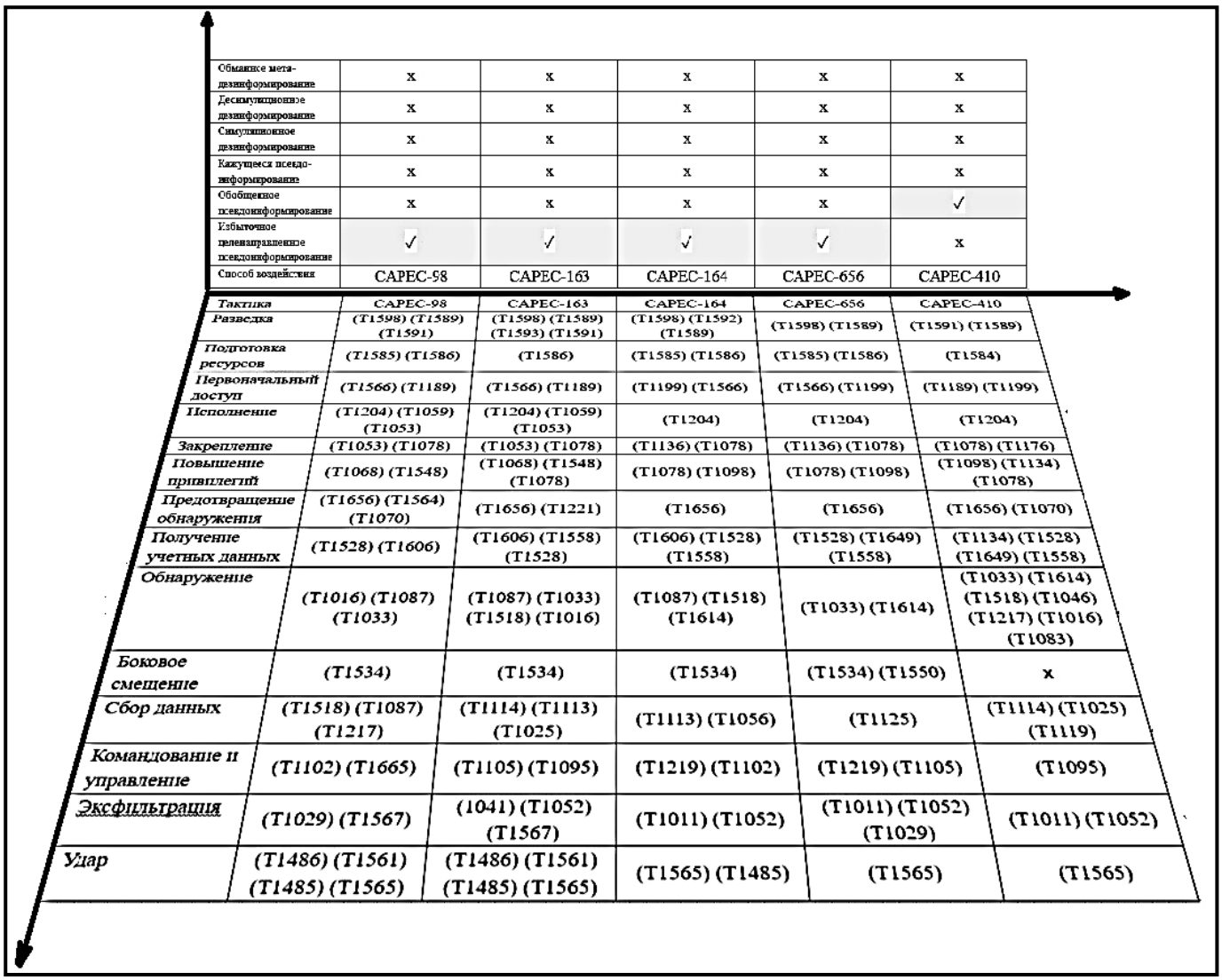


Рисунок 9 – Матрица сопоставления CAPEC-техника

Из схемы отчетливо видно сходство между CAPEC-98, CAPEC-163, CAPEC-164, CAPEC-656. Эта схожесть завязана на том, что все эти шаблоны – разновидности фишинга: CAPEC-98 – Фишинг; CAPEC-163 – Целевой фишинг; CAPEC-164 – Мобильный фишинг; CAPEC-656 – Голосовой фишинг.

Отличия же возникают из-за специфики. Так, например, просто фишинг не имеет конкретной направленности и зациклен на любом обмане. Целевой фишинг имеет особенность, которая заключается в направленности на конкретный объект. Мобильный фишинг – осуществляется через мобильные устройства. Голосовой фишинг как правило осуществляется посредством обмана голосом.

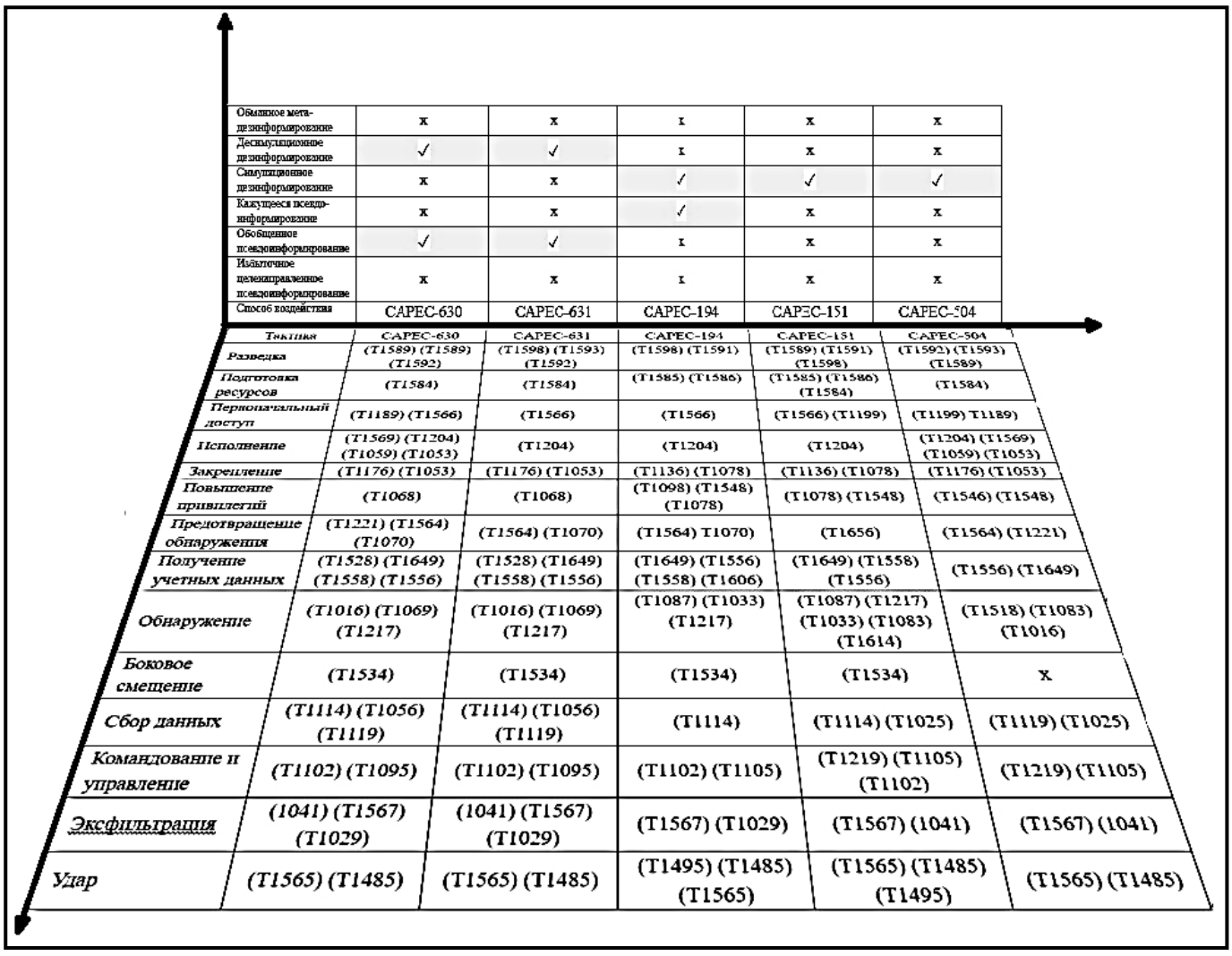
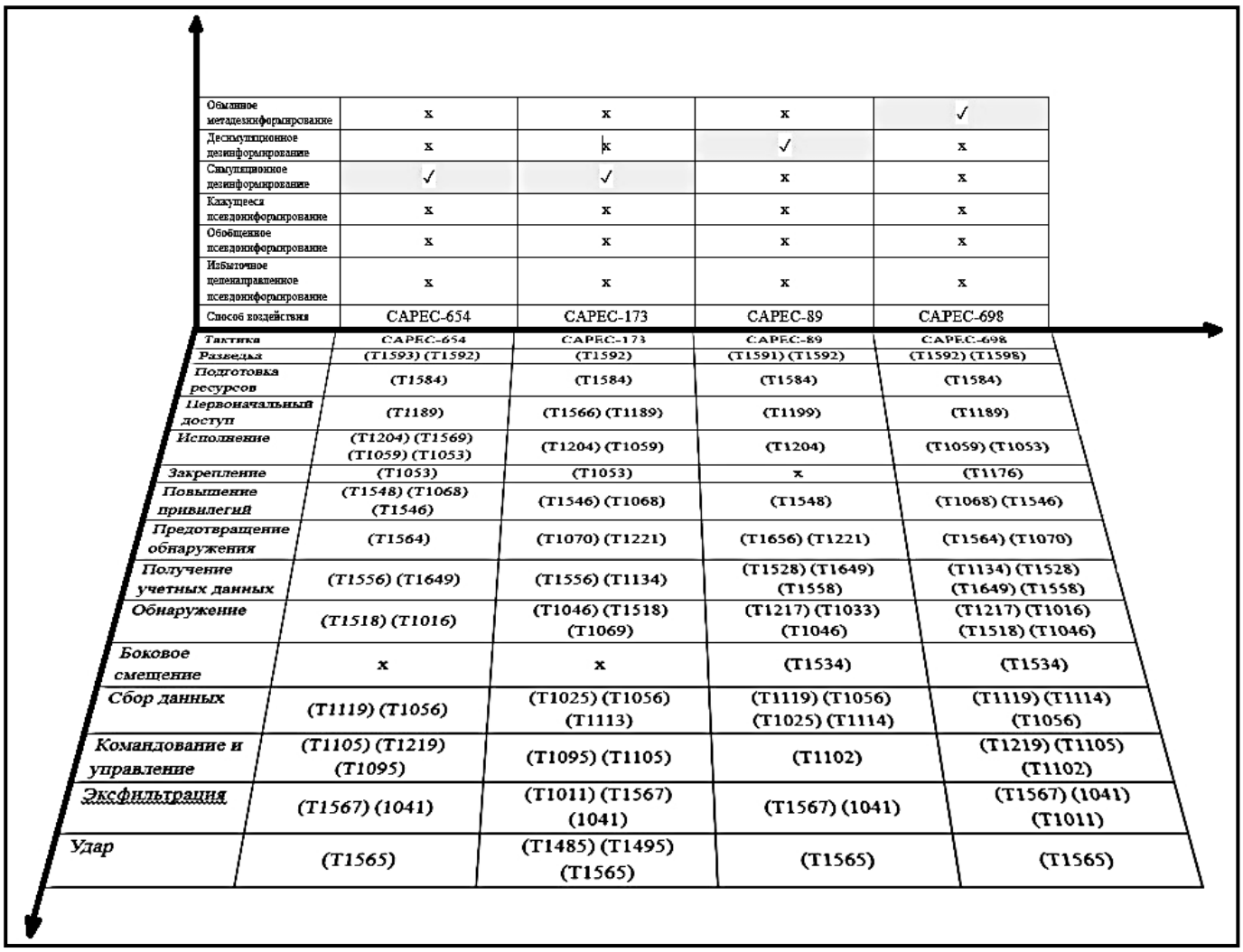


Рисунок 10 – Матрица сопоставления CAPEC-техника

На данной схеме явные сходства заметны между CAPEC-630 и CAPEC-631 поскольку оба шаблона основаны на сквоттинге, отличия лишь в том, что один для обмана использует схожесть звучания домена (омофон), а другой схожесть написания (использования “0” вместо “О” и другие уловки).



Обычное метадезинформирование	x	x	x	✓
Дискурсионное дезинформирование	x	x	✓	x
Симуляционное дезинформирование	✓	✓	x	x
Кажущееся псевдоинформирование	x	x	x	x
Обобщенное псевдоинформирование	x	x	x	x
Избыточное целенаправленное псевдоинформирование	x	x	x	x
Способ воздействия	CAPEC-654	CAPEC-173	CAPEC-89	CAPEC-698

Тактика	CAPEC-654	CAPEC-173	CAPEC-89	CAPEC-698
Разведка	(T1593) (T1592)	(T1592)	(T1591) (T1592)	(T1592) (T1598)
Подготовка ресурсов	(T1584)	(T1584)	(T1584)	(T1584)
Первоначальный доступ	(T1189)	(T1566) (T1189)	(T1199)	(T1189)
Исполнение	(T1204) (T1569) (T1059) (T1053)	(T1204) (T1059)	(T1204)	(T1059) (T1053)
Закрепление	(T1053)	(T1053)	x	(T1176)
Повышение привилегий	(T1548) (T1068) (T1546)	(T1546) (T1068)	(T1548)	(T1068) (T1546)
Предотвращение обнаружения	(T1564)	(T1070) (T1221)	(T1656) (T1221)	(T1564) (T1070)
Получение учетных данных	(T1556) (T1649)	(T1556) (T1134)	(T1528) (T1649) (T1558)	(T1134) (T1528) (T1649) (T1558)
Обнаружение	(T1518) (T1016)	(T1046) (T1518) (T1069)	(T1217) (T1033) (T1046)	(T1217) (T1016) (T1518) (T1046)
Боковое смещение	x	x	(T1534)	(T1534)
Сбор данных	(T1119) (T1056)	(T1025) (T1056) (T1113)	(T1119) (T1056) (T1025) (T1114)	(T1119) (T1114) (T1056)
Командование и управление	(T1105) (T1219) (T1095)	(T1095) (T1105)	(T1102)	(T1219) (T1105) (T1102)
Эксфильтрация	(T1567) (1041)	(T1011) (T1567) (1041)	(T1567) (1041)	(T1567) (1041) (T1011)
Удар	(T1565)	(T1485) (T1495) (T1565)	(T1565)	(T1565)

Рисунок 11 – Матрица сопоставления CAPEC-техника

Далее необходимо составить схемы для каждого шаблона. Такой подход позволит наглядно показать “узкие” и “широкие” места при реализации атак класса “Социальная инженерия”.

Итогами настоящего подраздела служат:

- сформированный перечень расчетных формул для определения наибольших значений вероятности реализации техник в рамках шаблонов осуществления атак, а также определения вероятностей успешной эксплуатации единичных уязвимостей и рисков для отдельно-взятых уязвимостей и для всего сценария;

- матрицы сопоставления CAPEC → техника → способ воздействия, для дальнейшего формирования регламентов, учитывающих социальные и технические аспекты.

2.2 Формирование перечня техник с наибольшим значением вероятности эксплуатации с учетом математического ожидания для дальнейшего формирования регламентов противодействия

Для CAPEC-98 (фишинг) существует множество сценариев. Множество таковых представлено на рисунке 12.

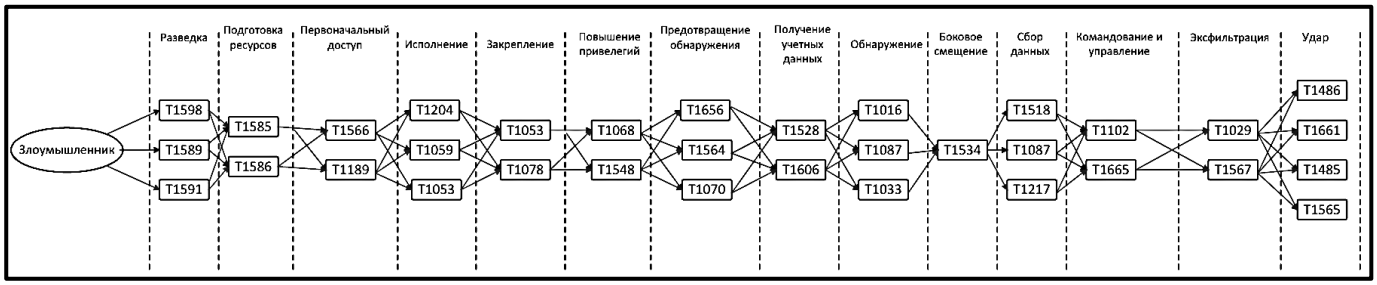


Рисунок 12 – Множество сценариев CAPEC-98

Далее отбиралась наиболее вероятно-используемые техники. Далее на основании этих данных будет легко сделать вывод о наиболее рациональном подходе при ручной разработке регламентов безопасности, а также о порядке применения мер и средств противодействия атакам класса “Социальная инженерия” (Таблица 22).

Таблица 22 – Наиболее вероятный сценарий для CAPEC-98

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор идентификационной информации (T1589)	CVE-2023-5561 CVE-2018-15473	0,562270025 0,791127933	0,080974797	0,2
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2021-21135 CVE-2020-1054	0,530202572 0,775112487	0,08125166	0,722679713
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2021-26291 CVE-2020-0753	0,802943396 0,616249201	0,080508339	0,804278151
Исполнение	Запланированная задача (T1053)	CVE-2020-0683 CVE-2024-20666	0,564711509 0,602953806	0,079851526	0,875
Закрепление	Запланированная задача (T1053)	CVE-2020-10136 CVE-2022-26925	0,563323334 0,757632855	0,080686397	0,372064644

Продолжение таблицы 22

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2020-1054 CVE-2021-3197	0,775112487 0,645486481	0,080143025	0,875
Предотвращение обнаружения	Удаление индикаторов (T1070)	CVE-2021-3197 CVE-2019-1476	0,645486481 0,582501536	0,085276634	0,824438
Получение учетных данных	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2021-21135 CVE-2023-5561	0,530202572 0,562270025	0,079843092	0,345597036
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2018-14847 CVE-2020-0836	0,82545643 0,590292076	0,080933018	0,640759889
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2023-5561 CVE-2021-44168 CVE-2023-36874	0,562270025 0,465193056 0,725092263	0,00848325	0,658440638
Сбор данных	Обнаружение информации о браузере (T1217)	CVE-2021-30657 CVE-2019-17563	0,604538411 0,730069612	0,080164082	0,705135965
Командование и управление	Веб-сервис (T1102)	CVE-2020-10136 CVE-2022-26925	0,563323334 0,757632855	0,080686397	0,372064644
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2020-16012 CVE-2022-26925	0,465754474 0,757632855	0,082181912	0,385787323
Удар	Уничтожение диска (T1561)	CVE-2016-0046 CVE-2019-3978	0,774026603 0,601163313	0,080446782	0,711069011

Далее на рисунке 13 изображено множество сценариев реализации для шаблона CAPEC-163.

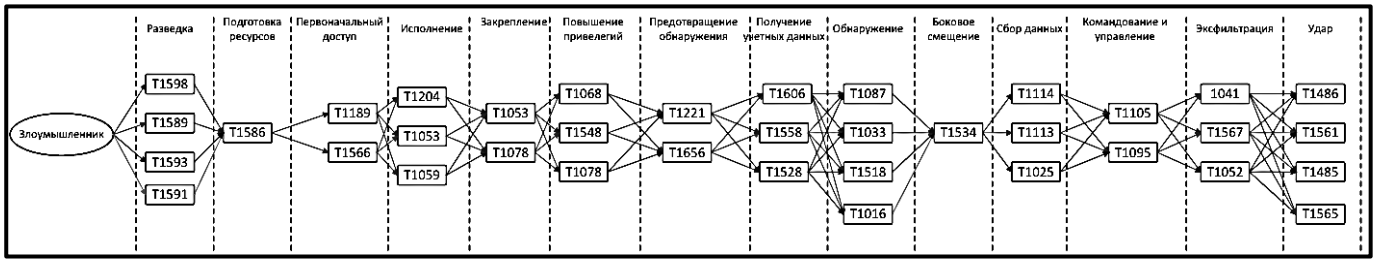


Рисунок 13 - Множество сценариев CAPEC-163

В таблице 23 приведен наиболее вероятный сценарий реализации атаки для шаблона.

Таблица 23 – Наиболее вероятный сценарий для CAPEC-163

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Информационный фишинг (T1598)	CVE-2019-9787 CVE-2020-4046	0,769382258 0,595915615	0,080460759	0,650216421
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2019-14287 CVE-2022-26925	0,773896132 0,757632855	0,079813189	0,689491059
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2019-0633 CVE-2020-11985	0,679082088 0,483550365	0,080958792	0,594260807
Исполнение	Запланированная задача (T1053)	CVE-2019-0804 CVE-2020-1054	0,552181428 0,775112487	0,080958792	0,718992327
Закрепление	Запланированная задача (T1053)	CVE-2019-0804 CVE-2020-1054	0,552181428 0,775112487	0,080958792	0,718992327
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2021-3197 CVE-2020-0753	0,645486481 0,616249201	0,079830124	0,875
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017	0,661546922 0,540679613	0,080215106	0,700953758
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2024-22017 CVE-2023-49084	0,540679613 0,688502863	0,080392154	0,704770588
Обнаружение	Изучение установленного ПО (T1518)	CVE-2019-0633 CVE-2020-16012	0,679082088 0,465754474	0,081231414	0,600389387
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2021-21135 CVE-2019-9787 CVE-2020-10136	0,530202572 0,769382258 0,563323334	0,008446108	0,564158475
Сбор данных	Данные со съемных носителей (T1025)	CVE-2022-44268 CVE-2016-3352	0,773181781 0,497200122	0,081761351	0,646766925
Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2016-2106 CVE-2011-3544	0,706469102 0,912419488	0,080462455	0,711353215

Продолжение таблицы 23

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2021-38165 CVE-2019-12643	0,520822592 0,692459524	0,082931838	0,714024684
Удар	Шифрование данных (T1486)	CVE-2023-37266 CVE-2020-1259	0,740479168 0,423937236	0,082931838	0,629248022

Далее такой же перечень сценариев, но уже для шаблона CAPEC-164 приведен на рисунке 14.

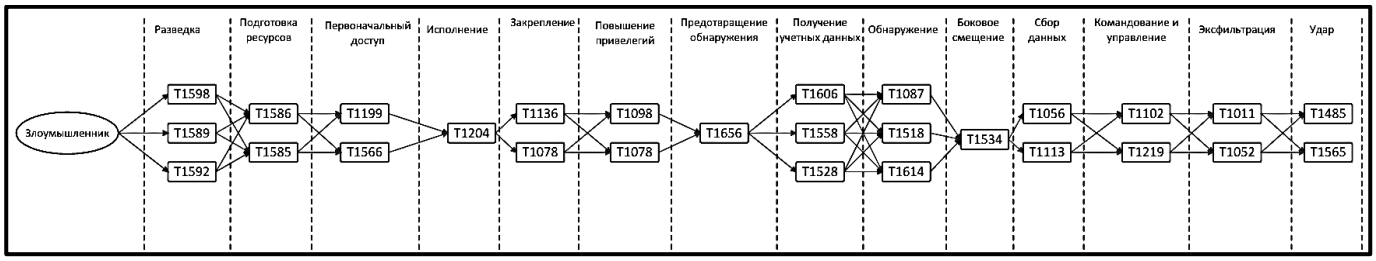


Рисунок 14 - Множество сценариев CAPEC-164

И в таблице 24 приведен подробный разворот наиболее вероятного сценария реализации для текущего шаблона.

Таблица 24 – Наиболее вероятный сценарий для CAPEC-164

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2022-30295 CVE-2017-0022 CVE-2020-1599	0,65137872 0,601819137 0,430970051	0,008467303	0,457620037
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197	0,773896132 0,616249201 0,645486481	0,008335393	0,875
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2020-10136 CVE-2022-40684 CVE-2018-15473	0,563323334 0,895052225 0,791127933	0,008506364	0,468574934

Продолжение таблицы 24

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168	0,63304643 0,604538411 0,465193056	0,00838554	0,741863491
Закрепление	Действующие учетные записи (T1078)	CVE-2022-26925 CVE-2020-0753	0,757632855 0,616249201	0,080234665	0,668204723
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2019-14287 CVE-2020-16996	0,648825153 0,773896132 0,540462545	0,008408022	0,689173175
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017 CVE-2020-16996	0,661546922 0,540679613 0,540462545	0,008331767	0,545592285
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2023-49084 CVE-2021-21134	0,688502863 0,549628167	0,08031551	0,708530896
Обнаружение	Изучение местоположения системы (T1614)	CVE-2023-35325 CVE-2022-34689	0,630864668 0,56490482	0,079930385	0,263790251
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2021-21135 CVE-2019-9787 CVE-2020-10136	0,530202572 0,769382258 0,563323334	0,008446108	0,564158475
Сбор данных	Захват входных данных (T1056)	CVE-2021-28169 CVE-2019-1563	0,683810439 0,534778576	0,080412317	0,2
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643	0,520822592 0,692459524	0,080619457	0,714024684
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2022-40684 CVE-2023-35325	0,895052225 0,630864668	0,081032412	0,719962559
Удар	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2014-3153	0,601163313 0,825915983	0,080817258	0,717029631

Множество сценариев для шаблона CAPEC-656 изображено на схеме, представленной на рисунке 15.

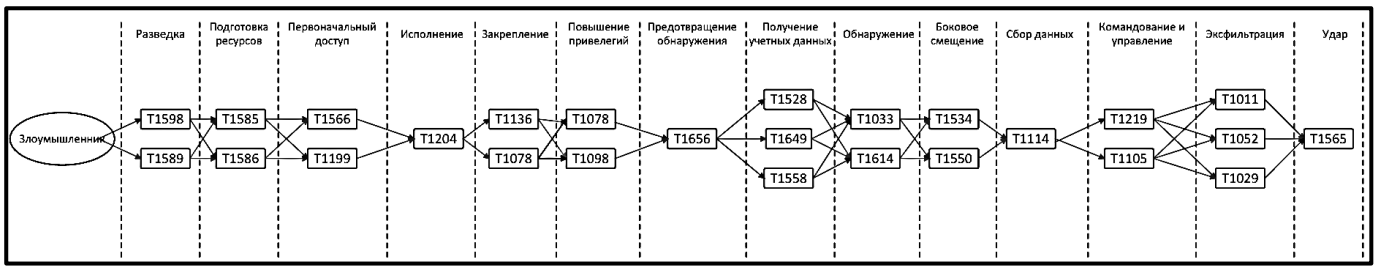


Рисунок 15 - Множество сценариев CAPEC-656

Как и ранее для шаблона представлен наиболее вероятный сценарий реализации и раскрыт в таблице 25.

Таблица 25 – Наиболее вероятный сценарий для CAPEC-656

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2022-26925	0,815829011 0,791127933 0,757632855	0,008279836	0,29612232
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2022-26925 CVE-2021-26291	0,757632855 0,802943396	0,079842349	0,628629312
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2022-40684 CVE-2021-21134	0,895052225 0,549628167	0,082192706	0,732331377
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168 CVE-2019-1563	0,63304643 0,604538411 0,465193056 0,534778576	0,001049228	0,630505474
Закрепление	Создание учетных записей (T1136)	CVE-2019-14287 CVE-2020-0683	0,773896132 0,564711509	0,080801388	0,875
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2023-30861 CVE-2023-49084	0,648825153 0,668943803 0,688502863	0,008405131	0,745964019
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017 CVE-2020-16996 CVE-2024-20666	0,661546922 0,540679613 0,540462545 0,602953806	0,001024022	0,630267423

Продолжение таблицы 25

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2024-22017	0,895052225 0,540679613	0,082356774	0,729260382
Обнаружение	Изучение местоположения системы (T1614)	CVE-2023-35325 CVE-2020-3175 CVE-2022-30295	0,630864668 0,624500678 0,65137872	0,008276136	0,534161833
Боковое смещение	Использование альтернативных материалов для аутентификации (T1550)	CVE-2021-26291 CVE-2022-40684	0,802943396 0,895052225	0,07992637	0,815890351
Сбор данных	Захват видеоданных (T1125)	CVE-2021-30682 CVE-2020-1599	0,596503098 0,430970051	0,080865032	0,37416604
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2018-13382 CVE-2017-0022	0,824377205 0,601819137	0,08079854	0,494936301
Эксфильтрация	Передача по расписанию (T1029)	CVE-2019-0804 CVE-2020-1054	0,630864668 0,521002989	0,080958792	0,718992327
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266	0,829950408 0,688811625 0,740479168	0,008310966	0,757009013

Далее набор сценариев для шаблона CAPEC-630, изображенный на рисунке 16.

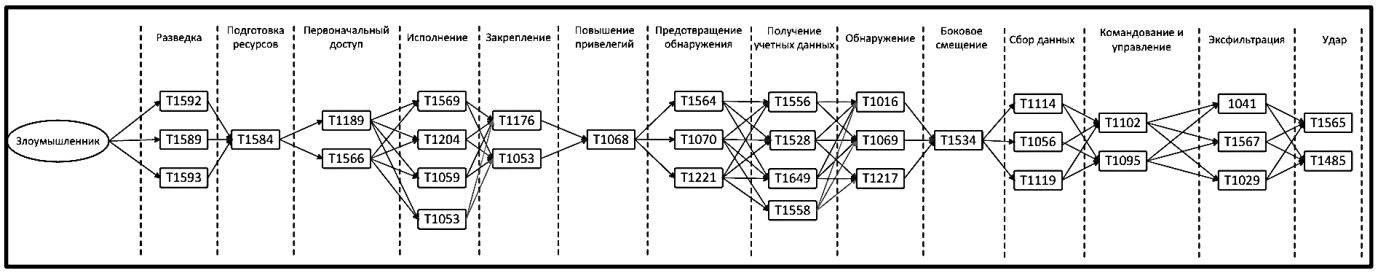


Рисунок 16 – Множество сценариев CAPEC-630

В таблице 26 отображен наиболее вероятный сценарий для текущего шаблона.

Таблица 26 – Наиболее вероятный сценарий для CAPEC-630

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2022-34689 CVE-2022-23614	0,56490482 0,746908609	0,080588093	0,498199682
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684 CVE-2017-0057 CVE-2023-38497	0,895052225 0,478266144 0,579870257	0,006377388	0,78023752
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2024-38143 CVE-2019-9787	0,530202572 0,482283227 0,769382258	0,00853907	0,66191903
Исполнение	Запланированная задача (T1053)	CVE-2020-1054 CVE-2024-38014	0,775112487 0,719644369	0,079863695	0,875
Закрепление	Расширения для браузера (T1176)	CVE-2021-21134 CVE-2020-1054	0,549628167 0,775112487	0,08099052	0,719414405
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197 CVE-2020-0683	0,773896132 0,616249201 0,645486481 0,564711509	0,001030494	0,875
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2019-1458	0,661546922 0,797905138	0,080159326	0,875
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2009-0217	0,895052225 0,554041985	0,082114768	0,727035674
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2019-14287 CVE-2020-0683 CVE-2021-3197	0,773896132 0,564711509 0,645486481	0,008378871	0,875
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787 CVE-2020-4046	0,482283227 0,530202572 0,769382258 0,595915615	0,001049228	0,586252657
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2017-0057	0,824377205 0,601819137 0,478266144	0,008591484	0,493194393
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643	0,520822592 0,692459524	0,080619457	0,714024684
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2023-35325 CVE-2017-0122 CVE-2022-44268	0,630864668 0,521002989 0,773181781	0,00843673	0,418806814

Продолжение таблицы 26

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Удар	Манипулирование данными (T1565)	CVE-2019-3978 CVE-2020-0836 CVE-2021-22204	0,601163313 0,590292076 0,860432559	0,008469986	0,65379919

Далее необходимо рассмотреть шестой по счету шаблон – CAPEC-194. Множество сценариев для него представлено на рисунке 17.

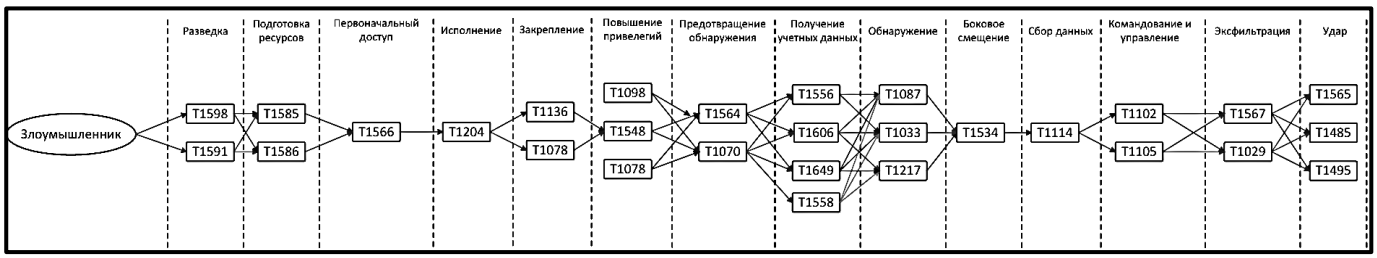


Рисунок 17 – Множество сценариев CAPEC-194

Дале для этого же шаблона CAPEC в таблице 27 приведен перечень техник, представляющих из себя наиболее вероятный сценарий реализации атаки класса “Социальная инженерия”.

Таблица 27 – Наиболее вероятный сценарий для CAPEC-194

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Информационный фишинг (T1598)	CVE-2024-38143 CVE-2019-9787 CVE-2020-4046 CVE-2021-21135	0,482283227 0,769382258 0,595915615 0,530202572	0,001049228	0,586252657
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0683 CVE-2024-20666	0,773896132 0,564711509 0,602953806	0,008392095	0,875
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2020-10136 CVE-2019-0633 CVE-2017-7821	0,530202572 0,563323334 0,679082088 0,740850704	0,001035566	0,6446126

Продолжение таблицы 27

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168 CVE-2019-1563	0,63304643 0,604538411 0,465193056 0,534778576	0,001031039	0,612357492
Закрепление	Создание учетных записей (T1136)	CVE-2023-30861 CVE-2024-38217	0,668943803 0,609298859	0,008304018	0,426986347
Повышение привилегий	Существующие учетные записи (T1078)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197	0,773896132 0,616249201 0,645486481	0,008335393	0,875
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2019-3978 CVE-2020-0836 CVE-2022-35751 CVE-2021-25281	0,601163313 0,590292076 0,637285561 0,829950408	0,001036749	0,704284706
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2021-26291 CVE-2009-0217	0,895052225 0,802943396 0,554041985	0,011995752	0,563487004
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2024-29988	0,549628167 0,833686081	0,081546488	0,726002357
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787 CVE-2020-10136 CVE-2020-4046 CVE-2021-26291	0,482283227 0,530202572 0,769382258 0,563323334 0,595915615 0,802943396	4,24629E-06	0,9125989
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2017-0057 CVE-2017-7821 CVE-2019-12643	0,824377205 0,601819137 0,478266144 0,740850704 0,692459524	0,000147921	0,657149799
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2023-49084	0,520822592 0,688502863	0,080587112	0,713498006
Эксфильтрация	Передача по расписанию (T1029)	CVE-2019-0804 CVE-2020-1054 CVE-2024-38014	0,552181428 0,775112487 0,719644369	0,00840263	0,773840118

Продолжение таблицы 27

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Удар	Повреждение программы (T1495)	CVE-2021-25281 CVE-2013-0209 CVE-2011-3544 CVE-2016-2106	0,829950408 0,688811625 0,912419488 0,706469102	0,001043734	0,611706519

Седьмой по счету шаблон – CAPEC-504. Перечень возможных сценариев из техник для заданного шаблона изображен на рисунке 18.

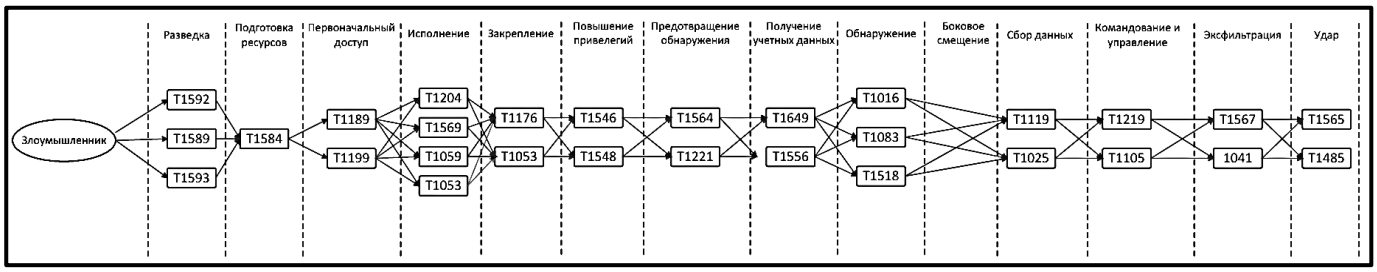


Рисунок 18 – Множество сценариев CAPEC-504

Как и ранее – в таблице 28 приведен наиболее вероятный сценарий реализации.

Таблица 28 – Наиболее вероятный сценарий для CAPEC-504

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-3197 CVE-2020-11985	0,645486481 0,483550365	0,080642477	0,585907135
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382 CVE-2022-26925 CVE-2021-26291 CVE-2020-0683	0,824377205 0,757632855 0,802943396 0,564711509	0,001043557	0,630596228
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2019-1322 CVE-2021-21135 CVE-2020-16012	0,648825153 0,530202572 0,465754474	0,008391502	0,562976782
Исполнение	Запланированная задача (T1053)	CVE-2023-22809 CVE-2019-0756 CVE-2019-0633	0,661546922 0,676396814 0,679082088	0,0092029	0,875

Продолжение таблицы 28

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Закрепление	Запланированная задача (T1053)	CVE-2023-49084 CVE-2024-39929 CVE-2023-38497	0,688502863 0,511455223 0,579870257	0,008367302	0,623558156
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2023-36874 CVE-2023-6208	0,725092263 0,477734066	0,081551765	0,52747077
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2019-12086 CVE-2018-13382 CVE-2021-36942 CVE-2022-40684	0,659104916 0,824377205 0,815829011 0,895052225	0,001029355	0,528455085
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2020-0836 CVE-2019-3978	0,590292076 0,601163313	0,079812011	0,494054746
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2016-0046 CVE-2019-3462 CVE-2017-12150	0,774026603 0,542650214 0,679189527	0,008406285	0,832462737
Боковое смещение	x	x	x	x	x
Сбор данных	Данные со съемных носителей (T1025)	CVE-2020-10136 CVE-2021-21134	0,563323334 0,549628167	0,079814731	0,633230283
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2021-26291 CVE-2021-21135	0,802943396 0,530202572	0,081533203	0,650573046
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2020-0951 CVE-2019-0804	0,551794174 0,552181428	0,079808693	0,350052617
Удар	Манипулирование данными (T1565)	CVE-2019-14287 CVE-2020-16996	0,773896132 0,540462545	0,081097961	0,597440895

Восьмой шаблон – спуффинг действий, он же CAPEC-173. Перечень всех возможных сценариев для заданного CAPEC-шаблона приведен на рисунке 19.

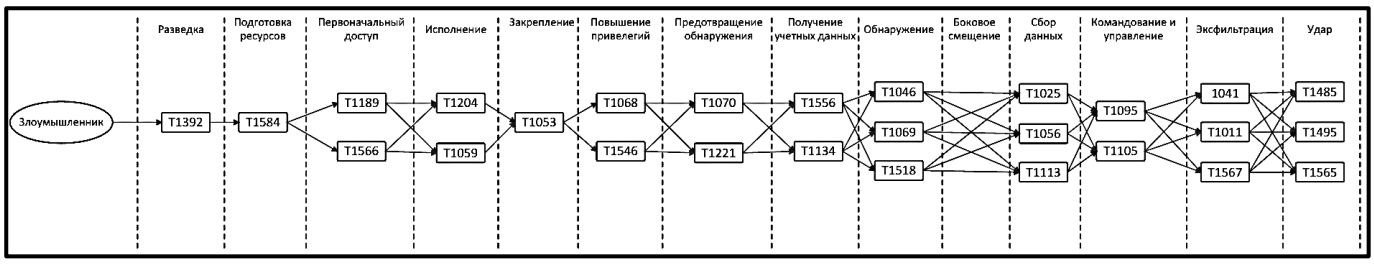


Рисунок 19 – Множество сценариев CAPEC-173

А в таблице 29 представлен наиболее вероятный сценарий реализации шаблона CAPEC-173.

Таблица 29 – Наиболее вероятный сценарий для CAPEC-173

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2023-49084 CVE-2024-22017	0,815829011 0,688502863 0,540679613	0,008450094	0,503399352
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-26925 CVE-2024-38143 CVE-2023-36851	0,757632855 0,482283227 0,535115977	0,008516188	0,49638238
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2020-16012 CVE-2023-6208	0,465754474 0,477734066	0,079815122	0,098730288
Исполнение	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-44168 CVE-2019-14287 CVE-2020-0753	0,465193056 0,773896132 0,616249201	0,008543561	0,875
Закрепление	Запланированная задача (T1053)	CVE-2020-16996 CVE-2024-38476 CVE-2024-39929	0,540462545 0,7103402 0,511455223	0,008406685	0,25804311
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2019-1405 CVE-2020-0683 CVE-2019-0756	0,762257053 0,564711509 0,676396814	0,008367886	0,875
Предотвращение обнаружения	Внедрение шаблона (T1221)	CVE-2019-0633 CVE-2024-38180	0,661546922 0,609298859	0,07990776	0,875
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2021-38165 CVE-2020-0836	0,520822592 0,590292076	0,079965135	0,493624866

Продолжение таблицы 29

Обнаружение	Изучение установленного ПО (T1518)	CVE-2023-30861 CVE-2024-29988	0,668943803 0,833686081	0,080292708	0,702714559
Боковое смещение	x	x	x	x	x
Сбор данных	Захват входных данных (T1056)	CVE-2023-36874 CVE-2024-38143	0,725092263 0,482283227	0,081473208	0,725207155
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2019-0633 CVE-2024-38180	0,679082088 0,614677785	0,07990776	0,875
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2021-38165 CVE-2020-0836	0,520822592 0,590292076	0,079965135	0,493624866
Удар	Манипулирование данными (T1565)	CVE-2023-30861 CVE-2024-29988	0,668943803 0,833686081	0,080292708	0,702714559

Далее на рисунке 20 представлено множество сценариев реализации для шаблона CAPEC-698, с расшифровкой “установка вредоносного расширения”.

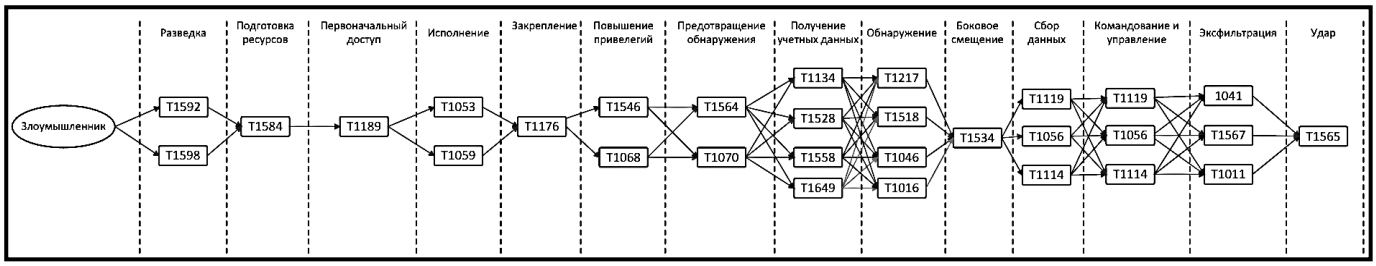


Рисунок 20 – Множество сценариев CAPEC-698

В таблице 30 представлен сценарий “максимума вероятности” для настоящего шаблона реализации CAPEC-698.

Таблица 30 – Наиболее вероятный сценарий для CAPEC-698

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Информационный фишинг (T1598)	CVE-2021-21135 CVE-2020-16012 CVE-2023-3676	0,530202572 0,465754474 0,720456614	0,008489262	0,413557072

Продолжение таблицы 30

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382 CVE-2022-26925 CVE-2024-38143	0,824377205 0,757632855 0,482283227	0,008605062	0,5
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2021-21132 CVE-2020-1054 CVE-2023-6208	0,63304643 0,775112487 0,477734066	0,008517706	0,65334516
Исполнение	Интерпретаторы командной строки и сценариев (T1059)	CVE-2021-44168 CVE-2019-14287 CVE-2020-0753 CVE-2019-0756	0,465193056 0,773896132 0,616249201 0,676396814	0,001051381	0,875
Закрепление	Расширения для браузера (T1176)	CVE-2021-30682 CVE-2023-36874	0,596503098 0,725092263	0,080189166	0,705743457
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2019-0633 CVE-2024-38180	0,679082088 0,614677785	0,07990776	0,875
Предотвращение обнаружения	Удаление индикаторов (T1070)	CVE-2024-38213 CVE-2023-49084	0,75113836 0,688502863	0,079884332	0,679342304
Получение учетных данных	Манипуляции с токенами доступа (T1134)	CVE-2021-22204 CVE-2022-29078	0,860432559 0,851723701	0,079809721	0,875
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2020-1599	0,549628167 0,430970051	0,08039948	0,368150877
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2021-21135 CVE-2020-16012 CVE-2023-3676	0,530202572 0,465754474 0,720456614	0,008489262	0,413557072
Сбор данных	Сбор электронной почты (T1114)	CVE-2020-1599 CVE-2021-3197	0,430970051 0,645486481	0,081442211	0,604757054
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2021-44168 CVE-2019-14287	0,465193056 0,773896132	0,082407131	0,875
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-49084 CVE-2024-22017	0,688502863 0,540679613	0,080392154	0,704770588
Удар	Манипулирование данными (T1565)	CVE-2022-30295 CVE-2021-3197 CVE-2023-30861	0,65137872 0,645486481 0,668943803	0,008275556	0,652185678

Десятый шаблон реализации атаки – CAPEC-410. Злоумышленник использует перечень методов социальной инженерии с целью извлечения информации (рисунок 21).

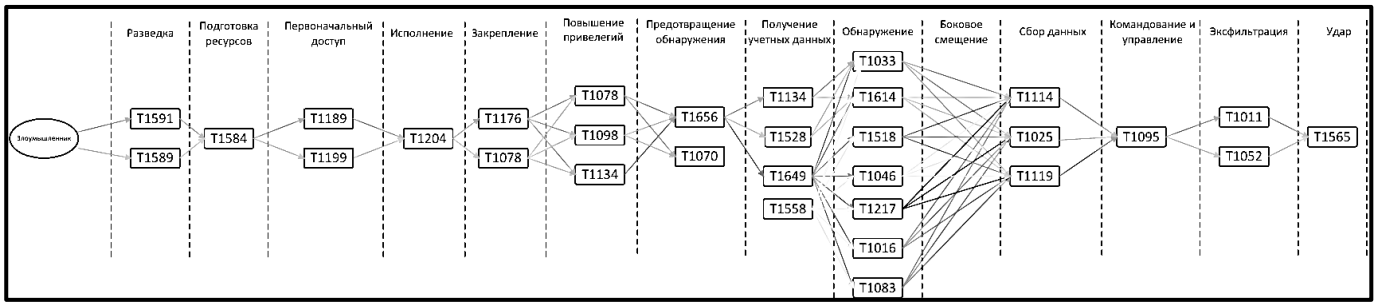


Рисунок 21 - Множество сценариев CAPEC-410

Далее в таблице 31 отображен сценарий для максимума вероятности для шаблона реализации “получение информации”.

Таблица 31 – Наиболее вероятный сценарий для CAPEC-410

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-36942 CVE-2018-15473 CVE-2020-11985	0,815829011 0,791127933 0,483550365	0,008615373	0,2
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684 CVE-2023-35325 CVE-2018-13382 CVE-2017-0022 CVE-2016-2106	0,895052225 0,630864668 0,824377205 0,601819137 0,706469102	0,000145924	0,589767764
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2020-10136 CVE-2019-12086	0,563323334 0,659104916	0,080054806	0,361753031
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657 CVE-2021-44168 CVE-2019-1563 CVE-2020-1054	0,63304643 0,604538411 0,465193056 0,534778576 0,775112487	0,000147043	0,679931292

Продолжение таблицы 31

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Закрепление	Расширения для браузера (T1176)	CVE-2021-21134 CVE-2023-49084 CVE-2023-22809	0,549628167 0,688502863 0,661546922	0,008332832	0,766502366
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2019-1322 CVE-2023-30861	0,648825153 0,668943803	0,079817991	0,678545796
Предотвращение обнаружения	Удаление индикаторов (T1070)	CVE-2019-3978 CVE-2020-0836 CVE-2021-25281 CVE-2013-0209	0,661546922 0,540679613 0,614677785 0,540462545	0,001036246	0,609172849
Получение учетных данных	Манипуляции с токенами доступа (T1134)	CVE-2023-49084 CVE-2024-20666	0,688502863 0,602953806	0,079984369	0,875
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2021-21134 CVE-2019-12643	0,549628167 0,692459524	0,08034165	0,709061183
Боковое смещение	x	x	x	x	x
Сбор данных	Сбор электронной почты (T1114)	CVE-2021-30682 CVE-2020-1599	0,596503098 0,430970051	0,080865032	0,37416604
Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2016-2106 CVE-2011-3544 CVE-2023-0386	0,706469102 0,912419488 0,57701551	0,008496162	0,754354516
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-35325 CVE-2017-0122	0,630864668 0,521002989	0,080174185	0,36430655
Удар	Манипулирование данными (T1565)	CVE-2021-25281 CVE-2013-0209 CVE-2023-37266 CVE-2020-1259	0,829950408 0,688811625 0,740479168 0,423937236	0,001079882	0,669002618

Следующий шаблон – CAPEC-631. Шаблон, связанный с омофонами. Множество сценариев изображено на рисунке 22.

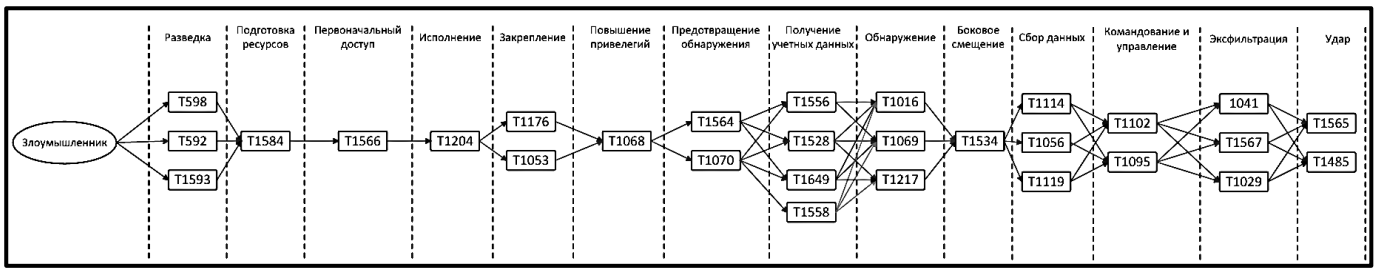


Рисунок 22 – Множество сценариев CAPEC-631

В таблице 32 представлен наиболее вероятный сценарий для CAPEC-631.

Таблица 32 – Наиболее вероятный сценарий для CAPEC-631

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2022-34689 CVE-2022-23614	0,56490482 0,746908609	0,080588093	0,498199682
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684 CVE-2017-0057 CVE-2023-38497	0,895052225 0,478266144 0,579870257	0,008724333	0,78023752
Первоначальный доступ	Фишинг (T1566)	CVE-2021-21135 CVE-2024-38143 CVE-2019-9787	0,530202572 0,482283227 0,769382258	0,00853907	0,66191903
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2021-30657	0,63304643 0,604538411	0,079829871	0,691819101
Закрепление	Расширения для браузера (T1176)	CVE-2021-21134 CVE-2019-1405	0,549628167 0,762257053	0,080878074	0,71788979
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2019-14287 CVE-2020-0753 CVE-2021-3197 CVE-2020-0683	0,773896132 0,616249201 0,645486481 0,564711509	0,001114568	0,837195162
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2019-1458	0,661546922 0,797905138	0,080159326	0,875
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2009-0217	0,895052225 0,554041985	0,082114768	0,727035674

Продолжение таблицы 32

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2019-14287 CVE-2020-0683 CVE-2021-3197	0,773896132 0,564711509 0,645486481	0,008378871	0,875
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787 CVE-2020-4046	0,482283227 0,530202572 0,769382258 0,595915615	0,001049228	0,586252657
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382 CVE-2017-0022 CVE-2017-0057	0,824377205 0,601819137 0,478266144	0,008591484	0,493194393
Командование и управление	Веб-сервис (T1102)	CVE-2021-38165 CVE-2019-12643	0,520822592 0,692459524	0,080619457	0,714024684
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2023-35325 CVE-2017-0122 CVE-2022-44268	0,630864668 0,521002989 0,773181781	0,00843673	0,418806814
Удар	Уничтожение данных (T1485)	CVE-2019-3978 CVE-2020-0836 CVE-2021-22204	0,601163313 0,590292076 0,860432559	0,008469986	0,65379919

Следующий шаблон – CAPEC-151. Злоумышленник подменяет идентичность и далее обманом добивается цели. Набор сценариев изображен на рисунке 23.

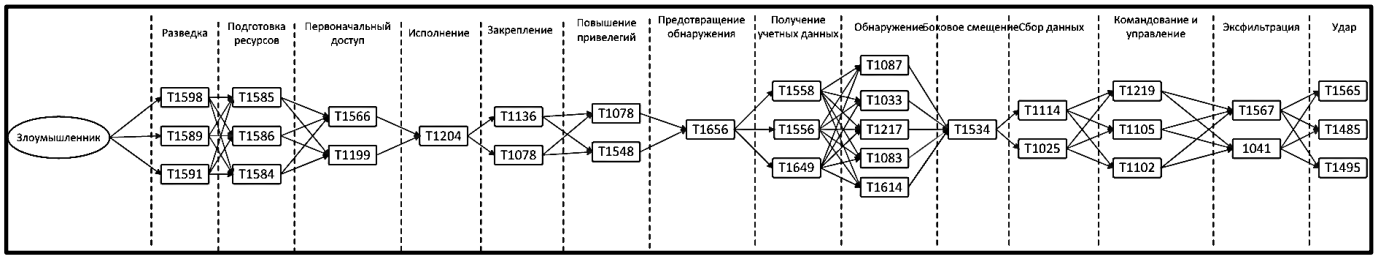


Рисунок 23 – Множество сценариев CAPEC-151

Наиболее вероятная последовательность техник в рамках шаблона представлена в таблице 33.

Таблица 33 – Наиболее вероятный сценарий для CAPEC-151

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Информационный фишинг (T1598)	CVE-2024-38143 CVE-2020-4046	0,482283227 0,595915615	0,080255643	0,422622634
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287 CVE-2020-0683	0,773896132 0,564711509	0,080801388	0,875
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2022-26925 CVE-2021-21134	0,757632855 0,549628167	0,080838566	0,5
Исполнение	Использование пользователем (T1204)	CVE-2021-21132 CVE-2019-1563	0,63304643 0,534778576	0,080092743	0,50910071
Закрепление	Создание учетных записей (T1136)	CVE-2024-38213 CVE-2024-38217	0,75113836 0,609298859	0,080246025	0,437298216
Повышение привилегий	Существующие учетные записи (T1078)	CVE-2019-14287 CVE-2021-36942	0,773896132 0,815829011	0,079836467	0,528597614
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809 CVE-2024-22017	0,661546922 0,540679613	0,080215106	0,700953758
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684 CVE-2009-0217	0,895052225 0,554041985	0,082114768	0,727035674
Обнаружение	Обнаружение учетной записи (T1087)	CVE-2018-15473 CVE-2020-0683	0,791127933 0,564711509	0,080945323	0,481139681
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143 CVE-2021-21135 CVE-2019-9787	0,482283227 0,530202572 0,769382258	0,00853907	0,66191903
Сбор данных	Данные со съемных носителей (T1025)	CVE-2018-13382 CVE-2017-0022	0,497200122 0,773181781	0,081761351	0,646766925
Командование и управление	Веб-сервис (T1102)	CVE-2023-5561 CVE-2019-12086 CVE-2018-0886	0,520822592 0,692459524	0,080619457	0,714024684

Продолжение таблицы 33

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2023-49084 CVE-2024-22017	0,688502863 0,540679613	0,080392154	0,704770588
Удар	Повреждение программы (T1495)	CVE-2011-3544 CVE-2016-2106	0,912419488 0,706469102	0,080462455	0,711353215

Следующий шаблон реализации атаки класса “Социальная инженерия” – CAPEC-654. Фальшивый запрос учетных данных, маскирующийся под легитимный процесс. Множество сценариев изображено на рисунке 24.

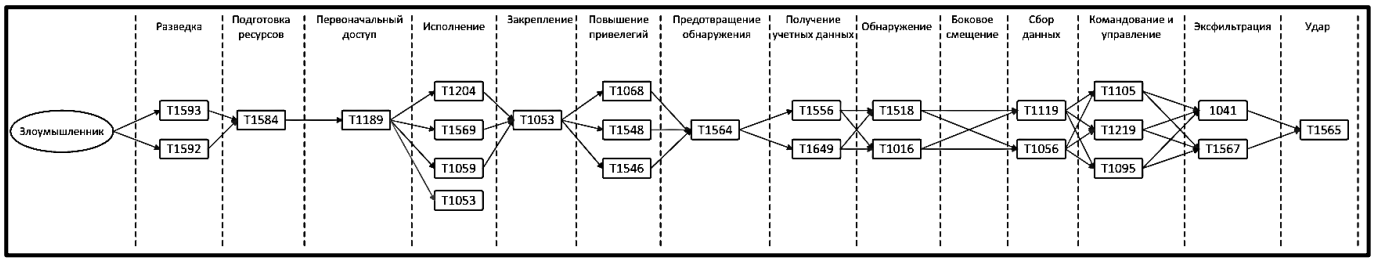


Рисунок 24 – Множество сценариев CAPEC-654

Как и ранее сценарий, использующий в себе только наиболее вероятные техники рассчитан и представлен в таблице 34.

Таблица 34 – Наиболее вероятный сценарий для CAPEC-654

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2018-15473 CVE-2021-30657	0,815829011 0,791127933 0,604538411	0,008383677	0,282008548
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-26925 CVE-2018-13382 CVE-2021-26291 CVE-2024-38143	0,757632855 0,824377205 0,802943396 0,482283227	0,001062189	0,570010212

Продолжение таблицы 34

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2021-21135 CVE-2020-16012 CVE-2021-21132 CVE-2023-3676	0,530202572 0,465754474 0,63304643 0,720456614	0,001045143	0,537889807
Исполнение	Использование пользователем (T1204)	CVE-2021-30682 CVE-2020-1054 CVE-2023-6208	0,596503098 0,775112487 0,477734066	0,008520932	0,528009928
Закрепление	Запланированная задача (T1053)	CVE-2024-39929 CVE-2023-38497	0,511455223 0,579870257	0,008383677	0,464926811
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2019-1405 CVE-2019-0756	0,762257053 0,676396814	0,079951201	0,875
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809 CVE-2024-38213 CVE-2024-38217 CVE-2020-11985	0,661546922 0,75113836 0,609298859 0,483550365	0,001042521	0,507069608
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2024-38143 CVE-2022-23614	0,482283227 0,746908609	0,08172502	0,647134243
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2019-3462 CVE-2020-3175	0,542650214 0,624500678	0,080005665	0,700649081
Боковое смещение	x	x	x	x	x
Сбор данных	Захват входных данных (T1056)	CVE-2021-21135 CVE-2020-16012 CVE-2021-30682	0,530202572 0,465754474 0,596503098	0,00833753	0,400116325
Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2021-44168 CVE-2019-14287	0,465193056 0,773896132	0,082407131	0,875
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2023-36874 CVE-2024-38143	0,725092263 0,482283227	0,081473208	0,649792845

Продолжение таблицы 34

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Удар	Манипулирование данными (T1565)	CVE-2020-1599 CVE-2021-3197 CVE-2021-38165 CVE-2024-38143	0,430970051 0,645486481 0,520822592 0,482283227	0,000146481	0,51212245

Последний шаблон реализации – CAPEC-89. Злоумышленник выдает себя за доверенные сайты, тем самым обманывая жертву. Множество сценариев изображено на рисунке 25.

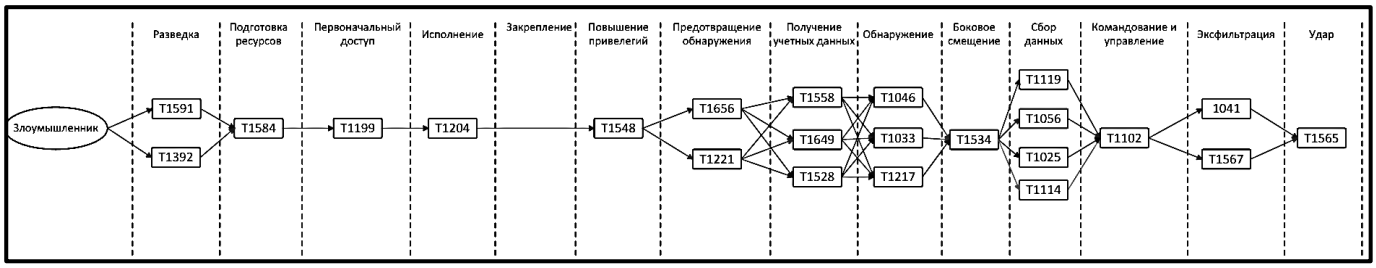


Рисунок 25 – Множество сценариев CAPC-89

В таблице 35 последовательно представлены наиболее используемые техники в рамках шаблона, то есть “максимум вероятности”.

Таблица 35 – Наиболее вероятный сценарий для CAPEC-89

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942 CVE-2023-49084 CVE-2024-22017	0,815829011 0,688502863 0,540679613	0,008450094	0,503399352
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382 CVE-2022-26925 CVE-2024-38143 CVE-2023-36851	0,824377205 0,757632855 0,482283227 0,535115977	0,001069406	0,497529673
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2020-0683 CVE-2019-1322 CVE-2021-21135 CVE-2020-16012 CVE-2023-3676	0,564711509 0,648825153 0,530202572 0,465754474 0,720456614	0,000145932	0,604679054

Продолжение таблицы 35

Тактика	Техника	Уязвимости	Критичность	P (Xi = Ki)	U
Исполнение	Использование пользователем (T1204)	CVE-2021-30682 CVE-2020-1054 CVE-2023-6208 CVE-2021-21132 CVE-2021-44168 CVE-2019-14287	0,596503098 0,775112487 0,477734066 0,63304643 0,465193056 0,773896132	2,3243E-05	0,702567242
Закрепление	x	x	x	x	x
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2021-36942 CVE-2020-0951 CVE-2019-14287 CVE-2020-0683 CVE-2019-0756 CVE-2020-0753 CVE-2021-44168	0,815829011 0,551794174 0,773896132 0,564711509 0,676396814 0,616249201 0,465193056	3,88545E-06	0,668205377
Предотвращение обнаружения	Внедрение шаблона (T1221)	CVE-2023-49084 CVE-2024-22017	0,688502863 0,540679613	0,080392154	0,704770588
Получение учетных данных	Кража или подделка билетов Kerberos (T1558)	CVE-2020-0836 CVE-2019-3978	0,590292076 0,601163313	0,079812011	0,494054746
Обнаружение	Изучение сетевых служб (T1046)	CVE-2018-13382 CVE-2022-40684	0,824377205 0,895052225	0,079876193	0,695206956
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2018-13382 CVE-2022-40684	0,824377205 0,895052225	0,079876193	0,695206956
Сбор данных	Данные со съемных носителей (T1025)	CVE-2024-38476 CVE-2024-39929	0,7103402 0,511455223	0,080887547	0,283718543
Командование и управление	Веб-сервис (T1102)	CVE-2019-1405 CVE-2024-38213 CVE-2024-38217	0,762257053 0,75113836 0,609298859	0,008337688	0,59447642
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2024-38213 CVE-2024-38217	0,75113836 0,609298859	0,080246025	0,437298216
Удар	Манипулирование данными (T1565)	CVE-2023-3676 CVE-2019-14287	0,720456614 0,773896132	0,079859769	0,68841975

Необходимо отметить, что далее речь пойдет о регламентировании, то есть формировании перечня мер и действий, направленных на противодействие атакам класса “Социальная инженерия”. С учетом полученного множества сценариев становится понятным, что в рамках настоящей работы представляется возможным формирование наиболее рациональных регламентов противодействия. Далее по ходу работы будут подробно описаны меры по противодействию для техник, являющихся “узкими местами” в каждом множестве сценариев. Из анализа таблиц 22-35 и рисунков 12-25, можно сделать вывод о том, что рассмотрение этих конкретных техник является наиболее оптимальным не только потому, что их предотвращение остановит атаку, но и так как эти техники имеют наибольшие значение вероятности. То есть реализовав меры противодействия удастся с наименьшими затратами предотвратить технику, которой с большой вероятностью воспользуется злоумышленник на заведомо определенном этапе, таким образом удастся предотвратив атаку на каком-либо из ее этапов. Именно для этого производился расчет вероятностей техники и определение техник с наибольшим значением вероятности. Также полученные в таблицах вероятности позволяют сделать вывод о том, что наиболее оптимально в первую очередь реализовывать меры в рамках тактики, имеющей минимальную выборку техник, так, как чем больше техник – тем меньшая вероятность эксплуатации приходится на каждую из них.

Также, исходя из таблиц 22-35, представляется возможность описать общие регламенты противодействия для всего перечня рассматриваемых техник с учетом технических и социальных аспектов.

Таким образом, результатами подраздела стали:

- полностью сформированный перечень техник, имеющих наибольшее значение вероятности в рамках тактик рассматриваемых шаблонов реализации атак, с учетом математического ожидания;

- сформированное множество сценариев (множество комбинаций техник в рамках шаблона) реализации в рамках рассматриваемого перечня шаблонов атак класса “Социальная инженерия”.

2.3 Риск-ландшафт сформированного перечня уязвимостей с наибольшим значением вероятности эксплуатации в рамках тактики

Далее необходимо осветить перспективу реализации единичных атак, для максимального сужения спектра рассматриваемых наиболее вероятных сценариев (при рассмотрении техник, реализуемых в ходе сценариев, оставался выбор среди CVE). Для этого необходимо рассчитать вероятности и ущербы для всех уязвимостей, выделить уязвимости с наибольшими вероятностями по тактике и произвести расчет рисков по формулам (4), (5), (7), (8). Все данные занесены в таблицу 36 и ландшафт отображен на рисунке 26.

Таблица 36 – Риск-анализ с учетом единичных атак

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
CAPEC-98					
Разведка	Сбор идентификационной информации (T1589)	CVE-2018-15473	0,584549377	0,2	0,116909875
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2020-1054	0,593812568	0,875	0,519585997
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2021-26291	0,565774792	0,75	0,424331094
Исполнение	Запланированная задача (T1053)	CVE-2024-20666	0,516375539	0,875	0,451828596
Закрепление	Запланированная задача (T1053)	CVE-2022-26925	0,573548814	0,5	0,286774407
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2020-1054	0,545623715	0,875	0,477420751
Предотвращение обнаружения	Удаление индикаторов (T1070)	CVE-2021-3197	0,525645586	0,875	0,459939888
Получение учетных данных	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2023-5561	0,514676548	0,2	0,10293531
Обнаружение	Изучение владельца или пользователей системы (T1033)	CVE-2018-14847	0,583053012	0,75	0,437289759
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2023-36874	0,413734303	0,875	0,362017515
Сбор данных	Обнаружение информации о браузере (T1217)	CVE-2019-17563	0,547029239	0,875	0,478650585

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Командование и управление	Веб-сервис (T1102)	CVE-2022-26925	0,573548814	0,5	0,286774407
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2022-26925	0,619291076	0,5	0,309645538
Удар	Уничтожение диска (T1561)	CVE-2016-0046	0,562850697	0,875	0,49249436
CAPEC-163					
Разведка	Информационный фишинг (T1598)	CVE-2019-9787	0,563527032	0,875	0,493086153
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2019-14287	0,50530949	0,875	0,442145804
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2019-0633	0,584090085	0,875	0,511078824
Исполнение	Запланированная задача (T1053)	CVE-2020-1054	0,583979538	0,875	0,510982096
Закрепление	Запланированная задача (T1053)	CVE-2020-1054	0,583979538	0,875	0,510982096
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2021-3197	0,511586135	0,875	0,447637868
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809	0,550268109	0,875	0,481484596
Получение учетных данных	Кража токена доступа к приложению (T1528)	CVE-2023-49084	0,560130718	0,875	0,490114378
Обнаружение	Кража или подделка билетов Kerberos (T1558)	CVE-2019-0633	0,593169462	0,875	0,51902328
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2019-9787	0,413000637	0,875	0,361375557
Сбор данных	Данные со съемных носителей (T1025)	CVE-2022-44268	0,608621532	0,5	0,304310766
Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2011-3544	0,563608573	0,875	0,493157501
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2019-12643	0,57073249	0,875	0,499390929
Удар	Шифрование данных (T1486)	CVE-2023-37266	0,635922996	0,875	0,556432621
CAPEC-164					
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2022-30295	0,386765902	0,6	0,232059541

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2020-0683	0,713581046	0,875	0,624383416
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2022-40684	0,397888791	0,875	0,348152692
Исполнение	Использование пользователем (T1204)	CVE-2021-21132	0,371772755	0,875	0,325301161
Закрепление	Действующие учетные записи (T1078)	CVE-2022-26925	0,551454073	0,5	0,275727036
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2019-14287	0,394204618	0,875	0,344929041
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809	0,379612709	0,875	0,33216112
Получение учетных данных	Подделка учетных данных для веб-ресурсов (T1606)	CVE-2022-40684	0,556082391	0,875	0,486572092
Обнаружение	Изучение местоположения системы (T1614)	CVE-2023-35325	0,527580503	0,5	0,263790251
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2019-9787	0,413000637	0,875	0,361375557
Сбор данных	Захват входных данных (T1056)	CVE-2021-28169	0,561149354	0,2	0,112229871
Командование и управление	Веб-сервис (T1102)	CVE-2019-12643	0,57073249	0,875	0,499390929
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2022-40684	0,586566824	0,875	0,513245971
Удар	Уничтожение данных (T1485)	CVE-2014-3153	0,578745684	0,875	0,506402473
CAPEC-656					
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-36942	0,345019255	0,2	0,069003851
Подготовка ресурсов	Компрометация учетных записей (T1586)	CVE-2021-26291	0,514517247	0,75	0,385887935
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2022-40684	0,619550338	0,875	0,542106546
Исполнение	Использование пользователем (T1204)	CVE-2021-44168	0,323571176	0,875	0,283124779
Закрепление	Создание учетных записей (T1136)	CVE-2019-14287	0,578135152	0,875	0,505868258

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2023-49084	0,343175265	0,875	0,300278357
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809	0,282032242	0,875	0,246778212
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684	0,623411839	0,875	0,545485359
Обнаружение	Изучение местоположения системы (T1614)	CVE-2022-30295	0,341618328	0,6	0,204970997
Боковое смещение	Использование альтернативных материалов для аутентификации (T1550)	CVE-2022-40684	0,527122811	0,875	0,46123246
Сбор данных	Захват видеоданных (T1125)	CVE-2021-30682	0,580553466	0,5	0,290276733
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2018-13382	0,578025045	0,5	0,289012523
Эксфильтрация	Передача по расписанию (T1029)	CVE-2020-1054	0,583979538	0,875	0,510982096
Удар	Манипулирование данными (T1565)	CVE-2021-25281	0,367358035	0,875	0,321438281
CAPEC-630					
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2022-23614	0,569371065	0,875	0,498199682
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684	0,458251811	0,875	0,400970334
Первоначальный доступ	Фишинг (T1566)	CVE-2019-9787	0,431784079	0,875	0,377811069
Исполнение	Использование пользователем (T1204)	CVE-2021-21132	0,518554228	0,875	0,453734949
Закрепление	Расширения для браузера (T1176)	CVE-2020-1054	0,58510508	0,875	0,511966945
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2019-14287	0,297613059	0,875	0,260411427
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2019-1458	0,546715551	0,875	0,478376107
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684	0,61766324	0,875	0,540455335

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Обнаружение	Изучение групп разрешений (T1069)	CVE-2019-14287	0,390050111	0,875	0,341293847
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2019-9787	0,323571176	0,875	0,283124779
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382	0,432866077	0,5	0,216433038
Командование и управление	Веб-сервис (T1102)	CVE-2019-12643	0,57073249	0,875	0,499390929
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2022-44268	0,401642558	0,5	0,200821279
Удар	Уничтожение данных (T1485)	CVE-2021-22204	0,419337011	0,875	0,366919885
CAPEC-194					
Разведка	Информационный фишинг (T1598)	CVE-2019-9787	0,323571176	0,875	0,283124779
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287	0,398594715	0,875	0,348770376
Первоначальный доступ	Фишинг (T1566)	CVE-2017-7821	0,294753482	0,875	0,257909297
Исполнение	Использование пользователем (T1204)	CVE-2021-21132	0,282918638	0,875	0,247553808
Закрепление	Создание учетных записей (T1136)	CVE-2023-30861	0,523330837	0,488	0,255385449
Повышение привилегий	Существующие учетные записи (T1078)	CVE-2019-14287	0,380174905	0,875	0,332653042
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2019-1458	0,416426785	0,875	0,364373437
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2023-3676	0,414376256	0,488	0,202215613
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2024-29988	0,602672952	0,875	0,527338833
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2024-38143	0,397441065	0,5	0,198720533
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382	0,246984224	0,5	0,123492112
Командование и управление	Веб-сервис (T1102)	CVE-2023-49084	0,569328017	0,875	0,498162015

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Эксфильтрация	Передача по расписанию (T1029)	CVE-2020-1054	0,378669202	0,875	0,331335552
Удар	Уничтожение данных (T1485)	CVE-2021-22204	0,304570379	0,875	0,266499082
CAPEC-504					
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-3197	0,571714274	0,875	0,50024999
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-26925	0,294011646	0,5	0,147005823
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2019-1322	0,394474815	0,875	0,345165463
Исполнение	Использование пользователем (T1204)	CVE-2019-14287	0,385313687	0,875	0,337149476
Закрепление	Запланированная задача (T1053)	CVE-2023-49084	0,386836666	0,875	0,338482083
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2023-36874	0,602823737	0,875	0,52747077
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2022-40684	0,280197374	0,875	0,245172702
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2019-3978	0,504562167	0,5	0,252281083
Обнаружение	Изучение сведений о конфигурации сети (T1016)	CVE-2016-0046	0,387814848	0,875	0,339337992
Боковое смещение	x	x	x	x	x
Сбор данных	Данные со съемных носителей (T1025)	CVE-2020-10136	0,506152634	0,2	0,101230527
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2021-26291	0,602292184	0,75	0,451719138
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2019-0804	0,500175391	0,5	0,250087695
Удар	Манипулирование данными (T1565)	CVE-2019-14287	0,588801326	0,875	0,51520116
CAPEC-173					
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942	0,398936151	0,2	0,07978723
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-26925	0,426827702	0,5	0,213413851

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2023-6208	0,506348562	0	0
Исполнение	Интерпретаторы командной строки и сценариев (T1059)	CVE-2019-14287	0,41711859	0,875	0,364978766
Закрепление	Запланированная задача (T1053)	CVE-2024-38476	0,403085254	0,488	0,196705604
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2019-1405	0,380488283	0,875	0,332927248
Предотвращение обнаружения	Внедрение шаблона (T1221)	CVE-2019-0633	0,524890362	0,875	0,459279067
Получение учетных данных	Изменение процесса аутентификации (T1556)	CVE-2020-0836	0,531261168	0,488	0,25925545
Обнаружение	Изучение установленного ПО (T1518)	CVE-2024-29988	0,554817983	0,875	0,485465735
Боковое смещение	x	x	x	x	x
Сбор данных	Захват входных данных (T1056)	CVE-2023-36874	0,600552412	0,875	0,525483361
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2019-0633	0,524890362	0,875	0,459279067
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2020-0836	0,531261168	0,488	0,25925545
Удар	Манипулирование данными (T1565)	CVE-2024-29988	0,554817983	0,875	0,485465735
CAPEC-698					
Разведка	Информационный фишинг (T1598)	CVE-2023-3676	0,419745327	0,488	0,20483572
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382	0,399350814	0,5	0,199675407
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2020-1054	0,411005552	0,875	0,359629858
Исполнение	Интерпретаторы командной строки и сценариев (T1059)	CVE-2019-14287	0,30567815	0,875	0,267468381
Закрепление	Расширения для браузера (T1176)	CVE-2023-36874	0,548649219	0,875	0,480068067
Повышение привилегий	Выполнение кода по событию (T1546)	CVE-2019-0633	0,524890362	0,875	0,459279067
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2023-22809	0,521753856	0,875	0,456534624

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2023-36851	0,772610296	0,488	0,377033825
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2021-21134	0,560502922	0,5	0,280251461
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2023-3676	0,419745327	0,488	0,20483572
Сбор данных	Захват входных данных (T1056)	CVE-2020-1054	0,59964008	0,875	0,52468507
Командование и управление	Перенос входящего инструмента (T1105)	CVE-2019-14287	0,624568545	0,875	0,546497477
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-49084	0,560130718	0,875	0,490114378
Удар	Манипулирование данными (T1565)	CVE-2023-30861	0,340289317	0,488	0,166061186
CAPEC-410					
Разведка	Сбор идентификационной информации (T1589)	CVE-2021-36942	0,390254082	0,2	0,078050816
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684	0,244644549	0,875	0,21406398
Первоначальный доступ	Теневая компрометация (T1189)	CVE-2019-12086	0,539176771	0,5	0,269588385
Исполнение	Использование пользователем (T1204)	CVE-2020-1054	0,257284321	0,875	0,225123781
Закрепление	Действующие учетные записи (T1078)	CVE-2019-14287	0,720316497	0,875	0,630276935
Повышение привилегий	Манипуляции с аккаунтом (T1098)	CVE-2023-30861	0,507633603	0,488	0,247725198
Предотвращение обнаружения	Удаление индикаторов (T1070)	CVE-2021-25281	0,306230194	0,875	0,26795142
Получение учетных данных	Манипуляции с токенами доступа (T1134)	CVE-2023-49084	0,533121149	0,875	0,466481005
Обнаружение	Обнаружение информации о браузере (T1217)	CVE-2019-12643	0,557496487	0,875	0,487809426
Боковое смещение	x	x	x	x	x

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Сбор данных	Автоматизированный сбор (T1119)	CVE-2021-30682	0,580553466	0,5	0,290276733
Командование и управление	Протоколы (кроме прикладного уровня) (T1095)	CVE-2011-3544	0,415509716	0,875	0,363571001
Эксфильтрация	Эксфильтрация через стороннюю среду (T1011)	CVE-2023-35325	0,547688499	0,5	0,273844249
Удар	Манипулирование данными (T1565)	CVE-2021-25281	0,309316144	0,875	0,270651626
CAPEC-631					
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2022-23614	0,569371065	0,875	0,498199682
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2022-40684	0,458251811	0,875	0,400970334
Первоначальный доступ	Фишинг (T1566)	CVE-2019-9787	0,431784079	0,875	0,377811069
Исполнение	Использование пользователем (T1204)	CVE-2021-21132	0,511517602	0,875	0,447577902
Закрепление	Расширения для браузера (T1176)	CVE-2019-1405	0,581039439	0,875	0,508409509
Повышение привилегий	Эксплуатация уязвимостей для повышения привилегий (T1068)	CVE-2020-0683	0,25440753	0,875	0,222606589
Предотвращение обнаружения	Сокрытие артефактов (T1564)	CVE-2019-1458	0,546715551	0,875	0,478376107
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684	0,61766324	0,875	0,540455335
Обнаружение	Изучение групп разрешений (T1069)	CVE-2019-14287	0,390050111	0,875	0,341293847
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2019-9787	0,323571176	0,875	0,283124779
Сбор данных	Сбор электронной почты (T1114)	CVE-2018-13382	0,432866077	0,5	0,216433038
Командование и управление	Веб-сервис (T1102)	CVE-2019-12643	0,57073249	0,875	0,499390929
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2022-44268	0,401642558	0,5	0,200821279
Удар	Уничтожение данных (T1485)	CVE-2021-22204	0,419337011	0,875	0,366919885
CAPEC-151					
Разведка	Информационный фишинг (T1598)	CVE-2020-4046	0,552695469	0,36	0,198970369

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Подготовка ресурсов	Создание учетных записей (T1585)	CVE-2019-14287	0,578135152	0,875	0,505868258
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2022-26925	0,579557443	0,5	0,289778721
Исполнение	Использование пользователем (T1204)	CVE-2021-21132	0,542073022	0,875	0,474313894
Закрепление	Создание учетных записей (T1136)	CVE-2024-38213	0,552130116	0,5	0,276065058
Повышение привилегий	Существующие учетные записи (T1078)	CVE-2021-36942	0,51318872	0,2	0,102637744
Предотвращение обнаружения	Имперсонация (T1656)	CVE-2023-22809	0,550268109	0,875	0,481484596
Получение учетных данных	Кража или подделка сертификатов аутентификации (T1649)	CVE-2022-40684	0,61766324	0,875	0,540455335
Обнаружение	Обнаружение учетной записи (T1087)	CVE-2018-15473	0,583496769	0,2	0,116699354
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2019-9787	0,431784079	0,875	0,377811069
Сбор данных	Данные со съемных носителей (T1025)	CVE-2022-44268	0,608621532	0,5	0,304310766
Командование и управление	Веб-сервис (T1102)	CVE-2019-12643	0,57073249	0,875	0,499390929
Эксфильтрация	Эксфильтрация через веб-сервис (T1567)	CVE-2023-49084	0,560130718	0,875	0,490114378
Удар	Повреждение программы (T1495)	CVE-2011-3544	0,563608573	0,875	0,493157501
CAPEC-89					
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942	0,398936151	0,2	0,07978723
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382	0,317140212	0,5	0,15857011
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2023-3676	0,245893798	0,488	0,11999617
Исполнение	Использование пользователем (T1204)	CVE-2020-1054	0,208280413	0,875	0,18224536
Закрепление	x	x	x	x	x

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2021-36942	0,182754533	0,2	0,03655091
Предотвращение обнаружения	Внедрение шаблона (T1221)	CVE-2023-49084	0,560130718	0,875	0,49011438
Получение учетных данных	Кража или подделка билетов Kerberos (T1558)	CVE-2019-3978	0,504562167	0,5	0,25228108
Обнаружение	Изучение сетевых служб (T1046)	CVE-2022-40684	0,520551882	0,875	0,45548290
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2022-40684	0,520551882	0,875	0,45548290
Сбор данных	Данные со съемных носителей (T1025)	CVE-2024-38476	0,581390457	0,488	0,28371854
Командование и управление	Веб-сервис (T1102)	CVE-2019-1405	0,359098841	0,875	0,31421149
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2024-38213	0,552130116	0,5	0,27606506
Удар	Манипулирование данными (T1565)	CVE-2019-14287	0,51788049	0,875	0,45314543
CAPEC-654					
Разведка	Сбор информации о хосте жертвы (T1592)	CVE-2021-36942	0,398936151	0,2	0,07978723
Подготовка ресурсов	Компрометация инфраструктуры (T1584)	CVE-2018-13382	0,317140212	0,5	0,15857011
Первоначальный доступ	Доверительные отношения (T1199)	CVE-2023-3676	0,245893798	0,488	0,11999617
Исполнение	Использование пользователем (T1204)	CVE-2020-1054	0,208280413	0,875	0,18224536
Закрепление	x	x	x	x	x
Повышение привилегий	Обход механизмов контроля привилегий (T1548)	CVE-2021-36942	0,182754533	0,2	0,03655091
Предотвращение обнаружения	Внедрение шаблона (T1221)	CVE-2023-49084	0,560130718	0,875	0,49011438
Получение учетных данных	Кража или подделка билетов Kerberos (T1558)	CVE-2019-3978	0,504562167	0,5	0,25228108
Обнаружение	Изучение сетевых служб (T1046)	CVE-2022-40684	0,520551882	0,875	0,45548290

Продолжение таблицы 36

Тактика	Техника	CVE	P (CVE_{max})	Ui	Risk (CVE)
Боковое смещение	Внутренний целевой фишинг (T1534)	CVE-2022-40684	0,520551882	0,875	0,45548290
Сбор данных	Данные со съемных носителей (T1025)	CVE-2024-38476	0,581390457	0,488	0,28371854
Командование и управление	Веб-сервис (T1102)	CVE-2019-1405	0,359098841	0,875	0,31421149
Эксфильтрация	Эксфильтрация по каналу C2 (1041)	CVE-2024-38213	0,552130116	0,5	0,27606506
Удар	Манипулирование данными (T1565)	CVE-2019-14287	0,51788049	0,875	0,45314543

Как итог, риск, рассчитанный по формуле 5 для единичных атак в рамках текущих шаблонов реализации атак класса “Социальная инженерия” был представлен в виде риск-ландшафта, который приведен на рисунке 26.

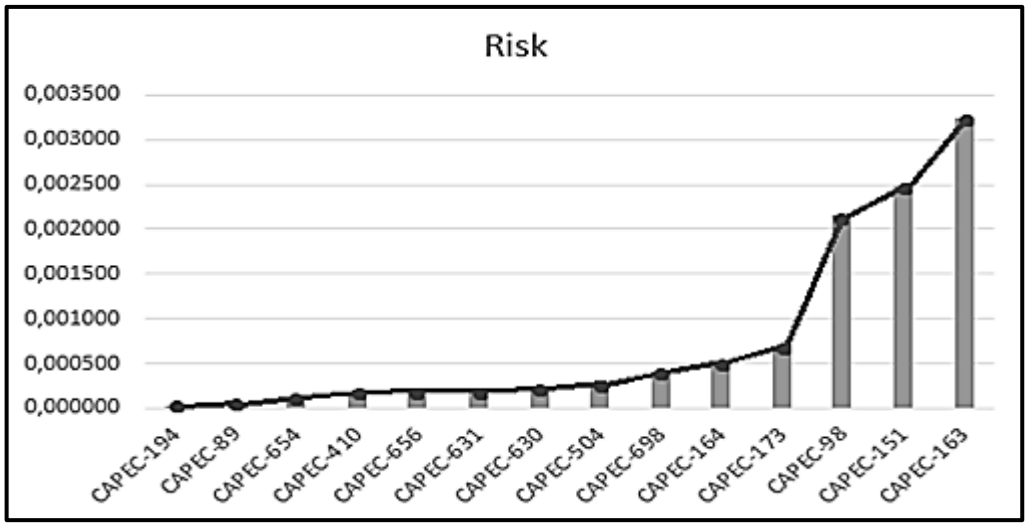


Рисунок 26 – Значения рисков для шаблонов CAPEC

Таким образом, в итогах подраздела стоит выделить, что был сформирован перечень наиболее вероятных сценариев в рамках каждого шаблона, учитывая значения вероятностей каждой отдельной уязвимости. В этих сценариях встречаются только уязвимости с наибольшим значением критичности, а как следствие – с наибольшим значением вероятности успешной эксплуатации [57-69].

Для каждого уникального сценария и каждой уникальной уязвимости в рамках этого сценария далее будут представлены целостные регламенты противодействия атакам класса “Социальная инженерия”.

По итогам раздела были рассчитаны и представлены:

- критичности для каждой уязвимости по отдельности;
- вероятности успешной эксплуатации для каждой уязвимости в рамках техники;
- вероятности использования текущей техники в рамках сценария;
- ущербы для наиболее вероятно используемых техник в рамках сценария;
- риски для каждой наиболее вероятно используемой уязвимости в рамках тактики;
- риски для каждого сценария (единичные атаки);
- риск-ландшафт для единичных атак.

Также помимо вышеперечисленного стоит отметить, что были сформированы наиболее вероятные сценарии реализации атак, как с отдельными уязвимостями, так и в целом с техниками. Далее это будет необходимо для наиболее рационального подбора мер и регламентов противодействия атакам класса “Социальная инженерия”.

3 Организационно-правовое противодействие атакам класса “Социальная инженерия”

3.1 Формирование перечня объектов воздействия с учетом социальных уязвимостей поколений, эксплуатируемых в ходе реализации атак класса “Социальная инженерия”

В ходе написания работы был произведен анализ ресурсов, в том числе зарубежных, с целью выявления наиболее часто выбираемых для атаки объектов воздействия. Невозможно объективно описать регламенты противодействия, не осветив объекты, на которые в большей степени направлено внимание злоумышленника в контексте атак класса “Социальная инженерия».

Согласно исследованиям, одного из крупнейших новостных порталов запада “Investopedia” в период с 2023 по 2025 год была зафиксирована следующая статистика, касающаяся атак класса “Социальная инженерия”:

- большое количество атак проводится на социальные сети и сети коммуникаций, так как дизайн платформ вызывает у людей чувство доверия и безопасности использования, что снижает их настороженность;

- оказалось, что за 2024 год 44% лиц в возрасте от 20-29 лет заявили о случаях мошенничества, тогда как для пенсионеров (65-79 лет) этот показатель составил почти в два раза меньшие 24%, выяснилось, что молодые люди чаще подвержены мошенническим атакам из-за высокой активности в сети “Интернет”, также исследования говорят о том, что молодёжь склонна к быстрому принятию решений, что снижает уровень способности критического мышления [70].

Портал “Keepnet” говорит о том, что в течение первых 90 дней работы новые сотрудники на 44% более подвержены фишинговым и социально-инженерным атакам, причинами служат недостаток опыта работы на новом месте, ограниченное понимание внутренних процессов и избыточное доверие к корпоративным коммуникациям [71].

В свою очередь портал “EMBROKER” приводит следующие актуальные для исследования атаки заданного класса данные:

- сотрудники компаний с численностью менее 100 человек получают на 350% больше атак социальной инженерии, чем сотрудники более крупных предприятий, это связано с отсутствием надежных планов по кибербезопасности, в связи с чем, либо совсем не пользуются инструментарием по обеспечения информационной безопасности, либо пользуются бесплатными решениями, что не приводит к значительному повышению уровня защищенности.

- согласно индексу киберпреступности “World Cybercrime Index”, Россия является страной, наиболее подверженной риску киберпреступлений, это связано с нехваткой специалистов в области обеспечения информационной безопасности, что очень сильно размывает круги представления о мошеннических кибератаках в стране [72].

Тематический сайт со своей продукцией “eftsure” говорит, что из 99% организаций заявивших, что у них есть программа обучения по вопросам безопасности, только 27% респондентов охватили социальную инженерию, это говорит о том, что высокий уровень атак заданного класса в том числе спровоцирован непониманием большинства процесса, лежащего в основе атаки [73]. Вся статистика по настоящим моментам отображена на рисунке 27.

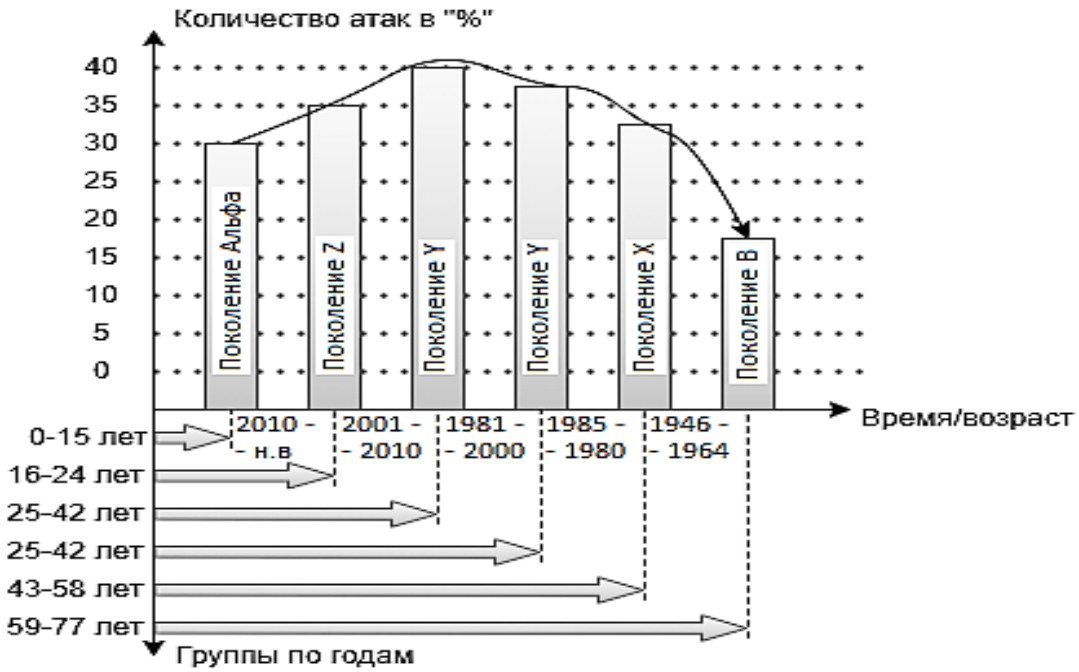


Рисунок 27 – Влияние социальной инженерии на различные возрастные категории

Прежде, чем строить таблицу 38 – необходимо также осветить основные “уязвимые места” людей разных возрастных категорий согласно различным исследованиям. Будет удобно представить такую структуру также в виде матрицы с взаимнооднозначными пересечениями по строкам/столбцам (таблица 37).

Таблица 37 – Матрица социальных уязвимостей

Возрастная категория / Уязвимость	A (2010+)	Z (2001-2010)	Y (1981-2000)	X (1965-1980)	B (1946-1964)
Трудности освоения цифровых технологий	-	-	-	+	+
Социальная изоляция из-за цифровизации	+	+	-	+	+
Риск депрессии и тревожности из-за изменений	+	+	+	+	+
Снижение занятости из-за роботизации	+	+	+	+	+
Потеря квалификации	-	-	-	+	+
Уязвимость к цифровому мошенничеству	+	-	-	+	+
Дискриминация на рынке труда	-	-	-	+	+
Сложности в живом общении	+	+	+	-	-
Девиантное поведение	+	+	+	-	-
Упрощенное системное мышление	+	+	+	-	-
Дезадаптация к социальной реальности	+	+	+	-	-
Чрезмерное доверие к информации из интернета	+	+	+	-	-
Нарушение межличностных коммуникаций	+	+	+	-	-
Снижение уважения к старшим поколениям	+	+	-	-	-
Проблемы с логическим и аналитическим мышлением	+	+	-	-	-
Зависимость от виртуального мира	+	+	-	-	-
Сложности в социализации со сверстниками	+	+	-	-	-
Риск формирования фейковой реальности	+	+	-	-	-

Смысл таблицы 37 в завершении понимания концепции построения перечня объектов воздействия не только с технической точки зрения, но и с социально-психологической [74]. Для большего углубления необходимо более подробно рассмотреть на бумаге каждое поколение.

Матрица с уязвимостями необходима именно здесь, поскольку без понимания полного перечня используемых уязвимостей (в том числе социальных) невозможно

составить перечень объектов воздействия, и, как следствие, – невозможно сформировать меры по обнаружению.

Также стоит отметить, что концепция социально-психологических уязвимостей в связке использования с техниками несколько отличается от классических CVE: в отличие от обычных CVE, социальных уязвимостей кратно меньше, также при реализации техники злоумышленник в зависимости от шаблона реализации атаки использует уникальный набор CVE-уязвимостей (при этом повторения уязвимостей в разных техниках и в разных шаблонах не исключены), в то время как любая социально-психологическая уязвимость может принадлежать любой технике. Так происходит, потому что в зависимости от вида уязвимости варьируется лишь возрастная категория, а не атака или шаблон. Так, например, сбор данных (техника) может осуществляться на Z поколение (используется уязвимость излишнего доверия) или на B поколение (используется уязвимость слабого уровня цифровизации).

Таким образом, освещения социально-психологического воздействия дополняет множество используемых уязвимостей, для адекватного формирования перечня объектов воздействия.

Углубляясь в выявленные уязвимости, можно отметить, что основными проблемами B-поколения и X-поколения стали психологические стрессы при освоении новых технологий в скупе с отставанием за столь стремительно-развивающимися технологиями в целом. Кроме того, рост дискриминации на рынке труда по отношению к данной возрастной категорий провоцирует развитие депрессии и чувства тревожности. Все это в совокупности подводит эти поколения под удар цифрового мошенничества.

Поколение миллениалов в свою очередь, как выяснилось, имеет заметные сложности в контексте живого общения в силу другого воспитания, также фиксируются частые случаи девиации и упрощенного системного мышления.

Поколения Z и Альфа часто склонны к принятию мгновенных решений, снижению уважения к старшим, проблемам с логическим и аналитическим мышлением, зависимости от виртуального мира. Часто люди этой возрастной категории пребывают в так называемой “фейковой” реальности.

Несмотря на то, что на текущий момент наиболее подвержены атакам социальной инженерии Z-поколение и миллениалы, в будущем тенденция изменится. Чтобы это понять необходимо рассчитать вероятность реализации атаки для каждого поколения, исходя из общего числа уязвимостей в целом по формуле (9) (рисунок 28). Важно упомянуть, что все уязвимости в своем уровне критичности являются усредненными, и далее будет рассматриваться ситуация, где каждая уникальная уязвимость имеет свое уникальное значение критичности.

$$P_v = 1 - \left(1 - \frac{1}{n}\right)^m, \quad (9)$$

где P_v – это вероятность реализации атаки в текущем поколении с учетом уязвимостей социального характера;

m – это количество уязвимостей для текущей возрастной категории;

n – количество уязвимостей всего.

В формуле (9) $\frac{1}{n}$ – это вероятность того, что одна конкретная уязвимость приведет к успешной атаке, если предположить, что все уязвимости равновероятны. $(1 - \frac{1}{n})$ – это вероятность того, что одна конкретная уязвимость не приведет к успешной атаке. $(1 - \frac{1}{n})^m$ – это вероятность того, что ни одна из m уязвимостей текущего поколения не приведет к успешной атаке. $1 - (1 - \frac{1}{n})^m$ – это вероятность того, что хотя бы одна уязвимость из m уязвимостей текущего поколения приведет к успешной атаке (то есть искомая вероятность).

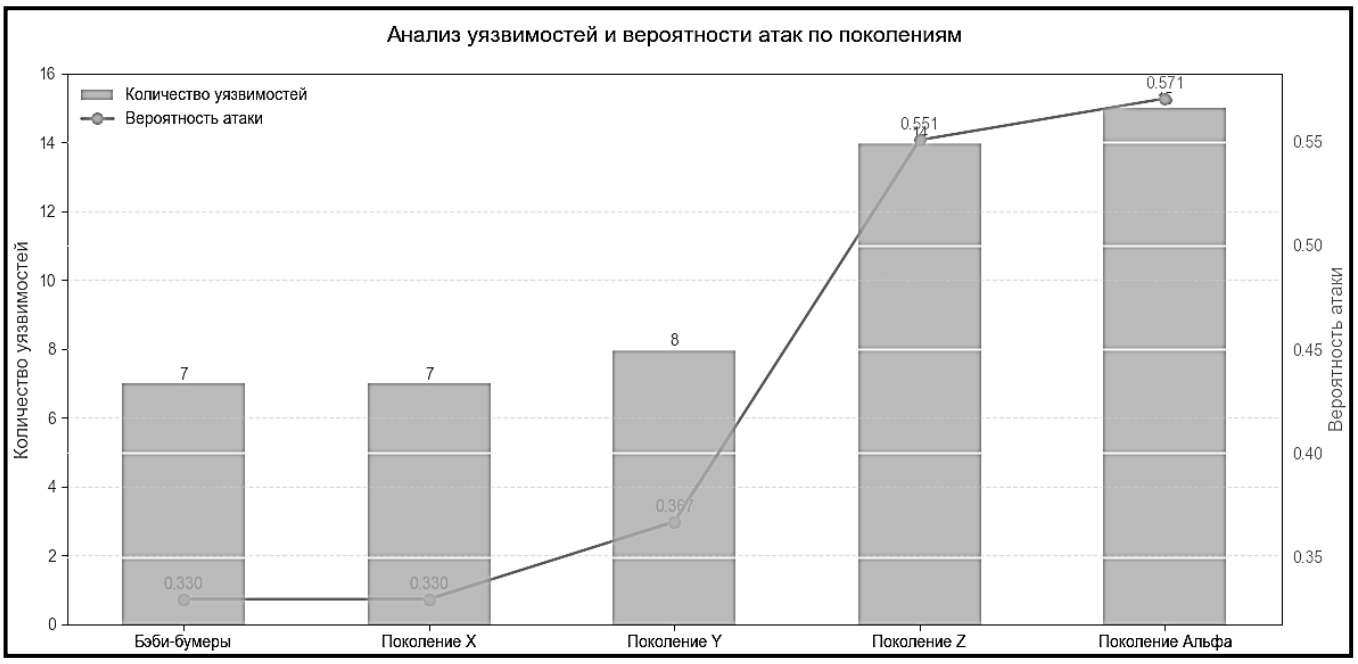


Рисунок 28 – Вероятность и количество уязвимостей для каждого поколения

Как видно из диаграммы – вероятность атак на более молодое поколение, как и количество уязвимостей растут. Это означает что в перспективе альфа-поколение не только заменит Z-поколение и миллениалов, но и количество атак разительно увеличится, судя по экспоненциальному характеру роста. Таким образом, из описанного выше можно выделить три объекта воздействия на социальном уровне: уровень осведомленности пользователей, влияние на массовое сознание, влияние на сознание индивида. Исходя из полученного, на языке Python с использованием библиотеки matplotib было написано мини приложение, отражающее зависимость вероятности от уровня осведомленности пользователя, уровня влияния на массовое сознание и на сознание индивида. Так как текущие глобальные объекты воздействия были получены путем анализа равновероятных социальных уязвимостей, то и модификаторы для этих объектов брались одинаковыми (упрощенная модель). Приложение опирается на классическую экспоненциальную функцию, так как такая тенденция прослеживается на рисунке 28, график на котором был построен в ручном режиме с использованием актуальных данных, более того преимущество экспоненциальной функции заключается в учете нелинейности вероятностей, а как следствие и реальных рисков. Помимо прочего, приложение облегчает и автоматизирует оценку вероятности реализации

атаки с учетом заданных параметров (используемых только в социально-психологическом контексте). Результат работы программы изображен на рисунке 29.

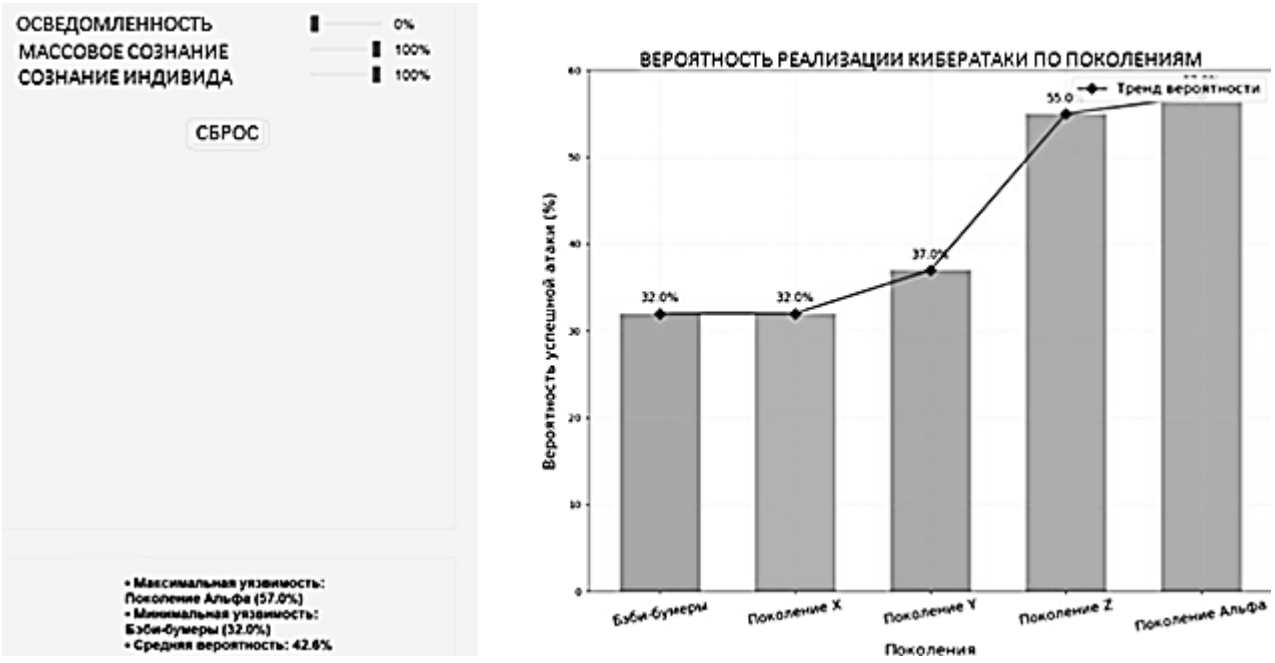


Рисунок 29 – Приложение динамического расчета вероятности

Важно, что все вышеописанные процедуры актуальны в случае, если не проводить анализ критичности каждой отдельной уязвимости. Однако в реальности зачастую требуются расчеты для конкретного сценария с точным значением вероятностей и критичностей для каждой уязвимости. Для каждой уязвимости представляется возможным определить ее критичность по следующей шкале: 0 - 0,975 – встречается у 1-го поколения из 5-ти; 1,95 – встречается у 2-х поколений из 5-ти; 3,9 – встречается у 3-х поколений из 5-ти; 6,9 – встречается у 4-х поколений из 5-ти; 9,9 – встречается у 5-ти поколений из 5-ти. Шкала оценки является несколько модифицированной версией шкалы CVSS калькулятора [55]. Имея в обороте критичность для каждой уязвимости возможен расчет вероятности по формуле (3) индивидуально для каждой социальной уязвимости:

В итоге получим матрицу (таблица 38), в которой будут отражены вероятности и критичности каждой уязвимости для всех рассматриваемых поколений с учетом нормировки по формуле (2).

Таблица 38 – Вероятности эксплуатации социальных уязвимостей.

Возрастная категория / Уязвимость	A (2010+)	Z (2001-2010)	Y (1981-2000)	X (1965-1980)	B (1946-1964)	Sf
Трудности освоения цифровых технологий	0	0	0	0,028017	0,028017	0,195
Социальная изоляция из-за цифровизации	0,099137	0,099137	0	0,099137	0,099137	0,69
Риск депрессии и тревожности из-за изменений	0,142241	0,142241	0,142241	0,142241	0,142241	0,99
Снижение занятости из-за роботизации	0,142241	0,142241	0,142241	0,142241	0,142241	0,99
Потеря квалификации	0	0	0	0,040816	0,040816	0,195
Уязвимость к цифровому мошенничеству	0,056034	0	0	0,056034	0,056034	0,39
Дискриминация на рынке труда	0	0	0	0,040816	0,040816	0,195
Сложности в живом общении	0,056034	0,056034	0,056034	0	0	0,39
Девиантное поведение	0,056034	0,056034	0,056034	0	0	0,39
Упрощенное системное мышление	0,056034	0,056034	0,056034	0	0	0,39
Дезадаптация к социальной реальности	0,056034	0,056034	0,056034	0	0	0,39
Чрезмерное доверие к информации из интернета	0,056034	0,056034	0,056034	0	0	0,39
Нарушение межличностных коммуникаций	0,056034	0,056034	0,056034	0	0	0,39
Снижение уважения к старшим поколениям	0,028017	0,028017	0	0	0	0,195
Проблемы с логическим и аналитическим мышлением	0,028017	0,028017	0	0	0	0,195
Зависимость от виртуального мира	0,028017	0,028017	0	0	0	0,195
Сложности в социализации со сверстниками	0,028017	0,028017	0	0	0	0,195
Риск формирования фейковой реальности	0,028017	0,028017	0	0	0	0,195

Далее возможно рассчитать среднюю вероятность реализации атак класса “Социальная инженерия”, взяв среднее значение по каждому поколению (столбцу). Для удобства возможно представить полученные выше результаты в виде диаграммы (рисунок 30).

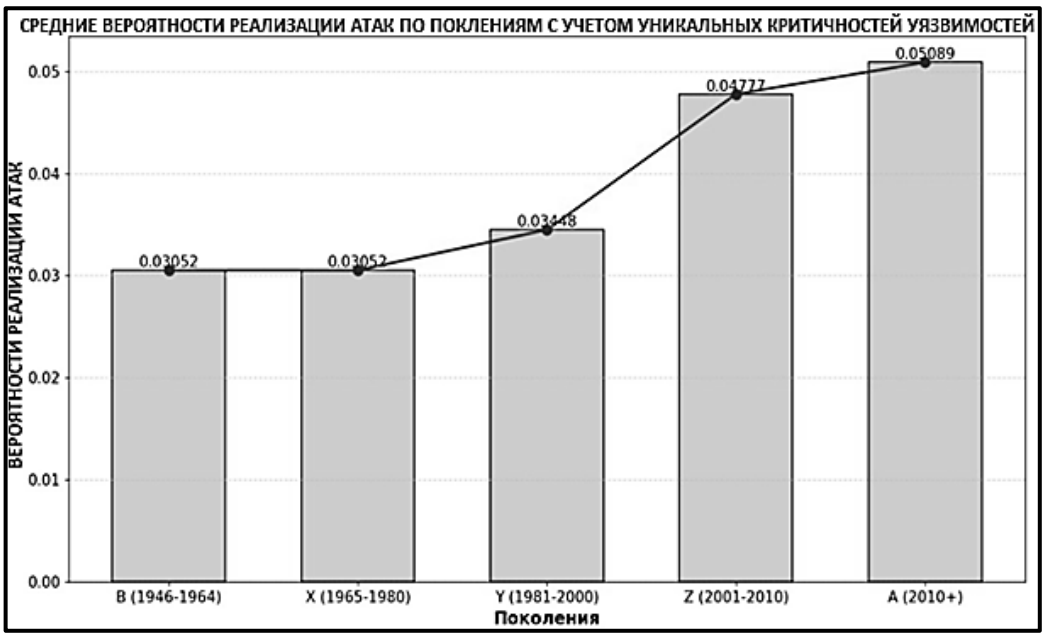


Рисунок 30 – Средние вероятности реализации атак по поколениям с учетом критичности отдельно взятых социальных уязвимостей.

Из рисунка 30 отчетливо видно, что график по-прежнему имеет похожую форму (рисунки 28 и 29), а значения разнятся в пределах погрешности, это подтверждает корректность и правильность вышеизложенного.

Теперь, когда есть полное понимание технической и социально-психологической сторон, можно составить таблицу с объектами воздействия социальной инженерии (таблица 39) для успешного формирования регламентов обнаружения и регистрации. При построении матрицы учитывались приказ ФСТЭК России от 5 февраля 2021 года (технические аспекты) и монография “Социальные сети и психологическая безопасность” (социальные аспекты). [13, 75].

Таблица 39 – Объекты воздействия при атаке класса “Социальная инженерия”

Направление	Объект воздействия/класс шаблона	Обманное метадезинформирование	Десимуляционное дезинформирование	Симуляционное дезинформирование	Кажущееся псевдо-информирование	Обобщенное псевдоинформирование	Избыточное целенаправленное псевдоинформирование
Социальное	Сознание индивида	-	-	CAPEC-173 CAPEC-194	CAPEC-194	CAPEC-410	CAPEC-98 CAPEC-163 CAPEC-164 CAPEC-656

Продолжение таблицы 39

Направление	Объект воздействия/класс шаблона	Обманное метадезинформирование	Десимуляционное дезинформирование	Симуляционное дезинформирование	Кажущееся псевдо-информирование	Обобщенное псевдоинформирование	Избыточное целенаправленное псевдоинформирование
	Массовое сознание	-	CAPEC-89 CAPEC-630 CAPEC-631	CAPEC-194	CAPEC-194	CAPEC-630 CAPEC-631	CAPEC-98 CAPEC-163 CAPEC-164 CAPEC-656
	Уровень осведомленности (обученности) персонала	-	CAPEC-630 CAPEC-631	CAPEC-194 CAPEC-173	CAPEC-194	CAPEC-410 CAPEC-630 CAPEC-631	CAPEC-98 CAPEC-163 CAPEC-164 CAPEC-656
Техническое	Программно-аппаратные средства	CAPEC-698	-	CAPEC-504 CAPEC-654	-	-	-
	Программные средства	CAPEC-698	CAPEC-630 CAPEC-631	CAPEC-173	-	CAPEC-631 CAPEC-630	-
	Привилегированные и непривилегированные пользователи систем	-	-	CAPEC-504 CAPEC-151 CAPEC-654	-	-	-
	Средства защиты информации	CAPEC-698	-	CAPEC-504 CAPEC-194	CAPEC-194	-	-
	Морально-психологическая обстановка в обществе	-	CAPEC-89	CAPEC-173	-	CAPEC-410	CAPEC-98 CAPEC-163 CAPEC-164 CAPEC-656
	Информация	-	-	CAPEC-504 CAPEC-194	CAPEC-194	CAPEC-410	-
	Машинные носители	CAPEC-698	-	-	-	-	-

Продолжение таблицы 39

Направление	Объект воздействия/класс шаблона	Обманное метадезинформирование	Десимуляционное дезинформирование	Симуляционное дезинформирование	Кажущееся псевдо-информирование	Обобщенное псевдоинформирование	Избыточное целенаправленное псевдоинформирование
	Авторизованные и неавторизованные пользователи системы	-	CAPEC-630 CAPEC-631	CAPEC-151 CAPEC-504 CAPEC-654	-	CAPEC-630 CAPEC-631	-
	Операционная система (ПАК)	CAPEC-698	CAPEC-89	CAPEC-173 CAPEC-654 CAPEC-504	-	-	-
	Механизмы аутентификации	-	CAPEC-89	CAPEC-194 CAPEC-654 CAPEC-151	CAPEC-194	-	-
	Телекоммуникационное оборудование	-	CAPEC-89 CAPEC-630 CAPEC-631	-	-	CAPEC-630 CAPEC-631	CAPEC-98 CAPEC-164
	Обеспечивающие системы	CAPEC-698	-	CAPEC-194 CAPEC-173	CAPEC-194	CAPEC-410	-
	Средства защиты	CAPEC-698	-	CAPEC-173 CAPEC-504 CAPEC-194	CAPEC-194	-	-
	Коммуникационное оборудование (сетевое)	-	CAPEC-89	CAPEC-194 CAPEC-173	CAPEC-194	-	-

Таким образом результатами подраздела стаи:

- расширенный социальными уязвимостями поколений список уязвимостей;

- мини-приложение, отражающее зависимость вероятности реализации атаки от уровня влияния на социально-психологические объекты воздействия;

-сформированные социальные и технические объекты воздействия, исходя из описания (включающего критичности) соответствующих уязвимостей.

3.2 Частные регламенты выявления и регистрации возникающих при эксплуатации техник и уязвимостей инцидентов нарушения безопасности для атак класса “Социальная инженерия”

Регламенты обеспечения информационной безопасности занимают середину в трехуровневой иерархической модели документов по защите организации. На втором уровне, находятся организационно-правовые аспекты, определяющие требования и рекомендации по применению процедур по обеспечению ИБ [69];

В большинстве своем регламенты направлены на повышение уровня информационной безопасности в среде. Это наводит на мысль о том, что адекватно составить регламенты возможно, обратившись к сформированному ранее в таблице 39 перечню объектов воздействия (объектов, которые необходимо защищать).

В данной работе делается фокус на формирование сценариев с вероятностным учетом именно из сформированного перечня техник Mitre&attack. Упор при формировании списка возможных объектов воздействия делался на уже знакомую схему с распределением шаблонов CAPEC по классам в связке с используемыми техниками (рисунки 9 - 11), однако в таблице 39 было проведено сопоставление объекта воздействия, шаблона (с помощью которого воздействуют на заданный объект) и сразу же – определение текущего шаблона к определенному классу воздействия. Далее в таблицах 40, 41 это позволит сформировать конкретные регламенты по обнаружению и регистрации атак класса “Социальная инженерия”, с учетом технических и социальных аспектов.

В таблице 1 приведено порядка 60-ти уникальных техник, используемых на различных этапах в контексте атаки “Социальная инженерия”. Далее весь перечень используемых техник был распределен по соответствующим отобранным шаблонам CAPEC, подходящим под определение “Социальная инженерия”. Таким образом, представляется возможным охватить все техники, а далее рассмотрев сценарии, найти “узкие” места и более детально закрыть их для каждого шаблона CAPEC.

Очевидно, что реализация атаки не может осуществляться без признаков, свидетельствующих о ней. В 2019 году Национальный координационный центр по компьютерным инцидентам опубликовал состав параметров инцидентов ИБ, которые необходимо указывать, когда происходит информирование ГосСОПКА (Государственная система обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации). Если резюмировать всю полезную в контексте настоящей работы информацию, то можно наглядно представить, что такое инцидент безопасности (рисунок 30) [76].

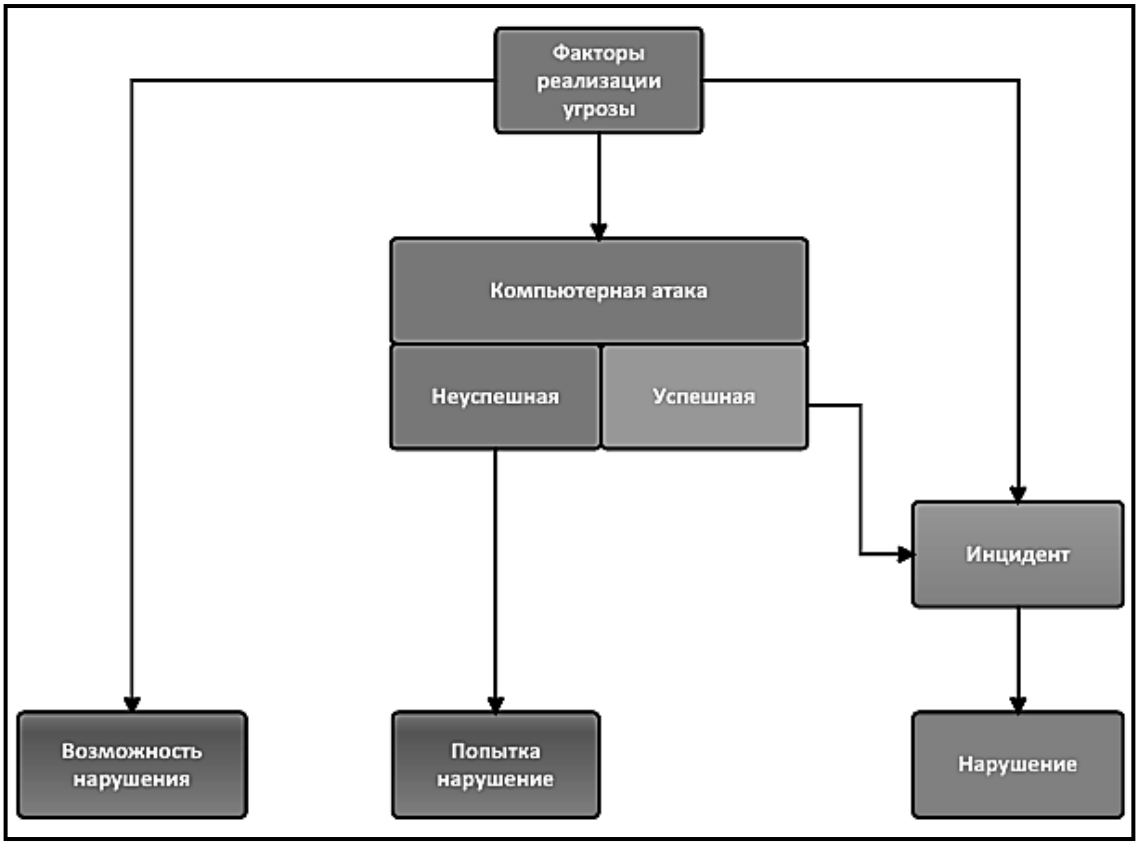


Рисунок 30 – Факторы реализации угрозы

Как видно из данной схемы – инцидент занимает место между началом реализации атаки и конечным этапом (непредотвращенным нарушением). Следовательно, можно сформировать группы из перечная текущих техник по инцидентам безопасности и для каждого инцидента в зависимости от вызывающих его техник сформировать

рекомендации по обнаружению и регистрации, подобная концепция приведена в таблице 40.

Таблица 40 – Средства и меры обнаружения для инцидентов безопасности, связанных с реализацией атак класса “Социальная инженерия”

Инцидент	Техники	Меры для обнаружения (по поколениям)	Меры для обнаружения (технические)
Фишинг и сбор информации	T1598 T1589 T1593 T1591 T1592 T1114 T1534 T1566	1) Проведение тренингов по цифровой грамотности для молодых поколений (A-поколение). 2) Создание общественных программ по информированию о фишинговых атаках через СМИ и социальные сети (Z-поколение). 3) Организация "горячих линий" для консультаций по подозрительным сообщениям (Y, X, B - поколения). 4) Развитие волонтерских сетей для помощи уязвимым группам населения (X, B - поколения).	1) Детальный анализ писем (DMARC, SPF, DKIM). 2) Мониторинг запросов к данным с сопутствующим аудитом. 3) Выявление аномалий в поведении пользователей (SIEM-системы). 4) Ручной или автоматизированный анализ логов на предмет сканирования. 5) Проведение тестовых фишинговых кампаний.
Компрометация учетных записей	T1585 T1136 T1586 T1078 T1098 T1087 T1550	1) Обучение молодых пользователей основам создания и защиты паролей (A - поколение). 2) Проведение мастер-классов по безопасному использованию учетных записей (Z - поколение). 3) Создание общественных советов по кибербезопасности на местном уровне (Y, X, B - поколения). 4) Внедрение программ инструктирования для старших поколений (B - поколение).	1) Анализ журнала входов и фиксация странного поведения пользователя. 2) Ручной или автоматизированный сбор данных о запросах к Active Directory внутри домена. 3) Мониторинг политики домена и списка учетных записей.
Кража учетных данных и токенов	T1528 T1649 T1558 T1056 T1606	1) Объяснение молодому поколению рисков и механизмов кражи данных учетных записей (A-поколение). 2) Организация общественных дискуссий о важности защиты УД и токенов (Z - поколение).	1) Анализ контекста использования токенов (наиболее эффективно OAuth). 2) Мониторинг использования билетов. 3) Анализ логов аутентификации.

Инцидент	Техники	Меры для обнаружения (по поколениям)	Меры для обнаружения (технические)
		3) Создание локальных групп взаимопомощи для выявления мошенничества (Y, X, B - поколения). 4) Популяризация программ по повышению осведомленности и наставничества в обеспечения кибербезопасности (X, B - поколения).	
Внедрение вредоносного кода	T1189 T1204 T1569 T1059 T1053 T1176 T1546 T1105	5) Обучение детей и подростков распознаванию подозрительных ссылок и вложений (A - поколение). 6) Популяризация среди школьников и студентов обучения по основам кибергигиены (Z-по). 7) Создание общественных центров по борьбе с вредоносным ПО (Y, X, B - поколения). 8) Развитие программ поддержки для пожилых пользователей (X, B - поколения).	1) Внедрение и использование систем выявления вредоносных процессов (EDR/XDR). 2) Анализ поведения приложений с сопутствующим аудитом. 3) Мониторинг и контроль планировщика задачи (Windows/Linux - системы).
Эскалация привилегий	T1068 T1548 T1556 T1656	1) Формирование у молодого поколения понимания механизмов разграничения доступа (A, Z - поколения). 2) Проведение тренингов по социальной инженерии в рамках обучения (A, Z - поколения). 3) Создание групповых (корпоративных) каналов обмена информацией об инцидентах с привилегиями (Z, Y, X -поколения). 4) Развитие программ по защите прав уязвимых групп на рабочих местах (X, B - поколения).	1) Обнаружение попыток эксплуатации уязвимостей (IDS/IPS/COB UserGate). 2) Мониторинг доменной политики (списка прав пользователей). 3) Анализ логов (UserGate Log Analyzer или Digital Q.ELK).
Сбор и эксфильтрация данных	T1119 T1025 T1113 T1125 T1567	1) Формирование у детей и подростков отчетливого понимания о среде передачи данных или о канале утечки информации (A - поколение).	1) Внедрение и использование DLP систем для обнаружения утечек. 2) Интеграция NMS систем для обнаружения странных объемов передаваемого трафика и общего анализа сетевого

Инцидент	Техники	Меры для обнаружения (по поколениям)	Меры для обнаружения (технические)
	T1011 T1052 T1029 T1217 T1041	2) Организация учебных треннингов в группах в рамках обучения по предотвращению утечек данных (A, Z - поколения). 3) Создание добровольческих формирований по мониторингу утечек (Z, Y, X - поколения). 4) Создание волонтерских движений по защите пожилых людей от вторжений класса “Социальная инженерия” (B - поколение).	трафика (в РФ популярны AggreGate Network Manager, Супертел-NMS v3, NMS “ФРАКТАЛ”, SINEC NMS).
Сокрытие активности	T1564 T1070 T1221 T1665 T1102 T1095	5) Формирование у молодого поколения понимания термина “журналирование событий” (A, Z - поколения). 6) Популяризация семинаров по выявлению скрытых киберугроз (Z - поколение). 7) Создание общественных наблюдательных советов (Y, X, B - поколения). 8) Внедрение механизмов, повышающих уровень прозрачности социальных взаимодействий (X, B - поколения).	1) Бэкапинг логов и журналов и последующий их анализ на предмет удаления событий. 2) Анализ системы на предмет наличия скрытых руткитов (EDR/XDR). 3) Ручной или автоматизированный мониторинг изменений в системе и системных компонентах.
Разрушение данных и систем	T1486 T1561 T1495 T1485 T1565	1) Обучение молодого поколения основам резервного копирования (A - поколение). 2) Проведение общественных акций и учебных треннингов по защите важных инфраструктур среди школьников и студентов (A, Z - поколения). 3) Создание сообществ взаимопомощи при кибератаках (Y, X - поколения). 4) Внедрение социальных норм цифровой устойчивости (Y, X, B - поколения).	1) Интеграция инструментов Anti-Ransomware, используемых для обнаружения попыток нанесения вреда информации. 2) Интеграция DCAP-систем для автоматизированного аудита данных в файловой системе, поиска нарушений прав доступа и отслеживания изменений в критичных документах. 3) Специализированное обучение персонала. В случае уничтожения/повреждения/блокировки данных сотрудники должны незамедлительно сообщать об инцидентах

Продолжение таблицы 40

Инцидент	Техники	Меры для обнаружения (по поколениям)	Меры для обнаружения (технические)
Злоупотребление доверительными отношениями	T1199 T1584 T1219	1) Повсеместное внедрение курсов информационно-психологической подготовки для детей и подростков для распознавания простейших психологических манипуляций и злоупотребления доверием (A, Z - поколения). 2) Проведение треннингов по безопасному сотрудничеству (Z, X, Y - поколения). 3) Развитие программ защиты старших поколений от психологической манипуляции и обманов (X, B - поколения). 4) Разработка и внедрение социальных стандартов доверия в цифровой среде для всех поколений (все поколения).	1) Анализ и контроль сеансов удаленного доступа, осуществляемых через такие протоколы как VPN/RDP. 2) Специализированное обучение персонала. 3) Требование от сотрудников сообщать о подозрительных контактах с коллегами.
Разведка внутренней среды	T1518 T1016 T1083 T1046 T1614 T1033 T1069 T1120	5) Внедрение в программу обучения школьников и студентов основ информационной безопасности вне зависимости от профиля обучения или специальности (A, Z - поколения). 6) Популяризация треннингов по противодействию корпоративной разведке, реализуемых в формате игры, квеста, квиза, корпоратива, и других неформальных активностей (Z, Y - поколения). 7) Разработка и внедрение общественных программ по защите от шпионажа (X, B - поколения). 8) Развитие национальных инициатив для повышения уровня социо-информационного пространства (X, B - поколения). 9) Популяризация культуры бдительности и этики в обществе, для обнаружения и дальнейшего предотвращения разведывательных действий злоумышленников (Z, Y, X, B - поколения).	4) Интеграция систем для обнаружения сканирования сети NIDS/IPS. 5) Ручной или автоматизированный мониторинг запросов к системным компонентам и данным. 6) Анализ попыток авторизации и выявление брутфорса по логам и журналам входа. 7) Специализированное обучение персонала. 8) Требование от сотрудников незамедлительно сообщать о подозрительных моментах во время работы.

При составлении таблицы активно учитывались анализировались следующие ресурсы: [13,74, 77-87].

Далее более подробно стоит углубиться в сформированные перечни сценариев по каждому шаблону (CAPEC) реализации атак класса “Социальная инженерия”. Всё дело в том, что у каждого множества сценариев существуют “узкие места”. В контексте множества сценариев – это ситуация, в которой все сценарии сводятся к одному месту. В этом месте достигается наименьшая вариативность для злоумышленника; следовательно, целесообразнее не устранять все уязвимости (не предусматривать все техники), а обратить внимание лишь на этот промежуток, чтобы не дать атаке завершиться. За такие места будут считаться тактики, в которых наименьшее количество техник в рамках множества сценариев для каждого шаблона.

Перечисляя шаблоны в том же порядке, что и в таблицах 22–35, стоит начать с шаблона CAPEC-98. В рассматриваемом шаблоне в тактике “Боковое смещение” присутствует одна техника – T1534, закрыв которую можно прервать атаку. Техника содержит 3 уязвимости: CVE-2023-5561, CVE-2021-44168, CVE-2023-36874. Чтобы обнаружить CVE-2023-5561, достаточно проводить детальный анализ HTTP-трафика и контролировать уровень роста запросов с течением времени. Для обнаружения CVE-2021-44168 будет актуально использовать мониторинг журналов FortiOS, а также интегрировать средства, контролирующие нестандартные TLS-соединения. Для обнаружения факта наличия процессов, связанных с повышением привилегий, можно анализировать журналы на предмет наличия событий Event ID 4688.

Для шаблона CAPEC-163 “узким местом” будет второй этап реализации – “Подготовка ресурсов”. В технике T1586 присутствует две уязвимости: CVE-2019-14287 и CVE-2022-26925. Для обнаружения CVE-2019-14287 достаточно настроить систему мониторинга подозрительных команд с меткой sudo, а для уязвимости CVE-2022-26925 – можно проверять конфигурации NTLM в ручном или автоматическом режиме или включить автоматический датчик использования NTLM на контроллере. Также стоит мониторить систему на наличие подозрительных вызовов LSARPC.

Для шаблона CAPEC-164 имеется сразу 3 места, где злоумышленник может использовать только одну технику: T1204 – в рамках исполнения, T1656 – в рамках предотвращения обнаружения, T1534 – в рамках бокового смещения. В таком случае, чтобы не терять в рациональности, необходимо рассматривать ту технику, которая реализуется на более ранних этапах атаки, так как если атаку прервать, то далее уже не важно количество техник на различных этапах. Поэтому представляется верным рассмотреть T1204. В рамках техники присутствует 3 уязвимости: CVE-2021-21132, CVE-2021-30657, CVE-2021-44168. CVE-2021-44168 уже была описана ранее в шаблоне CAPEC-98. Есть смысл углубиться в меры по обнаружению для уязвимостей CVE-2021-21132 и CVE-2021-30657. CVE-2021-21132 обнаруживается достаточно просто: для этого достаточно вести ручной или автоматизированный мониторинг расширений, а также интегрировать системы IDS для выявления аномального поведения. CVE-2021-30657 – уязвимость в macOS, которая сама по себе имеет достаточно жесткий и фиксированный функционал безопасности; тем не менее, с помощью базовых настроек можно включить контроль и ограничение запуска скриптов.

Для CAPEC-656 имеется 4 места, которые интересны с точки зрения обеспечения информационной безопасности; однако для рассмотрения возьмем ближайший к началу атаки этап – “Исполнение” и технику – T1204. Данная техника имеет 4 уязвимости: CVE-2021-21132, CVE-2021-30657, CVE-2021-44168, CVE-2019-1563. CVE-2019-1563 предполагает использование уязвимости в OpenSSL, поэтому для контроля достаточно мониторить использование приложениями закрытых RSA-ключей для функций CMS_decrypt или PKCS7_decrypt. Меры по обнаружению для CVE-2021-21132, CVE-2021-30657, CVE-2021-44168 уже описывались ранее по тексту (CAPEC-98 – CAPEC-164). Стоит уточнить, что повторяющиеся уязвимости в рамках текущих шаблонов – нормальное явление, поскольку все 4 шаблона – это фишинговые атаки с некоторыми различиями в способах реализации.

Для CAPEC-630 ближайший к началу предотвратимый этап – “Подготовка ресурсов”, и техника – T1584. В рамках техники имеется 3 уязвимости: CVE-2022-40684, CVE-2017-0057, CVE-2023-38497. Для CVE-2023-38497, связанной с маски-

ровкой выполняемого кода, – достаточно настроить систему, защищающую от вредоносных программ и скриптов. CVE-2017-0057 – мониторить запросы и действий, связанные с DNS, а для CVE-2022-40684 – настроить локальные политики доступа для контроля административного интерфейса, а также мониторить логи (ручной или автоматизированный) на предмет записей, свидетельствующих о попытках атаки (user=Local_Process_Access).

Для CAPEC-194 нужным к рассмотрению для рационального подрыва действий атакующего стал этап – “Первоначальный доступ”, и техника – T1566, которая содержит в себе 4 уязвимости: CVE-2021-21135, CVE-2020-10136, CVE-2019-0633, CVE-2017-7821. Для CVE-2021-21135 – установить систему контроля и ограничения исполняемых скриптов, так как уязвимость позволяет злоумышленнику получать данные с помощью подставной страницы. Для CVE-2020-10136 – достаточно настроить фильтрацию и фиксацию трафика, так как в данном случае злоумышленник выдает вредоносный трафик за нормальный, обманывая жертву. При реализации атаки через CVE-2019-0633 для обнаружения достаточно контролировать SMBv1 и SMBv2, а также настроить межсетевой экран. CVE-2017-7821 – контролировать установку расширений из различных источников, а также контролировать запускаемые и скачиваемые на устройстве программы и скрипты.

Для CAPEC-504 – ситуация схожа с CAPEC-630, однако в случае с данной атакой уязвимое для закрытия место лишь одно. Тактика – “Подготовка ресурсов”, техника – T1584. Теоретически используемые уязвимости: CVE-2018-13382, CVE-2022-26925, CVE-2021-26291, CVE-2020-0683. Однако уязвимости разные, хоть техника и одна. Это связано с тем, что в разных шаблонах реализации разные атаки подразумевают использование уязвимостей, отличных от уязвимостей в идентичной технике, но в другом шаблоне. Итак, CVE-2018-13382 – необходимо контролировать запросы ненадежных веб-порталов к SSL и VPN и мониторить логи на предмет аномалий. CVE-2022-26925 – описывалась в абзаце с CAPEC-163. Для CVE-2021-26291 (уязвимость с зависимостями) – достаточно использовать менеджеры репозиториев, что поз-

волит контролировать источники файлов. Для CVE-2020-0683 – достаточно установить систему контроля использования MSI-пакетов пользователями без административных прав.

Шаблон CAPEC-173 интересен тем, что атаку можно пресечь прямо на первом шаге, закрыв технику – T1592 в рамках тактики – “Разведка”. Настоящая техника имеет 3 уязвимости для перехода: CVE-2021-36942, CVE-2023-49084, CVE-2024-22017. Для CVE-2021-36942 – достаточно произвести грамотную настройку контроллера домена, чтобы контролировать его подключение ко всем серверам (уязвимость связана с подложным сервером). При реализации атаки через CVE-2023-49084 для обнаружения последней необходимо и достаточно сформировать перечень доверенных контролируемых лиц, имеющих доступ к интерфейсу cacti, и мониторить логи на предмет наличия подозрительной активности, связанной с link.php. Чтобы обнаружить CVE-2024-22017, достаточно проверять приложения на предмет использования последними setuid() и соответствующего управления привилегиями.

Для CAPEC-698 уязвимым местом будет – T1584 (“Подготовка ресурсов”), уникальной для нее уязвимостью служит CVE-2024-38143. Чтобы обнаружить попытки использования этой уязвимости, достаточно определить всех подозрительных лиц, имеющих физический доступ к машине, а также контролировать журнал безопасности на предмет наличия подозрительной активности (CVE-2018-13382 и CVE-2022-26925 упоминались ранее).

В случае с CAPEC-410, завершить атаку можно также, закрыв T1584 на этапе – “Подготовка ресурсов”. Уникальное сочетание этой техники именно с заданным шаблоном дает возможность злоумышленнику использовать 3 уникальные уязвимости: CVE-2023-35325, CVE-2017-0022, CVE-2016-2106. Чтобы обнаружить атаку, реализуемую посредством CVE-2023-35325, достаточно контролировать доступ сотрудников к службе Print Spooler и мониторить систему на предмет аномалий в сети печатающих устройств. Далее, CVE-2017-0022 – достаточно контролировать HTTP-трафик, так как атака может реализоваться только, если жертва зайдет на фишинговый сайт. Для CVE-2016-2106 – достаточно контролировать все операции с криптографическими систе-

мами и особенно сильно обращать внимание на зависимости, использующие уязвимые версии OpenSSL (CVE-2018-13382 и CVE-2022-40684 упоминались ранее по тексту).

Далее рассмотрим CAPEC-631. Для предотвращения необходимо также рассмотреть тактику – “Подготовка ресурсов” и технику – T1584. В рамках техники совместно используется 3 уязвимости: CVE-2022-40684, CVE-2017-0057, CVE-2023-38497. Описание мер по их обнаружению приводилось ранее по тексту.

Далее по списку идет шаблон CAPEC-151. В текущем шаблоне ближайшее “узкое место” – это тактика “Исполнение” и техника – T1204. В технике злоумышленник может выбрать две уязвимости: CVE-2021-21132 или CVE-2019-1563, и они уже были описаны ранее.

Для CAPEC-89 и CAPEC-654 уязвимым местом в очередной раз стала тактика – “Подготовка ресурсов” с единственной, но уже знакомой техникой – T1584. Для данной техники уникальной является уязвимость CVE-2023-36851. Для ее обнаружения необходимо настроить средства мониторинга активности, связанной с использованием скрипта webauth_operation.php. Другие уязвимости уже упоминались и описывались ранее. Закрыв именно эти уязвимости, представляется возможным остановить или значительно затруднить атаку, при этом не потратив большого количества ресурсов [44–49, 93–98].

Если же говорить о наиболее вероятно используемых уязвимостях в контексте единичных атак, то для представления мер по их обнаружению будет удобно построить таблицу 41. Сразу стоит отметить, что далее такие матрицы будут строиться и для других регламентов противодействия.

Таблица 41 – Меры по обнаружению уязвимостей с наибольшим значением вероятности.

Тактика	Техника	CVE	Меры по обнаружению
CAPEC-98			
Разведка	(T1589)	CVE-2018-15473	Анализ логов SSH на предмет разного времени ответа при входе.

Продолжение таблицы 41

Тактика	Тех-ника	CVE	Меры по обнаружению
Подготовка ресурсов	(T1586)	CVE-2020-1054	Использование средств мониторинга для выявления аномалий в Win32k.sys.
Первоначальный доступ	(T1189)	CVE-2021-26291	Проверка POM файлов на наличие ссылок на небезопасные HTTP-репозитории.
Исполнение	(T1053)	CVE-2024-20666	Анализ событий безопасности на предмет попыток обхода BitLocker через Windows Recovery Environment.
Закрепление	(T1053)	CVE-2022-26925	Отслеживание аномальных запросов к службе LSA.
Повышение привилегий	(T1548)	CVE-2020-1054	Мониторинг системных журналов на предмет аномальных действий, связанных с драйвером Win32k.sys.
Предотвращение обнаружения	(T1070)	CVE-2021-3197	Анализ логов Salt API на наличие нестандартных параметров SSH.
Получение учетных данных	(T1606)	CVE-2023-5561	Мониторинг обращений к REST API WordPress.
Обнаружение	(T1033)	CVE-2018-14847	Анализ логов доступа к интерфейсу WinBox на предмет попыток несанкционированного чтения или записи файлов.
Боковое смещение	(T1534)	CVE-2023-36874	Отслеживание создания и использования символических ссылок в каталогах, связанных с Windows Error Reporting.
Сбор данных	(T1217)	CVE-2019-17563	Проверка логов аутентификации Apache Tomcat на предмет аномальных сессий.
Командование и управление	(T1102)	CVE-2022-26925	Отслеживание аномальных запросов к службе LSA.
Эксфильтрация	(T1567)	CVE-2022-26925	Отслеживание аномальных запросов к службе LSA
Удар	(T1561)	CVE-2016-0046	Использование средств анализа сетевого трафика.
CAPEC-163			
Разведка	(T1598)	CVE-2019-9787	Анализ логов WordPress на наличие вредоносных комментариев.
Подготовка ресурсов	(T1586)	CVE-2019-14287	Мониторинг использования команды sudo с UID -1.
Первоначальный доступ	(T1189)	CVE-2019-0633	Анализ сетевого трафика SMBv2 на предмет подозрительных запросов.
Исполнение	(T1053)	CVE-2020-1054	Мониторинг системных журналов на предмет аномалий Win32k.sys.
Закрепление	(T1053)	CVE-2020-1054	Мониторинг системных журналов на предмет аномалий Win32k.sys.

Продолжение таблицы 41

Тактика	Техника	CVE	Меры по обнаружению
Повышение привилегий	(T1068)	CVE-2021-3197	Анализ логов Salt API на наличие нестандартных параметров SSH
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Отслеживание использования переменных окружения SUDO_EDITOR, VISUAL.
Получение учетных данных	(T1528)	CVE-2023-49084	Анализ логов Cacti на предмет SQL-инъекций и подозрительных включений файлов.
Обнаружение	(T1558)	CVE-2019-0633	Анализ сетевого трафика SMBv2 на предмет подозрительных запросов.
Боковое смещение	(T1534)	CVE-2019-9787	Анализ логов WordPress на наличие вредоносных комментариев.
Сбор данных	(T1025)	CVE-2022-44268	Проверка PNG-изображений на наличие встроенных данных, указывающих на попытки чтения произвольных файлов.
Командование и управление	(T1095)	CVE-2011-3544	Мониторинг использования устаревших версий Java и аномалий в поведении Java-приложений.
Эксфильтрация	(T1567)	CVE-2019-12643	Анализ логов Cisco IOS XE на предмет неаутентифицированных запросов к REST API
Удар	(T1486)	CVE-2023-37266	Отслеживание подозрительных JWT-токенов.
CAPEC-164			
Разведка	(T1592)	CVE-2022-30295	Анализ сетевого трафика на предмет предсказуемых идентификаторов транзакций DNS.
Подготовка ресурсов	(T1586)	CVE-2020-0683	Мониторинг системных журналов на предмет создания или использования символических ссылок в процессе установки MSI-пакетов.
Первоначальный доступ	(T1199)	CVE-2022-40684	Анализ логов Fortinet на предмет неаутентифицированных запросов к административному интерфейсу.
Исполнение	(T1204)	CVE-2021-21132	Проверка расширений Chrome на наличие подозрительных действий.
Закрепление	(T1078)	CVE-2022-26925	Отслеживание аномальных запросов к службе LSA.
Повышение привилегий	(T1098)	CVE-2019-14287	Мониторинг использования команды sudo с UID -1
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Отслеживание использования переменных окружения SUDO_EDITOR, VISUAL.
Получение учетных данных	(T1606)	CVE-2022-40684	Анализ логов Fortinet на предмет неаутентифицированных запросов к административному интерфейсу.
Обнаружение	(T1614)	CVE-2023-35325	Мониторинг системных журналов на предмет аномальных действий.

Продолжение таблицы 41

Тактика	Техника	CVE	Меры по обнаружению
Боковое смещение	(T1534)	CVE-2019-9787	Анализ логов WordPress на наличие вредоносных комментариев.
Сбор данных	(T1056)	CVE-2021-28169	Проверка логов Jetty на подозрительные запросы к ConcatServlet.
Командование и управление	(T1102)	CVE-2019-12643	Анализ логов Cisco IOS XE на предмет неаутентифицированных запросов к REST API.
Эксфильтрация	(T1011)	CVE-2022-40684	Анализ логов Fortinet на предмет неаутентифицированных запросов к административному интерфейсу
Удар	(T1485)	CVE-2014-3153	Мониторинг системных журналов на предмет использования функции futex_requeue.
CAPEC-656			
Разведка	(T1589)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Подготовка ресурсов	(T1586)	CVE-2021-26291	Проверка POM-файлов Maven на наличие ссылок на небезопасные репозитории.
Первоначальный доступ	(T1199)	CVE-2022-40684	Анализ логов Fortinet на неаутентифицированные REST API-запросы к административному интерфейсу.
Исполнение	(T1204)	CVE-2021-44168	Мониторинг использования команды execute restore srcvis в FortiOS для выявления загрузки неподписанных пакетов.
Закрепление	(T1136)	CVE-2019-14287	Отслеживание использования команды sudo с UID -1.
Повышение привилегий	(T1098)	CVE-2023-49084	Анализ логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Отслеживание использования переменных окружения SUDO_EDITOR, VISUAL.
Получение учетных данных	(T1649)	CVE-2022-40684	Анализ логов Fortinet на неаутентифицированные REST API-запросы к административному интерфейсу.
Обнаружение	(T1614)	CVE-2022-30295	Проверка сетевого трафика на предсказуемые идентификаторы транзакций DNS.
Боковое смещение	(T1550)	CVE-2022-40684	Анализ логов Fortinet на неаутентифицированные REST API-запросы к административному интерфейсу.

Продолжение таблицы 41

Тактика	Техника	CVE	Меры по обнаружению
Сбор данных	(T1125)	CVE-2021-30682	Мониторинг приложений Apple на попытки утечки чувствительной информации через человеческие уязвимости.
Командование и управление	(T1105)	CVE-2018-13382	Анализ логов Fortinet SSL VPN на неаутентифицированные запросы изменения пароля через HTTP.
Эксфильтрация	(T1029)	CVE-2020-1054	Мониторинг системных журналов на аномалии, связанные с Win32k.sys.
Удар	(T1565)	CVE-2021-25281	Анализ логов Salt API на выполнение команд wheel_async без соответствующих eAuth-учетных данных.
CAPEC-630			
Разведка	(T1592)	CVE-2022-23614	Анализ логов Twig на использование фильтра sort с неподходящими функциями.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Анализ логов Fortinet на неаутентифицированные REST API-запросы к административному интерфейсу.
Первоначальный доступ	(T1566)	CVE-2019-9787	Мониторинг комментариев WordPress на XSS-контент.
Исполнение	(T1204)	CVE-2021-21132	Проверка расширений Chrome на наличие подозрительных действий.
Закрепление	(T1176)	CVE-2020-1054	Отслеживание аномалий в работе драйвера Win32k.sys.
Повышение привилегий	(T1068)	CVE-2019-14287	Мониторинг использования sudo с UID -1.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Проверка системных журналов на аномалии в работе Win32k.
Получение учетных данных	(T1649)	CVE-2022-40684	Анализ логов Fortinet на неаутентифицированные REST API-запросы к административному интерфейсу.
Обнаружение	(T1069)	CVE-2019-14287	Мониторинг использования sudo с UID -1.
Боковое смещение	(T1534)	CVE-2019-9787	Мониторинг комментариев WordPress на XSS-контент.
Сбор данных	(T1114)	CVE-2018-13382	Анализ логов Fortinet SSL VPN на неаутентифицированные запросы.
Командование и управление	(T1102)	CVE-2019-12643	Проверка логов Cisco IOS XE на неаутентифицированные REST API-запросы.

Продолжение таблицы 41

Тактика	Техника	CVE	Меры по обнаружению
Эксфильтрация	(1041)	CVE-2022-44268	Анализ PNG-файлов на наличие встроенного содержимого файлов.
Удар	(T1485)	CVE-2021-22204	Проверка загружаемых изображений на наличие вредоносных DjVu-файлов.
CAPEC-194			
Разведка	(T1598)	CVE-2019-9787	Анализ логов WordPress на XSS в комментариях.
Подготовка ресурсов	(T1585)	CVE-2019-14287	Мониторинг использования sudo с UID -1.
Первоначальный доступ	(T1566)	CVE-2017-7821	Проверка логов Firefox на аномальные действия с IFRAME.
Исполнение	(T1204)	CVE-2021-21132	Проверка расширений Chrome на наличие подозрительных действий.
Закрепление	(T1136)	CVE-2023-30861	Мониторинг логов Exim на подозрительные команды.
Повышение привилегий	(T1078)	CVE-2019-14287	Мониторинг использования sudo с UID -1.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Проверка системных журналов на аномалии в работе Win32k.
Получение учетных данных	(T1556)	CVE-2023-3676	Анализ логов Linux на аномальные действия с файловой системой.
Обнаружение	(T1217)	CVE-2024-29988	Мониторинг логов OpenSSH на необычные команды.
Боковое смещение	(T1534)	CVE-2024-38143	Проверка логов на попытки обхода аутентификации.
Сбор данных	(T1114)	CVE-2018-13382	Анализ логов Fortinet SSL VPN на неаутентифицированные запросы.
Командование и управление	(T1102)	CVE-2023-49084	Анализ логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Эксфильтрация	(T1029)	CVE-2020-1054	Мониторинг системных журналов на аномалии, связанные с драйвером Win32k.sys.
Удар	(T1485)	CVE-2021-22204	Проверка загружаемых изображений на наличие вредоносных DjVu-файлов.
CAPEC-504			
Разведка	(T1589)	CVE-2021-3197	Анализ логов Salt API на команды с ProxyCommand или ssh_options.
Подготовка ресурсов	(T1584)	CVE-2022-26925	Мониторинг логов LSA на NTLM-аутентификацию от неизвестных источников.
Первоначальный доступ	(T1199)	CVE-2019-1322	Проверка системных журналов на изменения в службах.

Продолжение таблицы 41

Тактика	Тех-ника	CVE	Меры по обнаружению
Исполнение	(T1204)	CVE-2019-14287	Анализ использования sudo с UID -1.
Закрепление	(T1053)	CVE-2023-49084	Мониторинг логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Повышение привилегий	(T1546)	CVE-2023-36874	Проверка логов Windows на аномалии в службе отчётов об ошибках (WER).
Предотвращение обнаружения	(T1564)	CVE-2022-40684	Анализ логов Fortinet на неаутентифицированные REST API-запросы.
Получение учетных данных	(T1556)	CVE-2019-3978	Мониторинг трафика на порт 8291 для выявления несанкционированных DNS-запросов.
Обнаружение	(T1016)	CVE-2016-0046	Проверка логов IIS на аномальные HTTP-запросы, связанные с обработкой MIME.
Боковое смещение	x	x	x
Сбор данных	(T1025)	CVE-2020-10136	Анализ сетевого трафика на IP-in-IP пакеты без проверки источника.
Командование и управление	(T1105)	CVE-2021-26291	Проверка Maven на использование небезопасных внешних репозиториев.
Эксфильтрация	(1041)	CVE-2019-0804	Мониторинг создания swap-файлов Azure WaLinuxAgent на ресурсных дисках.
Удар	(T1565)	CVE-2019-14287	Анализ использования sudo с UID -1
CAPEC-173			
Разведка	(T1592)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Подготовка ресурсов	(T1584)	CVE-2022-26925	Мониторинг логов LSA на NTLM-аутентификацию.
Первоначальный доступ	(T1189)	CVE-2023-6208	Проверка логов Firefox на утечку данных через первичный буфер обмена.
Исполнение	(T1059)	CVE-2019-14287	Анализ использования sudo с UID -1.
Закрепление	(T1053)	CVE-2024-38476	Мониторинг логов Apache на подозрительные заголовки ответов от бэкенда.
Повышение привилегий	(T1546)	CVE-2019-1405	Проверка системных журналов на аномалии в работе службы UPnP.
Предотвращение обнаружения	(T1221)	CVE-2019-0633	Анализ логов SMBv2 на необычные или некорректные запросы.
Получение учетных данных	(T1556)	CVE-2020-0836	Мониторинг логов DNS-сервера на аномальные или некорректные запросы.

Тактика	Техника	CVE	Меры по обнаружению
Обнаружение	(T1518)	CVE-2024-29988	Проверка логов SmartScreen на попытки обхода предупреждений о безопасности.
Боковое смещение	x	x	x
Сбор данных	(T1056)	CVE-2023-36874	Анализ логов Windows Error Reporting на аномальные действия.
Командование и управление	(T1105)	CVE-2019-0633	Анализ логов SMBv2 на необычные или некорректные запросы.
Эксфильтрация	(1041)	CVE-2020-0836	Мониторинг логов DNS-сервера на аномальные или некорректные запросы.
Удар	(T1565)	CVE-2024-29988	Проверка логов SmartScreen на попытки обхода предупреждений о безопасности.
CAPEC-698			
Разведка	(T1598)	CVE-2023-3676	Анализ логов Kubernetes и PowerShell на подозрительные команды в Windows-подах.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Проверка логов Fortinet SSL VPN на неаутентифицированные запросы.
Первоначальный доступ	(T1189)	CVE-2020-1054	Мониторинг системных журналов на аномальные действия с объектами памяти в ядре Windows.
Исполнение	(T1059)	CVE-2019-14287	Анализ использования sudo с UID -1 или 4294967295 для обхода ограничений.
Закрепление	(T1176)	CVE-2023-36874	Проверка логов Windows Error Reporting на аномальные действия и попытки повышения привилегий.
Повышение привилегий	(T1546)	CVE-2019-0633	Мониторинг логов SMBv2 на необычные или некорректные запросы.
Предотвращение обнаружения	(T1564)	CVE-2023-22809	Анализ использования sudoedit с переменными окружения, содержащими дополнительные аргументы.
Получение учетных данных	(T1649)	CVE-2023-36851	Проверка логов Juniper J-Web на неаутентифицированные запросы к webauth_operation.php.
Обнаружение	(T1217)	CVE-2021-21134	Анализ логов браузера на попытки подмены UI безопасности через специально созданные HTML-страницы.
Боковое смещение	(T1534)	CVE-2023-3676	Анализ логов Kubernetes и PowerShell на подозрительные команды в Windows-подах.
Сбор данных	(T1056)	CVE-2020-1054	Мониторинг системных журналов на аномальные действия с объектами памяти в ядре Windows.

Продолжение таблицы 41

Тактика	Тех-ника	CVE	Меры по обнаружению
Командование и управление	(T1105)	CVE-2019-14287	Анализ использования sudo с UID -1.
Эксфильтрация	(T1011)	CVE-2023-49084	Проверка логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Удар	(T1565)	CVE-2023-30861	Анализ логов Flask-приложений на кэшированные ответы, содержащие данные других пользователей.
CAPEC-410			
Разведка	(T1589)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Проверка логов Fortinet на неаутентифицированные изменения конфигурации через REST API.
Первоначальный доступ	(T1189)	CVE-2019-12086	Анализ логов приложений на неожиданные JSON-запросы.
Исполнение	(T1204)	CVE-2020-1054	Мониторинг системных журналов на аномальные действия с объектами памяти в ядре Windows.
Закрепление	(T1078)	CVE-2019-14287	Анализ использования sudo с UID -1.
Повышение привилегий	(T1098)	CVE-2023-30861	Проверка логов Flask-приложений на кэшированные ответы.
Предотвращение обнаружения	(T1070)	CVE-2021-25281	Анализ логов SaltStack на неаутентифицированные вызовы wheel_async без eAuth.
Получение учетных данных	(T1134)	CVE-2023-49084	Проверка логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Обнаружение	(T1217)	CVE-2019-12643	Анализ логов Cisco IOS XE на неаутентифицированные запросы к REST API, указывающие на возможную эксплуатацию.
Боковое смещение	x	x	x
Сбор данных	(T1119)	CVE-2021-30682	Проверка логов Safari и iOS на утечки чувствительной информации через логические ошибки.
Командование и управление	(T1095)	CVE-2011-3544	Анализ логов Java на загрузку и выполнение неподписанных апплетов.
Эксфильтрация	(T1011)	CVE-2023-35325	Проверка логов приложений на аномальные запросы.
Удар	(T1565)	CVE-2021-25281	Анализ логов SaltStack на неаутентифицированные вызовы wheel_async без eAuth.
CAPEC-631			
Разведка	(T1592)	CVE-2022-23614	Анализ логов Twig.

Тактика	Техника	CVE	Меры по обнаружению
Подготовка ресурсов	(T1584)	CVE-2022-40684	Проверка логов Fortinet на неаутентифицированные изменения конфигурации через REST API.
Первоначальный доступ	(T1566)	CVE-2019-9787	Анализ логов WordPress на подозрительные комментарии, содержащие вредоносные скрипты.
Исполнение	(T1204)	CVE-2021-21132	Проверка логов Chrome DevTools.
Закрепление	(T1176)	CVE-2019-1405	Анализ системных журналов Windows на подозрительные действия, связанные с UPnP-службой.
Повышение привилегий	(T1068)	CVE-2020-0683	Мониторинг логов Windows Installer на обработку символических ссылок в MSI-пакетах.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Проверка логов Win32k на аномальные действия с объектами памяти, указывающие на возможное повышение привилегий.
Получение учетных данных	(T1649)	CVE-2022-40684	Проверка логов Fortinet на неаутентифицированные изменения конфигурации через REST API.
Обнаружение	(T1069)	CVE-2019-14287	Анализ использования sudo с UID -1.
Боковое смещение	(T1534)	CVE-2019-9787	Анализ логов WordPress на подозрительные комментарии, содержащие вредоносные скрипты.
Сбор данных	(T1114)	CVE-2018-13382	Проверка логов Fortinet на неаутентифицированные изменения паролей SSL VPN-пользователей.
Командование и управление	(T1102)	CVE-2019-12643	Анализ логов Cisco IOS XE на неаутентифицированные запросы к REST API, указывающие на возможную эксплуатацию.
Эксфильтрация	(1041)	CVE-2022-44268	Проверка логов ImageMagick на обработку PNG-изображений, содержащих встроенные данные из произвольных файлов.
Удар	(T1485)	CVE-2021-22204	Анализ логов ExifTool на обработку DjVu-файлов, содержащих вредоносные данные.
CAPEC-151			
Разведка	(T1598)	CVE-2020-4046	Анализ логов WordPress на наличие XSS-скриптов.
Подготовка ресурсов	(T1585)	CVE-2019-14287	Проверка использования sudo с UID -1.
Первоначальный доступ	(T1199)	CVE-2022-26925	Мониторинг событий LSA и NTLM для выявления подделки аутентификации.
Исполнение	(T1204)	CVE-2021-21132	Анализ логов Chrome.
Закрепление	(T1136)	CVE-2024-38213	Проверка загрузок файлов с отсутствием метки безопасности (Mark of the Web).

Тактика	Тех-ника	CVE	Меры по обнаружению
Повышение привилегий	(T1078)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Анализ использования sudoedit с переменными окружения, указывающими на произвольные файлы.
Получение учетных данных	(T1649)	CVE-2022-40684	Проверка логов Fortinet на неаутентифицированные изменения конфигурации через REST API.
Обнаружение	(T1087)	CVE-2018-15473	Анализ логов SSH на различия в ответах при аутентификации с существующими и несуществующими именами пользователей.
Боковое смещение	(T1534)	CVE-2019-9787	Проверка комментариев WordPress на наличие вредоносных скриптов, указывающих на возможную XSS-атаку.
Сбор данных	(T1025)	CVE-2022-44268	Анализ логов ImageMagick на обработку PNG-изображений.
Командование и управление	(T1102)	CVE-2019-12643	Проверка логов Cisco IOS XE на неаутентифицированные запросы к REST API.
Эксфильтрация	(T1567)	CVE-2023-49084	Анализ логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Удар	(T1495)	CVE-2011-3544	Мониторинг загрузки и выполнения Java-апплетов с веб-сайтов, особенно при использовании устаревших версий Java.
CAPEC-89			
Разведка	(T1592)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Проверка логов FortiOS на неаутентифицированные изменения паролей через SSL VPN.
Первоначальный доступ	(T1199)	CVE-2023-3676	Анализ логов Kubernetes и PowerShell на команды с инъекциями.
Исполнение	(T1204)	CVE-2020-1054	Мониторинг системных логов на попытки повышения привилегий через Win32k.
Закрепление	x	x	
Повышение привилегий	(T1548)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.

Тактика	Техника	CVE	Меры по обнаружению
Предотвращение обнаружения	(T1221)	CVE-2023-49084	Анализ логов Cacti на SQL-инъекции и подозрительные включения файлов через
Получение учетных данных	(T1558)	CVE-2019-3978	Проверка логов RouterOS на неаутентифицированные DNS-запросы через порт 8291.
Обнаружение	(T1046)	CVE-2022-40684	Мониторинг логов Fortinet на неаутентифицированные изменения конфигурации через REST API.
Боковое смещение	(T1534)	CVE-2022-40684	Повторная проверка логов Fortinet на признаки эксплуатации уязвимости через REST API.
Сбор данных	(T1025)	CVE-2024-38476	Анализ логов Apache на подозрительные внутренние перенаправления и SSRF-атаки.
Командование и управление	(T1102)	CVE-2019-1405	Мониторинг системных логов на попытки повышения привилегий через COM-объекты в UPnP.
Эксфильтрация	(1041)	CVE-2024-38213	Проверка логов SmartScreen на обходы метки безопасности и выполнение неподписанных файлов.
Удар	(T1565)	CVE-2019-14287	Анализ логов sudo на использование UID -1
CAPEC-654			
Разведка	(T1592)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Проверка логов FortiOS на неаутентифицированные изменения паролей через SSL VPN.
Первоначальный доступ	(T1199)	CVE-2023-3676	Анализ логов Kubernetes и PowerShell на команды с инъекциями.
Исполнение	(T1204)	CVE-2020-1054	Мониторинг системных логов на попытки повышения привилегий через Win32k.
Закрепление	x	x	x
Повышение привилегий	(T1548)	CVE-2021-36942	Фильтрование RPC, включение подписания SMB, отключение или установка тип запуска службы EFS на отключённый.
Предотвращение обнаружения	(T1221)	CVE-2023-49084	Анализ логов Cacti на SQL-инъекции и подозрительные включения файлов через link.php.
Получение учетных данных	(T1558)	CVE-2019-3978	Проверка логов RouterOS на неаутентифицированные DNS-запросы через порт 8291.
Обнаружение	(T1046)	CVE-2022-40684	Мониторинг логов Fortinet на неаутентифицированные изменения конфигурации через REST API.

Продолжение таблицы 41

Тактика	Тех-ника	CVE	Меры по обнаружению
Боковое смещение	(T1534)	CVE-2022-40684	Повторная проверка логов Fortinet на признаки эксплуатации уязвимости через REST API.
Сбор данных	(T1025)	CVE-2024-38476	Анализ логов Apache на подозрительные внутренние перенаправления и SSRF-атаки.
Командование и управление	(T1102)	CVE-2019-1405	Мониторинг системных логов на попытки повышения привилегий через COM-объекты в UPnP.
Эксфильтрация	(1041)	CVE-2024-38213	Проверка логов SmartScreen на обходы метки безопасности и выполнение неподписанных файлов.
Удар	(T1565)	CVE-2019-14287	Анализ логов sudo на использование UID -1.

При составлении марийцы 27 использовались открытые ресурсы по базам CVE [44-49, 93-98].

Итогами подраздела стали: собранная статистика по социальной инженерии; матрица с техниками, подходящими под шаблоны реализации атак класса “социальная инженерия”; сформированный перечень социально-психологических уязвимостей для различных поколений; произведенный расчёт вероятности успешной атаки с учётом количества социальных уязвимостей; программная модель, визуализирующая зависимость вероятности атаки от влияния на уровень осведомлённости, массовое и индивидуальное сознание; сформированная матрица объектов воздействия; комплекс мер и средств для обнаружения и регистрации атак, сгруппированных по инцидентам безопасности.

3.3 Частные регламенты реагирования на возникающие при эксплуатации техник и уязвимостей инциденты нарушения безопасности для атак класса “Социальная инженерия”

Своевременная реакция крайне важна в реагировании на инциденты нарушения безопасности. Это позволяет предотвратить распространение инцидентов, сохранить репутацию, снизить финансовые потери, обеспечить качественную безопасность индивидуальных пользователей, клиентов, сотрудников и партнеров, защитить важные ресурсы до того, как эта задача станет неактуальной.

Чтобы обеспечить своевременное реагирование на происшествия необходимо заранее иметь план действия на случай реализации атаки класса “Социальная инженерия”. Это достигается путем формирования первоочередных мер предотвращения атаки, а также перечня негативных последствия от уникальных инцидентов безопасности. Такую таблицу представляется возможным составить, имея в распоряжении перечень используемых техник и используемых уязвимостей, теоретические объекты воздействия (включая социально-психологическую сторону), а также список инцидентов, возникающих в ходе реализации атаки. В результате получится таблица 42.

Таблица 42 – Технические меры первоочередного реагирования и негативные последствия для инцидентов безопасности

Инцидент безопасности	Меры первоочередного реагирования	Возможные негативные последствия
Фишинг и сбор информации	1)Немедленная блокировка фишинговых писем и ссылок. 2)Информирование сотрудников о фишинговой атаке. 3)Проверка систем на наличие компрометации. 4)Оповещение об инциденте соответствующих регуляторов.	1) Утечка конфиденциальной информации. 2) Потери из-за мошенничества. 3) Раскрытие или модификация информации. 4) Хищение интеллектуальной собственности.
Компрометация учетных записей	1)Отключение скомпрометированных учетных записей. 2)Сброс паролей и внедрение MFA.	1) Возможность несанкционированного доступа. 2) Кража данных.

Продолжение таблицы 42

Инцидент безопасности	Меры первоочередного реагирования	Возможные негативные последствия
	3) Анализ журналов доступа для выявления подозрительной активности. 4) Оповещение об инциденте соответствующих регуляторов.	3) Потери, связанные с учетной записью (доверие, репутация, права, сама учетная запись).
Кража учетных данных и токенов	1) Аннулирование затронутых токенов и сертификатов. 2) Внедрение дополнительных мер аутентификации. 3) Проведение аудита безопасности. 4) Оповещение об инциденте соответствующих регуляторов.	1) Раскрытие или модификация информации. 2) Хищение интеллектуальной собственности. 3) Нарушение учетности. 4) Несанкционированные транзакции. 5) Нарушение целостности.
Внедрение вредоносного кода	1) Изоляция зараженных систем. 2) Удаление вредоносного ПО. 3) Проверка всех систем на наличие аналогичных угроз. 4) Оповещение об инциденте соответствующих регуляторов.	1) Может вызывать отказ в обслуживании. 2) Контроль злоумышленника над системой (полный или частичный). 3) Возможность неконтролируемого бокового смещения
Эскалация привилегий	1) Реализация принципа minimal trust. 2) Мониторинг подозрительных действий. 3) Обучение сотрудников. 4) Оповещение об инциденте соответствующих регуляторов.	1) Попытки расширения привилегий. 2) Использование систем с нарушением политики безопасности. 3) Нарушение конфигурирования систем
Сбор и эксфильтрация данных	1) Блокировка каналов эксфильтрации. 2) Уведомление затронутых сторон. 3) Анализ потерь. 4) Оповещение об инциденте соответствующих регуляторов.	1) Нарушение закона о защите данных. 2) Репутационный ущерб. 3) Потери данных. 4) Финансовые потери.
Сокрытие активности	1) Анализ журналов для выявления скрытых действий. 2) Анализ ущерба 3) Усиление мер контроля. 4) Проверка систем предотвращения вторжений 5) Оповещение об инциденте соответствующих регуляторов.	1) Возможность длительного пребывания преступника в системе незамеченным. 2) Повышение сложности и стоимости расследования. 3) Риск столкнуться с бэкдорами.

Продолжение таблицы 42

Инцидент безопасности	Меры первоочередного реагирования	Возможные негативные последствия
Разрушение данных и систем	1) Восстановление данных из резервных копий. 2) Проведение расследования. 3) Оповещение об инциденте соответствующих регуляторов.	1) Нарушение защиты безопасности. 2) Нанесение ущерба аппаратуре. 3) Неправильное функционирование систем.
Злоупотребление доверительными отношениями	1) Проверка списка сотрудников и прав сотрудников в соответствии с политикой. 2) Блокировка всех подозрительных подключений. 3) Усиление аутентификации.	1) Попытки расширения привилегий. 2) Нарушения конфигурирования систем
Разведка внутренней среды	1) Блокировка запросов. 2) Мониторинг активности. 3) Проведение аудита безопасности. 4) Настройка периодической аутентификации (IEEE 802.1X). 5) Оповещение об инциденте соответствующих регуляторов.	1) Раскрытие или модификация информации. 2) Сканирование сервисов по диапазону. 3) Сканирование доступных портов. 4) Зондирование системы с целью идентификации.

В ходе формирования матрицы использовались ГОСТ Р ИСО/МЭК 59712-2022, ГОСТ Р ИСО/МЭК ТО 18044-2007, и матрица Mitre&Attack. Помимо перечисленного, для формирования негативных последствий использовалась составленная ранее таблица 39 с объектами воздействия вторжений класса “Социальная инженерия” [13,40, 89, 91].

Далее, опираясь на изученные особенности каждого поколения в предыдущем разделе, а также зная перечень объектов воздействия на информационно-психологическом уровне, необходимо также описать меры первоочередного реагирования при реализации атак на различные возрастные категории людей. Таблица 43 будет составлена отдельно для повышения уровня читаемости (в отличие от предыдущего раздела, где социальные и технические меры объединены) [74].

Таблица 43 – Меры первоочередного реагирования на инциденты безопасности для различных поколений

Инцидент	Техники	Меры первоочередного реагирования
Фишинг и сбор информации	T1598 T1589 T1593 T1591 T1592 T1114 T1534 T1566	1) Настройка автоматической блокировки подозрительных ресурсов в мессенджерах и социальных сетях; уведомление через образовательные учреждения; ограничение доступа к отдельным интернет-ресурсам (A, Z - поколения). 2) Реализация рассылок в мессенджерах и по SMS о новых схемах фишинга на уровне государства; автоматическая проверка вложений почты посредством DLP (Z, Y, X - поколения). 3) Реализация горячей линии для экстренных консультаций; ручная проверка фишинговых вложений; телефонные звонки от доверенных лиц в случае фиксации подозрительной активности; оффлайн-инструкции через соцработников (X, B - поколения).
Компрометация учетных записей	T1585 T1136 T1586 T1078 T1098 T1087 T1550	1) Принудительный и полный сброс паролей, осуществляемый через школьные и вузовские системы при обнаружении подозрительной активности (A, Z - поколения). 2) Реализация отзывов корпоративных доступов на уровне руководства; проверка активности всех облачных сервисов всех сотрудников (Z, Y, X - поколения). 3) Введение обязательств для родственников о помощи старшим поколения в вопросах замены паролей от аккаунтов, банковских карт и т.д. (B-поколения).
Кража учетных данных и токенов	T1528 T1649 T1558 T1056 T1606	1) Реализация в Российских социальных сетях автоматического отзыва OAuth-токенов без подтверждения в случае детектирования возраста менее 18-ле, если обнаружена подозрительная активность (A, Z - поколения); формирование понимания и базовое обучение работе с Authenticator-приложениями (A, Z - поколения). 2) Формирование групп поддержки оперативного реагирования (“Я стал жертвой – что делать?”), содержащий автоматизированные инструкции и чат с поддержкой; реализация корпоративных плакатов с QR-кодами на системы проверки подозрительных действий/ресурсов (Z, Y, X - поколения). 3) Настройка быстрого вызова ответственных лиц: родственников, сотрудников правоохранительных органов, сотрудников поддержки и оперативного реагирования; реализация алгоритмов-напоминаний (в виде физических мини-плакатов и т.д.) (B - поколение).

Продолжение таблицы 43

Инцидент	Техники	Меры первоочередного реагирования
Внедрение вредоносного кода	T1189 T1204 T1569 T1059 T1053 T1176 T1546 T1105	1) Автоматическое детектирование возраста пользователя, в случае если возраст менее 18-ти лет – автоматический сброс установленных расширений без подтверждения; реализация экспертиз устройств, пользователями которых являются дети; установка родительского контроля; проведение занятий в школах/вузах после появлений новых видов заражений вне зависимости от профиля или специальности (A, Z - поколения). 2) Проверка на уровне организации осознанности взаимодействия с компьютерной техникой с целью повышения уровня осведомлённости и понимания пользователей (Z, Y, X - поколения). 3) Формирование групп (волонтеры или специалисты), которые незамедлительно анализируют технику жертвы вторжения мошенников, и помогают с дальнейшими действиями; установка и настройка базовых средств защиты; формирование тарифных программ для пенсионеров от производителей для пожилых пользователей ПК (B - поколение).
Эскалация привилегий	T1068 T1548 T1556 T1656	1) Отзыв возможности администрирования всем лицам, кроме главного администратора в школах и других учебных заведениях; проведение занятий с школьниками и студентами, где будут объяснены базовые элементы разграничения доступа (sudoers, active directory); проверка администраторов систем (A, Z - поколения). 2) Проверка всех работающих в домене сотрудников, анализ личных дел, сопоставление с имеющимися правами, отключение на время разбирательства учетных записей с подозрительными привилегиями; полный аудит GPO в корпоративных доменах (Z, Y, X - поколения). 3) Объяснение принципа разграничения доступа всем работающим специалистам старших поколений, ограничение привилегий в силу увеличения уровня безопасности, запрет установки ПО с устройства в домене без верификации (B - поколение).
Сбор и эксфильтрация данных	T1119 T1025 T1113 T1125 T1567 T1041	1) Блокировка возможностей эксфильтрации в учебных заведениях посредством блокировки каналов утечки информации (USB; Ethernet); предупреждение обучающихся о реализации атаки и указание сообщать о подозрительных моментах, чтобы обнаружить утечку (A, Z - поколения). 2) Обучение работающих поколений грамотному использованию

Продолжение таблицы 43

Инцидент	Техники	Меры первоочередного реагирования
	T1029 T1217 T1011 T1052	средств анализа сетевого трафика (Wireshark); конфискация съемных носителей у подозрительных сотрудников (DLP). 3) Физическое ограничений возможности производить эксфильтрации на устройстве, а также уменьшение числа каналов эксфильтрации; волонтерские формирования, помогающие старшим поколениям при реализации атаки.
Сокрытие активности	T1564 T1070 T1221 T1665 T1102 T1095	1) Настройка удаленного просмотра логов, журналов, историй и т.д.; формирование понимания у школьников и студентов понимания принципов журналирования; оповещение обучающихся о том, что происходит атака и злоумышленник всячески прячет свое присутствие (A, Z - поколения). 2) Просьба весь работающий персонал предоставить результаты анализа скрытых процессов (Volatility)/ предоставить доступ к устройству для проведения анализа; введение в рабочую среду понятия “руткит” (Z, Y, X - поколения). 3) Ручная проверка ПК на наличие скрытых процессов, автоматизированное отключение компьютерной техники от каналов передачи данных, обращение в специальные службы (B - поколение).
Разрушение данных и систем	T1486 T1561 T1495 T1485 T1565	1) Изолирование устройств, пользователями которых являются лица, не достигшие совершеннолетия от общей сети; восстановление файлов по возможности (A, Z - поколения). 2) Бэкап данных; обучение сотрудников основам резервного копирования с целью не допустить полного уничтожения данных (Z, Y, X - поколения). 3) Незамедлительное обращение к IT-специалистам, в соответствующие органы, в волонтерские службы для получения дальнейших инструкций (B - поколение).
Злоупотребление доверительными отношениями	T1199 T1584 T1219	1) Анализ и ограничение контакта со всеми подозрительными лицами из социальных сетей лиц, не достигших 18-летнего возраста (A, Z - поколения). 2) Аудит VPN-доступов в компании; реализация принципа: один пользователь – один уникальный сертификат удаленного доступа; анализ коммуникаций компании исключение подозрительных; полный запрет на межсетевые инструменты удаленного доступа (TeamViewer/AnyDesk) (Z, Y, X - поколения). 3) Звонок и консультация при первых признаках манипуляций с доверием лицам более компетентным в вопросах безопасности и защиты от кибератак (B - поколение).

Продолжение таблицы 43

Инцидент	Техники	Меры первоочередного реагирования
Разведка внутренней среды	T1518 T1016 T1083 T1046 T1614 T1033 T1069 T1120	1) Оповещение обучающихся о проведении атаки сканирования и настоятельное требование сообщать о всех подозрительных аспектах лицам более компетентным в вопросах безопасности и защиты от кибератак (A, Z - поколения). 2) Проверка лиц, следящих за настройками маршрутизации, блокировка всех подозрительных пакетов и временная настройка аутентификации через малые промежутки времени; формирование у работников базовых принципов понимание ARP – системы (пример с дверями и надписями на них). 3) Настройка и использование простого инструмента проверки количества устройств в домашней подсети без углубления в вопросы функционирования сети и сетевых устройств (B - поколение).

Как и в предыдущем разделе, в рамках каждого шаблона реализации CAPEC необходимо рассмотреть и “закрыть” все техники, являющиеся узким местом в множестве сценариев реализации (та техника, к которой сводятся все или почти все сценарии реализации по каждому шаблону). Важно отметить, что целесообразно будет также, как и ранее рассматривать не все такие техники, а лишь ближайшие к началу, так как важно как можно быстрее предотвратить развитие атаки. Таким образом далее будут подробно рассмотрены меры первоочередного реагирования для каждой уникальной уязвимости в рамках вышеописанных техник.

Не сбивая порядок, необходимо начать с шаблона CAPEC-98. В данном шаблоне имеется техника – T1534 на этапе – “Боковое смещение”. Техника содержит уязвимости: CVE-2023-5561, CVE-2021-44168, CVE-2023-36874. Для грамотного оперативного реагирования на эксплуатацию CVE-2023-5561 необходимо обновить версии WordPress, ограничить доступ к REST API, а также обучить пользователей. Для CVE-2021-44168 – контролировать загружаемые файлы, и обновить FortiOS, а также мониторить активность. Для CVE-2023-36874 – установить недостающие обновления безопасности, ограничить доступа для wermgr.exe и Report.wer, а также реализовать принципа минимального доверия, что позволит лучше контролировать права пользователей.

Для шаблона CAPEC-163 представляется оптимальным рассмотреть тактику – “Подготовка ресурсов” и технику – T1586. В ней имеются две уязвимости CVE-2019-14287 и CVE-2022-26925. При реализации атаки через CVE-2019-14287 необходимо анализировать конфигурацию файла /etc/sudoers на наличие записей с !root и ALL, особенно в сочетании с Runas ALL, и пересмотреть политику доступа. При использовании CVE-2022-26925 должна производиться настройка реестра, а также ограничение взаимодействия с NTLM на контроллерах домена.

В CAPEC-164 верным решением является рассмотреть T1204, как ближайшую ко “входу” (тактика “Исполнение”). В рамках техники есть уязвимости: CVE-2021-21132, CVE-2021-30657, CVE-2021-44168. CVE-2021-44168 Была описана ранее. На уязвимость CVE-2021-21132 целесообразно реагировать следующим образом: временно приостановить взаимодействия пользователей с каталогом расширений и проверить все браузеры на базе Chromium. Помимо прочего обязательной является процедура обучения пользователей правилам безопасного использования расширений. Если рассматривать уязвимость CVE-2021-30657, то рационально будет полный запретить запуск скрипт-приложений с помощью BeyondTrust Privilege Management для Mac, для блокировки запуска приложений, основанных на скриптах, которые могут обходить Gatekeeper.

Для CAPEC-656, с точки зрения рационального обеспечения информационной безопасности, интерес представляет этап – “Исполнение” и техника – T1204. Данная техника имеет 4 уязвимости: CVE-2021-21132, CVE-2021-30657, CVE-2021-44168, CVE-2019-1563. Для CVE-2019-1563 – необходимо срочно настроить ответы, не содержащие подробных отчетов, а также необходимо обеспечить использование приложениями сертификатов вместе с закрытым ключом (RSA). Меры первоочередного реагирования для CVE-2021-21132, CVE-2021-30657, CVE-2021-44168 уже описывались ранее по тексту (CAPEC-98 – CAPEC-164).

Для CAPEC-630 необходимо подробно остановиться на тактике – “Подготовка ресурсов” и технике – T1584. В рамках техники имеется 3 уязвимости: CVE-2022-40684, CVE-2017-0057, CVE-2023-38497. Для CVE-2023-38497, связанной с маски-

ровкой и возможностью выполняемого кода, – обновить Cargo и Rust, а также незамедлительно проверить политики безопасности в рамках организации (при необходимости реализация минимального доверяя). Для CVE-2017-0057 – фильтровать все DNS запросы внутри организации, для CVE-2022-40684 – полностью ограничить доступ к административному интерфейсу со всех IP-адресов, кроме доверенных (возможна настройка VPN-сервисов), а также временно заблокировать или фильтровать все HTTP-запросы.

В рамках CAPEC-194, интересующим с точки зрения грамотной нейтрализации атаки, стала тактика – “Первоначальный доступ” и техника – T1566, имеющая 4 уязвимости: CVE-2021-21135, CVE-2020-10136, CVE-2019-0633, CVE-2017-7821. Для CVE-2021-21135 – проверить обновления всех используемых Chromium браузеров, блокировать все ненадежные сайты, обучить пользователей правилам безопасного веб-серфинга, также имеет смысл приобрести лицензию сертифицированного СЗИ для защиты от подобных атак. Для CVE-2020-10136 – отключить поддержку IP-in-IP и проверить настройки фильтрации сетевого трафика. Для CVE-2019-0633 – временно ограничить взаимодействия посредством протоколов SMB и полностью мониторить действия, связанные с ними. Для CVE-2017-7821 – обеспечить ограничение (частичное) установки расширений из доверенных источников, обновить список расширений на подконтрольных устройствах внутри домена (удаление всех неизвестных расширений), а также информировать пользователей о рисках установки расширений из ненадёжных источников.

Для CAPEC-504 обязательна к рассмотрению тактика – “Подготовка ресурсов” и техника – T1584. Уязвимости: CVE-2018-13382, CVE-2022-26925, CVE-2021-26291, CVE-2020-0683. Для CVE-2018-13382 – реализовать ограничение доступа к SSL VPN веб-порталу только с доверенных IP-адресов. Для CVE-2021-26291 – реализовать полную проверку POM-файлов на наличие ссылок на небезопасные репозитории, и автоматически заменять их на HTTPS. Для CVE-2020-0683 – настроить автоматическое реагирование на подозрительные записи в журнале установок/удаления программного обеспечения, а также настроить временные ограничения установки MSI-пакетов

из неизвестных источников. CVE-2022-26925 – описывалась ранее в абзаце с CAPEC-163.

Исполнения CAPEC-173 можно избежать, перекрыв злоумышленнику возможность использовать технику – T1592 в рамках тактики – “Разведка”. Техника имеет 3 уязвимости: CVE-2021-36942, CVE-2023-49084, CVE-2024-22017. Для CVE-2021-36942 – в срочном порядке необходимо произвести отключение от всех неизвестных серверов, ограничить использование NTLM в сети (частичное или полное), выполнить действия описанные в статье базы знаний KB5005413[99]. При использовании злоумышленником CVE-2023-49084 необходимо ограничить права пользователям и оставить доступ только к самому необходимому, анализ журналов действий. Для CVE-2024-22017 – необходимо ввести другой инструмент управления привилегиями, а также обновить Node.js.

Для CAPEC-698 интересной к рассмотрению является техника – T1584 и тактика – “Подготовка ресурсов”, уникальной для нее уязвимостью служит CVE-2024-38143. Если было детектировано успешное использование, необходимо незамедлительно реализовать дополнительную проверку прав доступа, и временно ограничить взаимодействие с LSARPC. CVE-2018-13382 и CVE-2022-26925 упоминались ранее по тексту.

В случае с CAPEC-410, завершить атаку можно также на этапе “Подготовка ресурсов” (техника T1584). В этом случае есть 3 уникальные уязвимости: CVE-2023-35325, CVE-2017-0022, CVE-2016-2106. Для CVE-2023-35325 – необходимо полностью отключить Print Spooler на системах, где печать не требуется, настройка строгой фильтрации запросов, а также необходимо настроить проверку аутентификации пользователей для печати (как минимум временная). Для CVE-2017-0022 – ограничить доступа ко всем ip-адресам сторонних web-ресурсов, кроме доверенных (брандмауэр). Для CVE-2016-2106 – необходимо срочно и быстро проверить используемые библиотеки на наличие зависимостей от уязвимых версий OpenSSL и отключить/заменить их при необходимости. CVE-2018-13382 и CVE-2022-40684 упоминалась ранее по тексту.

Далее необходимо рассмотреть CAPEC-631. Для своевременного предотвращения необходимо также остановить выполнение техники в тактике – “Подготовка ресурсов”. В рамках техники имеется 3 уязвимости: CVE-2022-40684, CVE-2017-0057, CVE-2023-38497. Описание мер реагирования для них приводилось ранее по тексту.

Далее CAPEC-151. В настоящем шаблоне интересующая тактика – “Исполнение” и техника – T1204. В технике существует две уязвимости CVE-2021-21132 и CVE-2019-1563, обе имели описание мер реагирования в предыдущих шаблонах.

Для CAPEC-89 и CAPEC-654 к рассмотрению необходима тактика – “Подготовка ресурсов” с техникой – T1584. Для данной техники уникальной является уязвимость – CVE-2023-36851. Необходимо незамедлительно настроить аутентификацию для взаимодействия, настроить фильтрацию запросов, ограничение доступа к интерфейсу J-Web, проанализировать загруженные файлы.

Далее необходимо рассмотреть сценарии с использованием злоумышленником уязвимостей с наибольшим значением вероятностей. Для удобства, как и в предыдущем разделе нужно составить матрицу – таблица 43 [44-49, 93-98].

Таблица 44 – Первоочередные меры реагирования для уязвимостей с наибольшим значением вероятности

Тактика	Техника	CVE	Первоочередные меры реагирования
CAPEC-98			
Разведка	(T1589)	CVE-2018-15473	Настройка задержки отклика для предотвращения дальнейшего определения пользователей.
Подготовка ресурсов	(T1586)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Первоначальный доступ	(T1189)	CVE-2021-26291	Использование только HTTPS-репозиториев в Maven для предотвращения загрузки из ненадежных источников.
Исполнение	(T1053)	CVE-2024-20666	Обновление среды восстановления Windows (WinRE) для устранения обхода BitLocker через уязвимость в WinRE.
Закрепление	(T1053)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Повышение привилегий	(T1548)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Предотвращение обнаружения	(T1070)	CVE-2021-3197	Запрет передачи параметров ProxyCommand через API SaltStack для предотвращения внедрения команд.
Получение учетных данных	(T1606)	CVE-2023-5561	Ограничение полей, доступных через REST API WordPress, для предотвращения раскрытия адресов электронной почты авторов.
Обнаружение	(T1033)	CVE-2018-14847	Отключение интерфейса WinBox на MikroTik или ограничение его доступа только доверенным IP-адресам.
Боковое смещение	(T1534)	CVE-2023-36874	Предотвращение эксплуатации через файловые перенаправления, так как уязвимость связана с подменой wermgr.exe
Сбор данных	(T1217)	CVE-2019-17563	Переход на защищённые соединения для FORM-аутентификации и принудительное обновление идентификаторов сессий
Командование и управление	(T1102)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.
Эксфильтрация	(T1567)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.
Удар	(T1561)	CVE-2016-0046	Незамедлительный переход на альтернативные приложения для просмотра PDF и блокировка подозрительных файлов.
CAPEC-163			
Разведка	(T1598)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Подготовка ресурсов	(T1586)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root) и блокировка команд с UserID=-1.
Первоначальный доступ	(T1189)	CVE-2019-0633	Отключение SMBv2 через реестр и ограничение доступа к портам 445/TCP.
Исполнение	(T1053)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Закрепление	(T1053)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Повышение привилегий	(T1068)	CVE-2021-3197	Блокировка параметров ProxyCommand в API-запросах и изоляция salt-api в отдельном VLAN
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Обновление sudo до версии 1.9.12+, ограничьте использование sudoedit в /etc/sudoers.
Получение учетных данных	(T1528)	CVE-2023-49084	Отключение неиспользуемых приложений в Nextcloud, обновление до версии 27.1.3+/26.0.8+/25.0.12+.
Обнаружение	(T1558)	CVE-2019-0633	Отключение SMBv2 через реестр и ограничение доступа к портам 445/TCP.
Боковое смещение	(T1534)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Сбор данных	(T1025)	CVE-2022-44268	Ограничение прав magick на чтение системных файлов.
Командование и управление	(T1095)	CVE-2011-3544	Удаление JRE версий 6u27 и ниже, настройте политики для блокировки недоверенных JAR-файлов.
Эксфильтрация	(T1567)	CVE-2019-12643	Отключение REST API на IOS XE, проверяя токены через monitor event-trace.
Удар	(T1486)	CVE-2023-37266	Ограничение CasaOS от публичного интернета (через NAT/VPN) и настройка брандмауэра для блокировки портов CasaOS (по умолчанию – 80/443).
CAPEC-164			
Разведка	(T1592)	CVE-2022-30295	Обновление до версий uClibc-ng 1.0.41+ или применение патчей для устранения предсказуемости DNS transaction IDs.
Подготовка ресурсов	(T1586)	CVE-2020-0683	Отключение обработки символических ссылок в MSI-пакетах.
Первоначальный доступ	(T1199)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP)
Исполнение	(T1204)	CVE-2021-21132	Ограничение прав расширений.
Закрепление	(T1078)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Повышение привилегий	(T1098)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root) и блокировка команд с UserID=-1.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Ограничение использования sudoedit в /etc/sudoers.
Получение учетных данных	(T1606)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Обнаружение	(T1614)	CVE-2023-35325	Немедленная настройка СЗИ с функцией защиты печати (SecretNet и т.д.).
Боковое смещение	(T1534)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Сбор данных	(T1056)	CVE-2021-28169	Немедленная блокировка двойного кодирования URL.
Командование и управление	(T1102)	CVE-2019-12643	Отключение REST API на IOS XE, проверяя токены через monitor event-trace.
Эксфильтрация	(T1011)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP)
Удар	(T1485)	CVE-2014-3153	Проверка версии и обновление ядра Linux. Ограничение доступа к функции futex_requeue
CAPEC-656			
Разведка	(T1589)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Подготовка ресурсов	(T1586)	CVE-2021-26291	Использование менеджера репозиториев настройка, чтобы все ссылки на репозитории в POM-файлах использовали HTTPS, а не HTTP.
Первоначальный доступ	(T1199)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Исполнение	(T1204)	CVE-2021-44168	Ограничение прав локальных пользователей на выполнение команд execute restore src-vis.
Закрепление	(T1136)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Повышение привилегий	(T1098)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Ограничение использования sudoedit в /etc/sudoers.
Получение учетных данных	(T1649)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).

Тактика	Техника	CVE	Первоочередные меры реагирования
Обнаружение	(T1614)	CVE-2022-30295	Обновление до uClibc-ng 1.0.41+, настройка рандомизации DNS transaction IDs.
Боковое смещение	(T1550)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Сбор данных	(T1125)	CVE-2021-30682	Обновление iOS/tvOS до 14.6+, macOS до 11.4+, Safari до 14.1.1+
Командование и управление	(T1105)	CVE-2018-13382	Обновление FortiOS/FortiProxy, отключение сброса паролей через SSL VPN
Эксфильтрация	(T1029)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Удар	(T1565)	CVE-2021-25281	Временное отключение службы salt-api до момента, когда можно будет применить патч.
CAPEC-630			
Разведка	(T1592)	CVE-2022-23614	Запрет использования Closure в параметре arrow фильтра sort.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Первоначальный доступ	(T1566)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Исполнение	(T1204)	CVE-2021-21132	Проверка прав расширений.
Закрепление	(T1176)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Повышение привилегий	(T1068)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Незамедлительно применить принцип минимального доверия, проверить логи для определения ущерба.
Получение учетных данных	(T1649)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Обнаружение	(T1069)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Боковое смещение	(T1534)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Сбор данных	(T1114)	CVE-2018-13382	Отключение функции сброса паролей через SSL VPN, проверка параметра magic.

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Командование и управление	(T1102)	CVE-2019-12643	Отключение REST API на IOS XE, проверяя токены через monitor event-trace.
Эксфильтрация	(1041)	CVE-2022-44268	Ограничение прав magick на чтение системных файлов.
Удар	(T1485)	CVE-2021-22204	Блокировка обработки файлов DjVu с внедренными командами.
CAPEC-194			
Разведка	(T1598)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Подготовка ресурсов	(T1585)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Первоначальный доступ	(T1566)	CVE-2017-7821	Отключение автоматического открытия файлов WebExtensions.
Исполнение	(T1204)	CVE-2021-21132	Проверка прав расширений.
Закрепление	(T1136)	CVE-2023-30861	Настройка Cache-Control и SESSION_REFRESH_EACHO_REQUEST.
Повышение привилегий	(T1078)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Незамедлительно применить принцип минимального доверия, проверить логи для определения ущерба.
Получение учетных данных	(T1556)	CVE-2023-3676	Отключение создания модулей неавторизованными пользователями на узлах Windows. Обучение пользователей лучшим практикам безопасного развёртывания и управления модулями.
Обнаружение	(T1217)	CVE-2024-29988	Ограничение доступа к уязвимым системам (брандмауэр), блокировка возможности открытия файлов по ссылкам из ненадежных источников.
Боковое смещение	(T1534)	CVE-2024-38143	Введение дополнительного механизма аутентификации, проверка конфигурации сети на соответствие правилам безопасности.
Сбор данных	(T1114)	CVE-2018-13382	Отключение функции сброса паролей через SSL VPN.
Командование и управление	(T1102)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Эксфильтрация	(T1029)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.

Продолжение таблицы 44

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Удар	(T1485)	CVE-2021-22204	Блокировка обработки файлов DjVu с внедренными командами.
CAPEC-504			
Разведка	(T1589)	CVE-2021-3197	Блокировка параметров ProxyCommand в API-запросах и изоляция salt-api в отдельном VLAN
Подготовка ресурсов	(T1584)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.
Первоначальный доступ	(T1199)	CVE-2019-1322	Блокировка параметров ProxyCommand в API-запросах и изоляция salt-api в отдельном VLAN
Исполнение	(T1204)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Закрепление	(T1053)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Повышение привилегий	(T1546)	CVE-2023-36874	Предотвращение эксплуатации через файловые перенаправления, так как уязвимость связана с подменой wermgr.exe
Предотвращение обнаружения	(T1564)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Получение учетных данных	(T1556)	CVE-2019-3978	Обновление антивируса, отключение уязвимого компонента AMCore.
Обнаружение	(T1016)	CVE-2016-0046	Замена Windows Reader на альтернативные PDF-ридеры.
Боковое смещение	x	x	x
Сбор данных	(T1025)	CVE-2020-10136	Обновление ManageEngine до 10.0.75+, смена паролей LDAP-аккаунтов.
Командование и управление	(T1105)	CVE-2021-26291	Использование менеджера репозиториев настройка, чтобы все ссылки на репозитории в POM-файлах использовали HTTPS, а не HTTP.
Эксфильтрация	(T1041)	CVE-2019-0804	Отключение устаревших компонентов Win32k
Удар	(T1565)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
CAPEC-173			
Разведка	(T1592)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.

Продолжение таблицы 44

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Подготовка ресурсов	(T1584)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.
Первоначальный доступ	(T1189)	CVE-2023-6208	Виртуальные патчи реализуемые на файрволлах и препятствующие проникновению вредоносного трафика к уязвимому приложению.
Исполнение	(T1059)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Закрепление	(T1053)	CVE-2024-38476	Проверка надежности бэкэнд-приложений. Настройка или проверка конфигураций IDS/IPS.
Повышение привилегий	(T1546)	CVE-2019-1405	Отключение Credential Guard в тестовых средах.
Предотвращение обнаружения	(T1221)	CVE-2019-0633	Отключение SMBv2 через реестр и ограничение доступа к портам 445/TCP.
Получение учетных данных	(T1556)	CVE-2020-0836	Немедленная корректировка способов обработки запросов DNS.
Обнаружение	(T1518)	CVE-2024-29988	Ограничение доступа к уязвимым системам (брандмауэр), блокировка возможности открытия файлов по ссылкам из ненадежных источников.
Боковое смещение	x	x	x
Сбор данных	(T1056)	CVE-2023-36874	Предотвращение эксплуатации через файловые перенаправления, так как уязвимость связана с подменой wermgr.exe
Командование и управление	(T1105)	CVE-2019-0633	Отключение SMBv2 через реестр и ограничение доступа к портам 445/TCP.
Эксфильтрация	(1041)	CVE-2020-0836	Немедленная корректировка способов обработки запросов DNS.
Удар	(T1565)	CVE-2024-29988	Ограничение доступа к уязвимым системам (брандмауэр), блокировка возможности открытия файлов по ссылкам из ненадежных источников.
CAPEC-698			
Разведка	(T1598)	CVE-2023-3676	Отключение создания модулей неавторизованными пользователями на узлах Windows. Обучение пользователей лучшим практикам безопасного развёртывания и управления модулями.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Отключение функции сброса паролей через SSL VPN.

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Первоначальный доступ	(T1189)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Исполнение	(T1059)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Закрепление	(T1176)	CVE-2023-36874	Предотвращение эксплуатации через файловые перенаправления, так как уязвимость связана с подменой wermgr.exe
Повышение привилегий	(T1546)	CVE-2019-0633	Отключение SMBv2 через реестр и ограничение доступа к портам 445/TCP.
Предотвращение обнаружения	(T1564)	CVE-2023-22809	Ограничение использования sudoedit в /etc/sudoers.
Получение учетных данных	(T1649)	CVE-2023-36851	Отключение доступа к интерфейсу J-Web и временный переход на альтернативу.
Обнаружение	(T1217)	CVE-2021-21134	Обновление ПО до актуальной версии (касается программных продуктов Microsoft, Debian GNU/Linux, Novell).
Боковое смещение	(T1534)	CVE-2023-3676	Отключение создания модулей неавторизованными пользователями на узлах Windows. Обучение пользователей лучшим практикам безопасного развёртывания и управления модулями.
Сбор данных	(T1056)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Командование и управление	(T1105)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Эксфильтрация	(T1011)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Удар	(T1565)	CVE-2023-30861	Настройка Cache-Control и SESSION_REFRESH_EACHO_REQUEST.
CAPEC-410			
Разведка	(T1589)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Первоначальный доступ	(T1189)	CVE-2019-12086	Отключение параметра “По умолчанию” для внешних конечных точек JSON и обновление библиотеки jackson-databind.
Исполнение	(T1204)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.

Продолжение таблицы 44

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Закрепление	(T1078)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Повышение привилегий	(T1098)	CVE-2023-30861	Настройка Cache-Control и SESSION_RE-FRESH_EACHO_REQUEST.
Предотвращение обнаружения	(T1070)	CVE-2021-25281	Временное отключение службы salt-api до момента, когда можно будет применить патч.
Получение учетных данных	(T1134)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Обнаружение	(T1217)	CVE-2019-12643	Отключение REST API на IOS XE, проверяя токены через monitor event-trace.
Боковое смещение	x	x	x
Сбор данных	(T1119)	CVE-2021-30682	Обновление iOS/tvOS до 14.6+, macOS до 11.4+, Safari до 14.1.1+
Командование и управление	(T1095)	CVE-2011-3544	Удаление JRE версий 6u27 и ниже, настройте политики для блокировки недоверенных JAR-файлов.
Эксфильтрация	(T1011)	CVE-2023-35325	Немедленная настройка СЗИ с функцией защиты печати (SecretNet и т.д.).
Удар	(T1565)	CVE-2021-25281	Временное отключение службы salt-api до момента, когда можно будет применить патч.
CAPEC-631			
Разведка	(T1592)	CVE-2022-23614	Запрет использования не-Closure в параметре arrow фильтра sort.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Первоначальный доступ	(T1566)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Исполнение	(T1204)	CVE-2021-21132	Проверка прав расширений.
Закрепление	(T1176)	CVE-2019-1405	Отключение Credential Guard в тестовых средах.
Повышение привилегий	(T1068)	CVE-2020-0683	Отключение обработки символических ссылок в MSI-пакетах.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Незамедлительно применить принцип минимального доверия, проверить логи для определения ущерба.
Получение учетных данных	(T1649)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Обнаружение	(T1069)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Боковое смещение	(T1534)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Сбор данных	(T1114)	CVE-2018-13382	Отключение функции сброса паролей через SSL VPN.
Командование и управление	(T1102)	CVE-2019-12643	Отключение REST API на IOS XE, проверяя токены через monitor event-trace.
Эксфильтрация	(1041)	CVE-2022-44268	Ограничение прав magick на чтение системных файлов.
Удар	(T1485)	CVE-2021-22204	Блокировка обработки файлов DjVu с внедренными командами.
CAPEC-151			
Разведка	(T1598)	CVE-2020-4046	Анализ логов WordPress на наличие XSS-скриптов.
Подготовка ресурсов	(T1585)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
Первоначальный доступ	(T1199)	CVE-2022-26925	Отключение NTLM-аутентификации на контроллерах домена для предотвращения атак с подменой LSA.
Исполнение	(T1204)	CVE-2021-21132	Проверка прав расширений.
Закрепление	(T1136)	CVE-2024-38213	Блокировка WebDAV-шары через групповые политики, блокировка доступа к портам 80/443 для WebDAV в брандмауэре.
Повышение привилегий	(T1078)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Ограничение использования sudoedit в /etc/sudoers.
Получение учетных данных	(T1649)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Обнаружение	(T1087)	CVE-2018-15473	Настройка задержки отклика для предотвращения дальнейшего определения пользователей.
Боковое смещение	(T1534)	CVE-2019-9787	Добавление hashNonce для проверки комментариев и замена фильтра wp_filter_post_kses на альтернативный в ajax-actions.php.
Сбор данных	(T1025)	CVE-2022-44268	Ограничение прав magick на чтение системных файлов.
Командование и управление	(T1102)	CVE-2019-12643	Отключение REST API на IOS XE, проверяя токены через monitor event-trace.

Продолжение таблицы 44

Тактика	Техника	CVE	Первоочередные меры реагирования
Эксфильтрация	(T1567)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Удар	(T1495)	CVE-2011-3544	Удаление JRE версий 6u27 и ниже, настройте политики для блокировки недоверенных JAR-файлов.
CAPEC-89			
Разведка	(T1592)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Отключение функции сброса паролей через SSL VPN.
Первоначальный доступ	(T1199)	CVE-2023-3676	Отключение создания модулей неавторизованными пользователями на узлах Windows. Обучение пользователей лучшим практикам безопасного развёртывания и управления модулями.
Исполнение	(T1204)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Закрепление	x	x	x
Повышение привилегий	(T1548)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Предотвращение обнаружения	(T1221)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Получение учетных данных	(T1558)	CVE-2019-3978	Обновление антивируса, отключение уязвимого компонента AMCore
Обнаружение	(T1046)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Боковое смещение	(T1534)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Сбор данных	(T1025)	CVE-2024-38476	Проверка надежности бэкэнд-приложений. Настройка или проверка конфигураций IDS/IPS.
Командование и управление	(T1102)	CVE-2019-1405	Отключение Credential Guard в тестовых средах.
Эксфильтрация	(1041)	CVE-2024-38213	Блокировка WebDAV-шары через групповые политики, блокировка доступа к портам 80/443 для WebDAV в брандмауэре.

Продолжение таблицы 44

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Удар	(T1565)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).
CAPEC-654			
Разведка	(T1592)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Отключение функции сброса паролей через SSL VPN.
Первоначальный доступ	(T1199)	CVE-2023-3676	Отключение создания модулей неавторизованными пользователями на узлах Windows. Обучение пользователей лучшим практикам безопасного развёртывания и управления модулями.
Исполнение	(T1204)	CVE-2020-1054	Ограничение доступа к системам с уязвимым драйвером для минимизации возможности эксплуатации.
Закрепление	x	x	x
Повышение привилегий	(T1548)	CVE-2021-36942	Отключение уязвимых служб (EFS), блокировка RPC-методов, настройка брандмауэра, выключение SMB Signing.
Предотвращение обнаружения	(T1221)	CVE-2023-49084	Блокировка SQL-инъекций в link.php, ограничение доступа к TSDB.
Получение учетных данных	(T1558)	CVE-2019-3978	Обновление антивируса, отключение уязвимого компонента AMCore
Обнаружение	(T1046)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Боковое смещение	(T1534)	CVE-2022-40684	Ограничение доступа к интерфейсу управления (только доверенные IP).
Сбор данных	(T1025)	CVE-2024-38476	Проверка надежности бэкэнд-приложений. Настройка или проверка конфигураций IDS/IPS.
Командование и управление	(T1102)	CVE-2019-1405	Отключение Credential Guard в тестовых средах.
Эксфильтрация	(1041)	CVE-2024-38213	Блокировка WebDAV-шары через групповые политики, блокировка доступа к портам 80/443 для WebDAV в брандмауэре.
Удар	(T1565)	CVE-2019-14287	Проверка /etc/sudoers на наличие (ALL, !root).

Таким образом все вышеописанное представляет из себя регламентацию по первоочередному реагированию на атаки класса “Социальная инженерия”, и если говорить более конкретно, то включают в себя:

- перечень негативных последствий от реализации всего списка техник (с различным набором уязвимостей в зависимости от шаблона CAPEC);

- перечень первоочередных мер реагирования для всего списка техник (с различным набором уязвимостей в зависимости от шаблона CAPEC);

- полные набор инструкций по первоочередному реагированию на основе контекста используемых уязвимостей с максимальным значением вероятности (в рамках каждого шаблона CAPEC), взятого с различных ресурсов, посвященных CVE [44-49, 93-98].

3.4 Частные регламенты ликвидации последствий инцидентов нарушения безопасности, возникающих при эксплуатации техник и уязвимостей для атак класса “Социальная инженерия”

Ликвидация последствий компьютерной атаки – это необходимый шаг в многоуровневом обеспечении безопасности социо-информационного пространства. Ликвидация последствий возвращает систему в исходное состояние и минимизирует потери, на сколько это возможно после завершения атаки. Если последствия атаки не устранены, злоумышленники могут вновь использовать те же технические или социальные слабости для продолжения текущей или реализации новой атаки. Таким образом, основной смысл – максимально быстро вернуть систему в изначальное состояние и не допустить дальнейших атак со схожим принципом реализации

Необходимо представить классический план по ликвидации последствий:

- проводятся работы по устранению негативных последствий инцидентов безопасности, которые возникали в ходе реализации сетевой атак класса “Социальная инженерия”.

- после проведения мероприятий по ликвидации последствий проводится анализ произошедших инцидентов;

- выявляются причины и условия возникновения инцидентов безопасности в организации, в ходе реализации сценария вторжения класса “Социальная инженерия” [89].

Таким образом, учитывая специфику заданного класса атак, необходимо составить матрицу с техническими и социальными мерами по ликвидации последствий (таблица 45) [13, 40, 74].

Таблица 45 – Меры ликвидации последствий для инцидентов нарушения безопасности атак класса “Социальная инженерия”

Инцидент безопасности	Технические меры ликвидации последствий	Социальные меры ликвидации последствий (уникально для поколений)
Фишинг и сбор информации	1) Массовое оповещение потенциальных жертв через официальные каналы связи. 2) Отзыв компрометированных данных через взаимодействие с сервисами и провайдерами. 3) Проведение цифрового противоэпидемического мероприятия – временное блокирование подозрительных ресурсов. 4) Организация горячей линии психологической поддержки для пострадавших. 5) Запуск кампании по замене учетных данных для всех потенциально затронутых пользователей.	1) Повышение уровня цифрового иммунитета – интерактивные квесты, квизы и другие мероприятия в школах и институтах; популяризация творчества среди молодежи на тему защиты от фишинга (A, Z - поколения). 2) Группы взаимопомощи в мессенджерах под руководством психологов для жертв фишинговых атак (Z, Y, X - поколения). 3) Памятки безопасности в общественных местах; ТВ-передачи, направленные на повышение уровня осведомленности в области ИБ; телефонные горячие лини для жертв, пострадавших от фишинга (X, B - поколения).
Компрометация учетных записей	1) Принудительный сброс паролей во всей затронутой системе. 2) Создание системы "цифровых свидетелей" - пользователи помогают выявлять подозрительную активность. 3) Развертывание дополнительных уровней верификации для критичных операций.	1) Чаты поддержки, для лиц младше 18-ти лет, чьи данные УЗ были скомпрометированы; игровые треннинги по созданию безопасных паролей (A, Z - поколения). 2) Психологические треннинги по восстановлению профессионального имиджа; психологическая поддержка сотрудников после утечки данных (Z, Y, X - поколения). 3) Волонтерские объединения действующие, как личный цифровой помощник в вопросах банковских карт, УЗ (ГосУслуги и другие); упрощенные бумажные инструкции (B - поколение).
Кража учетных данных и токенов	1) Организация цифрового карантина для затронутых аккаунтов. 2) Глобальный отзыв и перевыпуск токенов во всей системе. 3) Внедрение системы мониторинга использования учетных данных. 4) Создание механизма экстренного оповещения при подозрительных действиях.	1) Проведение занятий, освещающих последствия кражи данных; конкурсы по безопасному хранению паролей (A, Z - поколения). 2) Корпоративные тренинги, популяризирующие тему важности защиты персональных данных; группы психологической поддержки для пострадавших (Z, Y, X - поколения). 3) Реализация принципа “безопасный чемодан” – физический носитель с подробными инструкциями по использованию (X, B - поколения).

Продолжение таблицы 45

Инцидент безопасности	Технические меры ликвидации последствий	Социальные меры ликвидации последствий (уникально для поколений)
Внедрение вредоносного кода	1) Изоляция зараженных систем от основной сети. 2) Развертывание мобильных групп "цифровой дезинфекции". 3) Организация непрерывного мониторинга за подозрительной активностью. 4) Создание системы восстановления "чистых" образов рабочих станций.	1) Практические занятию или лабораторные работы по повышению уровня “кибергигиены” в школах и институтах; анонимные группы поддержки для лиц младше 18-ти лет, подвергшихся атаке (A, Z - поколения). 2) Корпоративные треннинги по цифровой дезинфекции, освещающие вопросы быстрой и грамотной очистки устройств от заражения; психологическая поддержка сотрудников, подвергшихся атаке (Z, Y, X - поколения). 3) Популяризация выезжающих квалифицированных официальных специалистов для помощи пенсионерам, в том числе психологической (B-поколение).
Эскалация привилегий	1) Полный аудит системы прав доступа. 2) Временное снижение уровня привилегий для всех пользователей. 3) Создание системы двойного подтверждения для административных действий. 4) Жесткая настройка механизма отслеживания нестандартных действий.	1) Популяризация занятий по безопасному администрированию среди детей, а также соц. помощь лицам не достигшим 18-ти лет и подвергшимся атаке с использованием повышенных привилегий (A, Z - поколения). 2) Корпоративные занятия по ответственному доступу к данным; разборы кейсов из профессиональной практики, в том числе негативных (Z, Y, X - поколения). 3) Для сотрудников пенсионного возраста отдельные “цифровые опекуны” и упрощенная модель доступа вне зависимости от должности (B-поколение).
Сбор и эксфильтрация данных	1) Немедленное шифрование критичных данных. 2) Введение временного запрета на передачу данных. 3) Настройка контроля потоков данных (Secret Net и т.д.). 4) Организация восстановительных работ по возврату/уничтожению утерянных данных.	1) Проведение и популяризация конкурсов на лучшие механизмы защиты от утечек; флешмобы с визуализацией распределения данных в социальных сетях анонимные чаты для детей и подростков, столкнувшихся с утечкой личных данных. 2) Корпоративные программы “Анти-утечка” с групповыми разборами инцидентов; терапевтические группы для сотрудников,

Продолжение таблицы 45

Инцидент безопасности	Технические меры ликвидации последствий	Социальные меры ликвидации последствий (уникально для поколений)
		чьи профессиональные данные были скомпрометированы (Z, Y, X - поколения). 3) Популяризация ТВ-передач с разборами типичных способов кражи данных; простые бумажные инструкции по минимизации количества каналов утечки; психологическая помощь для снятия стресса жертвам-пенсионерам (B-поколение).
Сокрытие активности	1) Развертывание систем цифрового освещения – расширенный мониторинг активности. 2) Восстановление удаленных/измененных журналов из резервных копий. 3) Создание механизма цифровых отпечатков для всех операций (логирование всех событий). 4) Организация специальных расследований для выявления скрытых действий.	1) Введение внеурочного проектирования (при необходимости) по повышению уровня цифровой прозрачности в школах и институтах вне значимости от профиля или направления обучения; анонимные чаты поддержки детей и подростков, подвергшихся атакам (A, Z - поколения). 2) Корпоративные треннинги по важности открытости в работе; группы по восстановлению доверия после инцидентов (Z, Y, X - поколения). 3) Простые правила на бумажном носителе по безопасному поведения в компьютерных сетях; личные консультации по обнаружению скрытых угроз в сети (B-поколение).
Разрушение данных и систем	1) Активация аварийных протоколов восстановления. 2) Развертывание мобильных групп технической поддержки. 3) Создание временных рабочих сред для продолжения деятельности.	1) Игровые тренировки по восстановлению уничтоженных элементов, в том числе; анонимные терапии для снятия стресса после потери цифровых материалов для детей и подростков. 2) Корпоративные треннинги по повышению цифровой устойчивости; профессиональные группы поддержки после потери рабочих данных (Z, Y, X - поколения). 3) Помощь волонтеров в процессе восстановления утерянных данных для пожилых людей; упрощенные рекомендации по резервированию (B-поколение).

Продолжение таблицы 45

Инцидент безопасности	Технические меры ликвидации последствий	Социальные меры ликвидации последствий (уникально для поколений)
Злоупотребление доверительными отношениями	1) Временный пересмотр всех доверительных отношений в системе. 2) Введение дополнительных проверок для критичных операций. 3) Создание системы "социального контроля" за использованием доверия. 4) Организация тренингов по распознаванию манипуляций.	1) Активности в школах и институтах по распознаванию манипуляций; психологические треннинги по установлению здоровых границ в сети (A, Z - поколения). 2) Корпоративные программы с разбором кейсов злоупотреблений доверительными отношениями; групповая терапия для восстановления коллективного доверия после инцидентов (Z, Y, X - поколения). 3) Простые правила проверки собеседников (B-поколение).
Разведка внутренней среды	1) Изменение конфигураций системы для затруднения разведки. 2) Введение системы ложных целей для дезориентации злоумышленников. 3) Создание механизма быстрого обнаружения сканирующих действий. 4) Организация тренингов по обнаружению признаков разведки.	1) Популяризация в учебных заведения образовательных активностей по обнаружению киберслежки; терапия по установлению личных границ в цифровом пространстве (A, Z - поколения). 2) Корпоративные практикумы по обнаружению слежки; группы поддержки для сотрудников, ставших жертвами слежки (Z, Y, X - поколения). 3) Личные консультации по обнаружению признаков слежения; продвижение простых инструкций по защите от слежки для пенсионеров (B-поколение).

После ликвидации последствий инцидента критически важно провести тщательный анализ причин и условий его возникновения. Это позволяет не просто устранить симптомы проблемы, а понять, что является ключом к предотвращению повторных аналогичных инцидентов. Выявление причинно-следственных связей помогает организациям и отдельным пользователям перейти от реактивной к проактивной модели безопасности, где усилия направлены на устранение уязвимостей до их эксплуатации злоумышленниками. Такой анализ должен охватывать как технические аспекты (уязвимости в ПО, ошибки конфигурации), так и человеческий фактор (нарушения политик безопасности, недостаточную осведомлённость пользователей).

Таким образом, только такое комплексное рассмотрение причин и условий инцидента обеспечивает полноценный цикл управления информационными рисками, превращая каждый произошедший инцидент в набор регламентов для повышения общей устойчивости к атакам класса “Социальная инженерия”. Именно поэтому необходимо построить таблицу 46 – причины возникновения инцидентов безопасности [40, 74].

Таблица 46 – Причины возникновения инцидентов безопасности

Инцидент	Технические причины возникновения	Социальные причины возникновения
Фишинг и сбор информации	Отсутствие фильтрации спама/фишинга на почтовых серверах; уязвимости в веб-браузерах (переход по опасным ссылкам); недостаточная защита DNS (поддельные домены).	Чрезмерное доверие пользователей к официально выглядящим письмам (особенно X, B поколения); недостаток цифровой грамотности (A, Z поколения - невнимательность; X, B - незнание угроз); психологическая уязвимость к срочным/угрожающим сообщениям.
Компрометация учетных записей	Слабые/повторяющиеся пароли; отсутствие MFA (многофакторной аутентификации); уязвимости в системах аутентификации.	Использование личных данных в паролях (даты рождения, имена); небрежное хранение учетных данных (записи на бумаге у X, B); социальная инженерия (злоумышленники выдают себя за техподдержку).
Кража учетных данных и токенов	Техническая возможность проведения MITM-атаки; уязвимости в OAuth-реализациях; небезопасное хранение токенов в браузере.	Переход по фишинговым ссылкам "обновить учетные данные"; использование публичных компьютеров для доступа к важным аккаунтам; непонимание важности токенов безопасности (особенно у X, B - поколений).
Внедрение вредоносного кода	Необновленное ПО с известными уязвимостями; отсутствие EDR-решений; уязвимости в механизмах загрузки файлов.	Скачивание "взломанного" ПО (особенно Z поколение); открытие вложений от неизвестных отправителей (X, B поколения); использование неофициальных репозиториев/магазинов приложений.
Эскалация привилегий	Ошибки контроля доступа (например, вертикальный privilege escalation); уязвимости в сервисах, работающих с повышенными привилегиями; неправильная настройка групповых политик.	Чрезмерное доверие к сотрудникам (Y поколение в офисах); непонимание принципа минимальных привилегий; использование административных учетных записей для повседневных задач.
Сбор и эксфильтрация данных	Недостаточное шифрование данных; отсутствие DLP-систем; уязвимости в API передачи данных.	Небрежное обращение с данными (отправка конфиденциальной информации в личных чатах); непонимание ценности данных (особенно

Продолжение таблицы 46

Инцидент	Технические причины возникновения	Социальные причины возникновения
		у А поколения в соцсетях); использование личных облаков для рабочих файлов (Y поколение).
Сокрытие активности	Отсутствие мониторинга журналов событий; уязвимости, позволяющие очищать логи; недостатки в системах аудита.	Намеренное сокрытие ошибок/инцидентов сотрудниками (страх наказания); культура "замалчивания проблем" в организациях; непонимание важности журналирования (особенно у X поколения).
Разрушение данных и систем	Отсутствие резервного копирования; уязвимости в системах хранения данных; недостатки в управлении правами доступа.	Саботаж недовольных сотрудников (Y поколение в корпорациях); неосторожные действия с критическими системами (B поколение); игнорирование процедур безопасного удаления данных.
Злоупотребление доверительными отношениями	Слабые механизмы проверки доверенных подключений; уязвимости в системах SSO; недостатки в управлении сертификатами.	Слепое доверие к "официальным" запросам (особенно X, B поколения); культура "не перепроверять" коллег/партнеров; психологические манипуляции (имитация срочности/авторитетности).
Разведка внутренней среды	Открытые информационные системы без аутентификации; уязвимости, позволяющие перечислять пользователей/ресурсы; недостатки в системах обнаружения сканирования.	Излишняя открытость сотрудников в соцсетях (Z поколение); непонимание рисков избыточного делегирования информации; культура "покажи все" при демонстрации систем новичкам.

Исходя из сформированных сценариев, можно сказать, что при грамотном применении регламентов обнаружения и реагирования атака будет остановлена на этапе, ближайшем к начали и имеющем в себе наименьшее количество техник. Поэтому, также как и ранее, необходимо более подробно расписать инструкции для “узких мест”, то есть этапов, до которых наиболее вероятно дойдет злоумышленник, после чего в идеальном (для защищающегося) сценарии – вторжение будет предотвращено.

Как и ранее начать стоит с шаблона CAPEC-98. В рассматриваемом шаблоне в идеальных условиях злоумышленник может успеть реализовать технику T1534. Техника имеет 3 уязвимости, для которых целесообразнее всего рассмотреть план мероприятий по ликвидации: CVE-2023-5561, CVE-2021-44168, CVE-2023-36874. Для CVE-2023-5561 – необходимо обновить учетные данные адресов пользователей и

сбросить привилегии. Для устранения последствий использования CVE-2021-44168 – рекомендуется зашифровывать код с помощью надёжной схемы шифрования перед передачей, использовать проверенную библиотеку или фреймворк, который не позволяет злоумышленнику реализовать эту уязвимость [100]. Для CVE-2023-36874 – достаточно оповестить о всех затронутых инъекцией сегментах и применить обновления безопасности или прекратить использование настоящей базы.

В шаблоне CAPEC-163 интересен к рассмотрению с точки зрения обеспечения информационной безопасности этап реализации (тактика) – “Подготовка ресурсов”. В технике T1586 есть две уникальные уязвимости CVE-2019-14287 и CVE-2022-26925. Для CVE-2019-14287 – будет достаточно устранить все нестандартные настройки Linux-устройств, так как уязвимость возникает при индивидуальных настройках, а также оповестить о затронутых сегментах. Для ликвидации последствий эксплуатации CVE-2022-26925 – необходимо завершить все ранее новые сессии и добавить механизмы дополнительных проверок при аутентификации, помимо этого необходимо оповестить затронутые стороны и применить обновления безопасности.

В шаблоне CAPEC-164, будучи единственной в рамках тактики ближайшей к логическому началу шаблона реализации, интересна техника – T1204. В рамках техники есть 3 уязвимости: CVE-2021-21132, CVE-2021-30657, CVE-2021-44168. Для CVE-2021-21132 – необходимо получить информацию об ущербе, полученном при реализации атаки, проверить все установленные расширения, проверить систему на наличие вредоносного ПО. Для CVE-2021-30657 – установить соответствующую версии Catalina, использовать Gatekeeper и XProtect, для проверки всех установленных приложений, проверить целостность системы, обновление политик. Для CVE-2021-44168 – рекомендации по ликвидации последствий описывались ранее по тексту.

Для CAPEC-656 также будет рассмотрена техника – T1204. В технике 4 уязвимости: CVE-2021-21132, CVE-2021-30657, CVE-2021-44168, CVE-2019-1563. Для CVE-2019-1563 необходимо усилить безопасность с помощью приватных RSA ключей, а также в принципе заменить все имеющиеся ключи. Ликвидация последствий для 2021-21132, CVE-2021-30657, CVE-2021-44168 была представлена в описании шаблонов CAPEC-98 – CAPEC-164.

Для CAPEC-630 рассматриваемая тактика – “Подготовка ресурсов”, а техника – T1584. В технике есть 3 уязвимости CVE-2022-40684, CVE-2017-0057, CVE-2023-38497. Для CVE-2022-40684 – необходимо сменить все администраторские пароли, в качестве мер по ликвидации последствий, а также удалить все SSH-ключи, назначенные администраторам, если их подлинность вызывает сомнения. Для CVE-2017-0057 – необходимо полностью переработать аспекты политики безопасности, касающиеся DNS. Для CVE-2023-38497 – необходимо изменить права доступа к директории ~/.cargo, очистить кэш, провести анализ системы на предмет нанесенного ущерба.

Для CAPEC-194 целесообразно рассмотреть этап – “Первоначальный доступ” и технику – T1566, содержащую 4 уязвимости: CVE-2021-21135, CVE-2020-10136, CVE-2019-0633, CVE-2017-7821. Для CVE-2021-21135 – установить систему контроля и ограничения исполняемых скриптов, так как уязвимость позволяет злоумышленнику получать данные с помощью подставной страницы. Для CVE-2021-21135 – необходимо пересмотреть политики безопасности в части, касающейся обработки данных из различных источников, чтобы предотвратить подобные утечки в будущем. Для CVE-2020-10136 – строго фильтровать трафика IP-in-IP, анализировать все последствия и нанесенный ущерб. Для CVE-2019-0633 – как можно быстрее восстановить обмен данными в локальной сети, заменить альтернативными SMBv2, а также проанализировать ущерб. Для CVE-2017-7821 обязательное обновить все экземпляры Mozilla до версии 56 и выше, если техническое оборудование не предоставляет такой возможности, то заменить оборудования, а также проверить системы на вредоносное ПО.

Для CAPEC-504: тактика – “Подготовка ресурсов”, техника – T1584. Уязвимости: CVE-2018-13382, CVE-2022-26925, CVE-2021-26291, CVE-2020-0683. Для CVE-2018-13382 – проанализировать скомпрометированные данные, сменит пароли пользователей, использующих локальную аутентификацию, ограничить доступа к SSL VPN через интернет. Для CVE-2022-26925 – проанализировать журналы безопасности на события связанные с LSARPC и NTLM-аутентификацией (поможет проанализировать ущерб), усилить мониторинг для отслеживания аномалий, для предотвращения подобного в будущем. Для CVE-2021-26291 – проанализировать используемые HTTP-

репозитории, переработать аспекты политики безопасности, связанные с использованием непроверенных репозиториев. Для CVE-2020-0683 – сбросить привилегии пользователей, проанализировать логи или журналы для выявления затронутых элементов (запуск MSI-пакетов и т.д.).

Шаблон CAPEC-173 примечателен тем, при идеальном развитии событий злоумышленник сможет реализовать только самый первый этап (тактику) – “Разведка” и лишь одну технику – T1592. Техника имеет 3 уязвимости: CVE-2021-36942, CVE-2023-49084, CVE-2024-22017. Для CVE-2021-36942 – достаточно заменить контроллер домена на альтернативной, работающий на протоколах, которые являются заменой EFSRPC, а также произвести анализ на предмет нанесенного ущерба. Для CVE-2023-49084 – необходимо обновить все экземпляры Cacti до неуязвимой версии, проверить журналы веб-сервера и базы данных на наличие активности, связанной с link.php, для выявления затронутых деталей, а также ограничить доступ к административному интерфейсу Cacti. Для CVE-2024-22017 – необходимо усилить контроль за установкой приложений, например, строгой настройкой замкнутой программной среды.

В рамках CAPEC-698 необходимо рассмотреть технику – T1584, с уязвимостью CVE-2024-38143. В случае с этой уязвимостью необходимо проверить журналы на наличие подозрительной активности, связанной с WLAN AutoConfig для понимания целей злоумышленника и понимания ущерба. Усилить физическую безопасности, а также полностью сбросить и ограничить права пользователей.

В случае с CAPEC-410, в идеальном для защищающихся случае, атака завершится реализацией T1584 в тактике – “Подготовка ресурсов”. Уязвимости: CVE-2023-35325, CVE-2017-0022, CVE-2016-2106. Для CVE-2023-35325 – необходимо понимать, какие данные о системе или пользователях были раскрыты, усилить мониторинг логов службы Print Spooler. Для CVE-2017-0022 – необходимо осуществить проверку системы на наличие признаков эксплуатации уязвимости, особенно если пользователи посещали подозрительные веб-сайты, а также отключить ActiveX и других устаревших технологии, особенно в Internet Explorer. Для CVE-2016-2106 – проверить систему на наличие признаков эксплуатации уязвимости, таких как неожиданные сбои

или аномальное поведение приложений, использующих OpenSSL, это должно помочь характеризовать полученный в результате атаки ущерб, а также настроить системы мониторинга для отслеживания аномальной активности, связанной с использованием OpenSSL. (CVE-2018-13382 и CVE-2022-40684 упоминалась ранее по тексту).

В рамках шаблона CAPEC-631 целесообразно рассмотреть тактику – “Подготовка ресурсов” и технику – T1584. Уязвимости: CVE-2022-40684, CVE-2017-0057, CVE-2023-38497. Описание мер по ликвидации последствий приводилось в абзаце, посвящённом ликвидации последствий от реализации тактик и техник шаблона CAPEC-630 ранее по тексту.

Далее по списку идет шаблон CAPEC-151. В текущем шаблоне рассматривается тактика – “Исполнение” и техника – T1204. В технике есть уязвимости CVE-2021-21132 или CVE-2019-1563. Для CVE-2019-1563 – необходимо проанализировать журналы систем и приложений на предмет подозрительной активности, связанной с множественными попытками расшифровки сообщений, это поможет оценить объем скомпрометированных данных. Меры по ликвидации последствий для CVE-2021-21132 уже были описаны ранее.

Для CAPEC-89 и CAPEC-654 наиболее рациональным будет решение рассмотреть технику – T1584. Уязвимость – CVE-2023-36851. Для ликвидации последствий, как и в большинстве других уязвимостей необходимо понять уровень серьезности ущерба, нанесенного в результате реализации атаки с использованием данной уязвимости. Это возможно сделать, проанализировав журналы системы на предмет подозрительной активности, связанной с J-Web, особенно обращений к webauth_operation.php, другие уязвимости уже упоминались и описывались ранее, также необходимо провести анализ целостности файловой системы и проверку на остаточно вредоносное воздействие [44-49, 93-98].

Таким образом, для всех шаблонов реализации рассмотрены тактики, на которые делался акцент при разработке мер наиболее рационального противодействия (обнаружение/реагирование) атакам класса “Социальная инженерия”. Получается, что, добравшись до текущей тактики (этапа) → техники, она станет последним “пунктом” атаки, после чего в идеальном случае – атака будет предотвращена.

Важным уточнением является то, что текущие меры ликвидации последствий актуальны только для техник, которые предполагаются последней инстанцией в попытке атаки злоумышленника. Эти меры являются оперативными и ликвидируют лишь “свежие последствия”, однако не во всех шаблонах атака завершается на первом этапе, это говорит о том, что в попытке устроить вторжение, злоумышленник мог реализовать несколько предшествующих этапов (эта проблема частично решается разбором мер противодействия для единичных уязвимостей, имеющих наибольшую вероятность эксплуатации). Это значит, что в рамках разработки программного обеспечения со встроенной аналитикой необходимо рассмотреть ликвидацию последствий не только для последней реализованной техники, а для любой техники (а значит и для каждого уникального сочетания техника → уязвимость) в целом.

Далее необходимо осветить не просто наиболее рациональные пути ликвидации последствий, а меры по ликвидации, учитывающие эксплуатацию уязвимостей, имеющих наибольшее значение вероятности эксплуатации (таблица 47).

Таблица 47 – Меры оперативной ликвидации последствий для уязвимостей с наибольшим значением вероятности

Тактика	Техника	CVE	Первоочередные меры реагирования
CAPEC-98			
Разведка	(T1589)	CVE-2018-15473	Ограничить доступ к SSH, используя файрволы и модули, такие как xt_recent, чтобы предотвратить перечисление пользователей.
Подготовка ресурсов	(T1586)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Первоначальный доступ	(T1189)	CVE-2021-26291	Проверить и обновить все зависимости Maven, особенно те, которые используют небезопасные HTTP-репозитории, чтобы исключить возможность загрузки вредоносных артефактов.

Тактика	Техника	CVE	Первоочередные меры реагирования
Исполнение	(T1053)	CVE-2024-20666	Переустановить среду восстановления Windows (WinRE) с помощью предоставленного Microsoft PowerShell-скрипта, чтобы устранить возможность обхода BitLocker.
Закрепление	(T1053)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Повышение привилегий	(T1548)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Предотвращение обнаружения	(T1070)	CVE-2021-3197	Проверить конфигурации SaltStack Salt на наличие небезопасных параметров ProxyCommand и ssh_options, удалить или обезвредить их, чтобы предотвратить внедрение команд.
Получение учетных данных	(T1606)	CVE-2023-5561	Ограничить доступ к REST API WordPress, особенно к полям пользователей, и убедиться, что только авторизованные пользователи могут выполнять соответствующие запросы.
Обнаружение	(T1033)	CVE-2018-14847	Провести аудит конфигурации MikroTik RouterOS, удалить неизвестные или подозрительные настройки, и установить сильные пароли для всех учетных записей.
Боковое смещение	(T1534)	CVE-2023-36874	Проверить журналы Windows Error Reporting на предмет подозрительной активности и ограничить доступ к этой службе для неавторизованных пользователей.
Сбор данных	(T1217)	CVE-2019-17563	Провести аудит всех приложений, использующих Apache Struts, на предмет небезопасной десериализации, и внедрить фильтры для входящих данных, чтобы предотвратить эксплуатацию.
Командование и управление	(T1102)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Эксфильтрация	(T1567)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Удар	(T1561)	CVE-2016-0046	Проверить журналы .NET Framework на предмет отказов в обслуживании и убедиться, что все приложения корректно обрабатывают исключения, чтобы предотвратить сбои.
CAPEC-163			
Разведка	(T1598)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Подготовка ресурсов	(T1586)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Первоначальный доступ	(T1189)	CVE-2019-0633	Отключить SMBv2, если он не используется, и ограничить доступ к SMB-сервисам через брандмауэр для предотвращения удаленного выполнения кода.
Исполнение	(T1053)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Закрепление	(T1053)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Повышение привилегий	(T1068)	CVE-2021-3197	Проверить конфигурации SaltStack Salt на наличие небезопасных параметров ProxyCommand и ssh_options, удалить или обезвредить их, чтобы предотвратить внедрение команд.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Добавить переменные среды SUDO_EDITOR, VISUAL и EDITOR в список env_delete в файле sudoers, чтобы предотвратить их использование при выполнении команд.
Получение учетных данных	(T1528)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Обнаружение	(T1558)	CVE-2019-0633	Отключить SMBv2, если он не используется, и ограничить доступ к SMB-сервисам через брандмауэр для предотвращения удаленного выполнения кода.

Тактика	Техника	CVE	Первоочередные меры реагирования
Боковое смещение	(T1534)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Сбор данных	(T1025)	CVE-2022-44268	Ограничить доступ к ImageMagick и внедрить политику безопасности, запрещающую чтение произвольных файлов при обработке изображений.
Командование и управление	(T1095)	CVE-2011-3544	Отключить или ограничить использование Java Applets в браузерах и системах для предотвращения выполнения произвольного кода через уязвимость в Java.
Эксфильтрация	(T1567)	CVE-2019-12643	Отключить или ограничить доступ к Cisco REST API и внедрить аутентификацию для предотвращения несанкционированного доступа.
Удар	(T1486)	CVE-2023-37266	Ограничить доступ к уязвимым компонентам и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
CAPEC-164			
Разведка	(T1592)	CVE-2022-30295	Ограничить использование уязвимых версий uClibc/uClibc-ng и внедрить DNSSEC для предотвращения отравления DNS-кэша.
Подготовка ресурсов	(T1586)	CVE-2020-0683	Проверить системные журналы на наличие подозрительной активности, связанной с установкой MSI, и ограничить права доступа к установочным каталогам.
Первоначальный доступ	(T1199)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Исполнение	(T1204)	CVE-2021-21132	Удалить или отключить подозрительные расширения Chrome, особенно те, которые используют DevTools, и проверить системы на наличие признаков выхода из песочницы.
Закрепление	(T1078)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.

Тактика	Техника	CVE	Первоочередные меры реагирования
Повышение привилегий	(T1098)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Добавить переменные среды SUDO_EDITOR, VISUAL и EDITOR в список env_delete в файле sudoers, чтобы предотвратить их использование при выполнении команд.
Получение учетных данных	(T1606)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Обнаружение	(T1614)	CVE-2023-35325	Отключить или ограничить доступ к службе печати Windows Print Spooler и проверить журналы на наличие подозрительной активности, связанной с утечкой информации.
Боковое смещение	(T1534)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Сбор данных	(T1056)	CVE-2021-28169	Проверить конфигурации Apache Tomcat на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Командование и управление	(T1102)	CVE-2019-12643	Отключить или ограничить доступ к Cisco REST API и внедрить аутентификацию для предотвращения несанкционированного доступа.
Эксфильтрация	(T1011)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Удар	(T1485)	CVE-2014-3153	Проверить журналы ядра Linux на наличие признаков эксплуатации уязвимости и ограничить доступ к системам, где возможна эксплуатация.
CAPEC-656			
Разведка	(T1589)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Подготовка ресурсов	(T1586)	CVE-2021-26291	Проверить и обновить все зависимости Maven, особенно те, которые используют небезопасные HTTP-репозитории, чтобы исключить возможность загрузки вредоносных артефактов.
Первоначальный доступ	(T1199)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Исполнение	(T1204)	CVE-2021-44168	Ограничить доступ к команде execute restore src-vis в FortiOS и внедрить проверку целостности для предотвращения загрузки произвольных файлов.
Закрепление	(T1136)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Повышение привилегий	(T1098)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Добавить переменные среды SUDO_EDITOR, VISUAL и EDITOR в список env_delete в файле sudoers, чтобы предотвратить их использование при выполнении команд.
Получение учетных данных	(T1649)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Обнаружение	(T1614)	CVE-2022-30295	Ограничить использование уязвимых версий uClibc/uClibc-ng и внедрить DNSSEC для предотвращения отравления DNS-кэша.
Боковое смещение	(T1550)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Сбор данных	(T1125)	CVE-2021-30682	Ограничить доступ к уязвимым компонентам WebKit и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.

Тактика	Техника	CVE	Первоочередные меры реагирования
Командование и управление	(T1105)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Эксфильтрация	(T1029)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Удар	(T1565)	CVE-2021-25281	Ограничить доступ к уязвимым компонентам в SaltStack и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
CAPEC-630			
Разведка	(T1592)	CVE-2022-23614	Проверить шаблоны Twig на использование фильтра sort с небезопасными параметрами и ограничить выполнение небезопасных функций в песочнице.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Первоначальный доступ	(T1566)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Исполнение	(T1204)	CVE-2021-21132	Удалить или отключить подозрительные расширения Chrome, особенно те, которые используют DevTools, и проверить системы на наличие признаков выхода из песочницы.
Закрепление	(T1176)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Повышение привилегий	(T1068)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Проверить системные журналы на признаки эксплуатации уязвимости в ядре Windows и ограничить доступ к уязвимым системам.

Тактика	Техника	CVE	Первоочередные меры реагирования
Получение учетных данных	(T1649)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Обнаружение	(T1069)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Боковое смещение	(T1534)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Сбор данных	(T1114)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Командование и управление	(T1102)	CVE-2019-12643	Отключить или ограничить доступ к Cisco REST API и внедрить аутентификацию для предотвращения несанкционированного доступа.
Эксфильтрация	(1041)	CVE-2022-44268	Ограничить доступ к ImageMagick и внедрить политику безопасности, запрещающую чтение произвольных файлов при обработке изображений.
Удар	(T1485)	CVE-2021-22204	Ограничить использование ExifTool для обработки непроверенных изображений и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
CAPEC-194			
Разведка	(T1598)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Подготовка ресурсов	(T1585)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Первоначальный доступ	(T1566)	CVE-2017-7821	Отключить или ограничить использование уязвимых расширений WebExtensions в Firefox и внедрить фильтрацию входных данных для предотвращения загрузки вредоносных файлов.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Исполнение	(T1204)	CVE-2021-21132	Удалить или отключить подозрительные расширения Chrome, особенно те, которые используют DevTools, и проверить системы на наличие признаков выхода из песочницы.
Закрепление	(T1136)	CVE-2023-30861	Настроить кэш-прокси для удаления cookie, отключить session.permanent = True и установить заголовок Cache-Control: no-store для предотвращения утечки сессионных данных.
Повышение привилегий	(T1078)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Ограничить доступ к уязвимым системам и внедрить мониторинг системных журналов на признаки эксплуатации уязвимости Win32k.
Получение учетных данных	(T1556)	CVE-2023-3676	Ограничить возможность создания подов на Windows-нодах в Kubernetes и внедрить фильтрацию входных данных для предотвращения выполнения произвольных команд.
Обнаружение	(T1217)	CVE-2024-29988	Ограничить загрузку и выполнение файлов из ненадежных источников и внедрить политику безопасности, запрещающую обход SmartScreen.
Боковое смещение	(T1534)	CVE-2024-38143	Проверить конфигурации системы на наличие небезопасных настроек и ограничить доступ к уязвимым компонентам.
Сбор данных	(T1114)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Командование и управление	(T1102)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Эксфильтрация	(T1029)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.

Тактика	Техника	CVE	Первоочередные меры реагирования
Удар	(T1485)	CVE-2021-22204	Ограничить использование ExifTool для обработки непроверенных изображений и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
CAPEC-504			
Разведка	(T1589)	CVE-2021-3197	Проверить конфигурации SaltStack Salt на наличие небезопасных параметров ProxyCommand и ssh_options, удалить или обезвредить их, чтобы предотвратить внедрение команд.
Подготовка ресурсов	(T1584)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Первоначальный доступ	(T1199)	CVE-2019-1322	Ограничить права доступа к службе Update Orchestrator, удалив полные права у группы SERVICE.
Исполнение	(T1204)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Закрепление	(T1053)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Повышение привилегий	(T1546)	CVE-2023-36874	Проверить журналы Windows Error Reporting на предмет подозрительной активности и ограничить доступ к этой службе для неавторизованных пользователей.
Предотвращение обнаружения	(T1564)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Получение учетных данных	(T1556)	CVE-2019-3978	Ограничить доступ к порту 8291 в MikroTik RouterOS и очистить кэш DNS для предотвращения отравления кэша.
Обнаружение	(T1016)	CVE-2016-0046	Проверить журналы .NET Framework на предмет отказов в обслуживании и убедиться, что все приложения корректно обрабатывают исключения, чтобы предотвратить сбои.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Боковое смещение	x	x	x
Сбор данных	(T1025)	CVE-2020-10136	Проверить системные журналы на признаки эксплуатации уязвимости в ядре Windows и ограничить доступ к уязвимым системам.
Командование и управление	(T1105)	CVE-2021-26291	Проверить и обновить все зависимости Maven, особенно те, которые используют небезопасные HTTP-репозитории, чтобы исключить возможность загрузки вредоносных артефактов.
Эксфильтрация	(T1041)	CVE-2019-0804	Проверить системные журналы на признаки эксплуатации уязвимости в ядре Windows и ограничить доступ к уязвимым системам.
Удар	(T1565)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
CAPEC-173			
Разведка	(T1592)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Подготовка ресурсов	(T1584)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Первоначальный доступ	(T1189)	CVE-2023-6208	Ограничить использование Firefox и Thunderbird на системах с X11 до обновления до версии, устраняющей уязвимость, и внедрить политику безопасности, запрещающую автоматическое копирование данных в буфер обмена.
Исполнение	(T1059)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Закрепление	(T1053)	CVE-2024-38476	Проверить конфигурации Apache HTTP Server на наличие небезопасных настроек, особенно использование директивы 'AddType', и заменить её на 'SetHandler' для предотвращения SSRF и выполнения локальных скриптов.
Повышение привилегий	(T1546)	CVE-2019-1405	Ограничить доступ к службе UPnP и внедрить мониторинг системных журналов на признаки эксплуатации уязвимости.

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Предотвращение обнаружения	(T1221)	CVE-2019-0633	Отключить SMBv2, если он не используется, и ограничить доступ к SMB-сервисам через брандмауэр для предотвращения удаленного выполнения кода.
Получение учетных данных	(T1556)	CVE-2020-0836	Ограничить доступ к DNS-серверу из ненадежных источников и внедрить фильтрацию входящих DNS-запросов для предотвращения отказа в обслуживании.
Обнаружение	(T1518)	CVE-2024-29988	Ограничить загрузку и выполнение файлов из ненадежных источников и внедрить политику безопасности, запрещающую обход SmartScreen.
Боковое смещение	x	x	x
Сбор данных	(T1056)	CVE-2023-36874	Проверить журналы Windows Error Reporting на предмет подозрительной активности и ограничить доступ к этой службе для неавторизованных пользователей.
Командование и управление	(T1105)	CVE-2019-0633	Отключить SMBv2, если он не используется, и ограничить доступ к SMB-сервисам через брандмауэр для предотвращения удаленного выполнения кода.
Эксфильтрация	(1041)	CVE-2020-0836	Ограничить доступ к DNS-серверу из ненадежных источников и внедрить фильтрацию входящих DNS-запросов для предотвращения отказа в обслуживании.
Удар	(T1565)	CVE-2024-29988	Ограничить загрузку и выполнение файлов из ненадежных источников и внедрить политику безопасности, запрещающую обход SmartScreen.
CAPEC-698			
Разведка	(T1598)	CVE-2023-3676	Ограничить возможность создания подов на Windows-нодах в Kubernetes для пользователей без необходимости и проверить журналы на признаки выполнения команд от имени Kubelet.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Первоначальный доступ	(T1189)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Исполнение	(T1059)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Закрепление	(T1176)	CVE-2023-36874	Проверить журналы Windows Error Reporting на предмет подозрительной активности и ограничить доступ к этой службе для неавторизованных пользователей.
Повышение привилегий	(T1546)	CVE-2019-0633	Отключить SMBv2, если он не используется, и ограничить доступ к SMB-сервисам через брандмауэр для предотвращения удаленного выполнения кода.
Предотвращение обнаружения	(T1564)	CVE-2023-22809	Добавить переменные среды SUDO_EDITOR, VISUAL и EDITOR в список env_delete в файле sudoers, чтобы предотвратить их использование при выполнении команд.
Получение учетных данных	(T1649)	CVE-2023-36851	Ограничить доступ к J-Web на устройствах Juniper SRX и EX Series и проверить журналы на несанкционированные операции с файлами через webauth_operation.php.
Обнаружение	(T1217)	CVE-2021-21134	Проверить конфигурации Chrome на наличие небезопасных настроек и ограничить доступ к уязвимым компонентам.
Боковое смещение	(T1534)	CVE-2023-3676	Ограничить возможность создания подов на Windows-нодах в Kubernetes для пользователей без необходимости и проверить журналы на признаки выполнения команд от имени Kubelet.
Сбор данных	(T1056)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Командование и управление	(T1105)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Эксфильтрация	(T1011)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.

Тактика	Техника	CVE	Первоочередные меры реагирования
Удар	(T1565)	CVE-2023-30861	Проверить конфигурации системы на наличие небезопасных настроек и ограничить доступ к уязвимым компонентам.
CAPEC-410			
Разведка	(T1589)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Первоначальный доступ	(T1189)	CVE-2019-12086	Отключить использование Default Typing в Jackson Databind и удалить уязвимые версии mysql-connector-java из classpath.
Исполнение	(T1204)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Закрепление	(T1078)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Повышение привилегий	(T1098)	CVE-2023-30861	Отключить кэширование сессий в Flask-приложениях и установить заголовки Cache-Control для предотвращения утечек сессионных данных.
Предотвращение обнаружения	(T1070)	CVE-2021-25281	Ограничить доступ к уязвимым компонентам в SaltStack и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
Получение учетных данных	(T1134)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Обнаружение	(T1217)	CVE-2019-12643	Отключить или ограничить доступ к Cisco REST API и внедрить аутентификацию для предотвращения несанкционированного доступа.

Продолжение таблицы 47

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Боковое смещение	x	x	x
Сбор данных	(T1119)	CVE-2021-30682	Ограничить доступ к уязвимым компонентам WebKit и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
Командование и управление	(T1095)	CVE-2011-3544	Отключить или ограничить использование Java Applets в браузерах и системах для предотвращения выполнения произвольного кода через уязвимость в Java.
Эксфильтрация	(T1011)	CVE-2023-35325	Отключить или ограничить доступ к службе печати Windows Print Spooler и проверить журналы на наличие подозрительной активности, связанной с утечкой информации.
Удар	(T1565)	CVE-2021-25281	Ограничить доступ к уязвимым компонентам в SaltStack и внедрить фильтрацию входных данных для предотвращения выполнения произвольного кода.
CAPEC-631			
Разведка	(T1592)	CVE-2022-23614	Проверить шаблоны Twig на наличие вредоносных конструкций и ограничить использование пользовательских функций сортировки.
Подготовка ресурсов	(T1584)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Первоначальный доступ	(T1566)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Исполнение	(T1204)	CVE-2021-21132	Удалить или отключить подозрительные расширения Chrome, особенно те, которые используют DevTools, и проверить системы на наличие признаков выхода из песочницы.
Закрепление	(T1176)	CVE-2019-1405	Ограничить доступ к службе UPnP и проверить журналы на признаки эскалации привилегий через COM-объекты.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Повышение привилегий	(T1068)	CVE-2020-0683	Проверить системные журналы на наличие подозрительной активности, связанной с установкой MSI, и ограничить права доступа к установочным каталогам.
Предотвращение обнаружения	(T1564)	CVE-2019-1458	Проверить системные журналы на признаки эксплуатации уязвимости в компоненте Win32k и ограничить доступ к уязвимым системам.
Получение учетных данных	(T1649)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Обнаружение	(T1069)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
Боковое смещение	(T1534)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Сбор данных	(T1114)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Командование и управление	(T1102)	CVE-2019-12643	Отключить или ограничить доступ к Cisco REST API и внедрить аутентификацию для предотвращения несанкционированного доступа.
Эксфильтрация	(1041)	CVE-2022-44268	Ограничить доступ к ImageMagick и внедрить политику безопасности, запрещающую чтение произвольных файлов при обработке изображений.
Удар	(T1485)	CVE-2021-22204	Проверить журналы ExifTool на несанкционированные действия и ограничить доступ к уязвимым системам.
CAPEC-151			
Разведка	(T1598)	CVE-2020-4046	Обновить WordPress до версии 5.4.2 или выше, чтобы устранить возможность XSS-атаки через блоки embed .
Подготовка ресурсов	(T1585)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Первоначальный доступ	(T1199)	CVE-2022-26925	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Исполнение	(T1204)	CVE-2021-21132	Удалить или отключить подозрительные расширения Chrome, особенно те, которые используют DevTools, и проверить системы на наличие признаков выхода из песочницы.
Закрепление	(T1136)	CVE-2024-38213	Установить последние обновления безопасности от Microsoft, активировать функции Enhanced Security, ограничить привилегии пользователей и внедрить мониторинг целостности файлов для обнаружения несанкционированных изменений.
Повышение привилегий	(T1078)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Предотвращение обнаружения	(T1656)	CVE-2023-22809	Добавить переменные среды SUDO_EDITOR, VISUAL и EDITOR в список env_delete в файле sudoers, чтобы предотвратить их использование при выполнении команд.
Получение учетных данных	(T1649)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Обнаружение	(T1087)	CVE-2018-15473	Ограничить доступ к SSH, используя файрволы и модули, такие как xt_recent, чтобы предотвратить перечисление пользователей.
Боковое смещение	(T1534)	CVE-2019-9787	Внедрить CSRF-токены и хэш-подписи в формы комментариев WordPress для предотвращения несанкционированных изменений.
Сбор данных	(T1025)	CVE-2022-44268	Ограничить доступ к ImageMagick и внедрить политику безопасности, запрещающую чтение произвольных файлов при обработке изображений.
Командование и управление	(T1102)	CVE-2019-12643	Отключить или ограничить доступ к Cisco REST API и внедрить аутентификацию для предотвращения несанкционированного доступа.

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Эксфильтрация	(T1567)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Удар	(T1495)	CVE-2011-3544	Отключить или ограничить использование Java Applets в браузерах и системах для предотвращения выполнения произвольного кода через уязвимость в Java.
CAPEC-89			
Разведка	(T1592)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Первоначальный доступ	(T1199)	CVE-2023-3676	Ограничить возможность создания подов на Windows-нодах в Kubernetes для пользователей без необходимости и проверить журналы на признаки выполнения команд от имени Kubelet.
Исполнение	(T1204)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Закрепление	x	x	x
Повышение привилегий	(T1548)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Предотвращение обнаружения	(T1221)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Получение учетных данных	(T1558)	CVE-2019-3978	Ограничить доступ к порту 8291 в MikroTik RouterOS и очистить кэш DNS для предотвращения отравления кэша.

Тактика	Тех-ника	CVE	Первоочередные меры реагирования
Обнаружение	(T1046)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Боковое смещение	(T1534)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Сбор данных	(T1025)	CVE-2024-38476	Проверить конфигурации Apache HTTP Server на наличие небезопасных настроек, особенно использование директивы 'AddType', и заменить её на 'SetHandler' для предотвращения SSRF и выполнения локальных скриптов.
Командование и управление	(T1102)	CVE-2019-1405	Ограничить доступ к службе UPnP и проверить журналы на признаки эскалации привилегий через COM-объекты.
Эксфильтрация	(1041)	CVE-2024-38213	Установить последние обновления безопасности от Microsoft, активировать функции Enhanced Security, ограничить привилегии пользователей и внедрить мониторинг целостности файлов для обнаружения несанкционированных изменений.
Удар	(T1565)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.
CAPEC-654			
Разведка	(T1592)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Подготовка ресурсов	(T1584)	CVE-2018-13382	Проверить конфигурации Fortinet на наличие небезопасных настроек и ограничить доступ к административным интерфейсам.
Первоначальный доступ	(T1199)	CVE-2023-3676	Ограничить возможность создания подов на Windows-нодах в Kubernetes для пользователей без необходимости и проверить журналы на признаки выполнения команд от имени Kubelet.

Тактика	Техника	CVE	Первоочередные меры реагирования
Исполнение	(T1204)	CVE-2020-1054	Провести аудит системных журналов на предмет подозрительной активности, связанной с Win32k, и ограничить доступ к системам, где возможна эксплуатация уязвимости.
Закрепление	x	x	x
Повышение привилегий	(T1548)	CVE-2021-36942	Отключить или ограничить использование NTLM-аутентификации, особенно в средах с контроллерами домена, чтобы предотвратить подделку LSA.
Предотвращение обнаружения	(T1221)	CVE-2023-49084	Ограничить доступ к компоненту link.php в Cacti и внедрить фильтрацию входных данных для предотвращения SQL-инъекций и выполнения произвольного кода.
Получение учетных данных	(T1558)	CVE-2019-3978	Ограничить доступ к порту 8291 в MikroTik RouterOS и очистить кэш DNS для предотвращения отравления кэша.
Обнаружение	(T1046)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Боковое смещение	(T1534)	CVE-2022-40684	Проверить журналы Fortinet на наличие несанкционированных действий, изолировать скомпрометированные устройства и сбросить учетные данные администраторов.
Сбор данных	(T1025)	CVE-2024-38476	Проверить конфигурации Apache HTTP Server на наличие небезопасных настроек, особенно использование директивы 'AddType', и заменить её на 'SetHandler' для предотвращения SSRF и выполнения локальных скриптов.
Командование и управление	(T1102)	CVE-2019-1405	Ограничить доступ к службе UPnP и проверить журналы на признаки эскалации привилегий через COM-объекты.
Эксфильтрация	(1041)	CVE-2024-38213	Установить последние обновления безопасности от Microsoft, активировать функции Enhanced Security, ограничить привилегии пользователей и внедрить мониторинг целостности файлов для обнаружения несанкционированных изменений.

Продолжение таблицы 47

Тактика	Техника	CVE	Первоочередные меры реагирования
Удар	(T1565)	CVE-2019-14287	Проверить конфигурацию sudoers на наличие исключений root и скорректировать правила, чтобы предотвратить обход ограничений.

Таким образом, результатами настоящего раздела стали:

- классический план по ликвидации последствий инцидентов;

- сформированные перечни технических и социальных мер ликвидации последствий инцидентов вторжений класса “Социальная инженерия”;

- перечини социально-психологических и технических причин возникновения инцидентов безопасности;

- сформированные меры по ликвидации последствий для техник, на реализации которых (в идеальных условиях) закончится атака (меры наиболее оперативной и рациональной ликвидации последствий);

- сформированный перечень мер ликвидации последствий после эксплуатации уязвимостей, имеющих наиболее высокие значения показателя вероятности эксплуатации.

В свою очередь итогами главы в комплексе стали:

- сформированные частные регламенты выявления и регистрации нарушения безопасности для уязвимостей с максимальным значением вероятности эксплуатации для атак класса “Социальная инженерия”;

- сформированные частные регламенты реагирования на нарушения безопасности для атак класса “Социальная инженерия”;

- сформированные частные регламенты ликвидации последствий нарушений безопасности для атак класса “Социальная инженерия”.

ЗАКЛЮЧЕНИЕ

В ходе разрешения противоречий между необходимостью формирования множества сценариев реализации атак класса “Социальная инженерия” и отсутствием всеобъемлющих, полностью сформированных баз знаний об атаках заданного класса, объективной потребностью в создании регламентов оперативного противодействия вторжениям класса “Социальная инженерия” и отсутствием грамотного расчета вероятностей и рисков осуществления атак, необходимостью рационально противодействовать атакам класса “Социальная инженерия” и отсутствием единой методологии защиты (включающей в себя стандартизированные регламенты обнаружения, реагирования, ликвидации последствий) были получены результаты с определенной практической и теоретической значимостью.

Была впервые сформирована структурированная и достоверная база знаний, обеспечивающая полноту и системность описания тактик, техник и уязвимостей, применяемых злоумышленниками при реализации сценариев атак класса “Социальная инженерия”. Практическая ценность для этого результата заключатся в возможности использования в системах принятия решений в области информационной безопасности, при разработке обучающих курсов, симуляторов атак и инструментов анализа сценариев вторжений, а теоретическая в возможности расширения научного представления о классификации и структуре атак класса “Социальная инженерия” и создания основы для дальнейших исследований в области систематизации и формализации сценариев киберугроз от таких атак.

Впервые выполнена оценка рисков и вероятностей эксплуатации отдельных уязвимостей в контексте единичных атак, и впервые выполнен расчет вероятности реализации техник с учетом математического ожидания числа атак. Практическая ценность заключается в том, что рассчитанные показатели позволяют наиболее рационально формировать точные и обоснованные регламенты оперативного реагирования на инциденты, проранжировать уязвимости по уровню риска и величине вероятности успешной эксплуатации и эффективно распределять ресурсы на обеспечение кибер-

защиты. Теоретическая ценность заключается в том, что предложенный подход дополняет теорию анализа угроз и уязвимостей, обосновывая применение вероятностно-рисковой модели в условиях неопределенности, характерной для атак класса “Социальная инженерия”.

Впервые разработан комплекс организационно-технических мер и инструкций, составляющих единую методологию противодействия атакам социальной инженерии, включающую стандартизированные процедуры обнаружения, реагирования и устранения последствий для обеспечения эффективной защиты. В этом случает практическая ценность результата сводится к возможности внедрения методологии в практику информационной безопасности организаций для повышения эффективности защиты от вторжений класса “Социальная инженерия” за счёт стандартизации процессов реагирования и устранения последствий атак. Теоретическая ценность заключается в том, что методология вносит вклад в развитие теории управления инцидентами и построения адаптивных систем защиты, формируя научную основу для дальнейшей более глубокой стандартизации противодействия атакам класса “Социальная инженерия”.

СПИСОК ЛИТЕРАТУРЫ

1. Актуальные киберугрозы. III квартал 2024 года. – Электрон. дан. – Режим доступа: https://ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iii-kvartal-2024-goda/. – Текст: электронный.

2. Актуальные киберугрозы. IV квартал 2024 года и I квартал 2025 года. – Электрон. дан. – Режим доступа: https://ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/. – Текст: электронный.

3. Социальная инженерия в кибербезопасности. – Электрон. дан. – Режим доступа: https://ddos-guard.ru/blog/sotsialnaya-inzheneriya-v-kiberbezopasnosti/. – Текст: электронный.

4. Новости кибербезопасности: последние угрозы и тренды. – Электрон. дан. – Режим доступа: https://habr.com/ru/news/893242/. – Текст: электронный.

5. Блог о фишинге и кибербезопасности. – Электрон. дан. – Режим доступа: https://phishman.ru/blog/2025/. – Текст: электронный

6. TAdviser: портал о цифровых технологиях и ИТ-решениях. – Электрон. дан. – Режим доступа: https://www.tadviser.ru/index.php. – Текст: электронный.

7. Кибербезопасность: новые угрозы и методы защиты. – Электрон. дан. – Режим доступа: https://www.rbc.ru/life/news/67697c5d9a794759cf255043. – Текст: электронный.

8. Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9. Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

10. Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный

11. Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

12. Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

13. Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

14. Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

15. Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

16. Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло, А.С.Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 185-196 – Текст: непосредственный.

17. Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 197-208 – Текст: непосредственный.

18. Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть III) / Д.В. Щербакова, А.Ю. Пекло, Ю.В. Макаров, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 209-218 – Текст: непосредственный

19. Остапенко А.Г. Целеполагание проектной деятельности по созданию инструментария автоматизированного выявления и риск-анализа деструктивных контентов, аффилированных с персоналом корпораций / А.Г. Остапенко, И.А, Боков, С.В.

Лихобабин, Д.С. Ясенко, Е.Ю. Чапурин // Информация и безопасность. 2023. – Т. 26. № 4. – С. 465-494 – Текст: непосредственный.

20. Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4. - С. 597-602 – Текст: непосредственный.

21. Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598 – Текст: непосредственный.

22. Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. – Т. 25. Вып. 1. – С. 89-106 – Текст: непосредственный.

23. Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. – Т. 25. Вып. 1. – С. 115-128 – Текст: непосредственный.

24. Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. – Т. 25. Вып. 4. – С. 475-484 – Текст: непосредственный.

25. Остапенко А.Г. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А. Остапенко, А.И. Шеншин // Информация и безопасность. 2023. – Т. 26. № 2. – С. 169-176 – Текст: непосредственный.

26. Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М. Голембиовский, К.Е. Шинаков // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 135-142 – Текст: непосредственный.

27. Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 91-98 – Текст: непосредственный.

28. Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

29. Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный.

30. Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный.

31. Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и без опасность. 2024. – Т. 27. Вып. 3. – С. 319-336 – Текст: непосредственный.

32. Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. – Т. 27. Вып. 3. – С. 337-378 – Текст: непосредственный.

33. Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. – С. 389-400 – Текст: непосредственный.

34. Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 239-246 – Текст: непосредственный.

35. Статистика по росту количества атак класса "Социальная инженерия". – Электрон. дан. – Режим доступа: https://habr.com/ru/companies/pvs-studio/articles/580474/. – Текст: электронный.

36. Социальная инженерия: что это и как ее используют мошенники и манипуляторы. - Электрон. дан. - Режим доступа: https://www.psychologies.ru/articles/socialnaya-inzheneriya-chto-eto-i-kak-ee-ispolzuyut-moshenniki-i-manipulyatory/. - Текст: электронный.

37. Анализ современных киберугроз и методов защиты. – Электрон. дан. – Режим доступа: https://www.securitylab.ru/analytics/500877.php. – Текст: электронный.

38. Зорин В.А. Информационная безопасность и нейробиология социальной инженерии: когнитивные искажения, эмпатия / В.А. Зорин // Информация и безопасность. 2024. – Т. 27. Вып. 3. – С. 441-448. – Текст: непосредственный.

39. MITRE&ATTACK. – Электрон. дан. – Режим доступа: https://xakep.ru/2021/03/17/mitre-att-ck/. – Текст: электронный.

40. MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/. – Текст: электронный.

41. CAPEC. – Электрон. дан. – Режим доступа: https://capec.mitre.org/index.html. – Текст: электронный.

42. Парсер уязвимостей CVSS, EPSS, OWASP. – Электрон. дан. – Режим доступа: https://github.com/twentyoneh/CVSS_EPSS_OWASP. – Текст: электронный.

43. Кибератаки вида “Сопциальная инженерия”: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей/ Г.А. Остапенко, А.А. Остапенко, Э.И. Жидков, А.П. Васильченко // Информация и безопасность. 2024. – Текст: непосредственный.

44. NIST National Vulnerability Database. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/vuln. – Текст: электронный.

45. База CVE. – Электрон. дан. – Режим доступа: https://cve.mitre.org/cve/search_cve_list.html. – Текст: электронный.

46. База CVE. – Электрон. дан. – Режим доступа: https://access.redhat.com/security/cve/cve-2022-2820. – Текст: электронный.

47. БДУ ФСТЭК: база уязвимостей. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

48. CyberVimetric - база CVE. – Электрон. дан. – Режим доступа: https://cyber.vumetric.com/vulns/CVE-2020-4046/cross-site-scripting-vulnerability-in-multiple-products/. – Текст: электронный.

49. Vulmon: база данных уязвимости CVE-2020-4046. – Электрон. дан. – Режим доступа: https://vulmon.com/vulnerabilitydetails?qid=CVE-2020-4046. – Текст: электронный.

50. DREAD: модель оценки рисков информационной безопасности. – Электрон. дан. – Режим доступа: https://en.wikipedia.org/wiki/DREAD_(risk_assessment_model). – Текст: электронный.

51. Адам Шостак. "Опыт моделирования угроз в Майкрософт". – Электрон. дан. – Режим доступа: https://www.securitylab.ru/analytics/376951.php. – Текст: электронный.

52. EPSS Calculator: инструмент оценки вероятности эксплуатации уязвимостей. – Электрон. дан. – Режим доступа: https://www.secopsolution.com/epss-calculator. – Текст: электронный.

53. EPSS: процентные квантили вероятности эксплуатации. – Электрон. дан. – Режим доступа: https://www.first.org/epss/articles/prob_percentile_bins. – Текст: электронный.

54. CVSS 3.1 Calculator. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/calc31. – Текст: электронный.

55. CVSS 4.0 Calculator. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/calc4. – Текст: электронный.

56. OWASP Risk Rating Methodology. – Электрон. дан. – Режим доступа: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology. – Текст: электронный.

57. Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203-210. – Текст: непосредственный.

58. Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. – Т. 26. Вып. 2. – С. 235-246 – Текст: непосредственный.

59. Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. – Т. 26. Вып. 2. – С. 261-276 – Текст: непосредственный.

60. Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализции массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. – Т. 27. Вып. 3. – С. 401-420 – Текст: непосредственный.

61. Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 273-284 – Текст: непосредственный.

62. Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А.

Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. – Т. 24. Вып. 2. – С. 159-178 – Текст: непосредственный.

63. Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 55-66 – Текст: непосредственный.

64. Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 285-294 – Текст: непосредственный.

65. Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М. Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 99-108 – Текст: непосредственный.

66. Остапенко А.А. Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А.А. Остапенко, В.П. Шелякин, Е.С. Короткова, А.С. Кривошеин [и другие] // Информация и безопасность. 2024. – Т. 27. № 4. – С. 521-542 – Текст: непосредственный.

67. Остапенко А.А. Актуальные задачи и некоторые их решения в части риск калькуляции успешности реализации единичных кибератак / А.А. Остапенко // Информация и безопасность. 2024. – Т. 27. № 4. – С. 543-552 – Текст: непосредственный.

68. Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов, и инструкций обеспечения безопасности организации (Часть I)/ Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. Т. 26. Вып. 3. – С. 329-340

69. Остапенко Г.А. Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов, и инструкций обеспечения безопасности организации (Часть III)/ Г.А. Остапенко, Д.В. Щербакова, Т.Ю.

Мирошниченко, А.А. Остапенко, А.Ю. Егоров // Информация и безопасность. 2023. Т. 26. Вып. 3. – С. 329-340

70. Investopedia: Financial Statistics and Data. – Электрон. дан. – Режим доступа: https://www.investopedia.com/. – Текст: электронный.

71. Keepnet Labs: Статистика киберугроз и фишинговых атак. – Электрон. дан. – Режим доступа: https://keepnetlabs.com/. – Текст: электронный.

72. Embroker: Insurance Statistics and Risk Management Data. – Электрон. дан. – Режим доступа: https://www.embroker.com/. – Текст: электронный.

73. EFTSure: Payment Security Solutions. – Электрон. дан. – Режим доступа: https://eftsure.com/en-au/. – Текст: электронный.

74. Воронин В.Н. Социально-психологические риски разных поколений в процессе цифровизации общества/ В.Н. Воронин, Д.В., М.В. Ионцева, Л.Ю. Шураева // Современные тенденции в психологии 2022. Вып. 4. – С. 169-175. – Текст непосредственный.

75. Методика оценки угроз безопасности. – Электрон. дан. – Режим доступа: https://www.garant.ru/products/ipo/prime/doc/400325044/?ysclid=mcbwvuw170576717618. – Текст: электронный.

76. Инцидент безопасности. – Электрон. дан. – Режим доступа: https://www.securitylab.ru/blog/personal/valerykomarov/347857.php. – Текст: электронный.

77. DMARC, SPF, DKIM. – Электрон. дан. – Режим доступа: https://habr.com/ru/articles/343128/. – Текст: электронный.

78. SUIEM. - Электрон. дан. - Режим доступа: https://www.securitylab.ru/blog/personal/paragraph/354574.php. - Текст: электронный.

79. UFEBA (User and Entity Behavior Analytics). – Электрон. дан. – Режим доступа: https://habr.com/ru/articles/878142/. – Текст: электронный.

80. UFEBA (User and Entity Behavior Analytics). – Электрон. дан. – Режим доступа: https://www.securitylab.ru/blog/personal/paragraph/354574.php. – Текст: электронный.

81. OAuth 2.0: понятие и принцип работы. – Электрон. дан. – Режим доступа: https://skillbox.ru/media/code/chto-takoe-oauth-20-ponyatie-i-printsip-raboty/. – Текст: электронный.

82. EDR/XDR: сравнение технологий защиты. – Электрон. дан. – Режим доступа: https://www.microsoft.com/ru-ru/security/business/security-101/edr-vs-xdr. – Текст: электронный.

83. IDS/IPS UserGate. – Электрон. дан. – Режим доступа: https://www.usergate.com/ru/products/ips. – Текст: электронный.

84. Digital Q.ELK. – Электрон. дан. – Режим доступа:

https://q.diasoft.ru/products/infrastrukturnye-platformy/digital-q-elk/. – Текст: электронный.

85. DLP (Data Loss Prevention). – Электрон. дан. – Режим доступа: https://www.microsoft.com/ru-ru/security/business/security-101/what-is-data-loss-prevention-dlp. – Текст: электронный.

86. NMS (Network Management System). – Электрон. дан. – Режим доступа: https://wiki.merionet.ru/articles/nms-sistemy-polnyj-kontrol. – Текст: электронный.

87. DCAP (Data-Centric Audit and Protection). – Электрон. дан. – Режим доступа: https://www.anti-malware.ru/analytics/Technology_Analysis/Data-Centric-Audit-and-Protection-FileAuditor. – Текст: электронный.

88. Меры реагирования: Методические рекомендации по разработке плана реагирования на компьютерные инциденты и принятия мер по ликвидации последствий компьютерных атак, проведенных в отношении значимых объектов информационной инфраструктуры Российской Федерации. – Электрон. дан. – Режим доступа: https://www.mos.ru/upload/documents/files/8826/MetodikapoformirovaniuPlanareagirovaniyanakomputernieincidenti.pdf. – Текст: электронный.

89. Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (Часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. Т. 26. Вып. 3. – С. 341-358.

90. ГОСТ Р 59712-2022. – Электрон. дан. – Режим доступа: https://regulhub.kaspersky.ru/upload/iblock/dd9/0guscyux6bfh50dr9arhl48p4bl8dg80.pdf. . – Текст: электронный.

91. Негативные последствия инцидентов ИБ: ГОСТ Р ИСО/МЭК ТО 18044-2007. – Электрон. дан. – Режим доступа: https://meganorm.ru/Index2/1/4293832/4293832382.htm. – Текст: электронный.

92. Sudo Permission Elevation Vulnerability [CVE]. – Электрон. дан. – Режим доступа: https://nsfocusglobal.com/sudo-permission-elevation-vulnerability. – Текст: электронный.

93. CVE Details Database. – Электрон. дан. – Режим доступа: https://www.cvedetails.com/cve/. – Текст: электронный.

94. Snyk Vulnerability Database. – Электрон. дан. – Режим доступа: https://security.snyk.io/. – Текст: электронный.

95. Ubuntu Security Notice: CVE-2022-44268. – Электрон. дан. – Режим доступа: https://ubuntu.com/security/CVE-2022-44268. – Текст: электронный.

96. Red Hat Security Advisories. – Электрон. дан. – Режим доступа: https://access.redhat.com/security/cve/. – Текст: электронный.

97. FortiGuard Security Services. – Электрон. дан. – Режим доступа: https://www.fortiguard.com/. – Текст: электронный.

98. Vulners CVE Database. – Электрон. дан. – Режим доступа: https://vulners.com/cve/. – Текст: электронный.

99. Base KB5005413. – Электрон. дан. – Режим доступа: https://clck.ru/3MnQS3. – Текст: электронный.

100. Ликвидация последствий эксплуатации CVE-2021-44168 – Электрон. дан. – Режим доступа: https://service.securitm.ru/vm/vulnerability/cve/show/CVE-2021-44168 – Текст: электронный.